République du Cameroun

**Université de Yaoundé I**

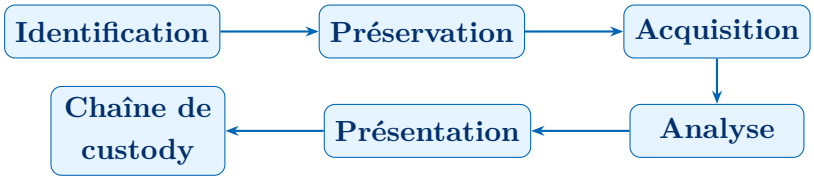
École Nationale Supérieure Polytechnique

Département de Génie Informatique - LIMSI


# Introduction à l'Investigation Numérique

*Fondements, méthodes et cadre juridique de la forensique numérique*

**IIN - UE SEC4031**





**MINKA MI NGUIDJOÏ Thierry Emmanuel**

Enseignant Chercheur | LIMSI | ENSPY

maletyon@proton.me



**Année académique 2026–2027**

Version 2.1 | Document pédagogique de l'UE SEC4031

# AVANT-PROPOS

> « La technique n'est jamais seulement technique. Elle redéfinit l'humain et son rapport au monde. »
>
> Bernard Stiegler

Ce cours est né d'une double conviction : que l'**investigation numérique** constitue aujourd'hui l'une des disciplines les plus stratégiques pour le continent africain, et que l'Afrique n'a pas à importer une vision de cette discipline, elle doit en construire une qui lui soit propre, ancrée dans ses réalités juridiques, ses enjeux économiques et ses capacités institutionnelles.

**Ce que ce cours n'est pas.** Il ne s'agit pas d'un catalogue d'outils, ni d'une traduction d'un syllabus occidental. Les ouvrages de référence en langue anglaise (Casey, Carrier, Carrier, Ligh) font un travail remarquable pour leurs contextes. Ce cours assume pleinement un ancrage africain et, plus précisément, camerounais : la Loi 2010/012, le rôle de l'ANTIC, la jurisprudence naissante des tribunaux, les fraudes MoMo, le SIM swapping en zone CEMAC, voilà les matières premières de l'investigateur numérique camerounais.

**Ce que ce cours est.** Un traité de treize chapitres, en un prologue et trois parties. Le prologue place l'étudiant sur une scène de crime numérique. La Partie I pose les fondements : philosophie de la preuve numérique, histoire de la discipline, grandes affaires, fondements théoriques et état de l'art. La Partie II donne la méthode : le processus investigatif universel (PIU), les méthodologies et standards internationaux, la chaîne de custody et l'acquisition. La Partie III présente le cadre normatif : instruments internationaux, législations du monde et de la région, droit camerounais et africain, déontologie de l'investigateur. Le cours progresse de la philosophie vers la pratique, et de la règle de droit vers l'outil technique. Sa suite logique est l'UE SEC4052, *Investigation Numérique Avancée*, qui passe à l'analyse des systèmes, des réseaux, des mobiles, du nuage et des objets connectés, puis aux fondements cryptographiques de la preuve. Chaque chapitre comporte des objectifs mesurables, des exercices gradués, des cas opérationnels ancrés dans la réalité locale, et une analyse systématique à travers le prisme du **Trilemme CRO**, cadre théorique original que les travaux de notre équipe au LIMSI ont formalisé en 2025.

**Le fil rouge : le Trilemme CRO.** Tout au long de cet ouvrage, vous rencontrerez l'encadré $\Gamma_{CRO}$ qui interroge systématiquement chaque technique, chaque protocole, chaque artefact sous trois dimensions :


© MaletYon

- **Confidentialité** ($\mathcal{C}$) : la technique protège-t-elle les données sensibles des parties impliquées ?
- **Fiabilité** ($\mathcal{R}$) : le résultat est-il intègre, reproductible, non altéré ?
- **Opposabilité juridique** ($\mathcal{O}$) : la preuve produite sera-t-elle recevable devant un tribunal ?

Le Trilemme établit qu'on ne peut pas maximiser simultanément ces trois dimensions. Comprendre ce compromis, c'est comprendre l'essence même de l'investigation numérique.

**Comment utiliser ce cours.** Chaque chapitre s'ouvre sur une *boîte objectifs* précisant les compétences attendues, et se ferme sur une *boîte résumé*. Les exercices sont gradués en trois niveaux : ★☆☆ fondamental, ★★☆ intermédiaire, ★★★ expert. Les codes sources sont testés et fonctionnels sous Linux (Ubuntu 22.04+) et Windows 10/11.




*Yaoundé, juin 2026*

# MODE D'EMPLOI DE CE COURS

## Structure générale

Ce livre correspond à l'UE **SEC4031**. Il compte un prologue et trois parties, soit treize chapitres, pour 60 heures en présentiel réparties en trente séances de deux heures. Les fiches d'auto-évaluation de NDAP SUKULU se font hors de ces 60 heures.

| Partie | Chapitres | Compétences visées | Séances |
|---|---|---|---|
| Prologue | Scène de crime numérique (Ch. 0) | Appréhender la réalité du terrain | 1 et 2 |
| I | Philosophie et fondements, histoire, grandes affaires, fondements théoriques, état de l'art (Ch. 1 à 5) | Comprendre l'origine et les bases théoriques de la discipline | 3 à 12 |
| II | Processus investigatif universel, méthodologies et standards, chaîne de custody, acquisition (Ch. 6 à 9) | Conduire une investigation structurée et défendable | 13 à 22 |
| III | Cadre normatif global, législation mondiale et régionale, droit camerounais et africain, déontologie (Ch. 10 à 13) | Opérer dans la légalité et l'éthique | 23 à 30 |

● Note

**La suite : l'UE SEC4052.** *Investigation Numérique Avancée* prolonge ce cours : forensique opérationnelle (système, réseau, mobile, nuage, objets connectés, sources ouvertes, rapport, cas intégrateurs), anti-forensique et défis émergents, puis fondements cryptographiques de la preuve. Elle suppose acquis les gestes et les principes de SEC4031.

## Les environnements visuels

■ Définition

**Définition**. Introduit un terme technique avec sa définition formelle. Tous les termes définis sont indexés en fin d'ouvrage.


© *MaletYon*

**✦ Objectifs du chapitre**

Objectifs du chapitre. Liste les compétences mesurables attendues à l'issue du chapitre. Ces objectifs correspondent aux critères d'évaluation.

**$\Gamma_{CRO}$ Analyse CRO · Confidentialité · Fiabilité · Opposabilité**

Analyse CRO. Évalue systématiquement une technique ou un protocole selon les trois dimensions du Trilemme : Confidentialité ($\mathcal{C}$), Fiabilité ($\mathcal{R}$), Opposabilité ($\mathcal{O}$).

**Scénario Opérationnel · Titre du scénario**

Scénario opérationnel. Présente un cas réel ou fictif ancré dans la réalité camerounaise ou africaine. Le cas MBONGO (fraude financière 12M FCFA) sert de fil rouge du prologue à la Partie II, puis dans le cours SEC4052.

**Application OPJ/Expert Judiciaire**

Application OPJ/DGSN. Traduit le concept académique en procédure opérationnelle destinée aux Officiers de Police Judiciaire.

**Chaîne de Custody**

Chaîne de Custody. Détaille les étapes et formulaires nécessaires à la préservation de la valeur probante d'une preuve numérique.

**Artefact · Nom de l'artefact**

Artefact forensique. Décrit un artefact numérique spécifique : sa localisation sur le système, la valeur qu'il porte pour l'investigation, et sa fragilité.

**Jurisprudence & Droit applicable**

Jurisprudence & Droit applicable. Référence les textes de loi, articles et jurisprudences pertinents, avec accent sur le droit camerounais et africain.

**★ Attention**

Attention. signale un risque procédural, légal ou technique pouvant invalider une investigation.

**★ À retenir**

À retenir. Synthèse des points essentiels du chapitre.

**✍ Exercice**

Exercice. Travaux pratiques gradués. Chaque exercice porte un indicateur de niveau : ★☆☆ fondamental, ★★☆ intermédiaire, ★★★ expert.

## Conventions typographiques

- Les **termes clés** apparaissent en **gras bleu marine** et sont indexés automatiquement.
- Les ACRONYMES utilisent des petites capitales.
- Les références aux normes utilisent la commande **[ISO/IEC 27037]**.
- Les références aux lois camerounaises utilisent **Loi 2010/012**.
- Les hachages cryptographiques sont formatés ainsi : `[SHA-256] 3a4b5c6d...`.
- L'impact CRO inline est noté : $\mathcal{C}$: +0.8 $\mathcal{R}$: -0.3 $\mathcal{O}$: +0.6.
- L'ordre de volatilité est indiqué : **1** *RAM*.

## Matériel d'accompagnement

Ce cours est complété par :

- **Images de pratique forensique**, images E01 préparées pour les TP Autopsy.
- **Captures réseau (.pcap)**, traces Wireshark pour les TP de forensique réseau.
- **Machines virtuelles**, VM Kali Linux et VM Windows avec artefacts préinstallés (clé USB fournie en TP).
- **Formulaires officiels**, formulaire de chaîne de custody (Annexe C), adapté du formulaire type DGSN.

# NDAP SUKULU, LA SALLE DE CLASSE COMPAGNON




## Un nom venu du pays bassa

> *Le soir tombe sur Éséka. Un enfant revient des champs avec son grand-père et lui demande pourquoi il doit marcher si loin, chaque matin, pour aller à l'école. Le vieil homme s'arrête au bord du chemin et répond, en bassa : «* Ndap sukulu*, la salle de classe, ce ne sont pas les murs. Ce sont les murs qui viennent après. La salle de classe, c'est l'endroit où quelqu'un t'attend pour t'apprendre ce qu'il sait. » L'enfant insiste : « Et qui m'attend ? » Le grand-père sourit : «* Malet yon*. Ton enseignant. »*

En bassa, la langue paternelle de l'auteur, ***ndap sukulu*** désigne la salle de classe et ***malet yon*** signifie « ton enseignant ». L'environnement compagnon de ce cours porte ce nom parce qu'il prolonge la salle de classe au-delà des heures de cours : il attend l'étudiant le soir, le week-end, à distance, avec des questions, des pièces à examiner et une correction immédiate. Il est édité par **MaletYon**, « ton enseignant », et mis à la disposition des étudiants et des praticiens qui souhaitent se perfectionner (maletyon@proton.me).

## Ce que l'on y trouve

- **Une fiche d'auto-évaluation par chapitre.** Chaque fiche puise vingt questions dans une banque de quarante (QCM, vrai ou faux, textes à trous). Elle dure trente minutes ; la copie validée est verrouillée et notée aussitôt. Le seuil de réussite est de 60 %.
- **Des laboratoires pratiques.** Chaque lab place l'étudiant devant les pièces d'une affaire du fil rouge (tableurs, journaux, contrats, procès-verbaux) dans un bureau d'analyste virtuel, ouvert dans le navigateur. Il dure soixante minutes, se termine par des points de contrôle notés automatiquement et renvoie aux sections du livre qu'il mobilise.


© *MaletYon*

➢ **Un suivi pour l'enseignant** : rapport de classe, notes par fiche et par lab, journal d'activité.

Les fiches et les labs sont des travaux à faire hors des heures de cours. Ils ne remplacent ni le livre ni les exercices de fin de chapitre : ils en vérifient la maîtrise.

## Comment y travailler

1. Se connecter au portail NDAP SUKULU avec ses identifiants et le code de cours **SEC4031**.
2. Pour un lab, commencer par vérifier l'empreinte SHA-256 des pièces (`sha256sum -c MANIFESTE_SHA256.txt`), puis travailler sur la copie du dossier `travail` : les pièces originales sont en lecture seule et l'activité est journalisée, comme dans une vraie mission.
3. Lire le rappel de cours affiché par le lab et relire les sections citées avant de répondre.

**Note**

**Si le portail n'est pas encore ouvert.** En attendant le déploiement de NDAP SUKULU, les fiches de questions sont fournies au format texte dans le dossier `fiches` du cours, prêtes à être distribuées. Les corrections des fiches figurent dans le livret de correction, à la suite des corrigés des exercices de chaque chapitre.

## Les laboratoires du cours

Sous le code SEC4031, NDAP SUKULU propose quatorze fiches d'auto-évaluation, une par chapitre, prologue compris, et dix laboratoires. Tous portent sur l'affaire MBONGO, le cas fil rouge du cours. Ils se font avec un terminal simple et un tableur, sans outil spécialisé, et durent de quarante-cinq à soixante minutes. Les laboratoires d'analyse sur pièces figurent dans le cours de suite, Investigation Numérique Avancée (UE SEC4052).

| Lab | Sujet | Chapitre |
|---|---|---|
| IIN-LAB-01 | Scellés et chaîne de custody : l'affaire MBONGO au tribunal | 8 |
| IIN-LAB-02 | Vérifier une acquisition : image segmentée et journal FTK Imager | 9 |
| IIN-LAB-03 | Métadonnées : qui a écrit la lettre anonyme ? | 3 |
| IIN-LAB-04 | Graphe des flux : trouver le compte pivot | 4 |
| IIN-LAB-05 | Empreintes : doublons et fichiers connus | 4 |
| IIN-LAB-06 | PIU : Quality Gate 2 et hypothèses concurrentes | 6 |
| IIN-LAB-07 | Ordre de volatilité : relire une intervention | 7 |
| IIN-LAB-08 | Coopération internationale : conserver avant de divulguer | 10 |
| IIN-LAB-09 | Qualifier les faits : de l'acte à l'article | 12 |
| IIN-LAB-10 | Relire un rapport : constatations, analyse, biais | 13 |

*Les laboratoires du cours dans NDAP SUKULU*

# TABLE DES MATIÈRES

**Avant-propos** iii

**Mode d'emploi** v

**NDAP SUKULU, la salle de classe compagnon** ix

## Prologue Opérationnel 3

### 0 Prologue: Scène de Crime Numérique 3

0.1 La Scène de Crime Numérique : un Lieu à Sécuriser . . . 4

0.1.1 Ce qui change par rapport à une scène physique . . . 4

0.1.2 Le paradoxe de l'observation . . . 5

0.2 Les Quatre Principes Fondamentaux . . . 5

0.2.1 Principe 1. Intégrité . . . 5

0.2.2 Principe 2. Traçabilité (chaîne de custody) . . . 7

0.2.3 Principe 3. Reproductibilité . . . 8

0.2.4 Principe 4. Admissibilité . . . 9

0.3 Le Trilemme CRO : la Tension Constitutive . . . 9

0.3.1 Les trois dimensions en opposition . . . 9

0.3.2 Le Trilemme sur la scène de crime : exemples immédiats . . . 10

0.4 Protocole d'Urgence : les 10 Premières Minutes . . . 11

0.4.1 Arrivée sur la scène : les trois questions immédiates . . . 11

0.4.2 PC allumé : procédure de triage . . . 11

0.4.3 PC éteint : procédure de saisie . . . 11

0.4.4 Téléphone mobile : les règles absolues . . . 12

0.5 Retour sur l'Affaire MBONGO : ce qui Aurait Dû se Passer . . . 12

## I Fondements Épistémologiques et Historiques 17

### 1 Philosophie et Fondements de l'Investigation Numérique 19

1.1 L'Investigation Numérique comme Pratique Discursive . . . 19

1.1.1 Au-delà de la technique : une discipline philosophique . . . 19

1.1.2 La notion foucaldienne de régime de vérité numérique . . . 20

1.1.3 Périodisation mathématique des régimes . . . 20

1.2 Ontologie de la Trace Numérique . . . 21

1.2.1 La trace comme phénomène existentiel . . . 21



© *MaletYon*

1.2.2 Temporalité numérique multidimensionnelle . . . 22
1.3 Épistémologie de la Preuve Numérique . . . 23
1.3.1 La crise de la vérité numérique . . . 23
1.3.2 La théorie de Kuhn appliquée à la forensique . . . 23
1.4 Fondements Mathématiques de la Discipline . . . 24
1.4.1 Théorie de l'information : l'entropie de Shannon . . . 24
1.4.2 Théorie des graphes : modélisation des relations . . . 25
1.4.3 Sensibilité aux conditions initiales . . . 25
1.5 Le Paradoxe de l'Authenticité Invisible . . . 26
1.5.1 Énoncé du paradoxe . . . 26
1.5.2 Implications épistémologiques . . . 26
1.5.3 Résolution partielle : les protocoles ZK-NR . . . 27
1.6 Le Trilemme CRO comme Grille de Lecture Unifiée . . . 27
1.6.1 Genèse et formalisation . . . 27
1.6.2 Le Trilemme comme boussole de la pratique . . . 28
1.7 Éthique et Responsabilité de l'Investigateur . . . 28
1.7.1 L'investigateur comme philosophe-praticien . . . 28
1.7.2 L'investigation comme praxis de liberté . . . 29
1.7.3 Vers une éthique post-quantique . . . 29

**2 Histoire de l'Investigation Numérique 33**

2.1 Les Prémices (1970–1990) : L'Émergence de la Trace Électronique . . . 34
2.1.1 Contexte socio-technique du premier régime . . . 34
2.1.2 The Creeper (1971) : le premier artefact forensique . . . 35
2.1.3 L'affaire des 414s (1983) : premier paradigme investigatif . . . 35
2.1.4 L'affaire BTK Killer (2005, racines 1974) : les métadonnées comme preuve . . . 35
2.2 La Professionnalisation (1990–2000) : Naissance d'une Discipline . . . 36
2.2.1 La révolution Internet et ses conséquences épistémiques . . . 36
2.2.2 L'Opération Sundevil (1990) : le choc de la standardisation . . . 36
2.2.3 L'arrestation de Kevin Mitnick (1995) : institution de la chaîne de custody . . . 37
2.3 La Standardisation (2000–2010) : Rationalisation Industrielle . . . 37
2.3.1 Le tournant du millénaire et les standards fondateurs . . . 38
2.3.2 L'affaire Enron (2001) : naissance de l'*e-discovery* . . . 38
2.3.3 L'affaire Gary McKinnon (2002–2012) : souveraineté numérique . . . 38
2.4 Le Big Data et le Cloud (2010–2020) : L'Échelle Critique . . . 39
2.4.1 Le changement d'échelle qualitatif . . . 39
2.4.2 L'affaire Silk Road (2013) : forensique blockchain . . . 39
2.4.3 Les Panama Papers (2016) : investigation transfrontière . . . 39
2.5 L'Ère Post-Quantique et IA (2020–. . . ) : Le Grand Saut . . . 40
2.5.1 La double révolution IA / quantique . . . 40
2.5.2 L'attaque SolarWinds (2020) : IA contre IA . . . 40
2.5.3 Affaire WannaCry (2017) : immunité collective numérique . . . 41

2.6 L'Afrique et le Cameroun dans l'Histoire de la Discipline . . . . . 41
2.6.1 Une histoire trop souvent absente des manuels . . . . . 41
2.6.2 Les fraudes 419 (1990s–présent) : la plus longue affaire forensique africaine . . . . . 41
2.6.3 Le Cameroun et la Loi 2010/012 : entrée dans le régime de standardisation . . . . . 42
2.6.4 Les Opérations FALCON (2020–2022) : la coopération en action . . . . . 42
2.7 Perspectives : la Loi d'Accélération Épistémique . . . . . 43
2.7.1 Le temps entre les régimes se raccourcit . . . . . 43
2.7.2 Trois scénarios pour 2030–2050 . . . . . 43

**3 Les Grandes Affaires. Leçons de l'Histoire 47**

3.1 L'Affaire BTK Killer. Dennis Rader (2005) . . . . . 48
3.1.1 Contexte et artefact décisif . . . . . 48
3.1.2 Anatomie technique . . . . . 48
3.1.3 Erreurs commises et ce qu'elles enseignent . . . . . 48
3.1.4 Leçon transférable . . . . . 49
3.2 L'Affaire Stuxnet (2010) . . . . . 49
3.2.1 Contexte et artefact décisif . . . . . 49
3.2.2 Anatomie technique . . . . . 49
3.2.3 Leçon transférable . . . . . 50
3.3 L'Affaire WannaCry (2017) . . . . . 51
3.3.1 Contexte et artefact décisif . . . . . 51
3.3.2 Anatomie technique . . . . . 51
3.3.2.1 Analyse du Domain Generation Algorithm (DGA) . . . . . 51
3.3.2.2 Attribution probabiliste : la piste Lazarus . . . . . 51
3.3.2.3 Forensique de l'impact : reconstitution de la chronologie . . 52
3.3.3 Leçon transférable . . . . . 52
3.4 L'Affaire Enron. L'E-Discovery à l'Échelle (2001) . . . . . 52
3.4.1 Contexte et artefact décisif . . . . . 52
3.4.2 Anatomie technique . . . . . 52
3.4.2.1 La problématique de l'e-discovery à grande échelle . . . . . 53
3.4.2.2 La règle de l'email : ce qui est envoyé ne disparaît jamais . . 53
3.4.3 Leçon transférable . . . . . 53
3.5 Opération ONAMBELE (Cameroun) . . . . . 54
3.5.1 Contexte . . . . . 54
3.5.2 Artefacts décisifs et anatomie technique . . . . . 54
3.5.3 Erreurs à éviter . . . . . 54
3.6 Opération TANGUE (Cameroun) . . . . . 55
3.6.1 Contexte . . . . . 55
3.6.2 Les huit artefacts et leur localisation . . . . . 56
3.6.3 Leçon transférable . . . . . 56
3.7 Opération MVOM (Cameroun) . . . . . 57
3.7.1 Contexte . . . . . 57

3.7.2 Anatomie technique : reconstruction sur la Kill Chain . . . 57
3.7.3 L'analyse Volatility : preuve de l'installation . . . 57
3.7.4 Leçon transférable : la double victime . . . 58
3.8 Opération WOURI (Cameroun) . . . 58
3.8.1 Contexte . . . 58
3.8.2 Cartographie du réseau criminel . . . 59
3.8.3 L'OSINT comme technique forensique à part entière . . . 59
3.9 Tableau de Synthèse : les Leçons Permanentes . . . 60

**4 Fondements Théoriques 65**

4.1 Le Principe de Locard Numérique . . . 65
4.1.1 Origine et transposition au numérique . . . 65
4.1.2 Taxonomie des traces numériques . . . 66
4.1.3 Locard dans les affaires étudiées . . . 66
4.2 Théorie de l'Information : l'Arsenal de Shannon . . . 67
4.2.1 L'entropie comme détecteur d'anomalie . . . 67
4.2.2 La distance de Hamming : identifier les variantes de malware . . . 67
4.2.3 La distance de Levenshtein : typosquatting et comparaison de textes . . . 68
4.3 Théorie des Graphes en Investigation Numérique . . . 69
4.3.1 Formalisation des réseaux criminels . . . 69
4.3.2 Métriques de centralité : identifier les acteurs clés . . . 69
4.3.2.1 Centralité de degré . . . 69
4.3.2.2 Centralité d'intermédiarité (*betweenness centrality*) . . . 69
4.3.2.3 PageRank forensique . . . 69
4.3.3 Graphes temporels : la chronologie comme dimension analytique . . . 69
4.4 Le Modèle Dolev-Yao : l'Adversaire Formel . . . 70
4.4.1 Définition . . . 70
4.4.2 Implications forensiques . . . 70
4.4.3 Du modèle Dolev-Yao au Trilemme CRO . . . 71
4.5 Complexité Computationnelle et Sécurité Forensique . . . 71
4.5.1 Problèmes difficiles et sécurité cryptographique . . . 71
4.5.2 La menace quantique : algorithme de Shor . . . 71
4.5.3 Fonctions à sens unique et hachage forensique . . . 72
4.6 Modèles de Processus Forensique . . . 72
4.6.1 Panorama et positionnement . . . 72
4.6.2 Le modèle DFRWS (2001) . . . 72
4.6.3 La distinction Examination / Analysis (NIST SP 800-86) . . . 73
4.6.4 ISO/IEC 27037 : standard international et rôles . . . 73
4.7 Théorie de la Preuve Numérique . . . 73
4.7.1 Conditions formelles d'admissibilité . . . 73
4.7.2 La distinction constatation / interprétation . . . 74
4.7.3 La méthode des hypothèses concurrentes (ACH) . . . 74

4.8 Synthèse : Fondements Théoriques et Trilemme CRO . . . 75

**5 État de l'Art et Défis Contemporains 79**

5.1 IA Forensique : Puissance et Limites . . . 80
5.1.1 L'IA comme accélérateur de triage . . . 80
5.1.2 Classification automatique de malware . . . 80
5.1.3 Les limites de l'IA forensique, la crise d'opposabilité . . . 81
5.2 Deepfake Detection : Authentifier les Médias Numériques . . . 81
5.2.1 Le défi de l'authenticité des médias . . . 81
5.2.2 Méthodes de détection . . . 82
5.3 Forensique Cloud, IoT et Mobile : la Scène de Crime Distribuée . . . 83
5.3.1 Les trois défis structurels du cloud forensique . . . 83
5.3.2 IoT forensique : l'explosion des surfaces de collecte . . . 84
5.3.3 Mobile forensique : spécificités africaines . . . 85
5.4 OSINT : Renseignement en Source Ouverte . . . 85
5.4.1 Définition, périmètre et cadre légal camerounais . . . 85
5.4.2 Le cycle OSINT pour les OPJ . . . 86
5.4.3 Boîte à outils OSINT pour les OPJ camerounais . . . 86
5.5 Benchmarking Mondial : le Framework DICES . . . 87
5.5.1 Le framework DICES . . . 87
5.5.2 Positionnement comparatif . . . 88
5.5.3 Atouts et lacunes du Cameroun : une lecture honnête . . . 88
5.6 Roadmap de Développement Professionnel . . . 88
5.6.1 Les certifications de référence mondiales . . . 89
5.6.2 Roadmap réaliste sur 36 mois en contexte camerounais . . . 89
5.7 Synthèse : la Carte de la Discipline en 2025–2026 . . . 90

**II Processus et Méthodologies d'Investigation 93**

**6 Processus Investigatif Universel 95**

6.1 Introduction et Architecture Générale . . . 95
6.1.1 Objectifs et principes fondateurs . . . 95
6.1.2 Principe d'adaptabilité : trois contextes . . . 96
6.1.3 Matrice de criticité . . . 96
6.1.4 Architecture globale : 5 phases, 17 étapes, 3 Quality Gates . . . 96
6.1.5 Principe des Quality Gates . . . 97
6.2 Phase 1 : Initialisation et Cadrage . . . 97
6.2.1 Étape E1. Réception et Évaluation Préliminaire . . . 97
6.2.2 Étape E2. Décision d'Engagement . . . 98
6.2.3 Étape E3. Planification Opérationnelle . . . 99
6.2.4 Quality Gate 1. Validation Pré-Opérationnelle . . . 100
6.3 Phase 2 : Acquisition et Préservation . . . 101

6.3.1 Étape E4. Collecte Systématique des Éléments Probatoires . . . 101
6.3.2 Étape E5. Sécurisation et Préservation . . . 101
6.3.3 Étape E6. Identification et Cartographie des Parties Prenantes . . . 102
6.3.4 Quality Gate 2. Intégrité Probatoire . . . 103
6.4 Phase 3 : Investigation Analytique . . . 104
6.4.1 Étape E7. Interrogatoires et Collecte Testimoniale . . . 104
6.4.2 Étape E8. Génération d'Hypothèses Multiples . . . 105
6.4.3 Étape E9. Confrontation Hypothèses/Preuves . . . 106
6.4.4 Étape E9bis. Falsification Active . . . 107
6.4.5 Étape E10. Validation et Vérification . . . 107
6.4.6 Quality Gate 3. Robustesse Analytique . . . 108
6.5 Phase 4 : Formalisation et Transmission . . . 109
6.5.1 Étape E11. Documentation Exhaustive et Consolidation . . . 109
6.5.2 Étape E12. Rédaction du Livrable Final . . . 109
6.5.3 Étape E13. Transmission Sécurisée du Livrable . . . 110
6.6 Phase 5 : Suivi Post-Transmission . . . 111
6.6.1 Étape E14. Préparation à la Défense Contradictoire . . . 111
6.6.2 Étape E15. Maintenance Probatoire Continue . . . 111
6.6.3 Étape E16. Analyse des Contre-Expertises . . . 112
6.6.4 Étape E17. Clôture et Retour d'Expérience . . . 112
6.7 Cas Pratique : L'Affaire de la Facture Suspecte . . . 112
6.7.1 Contexte général . . . 112
6.7.2 Application : Contexte particulier (niveau minimal/standard) . . . 112
6.7.3 Application : Contexte entreprise (niveau avancé) . . . 114
6.7.4 Application : Contexte judiciaire (niveau avancé systématique) . . . 114
6.7.5 Synthèse comparative des trois contextes . . . 115
6.8 Recommandations d'Usage et Domaines d'Application . . . 115
6.8.1 Principe fondamental . . . 115
6.8.2 Sélection du niveau de rigueur . . . 116
6.8.3 Domaines d'application . . . 116
6.8.4 Documentation comme investissement . . . 116
**7 Méthodologies et Standards Internationaux 119**
7.1 Architecture des Standards Forensiques : vue d'ensemble . . . 120
7.1.1 Pourquoi des standards ? . . . 120
7.1.2 Cartographie des standards . . . 120
7.1.3 Correspondance standards / phases PIU . . . 121
7.2 DFRWS : la Fondation Conceptuelle (2001) . . . 121
7.2.1 Les six phases DFRWS . . . 121
7.2.2 Limite historique du DFRWS et apport du PIU . . . 122
7.3 La Suite ISO/IEC 2703x : le Standard International de Référence . . . 122
7.3.1 Architecture de la famille . . . 122
7.3.2 ISO/IEC 27037:2012. Identification, Collecte et Préservation . . . 122

7.3.3 ISO/IEC 27041:2015. Validation des Méthodes . . . 123
7.3.4 ISO/IEC 27042:2015. Analyse et Interprétation . . . 124
7.3.5 ISO/IEC 27043:2015. Principes et Processus Intégrés . . . 124
7.4 NIST SP 800-86 : Forensique et Réponse aux Incidents . . . 124
7.4.1 Les quatre phases NIST . . . 125
7.4.2 Distinction Examination / Analysis : règle d'or du rapport . . . 125
7.5 RFC 3227 : l'Ordre de Volatilité . . . 125
7.5.1 L'ordre de volatilité canonique . . . 126
7.6 Les Quatre Principes ACPO : Responsabilité et Déontologie . . . 126
7.7 SANS FOR508 : Forensique d'Entreprise et Threat Hunting . . . 127
7.7.1 La méthodologie en six phases . . . 127
7.7.2 Apports distinctifs de FOR508 en 2025 . . . 128
7.8 Analyse Comparative : le Framework DICES Appliqué . . . 128
7.8.1 Grille comparative DICES des standards . . . 128
7.8.2 Quel standard pour quelle situation ? . . . 129
7.9 Standards Émergents : Cloud, IoT et Post-Quantique . . . 129
7.9.1 Forensique cloud . . . 129
7.9.2 Forensique IoT . . . 130
7.9.3 Post-quantique et authenticité des preuves . . . 130

**8 Chaîne de Custody et Admissibilité 133**

8.1 Définition et Fondements de la Chaîne de Custody . . . 134
8.1.1 Définition formelle . . . 134
8.1.2 Pourquoi la chaîne de custody prime sur l'analyse technique . . . 134
8.2 Cadre Légal Camerounais de la Custody . . . 135
8.2.1 Articles 52–59 de la Loi 2010/012 : les perquisitions numériques . . . 135
8.2.2 Tableau de correspondance : Loi 2010/012 et ISO 27037 . . . 136
8.3 Le Formulaire de Chaîne de Custody : Anatomie et Utilisation . . . 136
8.3.1 Principe général : le formulaire commence au premier contact . . . 137
8.3.2 Formulaire type. version académique complète . . . 137
8.3.3 Champ par champ : comment remplir correctement . . . 138
8.4 Protocole de Custody par Type d'Evidence . . . 138
8.4.1 PC allumé : préserver avant de saisir . . . 138
8.4.2 PC éteint : ne pas allumer . . . 139
8.4.3 Téléphone mobile : mode avion avant tout . . . 140
8.4.4 Données cloud et réponses opérateurs . . . 140
8.5 Les Cinq Erreurs Fatales de Custody . . . 141
8.5.1 Erreur 1 : allumer le PC suspect sans acquisition préalable . . . 141
8.5.2 Erreur 2 : travailler sur l'evidence originale . . . 141
8.5.3 Erreur 3 : le transfert non documenté . . . 141
8.5.4 Erreur 4 : oublier les versions d'outils . . . 142
8.5.5 Erreur 5 : les hash non calculés ou non conservés séparément . . . 142

8.6 Custody et Scénario MBONGO : l'Investigation Correcte . . . 142
8.7 Custody et Admissibilité : le Chemin vers le Tribunal . . . 144
8.7.1 Les quatre conditions d'admissibilité revisitées . . . 144
8.7.2 Ce que l'avocat de la défense cherche et comment s'y préparer . . . 145

**9 Outils et Techniques d'Acquisition 149**

9.1 Le Write Blocker : Protection Absolue de l'Evidence . . . 149
9.1.1 Principe et nécessité . . . 149
9.1.2 Write blocker matériel . . . 150
9.1.3 Write blocker logiciel . . . 150
9.2 Formats d'Image Forensique . . . 151
9.3 FTK Imager : Acquisition Disque et RAM . . . 152
9.3.1 Procédure d'acquisition disque en 7 étapes . . . 152
9.3.2 Acquisition de la mémoire RAM . . . 152
9.3.3 Acquisition Linux avec dd . . . 153
9.4 Acquisition Mobile : Android et iOS . . . 154
9.4.1 Les quatre niveaux d'acquisition mobile . . . 154
9.4.2 ADB. Android Debug Bridge . . . 154
9.4.3 iOS. contraintes spécifiques . . . 156
9.5 Volatility 3 : Analyse de la Mémoire RAM . . . 156
9.5.1 Architecture et principe . . . 156
9.5.2 Détecter un processus malveillant : cas MVOM . . . 157
9.6 Wireshark : Analyse du Trafic Réseau . . . 157
9.6.1 Modes d'utilisation forensique . . . 157
9.6.2 Filtres de référence . . . 158
9.7 File Carving : Récupérer les Fichiers Supprimés . . . 159
9.7.1 Principe des magic bytes . . . 159
9.8 Synthèse : Choisir ses Outils selon la Situation . . . 160

**III Cadre Normatif, Judiciaire et Déontologique 163**

**10 Cadre Normatif Global 165**

10.1 La Convention de Budapest : Premier Traité International sur la Cybercriminalité 166
10.1.1 Contexte, portée et position du Cameroun . . . 166
10.1.2 Architecture de la Convention . . . 167
10.1.3 Les infractions pénales : articles 2 à 11 . . . 167
10.1.4 Les mesures procédurales : articles 16, 17, 18 et 29 . . . 168
10.2 La Convention de Malabo : Réponse Africaine . . . 169
10.2.1 Contexte et entrée en vigueur . . . 169
10.2.2 Infractions spécifiques à Malabo . . . 170
10.2.3 Tableau comparatif Budapest / Malabo . . . 170
10.3 Les Protocoles Additionnels de Budapest . . . 171

10.4 INTERPOL et AFRIPOL : Architecture de la Coopération . . . 171
10.4.1 INTERPOL. réseau mondial . . . 172
10.4.2 AFRIPOL. coopération africaine . . . 172
10.5 Les MLAT et les Portails LEA . . . 173
10.5.1 La règle d'or : conservation avant divulgation . . . 173
10.5.2 Les portails LEA des grands fournisseurs . . . 173
10.6 Tableau de Décision : Quel Canal pour Quelle Demande ? . . . 175
10.7 Cas Pratique : Opération BAOBAB . . . 175

**11 Législation Mondiale et Régionale 179**

11.1 Droit Américain : le Cadre des Grands Fournisseurs . . . 180
11.1.1 Federal Rules of Evidence (FRE) : admissibilité aux États-Unis . . . 180
11.1.2 Stored Communications Act (SCA) : protection et accès . . . 180
11.1.3 Computer Fraud and Abuse Act (CFAA) : base des poursuites US . . . 181
11.1.4 CLOUD Act : accès transfrontalier aux données . . . 182
11.2 Droit Européen : RGPD, eIDAS, NIS 2 et e-Evidence . . . 182
11.2.1 RGPD : tensions avec l'investigation forensique . . . 182
11.2.2 eIDAS : valeur probatoire des signatures et horodatages électroniques . . . 183
11.2.3 NIS 2 : implications pour la forensique d'incident . . . 184
11.2.4 Règlement e-Evidence : la révolution en cours . . . 185
11.3 Droit Africain Régional : CEDEAO, SADC et EAC . . . 185
11.3.1 CEDEAO : le cadre d'Afrique de l'Ouest . . . 185
11.3.2 SADC : le modèle d'Afrique Australe . . . 185
11.3.3 EAC : le cadre d'Afrique de l'Est . . . 186
11.4 Grille de Lecture Comparative : Choisir sa Stratégie Juridique . . . 186
11.4.1 Tableau synthétique : droit local et implications opérationnelles . . . 187
11.4.2 Processus de qualification d'une affaire transfrontalière . . . 187

**12 Droit Camerounais et Africain 191**

12.1 Architecture du Cadre Normatif National : Trois Textes . . . 192
12.1.1 Vue d'ensemble . . . 192
12.1.2 Architecture de la Loi 2010/012 . . . 193
12.2 Les Infractions de la Loi 2010/012 : Titre III . . . 193
12.2.1 Articles 65 à 69 : accès, interception, atteinte à l'intégrité . . . 193
12.2.2 Articles 70 à 72 et 86 : fraude, manipulation, abus de dispositifs . . . 194
12.2.3 Article 88 : refus de remettre la clé de déchiffrement . . . 195
12.2.4 Article 76 : CSAM et contenus sexuels impliquant des mineurs . . . 196
12.3 La Loi 2024/017 : Protection des Données Personnelles . . . 196
12.3.1 Architecture et innovations par rapport à la Loi 2010 . . . 196
12.3.2 Définitions fondamentales : art. 5 . . . 197
12.3.3 Obligations clés du responsable du traitement . . . 197
12.3.4 Les sanctions pénales de la Loi 2024/017 . . . 198
12.4 Tableau Comparatif des Sanctions : les Trois Textes . . . 199

12.5 Règles d'Articulation des Trois Textes . . . 200
12.5.1 Grille de qualification par type d'infraction courant . . . 201
12.6 Six Erreurs de Qualification et Comment les Éviter . . . 202
12.7 Le Cadre Procédural : De la Plainte au Jugement . . . 202
12.7.1 Autorités compétentes . . . 203
12.7.2 Procédure type d'investigation numérique . . . 203
12.8 Jurisprudence Camerounaise : Premières Décisions de Référence . . . 203
12.8.1 Défis de la jurisprudence camerounaise . . . 204

**13 Déontologie de l'Investigateur Numérique 209**

13.1 Fondements Éthiques : Trois Cadres pour Décider . . . 210
13.1.1 Éthique déontologique : Kant et les droits absolus . . . 210
13.1.2 Éthique conséquentialiste : Mill et le calcul des conséquences . . . 210
13.1.3 Éthique des vertus : Aristote et le caractère de l'investigateur . . . 211
13.2 Les Cinq Tensions Déontologiques Majeures . . . 211
13.2.1 Tension 1 : Efficacité vs Droits fondamentaux . . . 211
13.2.2 Tension 2 : Confidentialité vs Obligation de divulgation . . . 212
13.2.3 Tension 3 : Objectivité vs Biais de confirmation . . . 212
13.2.4 Tension 4 : Loyauté institutionnelle vs Intégrité personnelle . . . 213
13.2.5 Tension 5 : Compétence personnelle vs Délégation nécessaire . . . 213
13.3 Droits des Personnes Interrogées . . . 214
13.3.1 Cadre légal et principe . . . 214
13.3.2 La méthode PEACE : entretien éthique et efficace . . . 214
13.4 Biais Cognitifs et Contre-Mesures . . . 215
13.4.1 Les six biais les plus dangereux en investigation . . . 216
13.4.2 La pratique de l'objectivité : protocoles concrets . . . 216
13.5 Responsabilité Personnelle de l'Investigateur . . . 217
13.5.1 Responsabilité pénale personnelle . . . 217
13.5.2 ACPO Principe 4 : responsabilité du chef d'investigation . . . 217
13.5.3 L'obligation d'auto-évaluation continue . . . 217
13.6 Déontologie et Témoignage Expert . . . 218
13.6.1 Obligations de l'expert judiciaire . . . 218
13.6.2 Résistance au contre-interrogatoire . . . 218
13.7 Cas Pratique : L'Affaire ONAMBELE. Décisions Déontologiques . . . 218

**A Glossaire 223**

**B Référentiel des Outils 227**

**C Modèles Opérationnels 229**

**D Textes Juridiques et Normatifs 231**

**E Bibliographie Commentée 235**

**F Contacts et Ressources** **237**

**Références bibliographiques** **239**

# TABLE DES FIGURES

3.1 Réseau criminel Opération WOURI. flux d'information et financiers . . . . . 59

5.1 Carte de la forensique numérique en 2025–2026 : cinq frontières actives toutes soumises aux tensions du Trilemme CRO . . . . . 90

6.1 Architecture globale du Processus Investigatif Universel (PIU) . . . . . 97

6.2 Exemple de matrice de compatibilité hypothèses/preuves : + Cohérent ; – Incohérent ; **o** Neutre . . . . . 106

7.1 Les 6 phases DFRWS et leurs correspondances avec le PIU . . . . . 121

7.2 Processus ISO/IEC 27043 : 8 phases avec boucle retour . . . . . 124

12.1 Procédure type d'investigation numérique au Cameroun . . . . . 203


© *MaletYon*

# LISTE DES TABLEAUX


© *MaletYon*

# Prologue Opérationnel


© *MaletYon*

# 0

# PROLOGUE: SCÈNE DE CRIME NUMÉRIQUE

« Un dossier judiciaire ne se perd jamais au tribunal.
Il se perd sur la scène de crime, dans les dix premières minutes. »

Thierry Minka, Expert Judiciaire

**Niveau :** *Introductif* • Aucun prérequis technique. Ce prologue se lit avant même d'ouvrir un terminal ou de brancher un disque dur.

**✦ Objectifs du chapitre**

- ➢ Comprendre, à travers un cas concret, pourquoi la méthode prime sur la technique en investigation numérique.
- ➢ Identifier les quatre principes fondamentaux, intégrité, traçabilité, reproductibilité, admissibilité, et reconnaître une violation de chacun d'eux.
- ➢ Mémoriser les réflexes immédiats sur une scène de crime numérique (PC allumé, PC éteint, téléphone) avant toute manipulation.
- ➢ Saisir la nature du **Trilemme CRO** comme tension constitutive de toute investigation numérique.

## Avant de commencer : une affaire qui n'aurait pas dû échouer

Douala, mars 2026. Le tribunal de grande instance vient de rendre son verdict dans l'affaire MBONGO[1]. Joseph MBONGO, comptable d'une PME de la Zone Industrielle de Bassa, était accusé d'avoir détourné **12 millions de francs CFA** via des virements frauduleux depuis le compte de son employeur vers un compte tiers. Les preuves semblaient accablantes : un email de virement portant sa signature, des captures d'écran du portail bancaire UBA sur son ordinateur, un historique de navigation Chrome daté et horodaté, un fichier Word supprimé nommé `faux_bon_de_commande.docx`.

L'avocat de la défense a demandé la parole. En dix minutes, il a obtenu l'irrecevabilité de la totalité des preuves numériques. Le dossier s'est effondré.

[1] Les noms, dates et montants de ce cas sont fictifs mais les mécanismes juridiques et techniques sont rigoureusement exacts.


© MaletYon

**★ Attention**

**Pourquoi ?** L'OPJ chargé de la saisie avait, en arrivant sur place, *allumé* l'ordinateur pour « constater visuellement les faits ». Windows avait automatiquement monté toutes les partitions, mis à jour les horodatages d'accès, créé des fichiers temporaires, modifié des clés de registre. L'avocat a prouvé au juge que l'heure de « création » de la capture d'écran `ecran_virement.png`, telle que lue dans Autopsy, était **postérieure** à l'heure de saisie déclarée dans le procès-verbal. Contamination prouvée. Irrecevabilité prononcée.
L'OPJ avait pourtant fait *tout le reste* correctement : il avait utilisé Autopsy, calculé les hash, rédigé un rapport de 40 pages. Tout cela est devenu sans valeur à cause de **dix secondes d'inattention** au moment d'appuyer sur le bouton Power.

Ce prologue n'est pas là pour vous enseigner Autopsy, ni le protocole TCP/IP, ni la cryptographie post-quantique. Ces sujets occupent les pages qui suivent. Ce prologue est là pour vous enseigner **le réflexe fondateur de toute la discipline** : *avant d'agir, comprendre ce que votre action va détruire.*

## 0.1 La Scène de Crime Numérique : un Lieu à Sécuriser

### 0.1.1 Ce qui change par rapport à une scène physique

Un investigateur criminaliste traditionnel sait qu'il ne doit pas marcher sur les traces de pas, ni toucher l'arme sans gants. L'équivalent numérique de cette règle est moins intuitif, parce que la contamination y est **invisible**. Brancher un clavier, allumer un écran, ouvrir un fichier : chacune de ces actions laisse des traces qui modifient l'état de la scène.

**■ Définition**

**Scène de crime numérique**: Tout environnement numérique susceptible de contenir des traces probantes d'un acte délictueux. Elle inclut les supports physiques (disques durs, clés USB, téléphones), la mémoire volatile (RAM), le trafic réseau, les journaux de serveurs et les données stockées dans le nuage.

La différence essentielle avec une scène physique est la **volatilité** : certaines données disparaissent en quelques secondes (mémoire vive), d'autres en quelques minutes (connexions réseau), d'autres subsistent mais peuvent être altérées sans laisser de trace visible à l' il nu (horodatages de fichiers).

| Type de donnée | Durée de vie | Menace principale |
|---|---|---|
| Registres CPU, cache | Nanosecondes | Non capturable |
| Mémoire RAM | Jusqu'à extinction | Extinction non planifiée |
| Connexions réseau actives | Secondes à minutes | Déconnexion réseau |
| Fichiers ouverts, sessions | Minutes | Fermeture de session |
| Disque dur / SSD | Mois à années | Chiffrement, TRIM |
| Journaux de serveur | Jours à semaines | Rotation automatique |
| Données cloud | Indéfini | Suppression distante |

*Tableau P.1. Ordre de volatilité des données numériques (d'après RFC 3227 [5])*

### 0.1.2 Le paradoxe de l'observation

En physique quantique, le principe d'Heisenberg stipule que l'acte de mesurer une particule modifie son état. L'investigation numérique connaît un paradoxe analogue : **tout acte d'observation d'un système numérique en cours d'exécution le modifie**. Lancer un outil forensique sur un PC allumé écrit dans la RAM, crée des fichiers temporaires, génère des entrées dans les journaux système.

Ce paradoxe ne constitue pas une impasse, il se gère par la **documentation rigoureuse** : l'investigateur note précisément chaque action entreprise et chaque modification connue qu'elle a induite. Le tribunal peut alors distinguer les traces *antérieures* à l'investigation des traces *créées par* l'investigation.

**Note**

**La règle d'or :** toute modification introduite pendant l'investigation doit être *documentée*, *justifiée* et *minimisée*. L'objectif n'est pas la perfection impossible, mais la traçabilité complète.

## 0.2 Les Quatre Principes Fondamentaux

Ces quatre principes structurent l'intégralité de la discipline. Ils seront formalisés mathématiquement dans la Partie II, mais les voici dans leur formulation la plus directe, illustrée par des violations réelles.

### 0.2.1 Principe 1. Intégrité

**Définition**

**Intégrité** (*Integrity*): Garantie que la preuve numérique n'a pas été modifiée depuis sa collecte. Elle se démontre par la correspondance des **empreintes cryptographiques** calculées avant et après acquisition.

L'intégrité est prouvée **mathématiquement**, pas déclarativement. Il ne suffit pas d'affirmer « je n'ai rien touché » ; il faut que le **hash** de l'image forensique soit bit-à-bit identique au hash du support original.

**★ Attention**

**Violation typique.** Un enquêteur branche un disque dur suspect directement sur son ordinateur Windows sans *write blocker*. Windows monte la partition, met à jour les horodatages d'accès du système de fichiers NTFS, crée un répertoire `System Volume Information`. Le hash du disque après branchement diffère du hash avant branchement. La preuve est contaminée.

**Règle absolue :** ne jamais monter un support suspect sans **write blocker** matériel ou logiciel activé et vérifié.

La vérification d'intégrité repose sur des fonctions de hachage cryptographiques. Les commandes de référence :

```
# Windows (CMD) -- calcul MD5 et SHA-256
certutil -hashfile C:\evidence\disque.E01 MD5
certutil -hashfile C:\evidence\disque.E01 SHA256

# Windows (PowerShell) -- alternative recommandée
Get-FileHash C:\evidence\disque.E01 -Algorithm SHA256

# Linux / Kali Linux -- syntaxe native
md5sum    /evidence/disque.E01
sha256sum /evidence/disque.E01
```

Listing 1: Calcul et vérification d'empreintes cryptographiques

Les deux hash, source et image, doivent être **identiques** et **documentés** dans le formulaire de chaîne de custody *avant* toute analyse.

**MD5 ou SHA-256 ?**

MD5 (128 bits) reste accepté en forensique pour l'intégrité d'une image car le risque n'est pas la falsification intentionnelle mais l'altération accidentelle. SHA-256 (256 bits) est recommandé pour toutes les nouvelles investigations et exigé en contexte à haute valeur probatoire. Calculez *toujours les deux simultanément* et documentez les deux dans le formulaire de custody.

### 0.2.2 Principe 2. Traçabilité (chaîne de custody)

**Définition**

**Chaîne de custody** (*Chain of custody*): Registre chronologique documentant chaque personne ayant eu accès à une preuve et toutes les actions effectuées sur celle-ci, depuis sa collecte jusqu'à sa présentation en audience.

La chaîne de custody est le **document le plus important d'une investigation numérique**, plus important que le rapport technique lui-même. Un rapport d'analyse de 100 pages perd toute valeur si on ne peut prouver que l'evidence analysée est bien celle saisie sur la scène de crime.

**Chaîne de Custody**

**Le formulaire commence au premier contact.** Les informations minimales à consigner immédiatement :

1. Numéro de dossier et numéro d'evidence (*ex.* : DOS-2026-004 / EV-001)
2. Description physique précise : marque, modèle, numéro de série, couleur, état apparent (rayures, caches manquants)
3. Lieu, date et heure de collecte (`JJ/MM/AAAA HH:MM`)
4. Nom, grade et matricule du collecteur
5. `[MD5]` et `[SHA-256]` du support original (avant acquisition)
6. `[MD5]` et `[SHA-256]` de l'image forensique (après acquisition)
7. Confirmation explicite que les deux hash correspondent

Le formulaire complet est disponible en Annexe C.

**Attention**

**Violation typique.** Un OPJ saisit le téléphone d'un suspect et le confie à un collègue pendant une heure pour « garder un œil dessus ». Ce transfert non documenté constitue un vide dans la chaîne de custody. À l'audience, l'avocat peut semer le doute : le téléphone a-t-il été manipulé pendant cette heure ?
**Règle :** tout transfert d'une evidence entre deux personnes doit être documenté immédiatement: date, heure, raison, signatures des deux parties. Si un doute existe, l'intégrité doit être re-vérifiée par re-hashage.

**Jurisprudence & Droit applicable**

**Droit camerounais, Loi 2010/012, article 53, alinéa 1 :** [34]

*« Les perquisitions [...] peuvent porter sur des copies réalisées en présence des*

*personnes qui assistent à la perquisition. »*

Cet article établit l'exigence légale d'une copie forensique réalisée *en présence* des parties. Le formulaire de chaîne de custody est la traduction procédurale de cette exigence : il prouve que la copie a été réalisée de façon transparente et documentée. Son absence peut suffire à faire rejeter l'ensemble du dossier numérique.

### 0.2.3 Principe 3. Reproductibilité

■ Définition

**Reproductibilité** (*Reproducibility*): Propriété d'une méthode d'investigation telle que, si elle est appliquée par un autre investigateur qualifié sur la même evidence avec les mêmes outils, elle produit les mêmes résultats.

La reproductibilité est la **condition de scientificité** de l'investigation numérique. Un résultat que seul son auteur peut obtenir, avec un outil non documenté, selon une méthode non explicitée, n'est pas une preuve scientifique : c'est une opinion.

En pratique, trois exigences concrètes s'imposent :

1. **Nommer les outils avec précision :** nom, version exacte, système d'exploitation hôte. *« Analysé avec Autopsy »* est insuffisant. La formulation correcte est : *« Autopsy 4.21.0 (The Sleuth Kit 4.12.0) sur Windows 11 Pro 22H2. »*
2. **Décrire la méthode :** les étapes dans leur ordre exact, suffisamment détaillées pour qu'un pair puisse les reproduire indépendamment.
3. **Documenter les limites :** ce qui n'a *pas* pu être analysé (partition chiffrée, fichier corrompu) doit être explicitement mentionné. Un rapport silencieux sur ses propres lacunes est un rapport trompeur.

★ Attention

**Violation typique.** Un analyste utilise un script Python maison pour extraire des artefacts de navigation. L'expert adverse tente de reproduire l'analyse sur la même image, et obtient des résultats différents, car le script contient une erreur sur certains formats SQLite. La méthode n'est pas reproductible. Les conclusions sont invalidées. **Règle :** utiliser des outils validés et documentés (Autopsy, Volatility, FTK Imager). Documenter la version exacte. Tester tout outil maison sur des données de référence connues avant utilisation en investigation réelle.

### 0.2.4 Principe 4. Admissibilité

**■ Définition**

**Admissibilité** (*Admissibility*): Qualité d'une preuve numérique lui permettant d'être recevable dans une procédure judiciaire. Elle suppose que la preuve a été obtenue légalement, qu'elle est pertinente aux faits allégués, et qu'elle est intègre.

Une preuve techniquement parfaite est sans valeur si elle est juridiquement irrecevable. L'admissibilité est la *finalité* de tous les autres principes : l'intégrité, la traçabilité et la reproductibilité existent *pour* garantir l'admissibilité.

**★ Attention**

**Violation typique.** Un supérieur hiérarchique accède au poste de travail d'un employé suspecté avec son propre compte administrateur, copie les fichiers sur une clé USB personnelle et les remet à la police. Ces fichiers sont irrecevables : collecte sans autorisation judiciaire, procédure de saisie non conforme aux articles 52–59 de la **Loi 2010/012**.

**Règle :** en contexte judiciaire, l'investigation numérique exige l'autorisation appropriée (mandat de perquisition, réquisition du procureur). En contexte interne (entreprise), elle doit être encadrée par le règlement intérieur et respecter le droit du travail camerounais.

**⚖ Jurisprudence & Droit applicable**

**Quatre critères d'admissibilité en droit camerounais**
*(d'après la jurisprudence et les articles 52–59 de la **Loi 2010/012**)*

1. **Légalité :** obtenue avec l'autorisation requise par la loi.
2. **Pertinence :** en lien direct avec les faits poursuivis.
3. **Intégrité :** non altérée depuis sa collecte (hachage vérifiable).
4. **Authenticité :** origine prouvable par la chaîne de custody.

## 0.3 Le Trilemme CRO : la Tension Constitutive

Avant d'entrer dans le détail des techniques, il est essentiel de comprendre la tension profonde qui traverse toute l'investigation numérique. Cette tension a été formalisée par les travaux du LIMSI sous le nom de **Trilemme CRO** [27].

### 0.3.1 Les trois dimensions en opposition

Toute investigation numérique doit simultanément satisfaire trois exigences qui se contrarient mutuellement :

➢ $\mathcal{C}$. **Confidentialité :** protéger la vie privée des personnes impliquées (suspect, victimes, témoins) et les données sensibles rencontrées.

- $\mathcal{R}$. **Fiabilité (*Reliability*) :** garantir que les preuves sont intègres, authentiques, reproductibles.
- $\mathcal{O}$. **Opposabilité juridique :** assurer que les preuves peuvent être présentées et défendues devant un tribunal.

**$\Gamma_{CRO}$ Analyse CRO · Confidentialité · Fiabilité · Opposabilité**

**Le Trilemme formulé :** il est impossible de maximiser simultanément les trois dimensions.

Pour qu'une preuve soit **opposable** ($\mathcal{O}$ haute), elle doit être vérifiable par toutes les parties, ce qui tend à *réduire* la confidentialité ($\mathcal{C}$ contrainte).
Pour maximiser la **confidentialité** ($\mathcal{C}$ haute), en chiffrant les données collectées, on risque de compromettre la reproductibilité et donc la fiabilité ($\mathcal{R}$ réduite).
Pour garantir la **fiabilité** ($\mathcal{R}$ haute), en collectant le maximum de données, on élargit le périmètre et empiète sur la vie privée de personnes non impliquées ($\mathcal{C}$ réduite).

$$\Gamma_{CRO}(\Pi) \;=\; \max\Big\{\mathcal{C}(\Pi),\ \mathcal{R}(\Pi),\ \mathcal{O}(\Pi)\Big\} \;\geq\; 0.4 + \mathrm{negl}(\lambda)$$

*Toute investigation est un compromis explicite entre ces trois dimensions. La maîtrise de ce compromis distingue l'investigateur expert du technicien.*

### 0.3.2 Le Trilemme sur la scène de crime : exemples immédiats

Ce n'est pas une abstraction théorique. Dès les premières secondes, l'investigateur fait face à des choix CRO concrets :

- *Doit-il capturer la RAM ?* Cette capture va légèrement modifier la RAM (atteinte à $\mathcal{R}$, documentable et acceptable) mais c'est la seule façon d'obtenir les clés de chiffrement actives (gain majeur pour $\mathcal{O}$). $\mathcal{C}$: $\sim$ $\mathcal{R}$: $\downarrow$faible $\mathcal{O}$: $\uparrow$
- *Peut-il lire tous les messages WhatsApp ?* Certains n'ont aucun lien avec l'affaire et révèlent la vie privée de tiers innocents. Lire plus que nécessaire améliore la fiabilité brute mais viole la proportionnalité légale. $\mathcal{C}$: $\downarrow$ $\mathcal{R}$: $\uparrow$ $\mathcal{O}$: $\sim$
- *Doit-il tout documenter publiquement ?* Certains artefacts sensibles (données médicales, correspondances protégées) peuvent être transmis sous pli scellé au juge. Gain pour $\mathcal{C}$, légère contrainte pour $\mathcal{O}$. $\mathcal{C}$: $\uparrow$ $\mathcal{R}$: $\sim$ $\mathcal{O}$: $\downarrow$faible

Tout au long de ce cours, chaque technique sera analysée à travers ce prisme. L'encadré **Analyse CRO** apparaîtra systématiquement pour expliciter quel compromis est réalisé et comment le justifier devant un tribunal.

## 0.4 Protocole d'Urgence : les 10 Premières Minutes

Ce protocole synthétise les décisions critiques des dix premières minutes. Il sera détaillé et justifié dans la Partie II (chapitres 8 et 9). Il est présenté ici dans sa forme la plus opérationnelle, pour être applicable immédiatement.

### 0.4.1 Arrivée sur la scène : les trois questions immédiates

1. **Le matériel est-il sous tension ?** → La réponse détermine tout ce qui suit.
2. **Y a-t-il du chiffrement actif visible ?** (BitLocker déverrouillé, VeraCrypt monté, Android déverrouillé) → Éteindre un support chiffré sans le capturer d'abord peut rendre les données définitivement inaccessibles.
3. **Y a-t-il une connexion réseau active ?** → Un suspect peut encore déclencher une destruction de données à distance tant que la connexion est maintenue.

### 0.4.2 PC allumé : procédure de triage

**Application OPJ/Expert Judiciaire**

**PC allumé: ordre des actions**

1. 1 *RAM*: Capturer la mémoire vive avec FTK Imager (`File → Capture Memory`). Le PC reste allumé pendant cette étape.
2. 2 *Écran*: Photographier l'écran dans son état actuel. Ne fermer aucune fenêtre.
3. 3 *Réseau*: Documenter les connexions actives : `netstat -ano` (CMD) ou `Get-NetTCPConnection` (PowerShell). Photographier ou noter.
4. 4 *Arrêt*: Éteindre proprement via le menu Windows. Sauf si une destruction de données est imminente, auquel cas l'arrachage du câble est justifiable et *doit être documenté*.
5. 5 *Disque*: Brancher avec write blocker. Acquérir l'image E01 avec FTK Imager. Calculer et noter hash MD5+SHA-256.

**Ne jamais :** ouvrir un fichier, lancer une application, connecter un périphérique USB sans write blocker, laisser Windows exécuter une tâche automatique (mise à jour, indexation).

### 0.4.3 PC éteint : procédure de saisie

**Application OPJ/Expert Judiciaire**

**PC éteint: ordre des actions**

1. **Ne pas allumer.** Appuyer sur le bouton Power contamine la scène avant même que l'OS ne soit chargé.

2. Photographier le matériel sous tous les angles, câbles en place, avant toute manipulation physique.
3. Activer le write blocker logiciel ou utiliser un write blocker matériel, puis retirer le disque dur ou SSD.
4. Acquérir l'image forensique en format E01 avec FTK Imager. Documenter les métadonnées du cas (numéro de dossier, examinateur).
5. Calculer et documenter les hash MD5 et SHA-256 source et image.
6. Sceller l'evidence originale dans un sachet inviolable étiqueté et consigner dans le formulaire de chaîne de custody.

### 0.4.4 Téléphone mobile : les règles absolues

**Application OPJ/Expert Judiciaire**

**Téléphone mobile: La règle d'or : mode avion en premier.**

Un téléphone connecté peut recevoir une commande d'effacement à distance (*remote wipe*) en quelques secondes. Le mode avion coupe la connexion sans effacer les données.

1. **Téléphone allumé :** mode avion immédiat. Si l'écran est inaccessible, placer dans un sac de Faraday[a]. Ne jamais brancher sur un chargeur avant isolation électromagnétique.
2. **Téléphone éteint, Android, code connu :** allumer en mode avion (maintenir le bouton Power et activer le mode avion dès l'affichage du démarrage). Extraire via ADB.
3. **Téléphone éteint, chiffré, code inconnu :** conserver éteint. Alimenter la batterie si nécessaire via câble contrôlé. Transmettre à un laboratoire spécialisé. N'allumer en aucun cas sans stratégie d'extraction préparée au préalable.
4. **Documenter :** numéro IMEI (`*#06#` ou sous la batterie), opérateur, état de l'écran, niveau de batterie estimé.

[a] À défaut de sac de Faraday : plusieurs épaisseurs d'aluminium ménager hermétiquement scellées. Vérifier que le signal opérateur disparaît.

## 0.5 Retour sur l'Affaire MBONGO : ce qui Aurait Dû se Passer

Voici la reconstitution de l'affaire d'ouverture, conduite cette fois conformément aux quatre principes.

**Scénario Opérationnel · Affaire MBONGO**

**Situation initiale :** PC Windows allumé et déverrouillé. Téléphone Android sur le bureau, écran actif. L'OPJ arrive sur place avec une clé USB write-protégée contenant FTK Imager Portable.

1. **Photographies d'état**: L'OPJ photographie l'écran PC (fenêtre navigateur ouverte sur le portail bancaire UBA, horodatage visible dans la barre des tâches) et l'écran du téléphone. Il ne touche ni l'un ni l'autre.
2. **Mode avion** sur le téléphone. Consigné dans le formulaire (*« 14h37 : téléphone passé en mode avion par OPJ NKENG »*).
3. **Capture RAM**: FTK Imager Portable lancé depuis la clé USB. `File → Capture Memory`. Fichier `RAM_MBONGO.mem` sauvegardé sur une clé de destination séparée. Taille : 16 Go. Hash MD5 calculé et noté : `[MD5] a3f7...`.
4. **Connexions réseau**: `netstat -ano` lancé dans CMD. Résultat photographié : deux connexions ESTABLISHED vers l'IP `41.202.219.X` (UBA Cameroun) et une connexion vers `185.62.X.X` (inconnue, notée pour investigation ultérieure).
5. **Arrêt propre** du PC via le menu Démarrer. Retrait du disque dur après déconnexion. Write blocker logiciel activé. Acquisition E01 en 47 minutes. Hash source : `[SHA-256] 3d9c...`. Hash image : `[SHA-256] 3d9c...`. **Intégrité vérifiée.**
6. **Formulaire de chaîne de custody** rempli pour le PC et le téléphone. Sachets scellés. Deux signatures. Transport au dépôt de preuves de la Brigade de Cybercriminalité.
7. **Analyse sur copie**: Autopsy 4.21.0 ouvre l'image E01. Jamais le disque original. Les 8 artefacts sont identifiés ; leurs horodatages sont tous *antérieurs* à la saisie.

**Résultat :** à l'audience, l'expert présente les hash correspondants, le formulaire de custody ininterrompu, la version exacte des outils. L'avocat de la défense ne peut pas arguer d'une contamination postérieure à la saisie. Le dossier tient.

$\Gamma_{CRO}$ **Analyse CRO · Confidentialité · Fiabilité · Opposabilité**

**Analyse CRO. Affaire MBONGO**

➢ $\mathcal{C}$. La capture RAM révèle peut-être des données sans rapport avec l'affaire. Ce risque est mentionné dans le rapport ; les données non pertinentes ne sont pas incluses dans le dossier. *Compromise acceptable et documentée.*

➢ $\mathcal{R}$. La capture RAM modifie légèrement la RAM elle-même (le processus FTK y réside pendant l'acquisition). Modification connue, quantifiable, minimale.

Hash pris *après* capture pour refléter cet état. *Maîtrisée.*

➢ $\mathcal{O}$. Le hachage, le formulaire de custody et les versions d'outils documentés permettent à l'expert de défendre chaque artefact devant le juge. *Maximisée.*

$\mathcal{C}$: ↓acceptable $\mathcal{R}$: ∼maîtrisé $\mathcal{O}$: ↑maximisé. Configuration standard d'une investigation judiciaire correctement conduite.

❍

**★ À retenir**

**Ce qu'il faut retenir de ce prologue :**

➢ Une investigation numérique peut être techniquement irréprochable et juridiquement anéantie par une erreur procédurale commise dans les premières minutes.

➢ Les **quatre principes fondamentaux** structurent toute la discipline : **intégrité** (hachage MD5+SHA-256), **traçabilité** (chaîne de custody continue), **reproductibilité** (méthodes et outils documentés), **admissibilité** (légalité + pertinence + intégrité).

➢ L'intégrité se prouve **mathématiquement**, jamais déclarativement. Deux hash identiques (source et image) constituent la preuve.

➢ La **chaîne de custody** commence à la seconde où l'investigateur touche l'evidence, pas quand il rédige son rapport.

➢ Le **Trilemme CRO** formalise la tension irréductible entre confidentialité ($\mathcal{C}$), fiabilité ($\mathcal{R}$) et opposabilité ($\mathcal{O}$). Toute investigation est un compromis explicite et documenté entre ces trois dimensions.

➢ Sur une scène numérique : **observer** avant d'agir, **agir dans l'ordre de volatilité**, **documenter chaque geste**.

**✍ Exercice P.1. Diagnostic d'une violation ★☆☆**

Lisez la description ci-dessous. Identifiez : (a) quel(s) principe(s) fondamentaux ont été violés ; (b) quelle dimension du Trilemme CRO a été sacrifiée ; (c) ce qu'il aurait fallu faire.

*Un chef d'entreprise suspecte un employé de fuite de données vers un concurrent. Sans prévenir les autorités, il demande à son informaticien de copier le disque dur de l'employé sur une clé USB personnelle et de « fouiller les fichiers ». L'informaticien ouvre les fichiers directement, prend des captures d'écran, et remet la clé au chef d'entreprise. Trois semaines plus tard, l'entreprise dépose plainte et présente ces*

*éléments au procureur.*

### ✍ Exercice P.2. Scénario de triage ★★☆

Vous arrivez sur une scène avec :

- Un ordinateur portable Windows 11, allumé, écran déverrouillé, fenêtre de navigateur ouverte sur un portail bancaire.
- Un téléphone Android, allumé, sans code PIN visible, Wi-Fi actif.
- Une clé USB branchée sur le laptop, voyant clignotant.

Décrivez, dans l'ordre exact des priorités, les six premières actions que vous effectuez. Pour chaque action, précisez : le principe fondamental qu'elle préserve, l'ordre de volatilité auquel elle répond, et l'impact CRO ($\mathcal{C}$: ? $\mathcal{R}$: ? $\mathcal{O}$: ?).

### ✍ Exercice P.3. Réflexion CRO ★★★

Dans l'affaire MBONGO, l'OPJ a capturé les 16 Go de RAM du PC. Cette RAM contenait : les preuves des virements, les identifiants de session bancaire, *et* 3 Go de correspondances personnelles de MBONGO sans rapport avec l'affaire (échanges WhatsApp Web, photos personnelles).
L'avocat de la défense plaide que ces données personnelles n'auraient pas dû être collectées (violation de la vie privée, article 17 du Pacte international relatif aux droits civils et politiques, applicable au Cameroun depuis 1984).

(a) Comment l'investigateur aurait-il dû anticiper ce problème avant la capture ?
(b) Comment le gérer dans son rapport pour préserver à la fois $\mathcal{O}$ et $\mathcal{C}$ ?
(c) Existe-t-il une solution technique qui aurait permis de réduire la surface de collecte ?

### ● Note

**La suite du cours.** Ce prologue vous a donné les réflexes de base et la tension fondamentale (Trilemme CRO) qui donne sens à toutes les techniques. La **Partie I** (Chapitres 1–5) apporte la philosophie et l'histoire qui ancrent ces réflexes dans leur contexte intellectuel. La **Partie II** (Chapitres 6–9) formalise le Processus Investigatif Universel, la chaîne de custody et les outils d'acquisition. La **Partie III** (Chapitres 10–13) en donne le cadre juridique et déontologique. L'UE suivante, SEC4052 (Investigation numérique avancée), vous entraîne ensuite sur des systèmes réels (Windows, réseau, mobile, cloud) avec les cas qui traversent ce cours.

# partie I

# Fondements Épistémologiques et Historiques


© MaletYon

1

# PHILOSOPHIE ET FONDEMENTS DE L'INVESTIGATION NUMÉRIQUE

« L'archéologie ne cherche pas à retrouver la continuité ininterrompue ; elle établit ce qu'il nous est possible de connaître. »

Michel Foucault, *L'Archéologie du savoir*, 1969

**Niveau :** *Fondamental* • Aucun prérequis. Ce chapitre articule philosophie, épistémologie et mathématiques à un niveau accessible. Les équations servent à préciser des intuitions, non à les remplacer.

**✦ Objectifs du chapitre**

- ➢ Caractériser l'investigation numérique comme pratique philosophique à part entière, distincte d'une simple maîtrise d'outils.
- ➢ Comprendre la notion foucaldienne de **régime de vérité numérique** et l'appliquer à la périodisation de la discipline.
- ➢ Maîtriser les fondements mathématiques mobilisés en forensique : entropie de Shannon, théorie des graphes, sensibilité aux conditions initiales.
- ➢ Articuler le **paradoxe de l'authenticité invisible** avec le Trilemme CRO comme grille de lecture unifiée.
- ➢ Formuler les obligations éthiques de l'investigateur numérique à partir de la notion de **praxis de liberté**.

## 1.1 L'Investigation Numérique comme Pratique Discursive

### 1.1.1 Au-delà de la technique : une discipline philosophique

L'investigation numérique est souvent présentée comme une affaire d'outils : Autopsy pour analyser les disques, Volatility pour la mémoire, Wireshark pour le réseau. Cette réduction est non seulement inexacte – elle est dangereuse. Un investigateur réduit à ses outils est un artisan. Ce cours forme des praticiens capables de produire des conclusions défendables devant n'importe quel tribunal, dans n'importe quel contexte, avec les outils

disponibles au moment de l'investigation. Cela exige une **théorie**, pas seulement une boîte à outils.

La théorie commence ici, avec une question que Foucault aurait reconnue : *qu'est-ce qui fait qu'un énoncé numérique compte comme preuve à une époque donnée ?* Cette question n'est pas rhétorique. La réponse a changé quatre fois depuis 1970, et elle changera encore. L'investigateur qui ne comprend pas ces changements travaille dans l'obscurité ; celui qui les comprend peut anticiper les défis de l'audience avant même de toucher le premier disque dur.

**Définition**

**Investigation numérique** (*Digital forensics*): Discipline scientifique appliquée ayant pour objet l'identification, la préservation, l'analyse et la présentation de preuves numériques en respectant des méthodes juridiquement admissibles. Elle mobilise simultanément l'informatique, le droit, les mathématiques et la philosophie de la connaissance.

### 1.1.2 La notion foucaldienne de régime de vérité numérique

Notre cadre d'analyse s'inspire de *L'Archéologie du savoir* de Foucault [12] pour analyser l'investigation numérique comme **pratique discursive** productrice de vérité. Chaque période historique correspond à un **régime de vérité numérique** différent : un système qui détermine a priori ce qui peut compter comme preuve légitime, quelles méthodes d'investigation sont autorisées, quelles institutions sont habilitées à certifier la vérité numérique, et quel statut épistémique est accordé à l'investigateur.

**Définition**

**Régime de vérité numérique**: Système historiquement situé qui détermine, de manière a priori : les types de traces considérées comme preuves légitimes ; les techniques d'investigation autorisées ; les institutions habilitées à certifier ; les conditions d'acceptabilité juridique et sociale ; et le statut épistémique de l'investigateur comme sujet de savoir.

Cette notion est plus qu'un exercice académique. Elle explique pourquoi certaines preuves irréfutables sur le plan technique restent irrecevables sur le plan juridique : elles appartiennent à un régime de vérité que le droit n'a pas encore assimilé. Elle explique aussi pourquoi un investigateur formé uniquement sur les outils actuels sera dépassé dans dix ans, tandis que celui qui comprend la logique des régimes pourra s'adapter.

### 1.1.3 Périodisation mathématique des régimes

La périodisation des régimes de vérité repose sur quatre axes d'analyse dont la dominance relative définit chaque époque. Pour toute période historique $t$, le régime est caractérisé par un **vecteur de dominance** [27] :

$$\vec{R}_t = \left(\alpha_T,\ \alpha_J,\ \alpha_S,\ \alpha_P\right) \quad \text{avec} \quad \sum_i \alpha_i = 1 \tag{1.1}$$

où $\alpha_T$ représente la dominance technologique, $\alpha_J$ la dominance juridique et normative, $\alpha_S$ la dominance sociale et culturelle, et $\alpha_P$ la dominance des pratiques professionnelles. La transition d'un régime $\vec{R}_t$ à son successeur $\vec{R}_{t+1}$ obéit à une équation de transition non linéaire :

$$\vec{R}_{t+1} = F\left(\vec{R}_t,\ \Delta\text{Tech}_t,\ \Delta\text{Legal}_t,\ \mathcal{I}_t\right) \tag{1.2}$$

où $\mathcal{I}_t$ représente l'ensemble des incidents critiques de la période $t$ – les affaires qui ont contraint le régime à se reconfigurer.

Le tableau suivant synthétise l'évolution des régimes depuis l'émergence de la discipline [13], [32] :

| Période | Régime dominant | Preuve paradigmatique | Autorité épistémique |
|---|---|---|---|
| 1970–1990 | Technique ($\alpha_T \approx 0.7$) | Log système, adresse IP | Expert technique isolé |
| 1990–2000 | Juridique ($\alpha_J \approx 0.5$) | Chaîne de custody | Tribunal |
| 2000–2010 | Standardisé ($\alpha_P \approx 0.5$) | Conformité ISO/IEC | Organisme de certification |
| 2010–2020 | Computationnel ($\alpha_T \approx 0.6$) | Analyse big data | Algorithme |
| 2020–... | Quantique / ZK | Preuve à divulgation nulle | IA / Protocole |

*Tableau 1.1. Évolution des régimes de vérité numérique (synthèse de l'auteur, d'après [32] et [27])*

## 1.2 Ontologie de la Trace Numérique

### 1.2.1 La trace comme phénomène existentiel

Dans la philosophie de Derrida, la *trace* est l'inscription d'une absence : quelque chose était là, a agi, et a laissé une marque. La **trace numérique** est une instanciation particulièrement pure de cette notion : elle est produite sans intention consciente de laisser une marque, elle persiste au-delà de l'action qui l'a générée, et elle peut être interprétée comme révélatrice d'intention *a posteriori*.

La trace numérique n'est pas une simple donnée ; elle est une **manifestation d'existence**. Chaque fichier créé, chaque connexion établie, chaque frappe de clavier enregistrée dans un journal est la matérialisation numérique d'un acte humain. L'investigateur

qui lit ces traces ne lit pas de la technique : il lit du comportement, de l'intention, de la relation. Cette lecture est herméneutique avant d'être technique.

**Herméneutique des données**

L'interprétation des traces numériques requiert ce que Gadamer appelle un *cercle herméneutique* : on ne comprend une trace qu'à la lumière du contexte global, et on ne comprend le contexte global qu'à la lumière des traces individuelles. En pratique : un fichier `.docx` nommé `faux_bon_de_commande.docx` n'a de signification forensique que replacé dans la chronologie des virements, l'historique de navigation et les échanges d'emails. Chaque artefact éclaire les autres.

### 1.2.2 Temporalité numérique multidimensionnelle

Le temps numérique n'est pas linéaire. Un fichier possède jusqu'à quatre horodatages distincts dans le système de fichiers NTFS : **M**odified, **A**ccessed, **C**hanged, **B**orn (horodatage de création). Ces quatre dimensions peuvent diverger de façon significative : un fichier créé en 2020, modifié en 2024, mais accédé pour la dernière fois en 2022 raconte une histoire non linéaire. L'investigateur doit maîtriser cette **temporalité plurielle** pour ne pas commettre d'erreurs d'interprétation.

| Horodatage | Signification | Remarque forensique |
|---|---|---|
| `Modified` | Dernière modification du contenu | Le plus couramment analysé ; peut être falsifié (*timestomping*) |
| `Accessed` | Dernier accès en lecture | Peu fiable : Windows désactive souvent la mise à jour pour des raisons de performance |
| `Changed` | Dernière modification des métadonnées | Révèle les opérations sur l'entrée MFT ; difficile à falsifier |
| `Born` | Date de création sur ce volume | Clé pour détecter les fichiers copiés (Born > Modified = copié depuis un autre volume) |

*Tableau 1.2. Les quatre horodatages NTFS (timestamps MAC-B) et leur interprétation forensique*

La comparaison entre la preuve traditionnelle et la preuve numérique révèle l'ampleur de cette transformation ontologique :

| Preuve traditionnelle | Preuve numérique |
|---|---|
| Matérialité tangible, physique | Immatérialité des bits |
| Stabilité physique dans le temps | Volatilité et mutabilité |
| Authenticité portée par l'objet | Authenticité par la chaîne de confiance |
| Temporalité linéaire, univoque | Temporalité multidimensionnelle (MAC-B) |
| Falsification visible à l'expert | Falsification indétectable sans hachage |
| Localité géographique claire | Dispersion cloud multi-juridictionnelle |

*Tableau 1.3. Transition ontologique de la preuve : du physique au numérique*

## 1.3 Épistémologie de la Preuve Numérique

### 1.3.1 La crise de la vérité numérique

L'ère numérique engendre une **crise de la vérité** sans précédent. Trois phénomènes convergents l'alimentent :

- **Manipulation algorithmique :** les *deepfakes*, les documents générés par intelligence artificielle, les voix synthétiques brouillent la frontière entre l'authentique et le fabriqué avec une précision qui dépasse la capacité de détection humaine non assistée.
- **Érosion de l'autorité épistémique :** la multiplication des sources d'information, la désintermédiation des médias et la fragmentation des espaces discursifs ont détruit le consensus sur ce qui constitue une source fiable.
- **Fragmentation du réel :** les mêmes événements peuvent être documentés par des enregistrements contradictoires, tous authentiques, correspondant à des points de vue partiels sur une réalité complexe.

L'investigateur numérique devient dans ce contexte un **archiviste du réel** : celui dont le rôle est de préserver l'intégrité de la mémoire collective contre l'effacement, la falsification et la réécriture. Ce rôle dépasse largement le cadre judiciaire ; il touche à la démocratie, à la justice et à l'histoire.

### 1.3.2 La théorie de Kuhn appliquée à la forensique

Thomas Kuhn, dans *La Structure des révolutions scientifiques* [24], a montré que les sciences ne progressent pas par accumulation continue mais par ruptures paradigmatiques. La forensique numérique illustre parfaitement ce modèle : chaque décennie depuis 1970 a correspondu à un changement de paradigme, pas à une simple amélioration.

Le paradigme **technique** (1970–1990) posait que la vérité numérique était une affaire d'experts isolés lisant des logs. Le paradigme **juridique** (1990–2000) a introduit la

chaîne de custody et fait du tribunal l'arbitre final. Le paradigme **standardisé** (2000–2010) a délégué cette autorité aux organismes de certification (ISO/IEC). Le paradigme **computationnel** (2010–2020) a transféré l'autorité aux algorithmes d'analyse massive. Le paradigme **quantique/ZK** (2020–. . . ) en cours de formation pose que la vérité numérique peut et doit être prouvée sans divulgation de contenu.

Chaque transition a rendu caduques des pans entiers de la pratique existante. Un investigateur formé uniquement dans le paradigme standardisé, maîtrisant parfaitement les procédures ISO 27037 [18], n'est pas naturellement préparé à travailler avec des preuves à divulgation nulle. C'est pourquoi ce cours enseigne les *fondements*, pas les procédures : les fondements survivent aux changements de paradigme.

## 1.4 Fondements Mathématiques de la Discipline

Les mathématiques de l'investigation numérique ne sont pas décoratives : elles fournissent des outils opérationnels utilisés quotidiennement. Trois théories fondent la discipline.

### 1.4.1 Théorie de l'information : l'entropie de Shannon

La théorie de l'information de Shannon [37] quantifie l'incertitude contenue dans un système d'information. Son concept central, l'**entropie informationnelle**, est défini par :

$$H(X) = -\sum_{i=1}^{n} P(x_i) \log_2 P(x_i) \tag{1.3}$$

où $X$ est une variable aléatoire prenant les valeurs $x_1, \ldots, x_n$ avec les probabilités $P(x_1), \ldots, P(x_n)$, et $H(X)$ est mesurée en bits. Cette équation a trois applications forensiques directes :

1. **Détection de données chiffrées ou compressées :** un fichier chiffré ou compressé présente une entropie proche de 8 bits/octet (distribution quasi uniforme des octets). Un fichier texte ordinaire présente une entropie de 3 à 5 bits/octet. Un examinateur peut ainsi identifier rapidement les zones d'un disque contenant des données potentiellement chiffrées.
2. **Détection de stéganographie :** l'insertion de données cachées dans un fichier image ou audio modifie la distribution statistique des pixels ou des échantillons, entraînant une divergence entropique mesurable par rapport à un fichier non modifié de même type.
3. **Analyse de malware :** les sections de code d'un exécutable malveillant chiffré (shellcode chiffré, packer) présentent une entropie anormalement haute, ce qui permet de les identifier avant même d'exécuter le binaire.

**Artefact · Entropie d'un fichier - indicateur forensique**

**Interprétation pratique de l'entropie :**

| | |
|---|---|
| $H \in [0, 1]$ | Fichier quasi vide ou très répétitif (logs compressés, fichiers sparse) |
| $H \in [3, 5]$ | Texte naturel, code source, XML/JSON non compressé |
| $H \in [6, 7]$ | Données binaires compilées, exécutables standard |
| $H \in [7.5, 8]$ | Chiffrement, compression, stéganographie – investigation approfondie recommandée |

### 1.4.2 Théorie des graphes : modélisation des relations

L'analyse relationnelle repose sur la **théorie des graphes**, qui modélise les entités et leurs interactions :

$$G = (V, E) \quad \text{avec} \quad E \subseteq V \times V \tag{1.4}$$

où $V$ est l'ensemble des *sommets* (entités : personnes, machines, comptes, adresses IP) et $E$ l'ensemble des *arêtes* (relations : communications, transferts, accès). Un graphe pondéré $G = (V, E, w)$ où $w : E \to \mathbb{R}$ associe un poids à chaque relation (volume de communications, fréquence, montants transférés) est particulièrement utile en investigation financière.

Les applications forensiques sont nombreuses :

- **Analyse de réseau de communication :** les échanges d'emails ou de messages forment un graphe dont les algorithmes de centralité (PageRank, betweenness centrality) permettent d'identifier les acteurs clés d'un réseau criminel.
- **Corrélation d'incidents :** les logs de plusieurs systèmes peuvent être modélisés comme un graphe temporel pour reconstituer un chemin d'attaque.
- **Forensique blockchain :** les transactions cryptomonnaies forment un graphe de flux dont l'analyse permet de remonter des fonds jusqu'à des entités identifiables.

### 1.4.3 Sensibilité aux conditions initiales

L'investigation numérique opère dans des systèmes complexes où de minuscules altérations peuvent avoir des conséquences considérables. Cela est formalisé par la théorie du chaos : pour un système dynamique, la distance entre deux trajectoires initialement proches croît exponentiellement :

$$\delta(t) \approx \delta(0) \cdot e^{\lambda t} \tag{1.5}$$

où $\lambda$ est l'exposant de Lyapunov caractérisant la sensibilité du système. En forensique, ce résultat justifie mathématiquement l'obsession pour la préservation de l'intégrité : une modification infinitésimale de l'état initial (allumer le PC, monter une partition) peut produire une divergence massive dans l'état final (modification de centaines d'horodatages, création de fichiers temporaires, mise à jour du registre). La sensibilité aux conditions initiales est la justification théorique profonde du principe d'**intégrité**.

## 1.5 Le Paradoxe de l'Authenticité Invisible

### 1.5.1 Énoncé du paradoxe

Le **paradoxe de l'authenticité invisible**, théorisé dans [28], capture la tension fondamentale entre authentification et confidentialité :

> *Plus une preuve numérique est authentique et vérifiable, plus elle tend à révéler des informations sur son contenu et son origine, compromettant ainsi la confidentialité. Inversement, plus une preuve préserve la confidentialité, plus son authenticité devient difficile à établir de manière certaine.*

Cette tension peut s'exprimer comme une relation d'incertitude analogue au principe d'Heisenberg :

$$\Delta\mathcal{A} \cdot \Delta\mathcal{C} \;\geq\; \hbar_{\text{num}} \tag{1.6}$$

où $\Delta\mathcal{A}$ est l'incertitude sur l'authenticité (fiabilité de la preuve), $\Delta\mathcal{C}$ est l'incertitude sur la confidentialité (protection de l'information), et $\hbar_{\text{num}}$ est une constante numérique fondamentale caractérisant le système considéré.

**Statut de la formule (1.6)**

Cette relation d'incertitude est une *analogie formalisée*, pas une dérivation de la mécanique quantique. Sa valeur est heuristique : elle nomme une tension réelle et irréductible, lui donne une forme mathématique précise, et ouvre la voie à des mesures opérationnelles. La constante $\hbar_{\text{num}}$ dépend du système cryptographique et du contexte juridique ; sa quantification précise est l'objet de travaux en cours au LIMSI.

### 1.5.2 Implications épistémologiques

Le paradoxe soulève trois questions profondes que l'investigateur doit intégrer dans sa pratique :

1. **Peut-on savoir qu'une preuve est authentique sans en connaître le contenu ?** Les preuves à divulgation nulle (protocoles ZK) répondent oui, à condition d'accepter que la preuve change de nature : elle n'est plus un objet à examiner mais un processus à vérifier.

2. **Comment fonder la confiance dans ce qui reste invisible ?** La réponse est institutionnelle autant que technique : la confiance repose sur la robustesse mathématique du protocole ET sur la légitimité de l'institution qui le met en œuvre.
3. **L'authenticité peut-elle exister sous forme chiffrée ?** Oui : un hash cryptographique prouve l'intégrité d'un fichier sans en révéler le contenu. Mais l'opposabilité juridique de cette preuve reste dépendante de la juridiction.

### 1.5.3 Résolution partielle : les protocoles ZK-NR

Les protocoles **Zero-Knowledge Non-Repudiation** (ZK-NR) [28] apportent une résolution pratique en permettant :

Vérification sans Divulgation

Confiance sans Transparence totale

Preuve sans Révélation du contenu

Cette résolution n'est pas magique : elle ne supprime pas la tension du paradoxe, elle en gère les effets de façon contrôlée. La Partie VI du cours SEC4052 (Chapitres 26–32) est entièrement consacrée à ces protocoles. Le paradoxe de l'authenticité invisible sera alors revisité dans toute sa profondeur mathématique.

## 1.6 Le Trilemme CRO comme Grille de Lecture Unifiée

### 1.6.1 Genèse et formalisation

Les tensions identifiées dans les sections précédentes, entre authentification et confidentialité, entre opposabilité et protection de la vie privée, entre rigueur technique et admissibilité juridique, ne sont pas des accidents. Elles constituent la structure profonde de toute investigation numérique, formalisée par le **Trilemme CRO** [27].

**$\Gamma_{CRO}$ Analyse CRO · Confidentialité · Fiabilité · Opposabilité**

**Le Trilemme CRO. Définition formelle**

Soit $\Pi$ un protocole ou une méthode d'investigation numérique. On définit :

- $\mathcal{C}(\Pi) \in [0,1]$ : indice de confidentialité, mesure dans quelle proportion $\Pi$ protège les informations sensibles des parties impliquées.
- $\mathcal{R}(\Pi) \in [0,1]$ : indice de fiabilité, mesure dans quelle proportion $\Pi$ garantit l'intégrité et la reproductibilité des preuves.
- $\mathcal{O}(\Pi) \in [0,1]$ : indice d'opposabilité juridique, mesure dans quelle proportion $\Pi$ produit des preuves recevables et défendables devant un tribunal.

**Énoncé du trilemme [27] :**

$$\Gamma_{CRO}(\Pi) \;=\; \max\Big\{\mathcal{C}(\Pi),\; \mathcal{R}(\Pi),\; \mathcal{O}(\Pi)\Big\} \;\geq\; 0.4 + \mathrm{negl}(\lambda) \tag{1.7}$$

où $\lambda$ est le paramètre de sécurité du système cryptographique sous-jacent et $\text{negl}(\lambda)$ une fonction négligeable.

*Interprétation : aucun protocole ne peut simultanément maximiser les trois indices. Au moins l'une des trois dimensions sera contrainte à demeurer sous son maximum théorique. La compétence de l'investigateur se mesure précisément à sa capacité à choisir et justifier le compromis optimal pour le contexte.*

### 1.6.2 Le Trilemme comme boussole de la pratique

À chaque étape d'une investigation, l'analyste du Trilemme CRO pose trois questions :

1. **Cette technique augmente-t-elle $\mathcal{C}$, $\mathcal{R}$ ou $\mathcal{O}$ ?** Si elle augmente $\mathcal{R}$ (ex. : capture RAM complète), quelle dimension sacrifie-t-elle ? ($\mathcal{C}$ : accès à des données personnelles non pertinentes).
2. **Le compromis est-il justifiable et documenté ?** Un compromis non documenté n'est pas défendable. Un compromis documenté et justifié est presque toujours défendable.
3. **Ce compromis est-il proportionnel à l'enjeu ?** Une investigation pour un détournement de 500 000 FCFA ne justifie pas la même atteinte à $\mathcal{C}$ qu'une investigation pour une affaire de terrorisme.

Le Trilemme CRO n'est pas une contrainte abstraite : c'est l'outil qui transforme chaque décision technique en décision éthique consciente. Il sera appliqué systématiquement à chaque chapitre de ce cours, sous la forme de l'encadré **Analyse CRO**.

## 1.7 Éthique et Responsabilité de l'Investigateur

### 1.7.1 L'investigateur comme philosophe-praticien

L'investigateur numérique moderne endosse ce que Ricoeur appellerait une **identité narrative composite** : il est simultanément :

1. **Archéologue du digital :** il exhume et préserve les traces numériques comme un archéologue préserverait des vestiges – avec la conscience que toute intervention modifie irréversiblement ce qu'on tente de conserver.
2. **Épistémologue pratique :** il évalue en permanence la fiabilité de ce qu'il trouve, distingue la corrélation de la causalité, et refuse de conclure au-delà de ce que les preuves permettent.
3. **Éthicien appliqué :** il navigue des dilemmes moraux réels, souvent sans temps de réflexion, et doit avoir internalisé des principes suffisamment robustes pour guider ses choix dans l'urgence.

### 1.7.2 L'investigation comme praxis de liberté

Bien comprise, l'investigation numérique est une **praxis de liberté** : elle protège les individus contre l'arbitraire en documentant le réel ; elle permet la reddition des comptes dans des sociétés où le pouvoir numérique est concentré ; elle préserve la mémoire collective contre l'effacement délibéré ; elle équilibre des rapports de force asymétriques par la transparence.

Cette dimension politique et éthique n'est pas extérieure à la technique : elle lui donne son sens. C'est pourquoi ce cours insiste autant sur les conditions juridiques d'admissibilité que sur les commandes forensiques : une preuve obtenue illégalement ou de façon disproportionnée n'est pas seulement irrecevable, elle est une atteinte aux droits fondamentaux.

**Définition**

**Charte de l'investigateur numérique**: Ensemble des obligations éthiques fondamentales :

1. Je préserverai l'intégrité de la preuve avant toute autre considération, y compris celle d'efficacité.
2. Je respecterai la dignité numérique des personnes impliquées, qu'elles soient suspectes, victimes ou témoins.
3. Je reconnaîtrai les limites de ma connaissance et les documenterai dans mes rapports.
4. Je travaillerai pour la vérité, pas pour la conviction d'une partie, ma loyauté est envers le tribunal, pas envers le commanditaire.
5. Je me souviendrai que derrière chaque donnée se trouve un humain dont la vie peut être affectée par mes conclusions.

### 1.7.3 Vers une éthique post-quantique

L'avènement de la cryptographie post-quantique et des preuves à divulgation nulle soulève de nouveaux impératifs éthiques que la pratique actuelle n'a pas encore intégrés. Trois enjeux majeurs :

- **La résistance à l'obsolescence :** les preuves numériques collectées aujourd'hui avec des algorithmes cryptographiques classiques (RSA, ECDSA) seront potentiellement cassables dans dix à quinze ans par un ordinateur quantique suffisant. L'investigateur a-t-il une obligation de collecter dès maintenant avec des algorithmes post-quantiques ? La réponse est oui, pour les affaires à haute valeur ou longue durée.
- **Le droit à l'oubli dans un monde de mémoire parfaite :** les capacités croissantes de stockage et de traitement permettent de conserver et d'analyser des traces numériques sur des décennies. L'investigateur doit intégrer le principe de

proportionnalité temporelle : la durée de conservation des preuves collectées doit être proportionnelle à l'enjeu judiciaire.

- **La responsabilité des algorithmes :** quand un outil d'IA identifie un suspect ou classe un artefact, qui est responsable de cette conclusion ? L'investigateur ne peut pas déléguer sa responsabilité épistémique à un algorithme opaque.

❍

★ À retenir

**Ce qu'il faut retenir de ce chapitre :**

- L'investigation numérique est une **pratique discursive** au sens foucaldien : chaque époque définit ses propres critères de vérité numérique. Comprendre ces régimes permet d'anticiper les défis judiciaires à venir.
- Le **vecteur de dominance** $\vec{R}_t = (\alpha_T, \alpha_J, \alpha_S, \alpha_P)$ formalise mathématiquement le régime de vérité dominant à chaque période.
- La **trace numérique** est une manifestation d'existence : sa lecture est herméneutique avant d'être technique. La temporalité numérique est multidimensionnelle (horodatages MAC-B).
- Trois outils mathématiques fondent la discipline : **entropie de Shannon** (détection d'anomalies), **théorie des graphes** (analyse relationnelle), **sensibilité aux conditions initiales** (justification du principe d'intégrité).
- Le **paradoxe de l'authenticité invisible** ($\Delta\mathcal{A} \cdot \Delta\mathcal{C} \geq \hbar_{\text{num}}$) nomme la tension irréductible entre authentification et confidentialité. Les protocoles ZK-NR en gèrent les effets, sans la supprimer.
- Le **Trilemme CRO** ($\Gamma_{CRO}(\Pi) \geq 0.4 + \text{negl}(\lambda)$) est la grille d'analyse qui traverse tout ce cours : toute investigation est un compromis explicite entre Confidentialité, Fiabilité et Opposabilité.
- L'investigateur est un **philosophe-praticien** : sa responsabilité est envers la vérité et la justice, pas envers la conviction d'une partie. La Charte de l'investigateur traduit cette responsabilité en obligations concrètes.

✍ **Exercice 1.1. Diagnostic de régime** ★☆☆

Identifiez le régime de vérité numérique dominant (1970–1990, 1990–2000, 2000–2010, 2010–2020 ou 2020–...) pour chacun des scénarios suivants, en justifiant votre réponse par les caractéristiques du régime (preuve paradigmatique, autorité épistémique, vecteur dominant) :

(a) Un juge rejette une preuve numérique au motif qu'elle a été collectée sans protocole de hachage documenté.

(b) Un investigateur présente au tribunal une analyse de clustering automatique de 2 millions d'emails, sans pouvoir expliquer précisément comment l'algorithme a identifié les messages suspects.

(c) Une entreprise engage un consultant qui, à partir de logs système, reconstitue manuellement l'activité d'un intrus et rédige un rapport non structuré mais techniquement exact.

(d) Une unité spécialisée utilise une preuve à divulgation nulle pour prouver qu'un document a été modifié, sans révéler son contenu.

### ✍ Exercice 1.2. Application du Trilemme CRO ★★☆

Pour chacune des situations suivantes, calculez qualitativement les trois indices CRO (*faible / moyen / élevé*), identifiez le compromis réalisé et évaluez s'il est justifiable :

(a) Un investigateur capture l'intégralité du trafic réseau d'une entreprise pendant 72 heures pour analyser une fuite de données.

(b) Un OPJ exige du prestataire cloud qu'il livre les données chiffrées d'un suspect sans lui fournir la clé de déchiffrement.

(c) Un analyste publie ses outils d'investigation en open source pour garantir la reproductibilité de ses méthodes.

(d) Une juridiction autorise l'utilisation d'une analyse IA pour classer les messages comme "suspects" mais interdit à l'avocat de la défense d'accéder à l'algorithme utilisé.

### ✍ Exercice 1.3. Réflexion sur l'entropie ★★★

Vous analysez une image forensique d'un disque dur de 500 Go. L'outil d'analyse d'entropie détecte une zone de 47 Go présentant une entropie uniforme de 7.98 bits/-octet. Le reste du disque présente des entropies variables entre 3.2 et 6.8 bits/octet.

(a) Quelle est votre hypothèse principale sur la nature de cette zone ?

(b) Proposez deux hypothèses alternatives (sans supposer d'activité malveillante) qui pourraient expliquer cette observation.

(c) Quelles analyses complémentaires effectueriez-vous pour discriminer entre ces hypothèses ? Précisez les outils et les commandes.

(d) Comment documenteriez-vous ces analyses dans votre rapport pour satisfaire simultanément $\mathcal{R}$ et $\mathcal{O}$ ?

**Note**

**Ce qui vient.** Le Chapitre 2 reprendra le cadre foucaldien posé ici pour décrire, affaire par affaire, comment chaque régime de vérité s'est constitué historiquement. La périodisation mathématique $\vec{R}_t$ servira de fil conducteur. Les fondements mathématiques (entropie, graphes) seront mis en pratique dans la Partie IV du cours SEC4052. Le Trilemme CRO et le paradoxe de l'authenticité invisible y seront formalisés rigoureusement dans la Partie VI.

2

# HISTOIRE DE L'INVESTIGATION NUMÉRIQUE

« Plus vous regarderez loin dans le passé, plus vous verrez loin dans le futur. »

Winston Churchill, *The Gathering Storm*, 1948

**Niveau :** *Fondamental* • Ce chapitre prolonge le Chapitre 1 : la notion de régime de vérité numérique ($\vec{R}_t$) y est appliquée cas par cas. Aucun prérequis technique.

**✦ Objectifs du chapitre**

- ➢ Reconstituer la **double hélice** de l'investigation numérique : l'enroulement historique du technique et du juridique.
- ➢ Appliquer le modèle des régimes de vérité $\vec{R}_t$ à chaque période pour comprendre pourquoi les affaires ont produit les innovations qu'elles ont produites.
- ➢ Identifier les jalons africains et camerounais de l'histoire de la discipline ; positionner le Cameroun dans ce récit.
- ➢ Extraire de chaque affaire une leçon opérationnelle directement applicable à la pratique contemporaine.
- ➢ Anticiper les configurations futures des régimes de vérité à partir de la loi d'accélération épistémique.

## La Double Hélice de l'Investigation Numérique

L'histoire de l'investigation numérique ne se raconte pas en ligne droite. Elle s'enroule selon une **double hélice**, image empruntée à la biologie moléculaire, où deux brins s'entrelacent sans jamais se confondre : le brin **technique** (ce que les outils permettent de faire) et le brin **juridique** (ce que le droit autorise à faire et ce qu'il exige pour que ce soit recevable). Chaque rupture dans l'un des brins provoque une tension dans l'autre. C'est cette tension répétée qui fait avancer la discipline [32].

L'histoire se découpe en cinq régimes de vérité successifs, chacun déclenché par un incident fondateur qui a contraint le régime précédent à se reconfigurer. Le vecteur


© MaletYon

de dominance $\vec{R}_t$ de chaque époque, rappelé dans le tableau synthétique ci-après, sera illustré affaire par affaire.

| Période | Incident fondateur | Innovation | Vecteur $\vec{R}_t$ dominant |
|---|---|---|---|
| 1970–1990 | Creeper / 414s | Trace électronique | $\alpha_T \approx 0.7$ |
| 1990–2000 | Op. Sundevil / Mitnick | Chain of custody | $\alpha_J \approx 0.5$ |
| 2000–2010 | Enron / McKinnon | Standards ISO/-NIST | $\alpha_P \approx 0.5$ |
| 2010–2020 | Silk Road / Panama | Analyse massive | $\alpha_T \approx 0.6$ |
| 2020–. . . | SolarWinds / IA | Preuves ZK / IA | $\alpha_T + \alpha_J \approx 0.8$ |

*Tableau 2.1. La double hélice en cinq régimes (synthèse de l'auteur, d'après [32])*

## 2.1 Les Prémices (1970–1990) : L'Émergence de la Trace Électronique

### 2.1.1 Contexte socio-technique du premier régime

Cette période correspond à ce que Manovich appelle « la logique culturelle de l'ordinateur personnel » : le numérique est le territoire d'une élite technique restreinte, les crimes sont commis par curiosité autant que par appât du gain, et le cadre juridique est absent ou analogique. Le régime de vérité est dominé par la technique ($\alpha_T \approx 0.7$) : l'expert technique isolé est l'unique autorité épistémique, et ses méthodes ne sont soumises à aucune contrainte procédurale.

Les premières investigations sont de l'**artisanat** : chaque analyste invente ses propres méthodes, documente selon son intuition, conclut selon son expertise. La preuve paradigmatique de l'époque est le log système une trace brute, technique, dont la signification est accessible seulement aux initiés.

| Dimension | Caractéristiques du régime 1970–1990 |
|---|---|
| Technologie | Mainframes, premiers PC, réseau ARPANET, absence de sécurité |
| Juridique | Absence de cadre spécifique ; application analogique du droit pénal existant |
| Social | Fracture numérique massive ; les hackers sont des héros ou des démons |
| Pratique | Méthodes ad hoc ; expertise individuelle non transmissible ; aucun standard |

*Tableau 2.2. Contexte socio-technique des prémices (d'après [32])*

### 2.1.2 The Creeper (1971) : le premier artefact forensique

**The Creeper** n'est pas un crime : c'est une expérience. Bob Thomas, ingénieur chez BBN Technologies, écrit en 1971 un programme capable de se déplacer d'ordinateur en ordinateur sur ARPANET en affichant le message `I'M THE CREEPER: CATCH ME IF YOU CAN!`. La réponse, **The Reaper**, programme écrit pour supprimer The Creeper, constitue la première *investigation active* de l'histoire numérique : pour attraper The Creeper, il fallait comprendre son comportement, sa propagation, ses traces.

La leçon n'est pas technique ; elle est épistémologique : **tout programme laisse des traces**, et ces traces peuvent être lues par qui sait les interpréter. Ce principe, évident aujourd'hui, était révolutionnaire en 1971.

### 2.1.3 L'affaire des 414s (1983) : premier paradigme investigatif

En 1983, six adolescents de Milwaukee, surnommés les **414s** d'après leur indicatif régional, pénètrent dans 60 systèmes informatiques incluant le Los Alamos National Laboratory et le Memorial Sloan-Kettering Cancer Center. Ils sont arrêtés, non par des techniques forensiques sophistiquées, mais parce que l'un d'eux se vante devant ses pairs, un informateur prévient la police.

Du point de vue forensique, cette affaire établit que les traces réseau constituent une preuve légitime, créant le premier régime de vérité basé sur l'adresse IP [32] :

$$P_{\text{réseau}} = \Big\{\text{logs},\ \text{adresses IP},\ \text{horodatages}\Big\} \in \mathcal{P}_{\text{légitime}} \tag{2.1}$$

**$\Gamma_{CRO}$ Analyse CRO · Confidentialité · Fiabilité · Opposabilité**

**Analyse CRO. Affaire des 414s**
L'investigation repose sur l'exploitation des logs système : aucune protection de la vie privée n'est invoquée. $\mathcal{C}$: $\downarrow$ $\mathcal{R}$: $\uparrow$ $\mathcal{O}$: $\downarrow$, Les preuves sont techniquement solides mais le cadre juridique n'existe pas encore pour les qualifier. L'absence de **Loi** ou de *Computer Fraud and Abuse Act* avant 1986 illustre le retard du brin juridique sur le brin technique.

**Impact :** création du *Computer Fraud and Abuse Act* aux États-Unis en 1986. Prise de conscience politique mondiale de la nécessité d'un cadre juridique propre aux crimes informatiques.

### 2.1.4 L'affaire BTK Killer (2005, racines 1974) : les métadonnées comme preuve

Dennis Rader, tueur en série surnommé BTK (*Bind, Torture, Kill*), avait communiqué avec la police pendant 30 ans sans être identifié. En janvier 2005, il envoie une disquette contenant un fichier `Test.A.rtf`. Les enquêteurs du FBI extraient les **métadonnées** du fichier avec un outil basique : le champ « Auteur » contient `Dennis`, et la propriété « Dernière organisation » indique `Christ Lutheran Church`. En croisant avec les membres

actifs de cette paroisse, Rader est identifié en quelques heures.

Cette affaire illustre un principe cardinal : **la valeur probatoire d'un artefact numérique peut dépasser celle de son contenu**. Le message de Rader n'incriminait personne ; ses métadonnées l'ont trahi :

$$V_{\text{probatoire}}(\text{métadonnées}) \geq V_{\text{probatoire}}(\text{contenu}) \tag{2.2}$$

**Artefact · Métadonnées de fichier Office**

**Localisation :** `Propriétés` du fichier → `Détails` (Windows) ou extraction via ExifTool/Autopsy.
**Informations typiquement contenues :** auteur, organisation, date de création, date de dernière modification, logiciel utilisé, parfois chemin du fichier sur l'ordinateur source, nom d'imprimante.
**Commande d'extraction :** `exiftool fichier.docx`
**Vulnérabilité :** la plupart des utilisateurs ignorent que ces données existent et n'ont pas l'habitude de les supprimer avant d'envoyer un fichier. L'investigateur doit systématiquement les extraire.

## 2.2 La Professionnalisation (1990–2000) : Naissance d'une Discipline

### 2.2.1 La révolution Internet et ses conséquences épistémiques

L'émergence du web transforme radicalement le régime de vérité. Le brin juridique ($\alpha_J$) et le brin pratique ($\alpha_P$) deviennent dominants : l'investigation ne peut plus être artisanale quand elle touche des millions d'internautes. La **professionnalisation** au sens d'Abbott correspond à ce moment où un groupe construit sa juridiction professionnelle autour : d'un corps de connaissances formalisé ; de méthodes standardisées et reproductibles ; d'une reconnaissance juridique et institutionnelle ; et d'un code déontologique contraignant [1].

### 2.2.2 L'Opération Sundevil (1990) : le choc de la standardisation

Le 8 mai 1990, le Secret Service américain lance la plus grande opération contre la cybercriminalité jamais conduite : saisie de 42 systèmes informatiques dans 14 villes simultanément. L'opération est un succès opérationnel et un désastre juridique. La majorité des poursuites s'effondrent : les preuves saisies n'ont pas été préservées selon des protocoles cohérents ; les hash n'existent pas encore comme concept forensique ; plusieurs systèmes saisis appartiennent à des innocents ciblés par erreur.

L'Opération Sundevil représente, selon Durkheim, un **fait social total** : elle cristallise tous les enjeux de la nouvelle société numérique et révèle l'impossibilité de continuer avec des méthodes artisanales. Elle conduit directement à la création de l'IOCE (*International Organization on Computer Evidence*) en 1995, première institution dédiée à la

standardisation de la forensique numérique.

**⚖ Jurisprudence & Droit applicable**

**Héritage normatif de l'Opération Sundevil :**

- ➢ Création de l'IOCE (1995), premiers principes de collecte de preuves numériques.
- ➢ Fondation du DFRWS (*Digital Forensics Research Workshop*) (2001), qui produira le premier modèle de processus forensique.
- ➢ Inspiration directe pour la Convention de Budapest [9] (2001).

### 2.2.3 L'arrestation de Kevin Mitnick (1995) : institution de la chaîne de custody

Le 15 février 1995, Kevin Mitnick « le hacker le plus recherché du monde » est arrêté à Raleigh (Caroline du Nord) grâce au travail de Tsutomu Shimomura. L'affaire dure depuis 1993 : Mitnick a utilisé le *IP spoofing*, le *TCP session hijacking* et l'ingénierie sociale pour pénétrer des dizaines de systèmes militaires et corporatifs.

La contribution épistémologique de cette affaire est plus importante que sa dimension médiatique : elle institue la *chain of custody* comme **condition nécessaire de la validité épistémique** d'une preuve numérique [7] :

$$\text{Validit}(P) \;\Leftrightarrow\; \exists \mathcal{C} \;\text{ telle que }\; \int \text{grit}(\mathcal{C})\, dt = 1 \tag{2.3}$$

où $\mathcal{C}$ représente la chaîne de custody et $\text{grit}(\mathcal{C})$ sa densité documentaire. Informellement : une preuve n'est valide que si elle est accompagnée d'une documentation continue de sa traçabilité.

**$\Gamma_{CRO}$ Analyse CRO · Confidentialité · Fiabilité · Opposabilité**

**Analyse CRO. Arrestation Mitnick**
L'affaire Mitnick mobilise les trois dimensions sous forte tension. $\mathcal{C}$ : les écoutes téléphoniques étendues soulèvent des questions de vie privée qui alimenteront la littérature juridique pendant une décennie. $\mathcal{R}$ : l'innovation de Shimomura (analyse de honeypot, corrélation temporelle avancée) est robuste et reproductible. $\mathcal{O}$ : la chaîne de custody, bien que perfectible, est suffisamment documentée pour permettre une condamnation. $\mathcal{C}$: ↓ tendu $\mathcal{R}$: ↑ $\mathcal{O}$: ↑ émergent

## 2.3 La Standardisation (2000–2010) : Rationalisation Industrielle

### 2.3.1 Le tournant du millénaire et les standards fondateurs

Cette période correspond à ce que Beck appelle « la société du risque » : le numérique est devenu infrastructure critique, et les États comme les entreprises comprennent que les méthodes artisanales sont un risque systémique. Quatre standards fondateurs émergent simultanément, créant une infrastructure normative sans précédent :

| Standard | Portée | Contribution principale | Acteurs moteurs |
|---|---|---|---|
| [ISO 27037] | International | Méthodologie unifiée de collecte | Organisations internationales |
| [NIST SP 800-86] | États-Unis | Gouvernance processuelle complète | Agences gouvernementales |
| [RFC 3227] | Internet | Ordre de volatilité, bonnes pratiques | Communauté technique |
| [ACPO Guide] | Royaume-Uni | 4 principes déontologiques | Forces de l'ordre britanniques |

*Tableau 2.3. Standards fondateurs de l'ère 2000–2010 (d'après [3], [5], [18], [29], [31])*

### 2.3.2 L'affaire Enron (2001) : naissance de l'*e-discovery*

La faillite d'Enron produit l'investigation numérique la plus massive de l'histoire jusqu'alors : 500 000 documents électroniques doivent être analysés, croisés, et présentés en justice. Les méthodes manuelles sont impossibles ; la réponse est la création des premiers outils d'**analyse automatisée** (précurseurs du *Technology-Assisted Review*). L'affaire établit que les résultats d'un algorithme d'analyse constituent des preuves légitimes si l'algorithme est validé et documenté :

$$P_{\text{algo}} = \mathcal{A}(\mathcal{D}) \in \mathcal{P}_{\text{légitime}} \quad \text{si} \quad \text{si}(\mathcal{A}) > \theta \tag{2.4}$$

où $\text{si}(\mathcal{A})$ est l'indice de scientificité de l'algorithme et $\theta$ le seuil d'acceptabilité judiciaire. Les amendements aux *Federal Rules of Civil Procedure* (2006) codifient ces principes en droit positif américain, ouvrant la voie à l'automatisation de l'investigation.

### 2.3.3 L'affaire Gary McKinnon (2002–2012) : souveraineté numérique

Gary McKinnon, informaticien britannique autiste, passe deux ans à infiltrer 97 serveurs militaires américains à la recherche de preuves d'existence extraterrestre. L'affaire dure dix ans, non pour des raisons techniques (McKinnon est rapidement identifié), mais parce qu'elle cristallise un conflit de **souveraineté numérique** : les États-Unis réclament l'extradition pour 70 ans de prison potentiels ; le Royaume-Uni refuse pendant une décennie au nom du droit à la santé de McKinnon.

La leçon forensique est la corrélation multi-juridictionnelle : quand une attaque traverse des frontières, les logs se trouvent dans des pays différents, les règles d'admissibilité divergent, et la coopération judiciaire internationale devient le vrai défi, pas la technique.

## 2.4 Le Big Data et le Cloud (2010–2020) : L'Échelle Critique

### 2.4.1 Le changement d'échelle qualitatif

Cette période correspond à ce que Boyd et Crawford appellent « l'ère des big data » où l'échelle change la nature même de l'investigation. Au-delà d'un certain seuil $N_{\text{critique}}$, l'analyse ne peut plus être humaine :

$$\lim_{N \to \infty} \frac{\text{Analyse humaine}}{\text{Analyse algorithmique}} = 0 \tag{2.5}$$

Cette équation a une implication directe sur le Trilemme CRO : quand l'analyse est déléguée à un algorithme opaque, $\mathcal{O}$ (opposabilité) est menacée, l'avocat de la défense peut contester une conclusion qu'aucun expert humain ne peut entièrement expliquer.

### 2.4.2 L'affaire Silk Road (2013) : forensique blockchain

Ross Ulbricht exploite Silk Road, première grande place de marché du dark web, depuis 2011. L'investigation du FBI combine trois innovations : la **forensique Tor** (corrélation de flux pour désanonymiser les serveurs), la **forensique blockchain** (analyse du graphe de transactions Bitcoin pour remonter les flux financiers), et l'**OSINT** (Ulbricht a publié des messages identifiables sur un forum public). La saisie de 144 000 bitcoins (environ 28 millions USD à l'époque, bien plus aujourd'hui) établit que les cryptomonnaies ne sont pas anonymes : elles sont pseudonymes, et le pseudonymat se brise par corrélation de métadonnées.

**La Blockchain comme registre forensique**

La blockchain Bitcoin est, du point de vue forensique, le registre comptable le plus complet jamais créé : chaque transaction est permanente, publique, et cryptographiquement liée à toutes les précédentes. La forensique blockchain exploite cette propriété en construisant le graphe complet des flux pour identifier les points d'échange (exchanges) où les cryptomonnaies sont converties en monnaie réelle, permettant l'identification des acteurs.

### 2.4.3 Les Panama Papers (2016) : investigation transfrontière

La fuite de 2,6 To de données (11,5 millions de documents) du cabinet Mossack Fonseca constitue la plus grande investigation de données de l'histoire. 376 journalistes de 76 pays collaborent pendant un an sur un corpus unifié. L'impact forensique est l'émergence de l'**investigation transnationale** comme nouveau paradigme :

$$I_{\text{global}} = \sum_{i=1}^{n} I^i_{\text{locale}} + C_{\text{collaboration}} - L_{\text{juridique}} \tag{2.6}$$

où $C_{\text{collaboration}}$ est le bénéfice de la coopération et $L_{\text{juridique}}$ les frictions des barrières légales entre juridictions. La leçon : la coordination internationale compense les barrières juridiques, mais cette coordination exige des protocoles techniques et déontologiques

communs, exactement ce que ce cours enseigne.

## 2.5 L'Ère Post-Quantique et IA (2020–. . . ) : Le Grand Saut

### 2.5.1 La double révolution IA / quantique

Nous entrons dans ce que l'on pourrait appeler l'ère de la « guerre algorithmique » : l'IA est simultanément l'arme de l'attaquant et le bouclier de l'investigateur. Deux ruptures parallèles redéfinissent les fondamentaux.

La première rupture est l'**émergence du régime de vérité algorithmique** : la vérité numérique est désormais établie par des systèmes d'IA dont le fonctionnement peut être incompréhensible pour les humains (*black box problem*). Cela crée une tension épistémique fondamentale : peut-on fonder une condamnation pénale sur un résultat algorithmique inexplicable ?

La seconde rupture est la **menace quantique sur la cryptographie** : l'algorithme de Shor rend théoriquement cassables RSA et ECC sur un ordinateur quantique suffisant. Les preuves numériques collectées aujourd'hui et reposant sur ces algorithmes pourraient être invalidées rétroactivement.

### 2.5.2 L'attaque SolarWinds (2020) : IA contre IA

L'attaque SolarWinds est la première illustration documentée d'une **attaque *living-off-the-land*** à l'échelle des États : les attaquants (groupe APT29, attribué aux services de renseignement russes) compromettent la chaîne d'approvisionnement logicielle de SolarWinds en injectant un code malveillant dans une mise à jour légitime. 18 000 organisations téléchargent la mise à jour infectée ; la compromission reste non détectée pendant **9 mois** malgré des outils de sécurité sophistiqués.

La leçon forensique centrale : la détection classique basée sur des signatures est morte. Seule l'**analyse comportementale basée sur l'IA** permet de détecter ce type d'attaque, et encore, après le fait. L'attribution reste incertaine : les techniques d'obfuscation masquent l'origine, et l'investigateur doit composer avec une probabilité, pas une certitude.

$\Gamma_{CRO}$ **Analyse CRO · Confidentialité · Fiabilité · Opposabilité**

**Analyse CRO. Attaque SolarWinds**
$\mathcal{C}$ : l'investigation exige l'accès aux systèmes internes de 18 000 organisations, tension massive avec la vie privée des clients. $\mathcal{R}$ : la reproductibilité est problématique ; les outils IA utilisés pour la détection ne produisent pas des conclusions entièrement auditables. $\mathcal{O}$ : l'attribution probabiliste basée sur l'IA est encore mal acceptée par les juridictions pénales ; aucune condamnation n'a suivi.
$\mathcal{C}$: $\downarrow$ critique $\mathcal{R}$: $\sim$ partielle $\mathcal{O}$: $\downarrow$ problématique
Ce cas illustre la **crise d'opposabilité du régime algorithmique** : les outils sont puissants, les conclusions solides techniquement, mais leur défendabilité devant un

tribunal reste à construire.

### 2.5.3 Affaire WannaCry (2017) : immunité collective numérique

Le 12 mai 2017, le ransomware WannaCry infecte 300 000 ordinateurs dans 150 pays en 72 heures, exploitant la vulnérabilité *EternalBlue* volée à la NSA. La réponse forensique de Marcus Hutchins, un chercheur de 22 ans qui identifie et active un *kill switch* caché dans le code, arrêtant la propagation, illustre un principe nouveau : la réponse aux incidents majeurs devient une entreprise **décentralisée et collaborative** similaire à l'immunité collective en épidémiologie :

$$R_0 = \beta \cdot \gamma^{-1} \tag{2.7}$$

où $\beta$ est le taux d'infection et $\gamma$ le taux de désinfection. L'analyse du *Domain Generation Algorithm* (DGA) de WannaCry par des dizaines d'équipes en parallèle constitue un modèle d'investigation distribuée qui préfigure les pratiques actuelles du partage de renseignement sur les menaces (*Threat Intelligence*).

## 2.6 L'Afrique et le Cameroun dans l'Histoire de la Discipline

### 2.6.1 Une histoire trop souvent absente des manuels

Les histoires standard de l'investigation numérique sont presque exclusivement nord-américaines et européennes. C'est une distorsion : l'Afrique n'est pas un spectateur de la cybercriminalité mondiale, elle en est simultanément une cible croissante, un terrain d'opération, de plus en plus, une source d'innovation forensique. Cette section comble ce vide historiographique.

### 2.6.2 Les fraudes 419 (1990s–présent) : la plus longue affaire forensique africaine

Les escroqueries dites **419**, du numéro de l'article du Code pénal nigérian qui les prohibe, constituent la première grande catégorie de cybercriminalité d'origine africaine à portée mondiale. Dès les années 1990, des réseaux nigérians envoient par email des millions de messages proposant des fortunes fictives. La réponse investigative révèle les limites fondamentales du régime de vérité de l'époque : les suspects sont en Afrique, les victimes en Europe et en Amérique, les preuves traversent des dizaines de juridictions, et aucune convention de coopération n'existe.

Cette affaire permanente a deux héritages directs pour notre cours : elle a forcé la Convention de Budapest (2001) à inclure une dimension coopération internationale, et elle a conduit le Cameroun à adopter la **Loi 2010/012** [34], qui criminalise explicitement ces pratiques en droit positif camerounais.

### 2.6.3 Le Cameroun et la Loi 2010/012 : entrée dans le régime de standardisation

Le 21 décembre 2010, le Cameroun adopte la **Loi N°2010/012 relative à la cybersécurité et la cybercriminalité**. Cette date marque l'entrée formelle du Cameroun dans le régime de standardisation mondial, avec un décalage de dix ans sur les pays pionniers, mais avec l'avantage de bénéficier du retour d'expérience d'une décennie d'application internationale. La même année, l'ANTIC est opérationnalisée comme autorité compétente.

**Jurisprudence & Droit applicable**

**Jalons camerounais de l'histoire forensique :**

- **2010** : Loi 2010/012 (cybersécurité et cybercriminalité) et Loi 2010/013 [35] (communications électroniques).
- **2011** : Création et montée en puissance de l'ANTIC comme autorité de régulation et de certification.
- **2016** : Compétence du Tribunal Criminel Spécial (TCS) étendue à certaines infractions cyber.
- **2017** : Opérationnalisation du CIRT national (Computer Incident Response Team).
- **2019–présent** : Multiplication des affaires de fraude Mobile Money (SIM swapping, BEC), première jurisprudence camerounaise en investigation numérique.
- **2024** : Loi sur la protection des données personnelles, nouveau cadre pour les investigations impliquant des données privées.

### 2.6.4 Les Opérations FALCON (2020–2022) : la coopération en action

En 2020, puis en 2021–2022, INTERPOL, la police nigériane et des partenaires privés de la cybersécurité conduisent les Opérations FALCON et FALCON II contre des réseaux de fraude au courriel d'affaires et d'hameçonnage basés au Nigeria : trois arrestations lors de la première, onze lors de la seconde, visant des membres du groupe **SilverTerrier** [16], [17].

Ces opérations montrent qu'une enquête transnationale peut aboutir sur le continent quand la police nationale, une organisation internationale et les détenteurs de données techniques partagent leurs informations. Elles montrent aussi sa dépendance à des partenaires étrangers : un enjeu pour la souveraineté des enquêtes africaines.

**Scénario Opérationnel · Fraude Mobile Money. Cameroun, 2021**

**Faits :** Un réseau de SIM swapping opère dans la région du Centre. Méthode : collecte des données personnelles des victimes via de faux sondages diffusés sur WhatsApp, puis substitution de la SIM dans une agence MTN complice. Résultat : 47 millions FCFA détournés en 3 semaines, 23 victimes.
**Arrestations :** 4 personnes dont 2 employés MTN. Qualification juridique : escroquerie informatique (**Loi 2010/012**, art. 72) et complicité.
**Leçon forensique :** La preuve numérique centrale n'est pas le message WhatsApp (contenu) mais les métadonnées de connexion (qui s'est connecté au système MTN, depuis quelle adresse IP, à quelle heure) et les logs de transactions Mobile Money. L'enquête illustre que la chaîne de custody doit commencer chez l'opérateur télécom, avant même la saisie du téléphone du suspect.
**Analyse CRO :** $\mathcal{C}$: ↓ $\mathcal{R}$: ↑ $\mathcal{O}$: ↑. Les logs opérateur sont techniquement fiables ($\mathcal{R}$ haute) et leur communication est encadrée par l'art. 57 de la Loi 2010/012 (réquisition judiciaire), garantissant $\mathcal{O}$. La vie privée des victimes ($\mathcal{C}$) est sacrifiée dans la limite du nécessaire, ce qui est justifiable et proportionnel.

## 2.7 Perspectives : la Loi d'Accélération Épistémique

### 2.7.1 Le temps entre les régimes se raccourcit

L'observation la plus frappante de l'histoire que nous venons de parcourir est que le temps entre les ruptures de paradigme semble se réduire. Le cours en propose un modèle simple, qui est une hypothèse de lecture et non un résultat établi :

$$\Delta t_{n+1} = k \cdot \Delta t_n \quad \text{avec} \quad 0 < k < 1 \tag{2.8}$$

Le passage du régime technique au régime juridique a pris vingt ans (1970–1990). Du juridique au standardisé : dix ans. Du standardisé au computationnel : dix ans. Du computationnel au post-quantique/IA : probablement cinq ans. La conséquence pratique est directe : un investigateur formé uniquement sur les outils actuels sera partiellement obsolète dans moins de cinq ans. La compréhension des *régimes*, pas des outils, est la seule formation qui résiste à cette accélération.

### 2.7.2 Trois scénarios pour 2030–2050

L'analyse prospective que propose ce cours retient trois régimes plausibles, à discuter :

1. **Régime quantique dominant :** le calcul quantique devient accessible. RSA et ECC sont cassées. Toute la forensique des preuves collectées avant 2030 doit être revue. Les protocoles ZK et les algorithmes post-quantiques standardisés par le NIST (CRYSTALS-Kyber, CRYSTALS-Dilithium) deviennent la nouvelle norme.
2. **Régime IA investigatif :** les LLM et les agents autonomes conduisent les premières phases de triage forensique sans intervention humaine. La question d'oppo-

sabilité devient centrale : peut-on présenter en justice une preuve identifiée par un agent IA qu'aucun expert humain ne peut entièrement auditer ?

3. **Régime post-humain :** existe un point $t_s$ (*singularité investigative*) où l'IA investigative dépasse durablement les capacités humaines. Ce régime pose la question fondamentale de la responsabilité : si l'IA se trompe et conduit à une condamnation injuste, qui en est responsable ?

Ces scénarios ne sont pas des spéculations : ils se préparent maintenant. Les Parties V et VI du cours SEC4052 sont construites précisément pour équiper l'étudiant face aux deux premiers scénarios.

❍

**★ À retenir**

**Ce qu'il faut retenir de ce chapitre :**

- L'histoire de l'investigation numérique suit une **double hélice** : le brin technique et le brin juridique s'enroulent et se contraignent mutuellement. Chaque rupture dans l'un provoque une réorganisation dans l'autre.
- Cinq régimes successifs : **technique** (1970–1990), **juridique** (1990–2000), **standardisé** (2000–2010), **computationnel** (2010–2020), **post-quantique/IA** (2020–. . . ). Chacun est déclenché par un incident fondateur.
- Leçons opérationnelles permanentes : les métadonnées peuvent dépasser le contenu en valeur probatoire (BTK) ; la chaîne de custody est une condition de validité, pas un formalisme (Mitnick) ; les algorithmes d'analyse sont des preuves à documenter (Enron) ; le pseudonymat blockchain se brise par corrélation (Silk Road) ; l'attribution probabiliste reste à la limite de l'opposabilité (SolarWinds).
- L'Afrique et le Cameroun ont leur propre histoire : les fraudes 419, la **Loi 2010/012** (2010), le SIM swapping, les Opérations FALCON. Cette histoire n'est pas un appendice de l'histoire mondiale, elle en est une dimension constitutive.
- La **loi d'accélération épistémique** ($\Delta t_{n+1} = k \cdot \Delta t_n$) prédit que les ruptures s'accélèrent. Maîtriser les régimes est plus durable que maîtriser les outils.

**✍ Exercice 2.1. Analyse d'un incident par son régime ★☆☆**

Pour chacun des incidents suivants, identifiez le régime de vérité dominant, le brin (technique ou juridique) qui a été le plus sollicité, et la leçon forensique principale :

(a) Un journaliste publie un reportage sur la corruption d'un ministre en utilisant

des emails obtenus par un lanceur d'alerte. Le tribunal accepte les emails comme preuves. Année : 2004.

(b) Une entreprise camerounaise perd 80 millions FCFA via un BEC. La police obtient les logs de connexion auprès de l'opérateur internet sur réquisition judiciaire. Année : 2022.

(c) Un analyste utilise un modèle LLM pour classer automatiquement 50 000 messages WhatsApp dans une affaire de trafic de drogue. L'avocat de la défense conteste la méthode. Année : 2025.

### ✍ Exercice 2.2. La double hélice appliquée ★★☆

L'affaire Stuxnet (2010) est un cas où un programme malveillant, conçu par des services étatiques, a physiquement endommagé des centrifugeuses iraniennes d'enrichissement d'uranium. Son investigation a mobilisé simultanément : reverse engineering de code polymorphe (4 zero-days simultanés), attribution géopolitique, droit international, et éthique de la guerre numérique.

(a) Appliquez le modèle $\vec{R}_t$ à cette affaire : quelles composantes $(\alpha_T, \alpha_J, \alpha_S, \alpha_P)$ sont les plus sollicitées ?

(b) Identifiez deux tensions CRO spécifiques à cette affaire et proposez comment un investigateur mandaté par une institution internationale devrait les gérer.

(c) En quoi cette affaire préfigure-t-elle le « régime IA contre IA » décrit en Section 2.5 ?

### ✍ Exercice 2.3. Prospective ★★★

La loi d'accélération épistémique ($\Delta t_{n+1} = k \cdot \Delta t_n$) suggère que le prochain régime de vérité émergera vers 2027–2030.

(a) Sur la base des tendances actuelles (IA générative, informatique quantique, blockchain forensique), construisez un scénario de rupture plausible : quel incident fondateur pourrait déclencher le prochain changement de régime ?

(b) Quelles compétences un investigateur formé aujourd'hui devrait-il développer pour rester pertinent dans ce nouveau régime ?

(c) Positionnez le Cameroun dans ce scénario : quels atouts et quelles vulnérabilités spécifiques le pays présente-t-il face à cette transition ?

**Note**

**Transition.** Le Chapitre 3 approfondit cinq affaires choisies pour leur valeur pédagogique maximale, chacune illustrant une innovation forensique qui a redéfini la pratique. Le Chapitre 4 formalisera ensuite les outils théoriques (théorie de l'information, théorie des graphes, cryptographie) sur lesquels repose la forensique moderne.

3

# LES GRANDES AFFAIRES. LEÇONS DE L'HISTOIRE

> « Chaque grande affaire forensique est un laboratoire où s'expérimente l'avenir de notre discipline. »
>
> — D[r] Henry C. Lee

**Niveau :** *Fondamental* • Ce chapitre prolonge le Chapitre 2 en approfondissant l'anatomie technique des affaires fondatrices. Aucun prérequis – les concepts techniques sont introduits et définis au fil du texte.

**✦ Objectifs du chapitre**

- ➢ Analyser l'anatomie technique et judiciaire de sept affaires fondatrices pour en extraire les principes forensiques durables.
- ➢ Identifier, dans chaque affaire, l'**artefact décisif**, la preuve unique qui a fait basculer le dossier, et la méthode employée pour le découvrir.
- ➢ Reconnaître les erreurs procédurales récurrentes qui affaiblissent les dossiers, afin de ne pas les reproduire.
- ➢ Appliquer la grille d'analyse CRO à des cas réels pour comprendre comment les tensions entre confidentialité, fiabilité et opposabilité se manifestent concrètement.
- ➢ S'approprier les quatre cas camerounais (Opérations ONAMBELE, TANGUE, MVOM, WOURI) comme référentiels de pratique locale.

## Comment lire ce chapitre

Chaque affaire est disséquée selon la même structure : **contexte** (ce qui s'est passé, en bref), **artefact décisif** (la preuve qui a tout changé), **anatomie technique** (comment cette preuve a été trouvée et pourquoi elle a tenu juridiquement), **erreurs commises** (ce qui a failli faire échouer l'investigation), et **leçon transférable** (ce que vous devez emporter de cette affaire dans votre pratique quotidienne).

Les quatre premières affaires sont internationales et fondatrices. Les quatre suivantes

sont camerounaises, fictives mais construites sur les patterns exacts des affaires traitées par la DGSN et l'ANTIC entre 2020 et 2026.

## 3.1 L'Affaire BTK Killer. Dennis Rader (2005)

### 3.1.1 Contexte et artefact décisif

Dennis Rader, tueur en série surnommé **BTK** (*Bind, Torture, Kill*), a assassiné 10 personnes dans la région de Wichita (Kansas) entre 1974 et 1991. Après une longue absence, il reprend contact avec la police en 2004 par lettres, puis par disquette. En janvier 2005, il envoie une disquette contenant un fichier `Test.A.rtf`. Les métadonnées extraites par les enquêteurs du FBI en quelques minutes conduisent à son arrestation en quatre jours.

**L'artefact décisif** : les propriétés du fichier `.rtf` révèlent le champ *Auteur* : `Dennis`, et le champ *Dernière organisation* : `Christ Lutheran Church`. Le croisement avec les membres actifs de cette paroisse identifie Rader immédiatement.

### 3.1.2 Anatomie technique

**Artefact · Métadonnées Office, champs auteur et organisation**

**Localisation dans Windows :** Clic droit sur le fichier → `Propriétés` → onglet `Détails`. Ou dans Office : `Fichier` → `Informations` → `Propriétés`.
**Localisation dans Autopsy :** `Results` → `Extracted Content` → `Document Metadata`.
**Extraction en ligne de commande :**

```
# ExifTool -- extraction complete des metadonnees
exiftool fichier.docx

# Sortie typique
Author                  : Dennis
Last Modified By        : Dennis
Organization            : Christ Lutheran Church
Create Date             : 2005:01:15 19:42:33
```

**Principe clé :** tout document Office créé depuis 1997 porte ces métadonnées. La plupart des utilisateurs ignorent leur existence. Elles survivent au renommage, à la copie, au transfert par email.

### 3.1.3 Erreurs commises et ce qu'elles enseignent

Rader a commis une erreur élémentaire : utiliser un ordinateur institutionnel (celui de son église) pour préparer un document destiné à la police, sans jamais nettoyer les métadonnées. Cette erreur révèle un **angle mort cognitif** universel : les utilisateurs visualisent le contenu de leurs documents mais ignorent la couche de métadonnées sous-jacente. Pour l'investigateur, cet angle mort est une opportunité systématique.

★ Attention

**Le principe des métadonnées survivantes** : tout fichier numérique produit une *deuxième couche d'information*, les métadonnées, que son auteur ne voit pas et oublie donc de supprimer. Cette couche contient souvent : l'identité de l'auteur, l'organisation, l'équipement utilisé, le chemin de fichier sur l'ordinateur source, parfois des coordonnées GPS (photos), la géolocalisation de l'imprimante, les révisions successives du document. L'examen systématique des métadonnées est une étape non optionnelle de toute investigation numérique.

### 3.1.4 Leçon transférable

★ À retenir

**BTK. Ce que vous emportez :**

- ➢ Extraire systématiquement les métadonnées de **tous** les fichiers collectés ; ne jamais se limiter au contenu visible.
- ➢ La commande `exiftool -r /dossier/` traite récursivement un répertoire entier.
- ➢ Un champ auteur vide n'est pas neutre : il signifie que le fichier a été créé avec un outil qui ne l'inscrit pas, ou que les métadonnées ont été *délibérément* supprimées (*timestomping* ou nettoyage EXIF), ce qui est en soi un indice forensique.

## 3.2 L'Affaire Stuxnet (2010)

### 3.2.1 Contexte et artefact décisif

**Stuxnet** est le premier programme malveillant conçu pour causer des dommages physiques à une infrastructure industrielle. Découvert en juin 2010 par VirusBlokAda, il cible spécifiquement les centrifugeuses d'enrichissement d'uranium iraniennes de Natanz. Quatre zero-days simultanés, un code polymorphe sophistiqué, une précision chirurgicale sur les automates Siemens `SIMATIC S7-315/S7-417` : l'attribution à des services étatiques (États-Unis et Israël, selon les sources) est largement acceptée.

**L'artefact décisif** : la présence de **quatre zero-days simultanés** dans un seul programme. Un groupe cybercriminel ordinaire en exploite rarement plus d'un ; en utiliser quatre simultanément signale des ressources d'État. Ce *marqueur de sophistication* a été l'argument principal de l'attribution.

### 3.2.2 Anatomie technique

L'investigation de Stuxnet a fondé la sous-discipline de la **cyberforensique industrielle**. Quatre techniques innovantes ont été nécessaires :

1. **Reverse engineering de code polymorphe :** Stuxnet modifiait son propre code à chaque exécution pour contourner les signatures antivirales. L'analyse a requis

l'extraction du code depuis la mémoire du processus en cours d'exécution, avant que la polymorphie ne l'altère.

2. **Sandboxing comportemental :** l'exécution dans un environnement virtualisé isolé (*sandbox*) a permis d'observer le comportement du malware sans risquer de propager l'infection. Stuxnet vérifiait lui-même s'il tournait dans une sandbox ; les analystes ont dû contourner cette détection.
3. **Identification des quatre zero-days :**
   - ➢ CVE-2010-2568 : vulnérabilité dans le traitement des fichiers `.lnk` (raccourcis Windows).
   - ➢ CVE-2010-2772 : vulnérabilité dans le *Windows Task Scheduler*.
   - ➢ CVE-2010-2729 : vulnérabilité dans le service *Print Spooler* pour la propagation réseau.
   - ➢ CVE-2010-2743 : vulnérabilité dans le pilote noyau Windows pour l'élévation de privilèges.
4. **Forensique des automates industriels (ICS/SCADA) :** les PLC (*Programmable Logic Controllers*) Siemens ciblés ne sont pas des PC ; leur forensique exige des outils et des compétences spécifiques absents des boîtes à outils classiques.

$\Gamma_{CRO}$ **Analyse CRO · Confidentialité · Fiabilité · Opposabilité**

**Analyse CRO. Affaire Stuxnet**
$\mathcal{C}$ : l'investigation a nécessité l'accès à des données sensibles d'États souverains et d'installations nucléaires. Le niveau de classification a fortement contraint la diffusion des résultats.
$\mathcal{C}$: ↓ très contrainte $\mathcal{R}$: ↑ robuste $\mathcal{O}$: ∼ limitée aux instances spécialisées
La tension CRO de Stuxnet est atypique : l'opposabilité n'est pas un objectif pénal (personne ne sera jugé) mais stratégique (attribution pour la diplomatie et la dissuasion). Cela illustre que l'investigation numérique sert des finalités multiples, pas seulement judiciaires.

### 3.2.3 Leçon transférable

★ **À retenir**

**Stuxnet. Ce que vous emportez :**

- ➢ La sophistication d'un malware est un **marqueur d'attribution** : zéro à deux zero-days = acteur criminel ou hacktiviste ; trois zero-days et plus = ressources d'État.
- ➢ Les systèmes industriels (ICS/SCADA) sont une frontière en expansion de l'investigation numérique ; leur forensique nécessite des compétences spécifiques au-delà de l'informatique classique.

➢ L'analyse comportementale en sandbox est indispensable pour tout malware inconnu : ne jamais exécuter un binaire suspect sur un système de production ou d'analyse non isolé.

## 3.3 L'Affaire WannaCry (2017)

### 3.3.1 Contexte et artefact décisif

Le 12 mai 2017, le ransomware **WannaCry** infecte 300 000 ordinateurs dans 150 pays en moins de 72 heures, en exploitant la vulnérabilité *EternalBlue* (CVE-2017-0144) volée à la NSA et publiée par le groupe Shadow Brokers. Les systèmes Windows non patchés, notamment ceux du National Health Service britannique (NHS), sont frappés de plein fouet : des hôpitaux doivent reporter des opérations chirurgicales non urgentes.

**L'artefact décisif** : le **kill switch**. Marcus Hutchins, chercheur de 22 ans, découvre dans le code de WannaCry une requête vers un domaine non enregistré (`iuqerfsodp9ifjaposdfjhgosu`
En enregistrant ce domaine pour 10,69 USD, il active le kill switch et stoppe la propagation mondiale.

### 3.3.2 Anatomie technique

Trois techniques d'investigation ont été déterminantes :

#### *3.3.2.1 Analyse du Domain Generation Algorithm (DGA)*

WannaCry ne s'appuie pas sur un DGA classique, le domaine kill switch est codé en dur. Mais l'analyse de ce domaine a révélé l'architecture de contrôle du malware : la présence d'un kill switch hard-codé est une signature des opérations de malware à grande échelle (permet à l'auteur de désactiver le malware en cas d'attribution imminente).

```
# Strings -- recherche de domaines et URLs dans le binaire
strings wannacry.exe | grep -E "\.(com|net|org|onion)"

# Sortie attendue :
# iuqerfsodp9ifjaposdfjhgosurijfaewrwergwea.com  <- kill switch
# 2.0.0.10 <- C2 IP candidate
# @WanaDecryptor@  <- marqueur de famille

# Vérification dynamique en sandbox (REMnux)
remnux analyze --timeout 60 wannacry.exe
```

Listing 3.1: Extraction du kill switch depuis un binaire WannaCry

#### *3.3.2.2 Attribution probabiliste : la piste Lazarus*

L'attribution à la Corée du Nord (groupe Lazarus) repose sur trois artefacts corrélés : similitudes de code avec des malwares Lazarus précédents (2014 : Sony Pictures), utilisation de la même adresse Bitcoin pour les paiements de rançons, et présence de commentaires en coréen dans certaines chaînes de débogage.

**Attribution numérique : probabilité, pas certitude**

L'attribution d'une attaque numérique à un acteur étatique ou criminel est un **jugement probabiliste**, jamais une certitude. Les bons acteurs imitent les signatures d'autres groupes (*false flag*). L'investigateur doit présenter ses conclusions d'attribution avec un niveau de confiance explicite (*ex.* : « attribution avec confiance modérée, sur la base de trois indicateurs corrélés »), non comme des faits établis.

#### *3.3.2.3 Forensique de l'impact : reconstitution de la chronologie*

La réponse à WannaCry a révélé l'importance de la **forensique des journaux distribués** : les logs de 150 pays devaient être corrélés temporellement. La leçon fondamentale est que les horloges système ne sont pas synchronisées universellement, une écart de quelques minutes entre deux systèmes peut inverser la chronologie d'une infection et fausser l'attribution.

### 3.3.3 Leçon transférable

**★ À retenir**

**WannaCry. Ce que vous emportez :**

- ➢ Analyser systématiquement les requêtes réseau d'un malware : elles révèlent l'architecture de contrôle et parfois un mécanisme de désactivation.
- ➢ L'attribution est une **opinion raisonnée**, pas une certitude ; la présenter comme telle protège l'expert lors du contre-interrogatoire.
- ➢ La corrélation temporelle multi-sources exige une **synchronisation des horloges** : documenter le décalage NTP de chaque système analysé avant toute chronologie.

## 3.4 L'Affaire Enron. L'E-Discovery à l'Échelle (2001)

### 3.4.1 Contexte et artefact décisif

La faillite d'Enron en décembre 2001 génère la première investigation numérique à grande échelle de l'histoire : 500 000 documents électroniques (emails, feuilles Excel, présentations PowerPoint) doivent être collectés, préservés, analysés et présentés en justice. L'enjeu dépasse le périmètre technique : pour la première fois, un tribunal doit statuer sur la recevabilité de preuves numériques massives.

**L'artefact décisif** : l'**email d'Enron** du 23 août 2001, dans lequel le vice-président Sherron Watkins avertit le PDG : *« I am incredibly nervous that we will implode in a wave of accounting scandals. »* Cet email n'était pas destiné à être conservé, mais il l'était, dans les sauvegardes automatiques des serveurs Exchange.

### 3.4.2 Anatomie technique

#### 3.4.2.1 La problématique de l'e-discovery à grande échelle

500 000 documents ne peuvent pas être examinés manuellement. Enron a conduit au développement des premières techniques de **Technology-Assisted Review** (TAR), ancêtre des outils d'IA forensique actuels. Les principes :

1. **Collecte préservante :** extraction des emails depuis les serveurs Exchange avec préservation des métadonnées (horodatages, en-têtes SMTP, codes de priorité). La simple exportation en `.pst` aurait supprimé des informations cruciales.
2. **Déduplication :** les mêmes emails existent en copies multiples (boîtes envoi, reçu, sauvegardes). La déduplication basée sur le hachage permet de réduire le volume sans perte d'information.
3. **Classification assistée :** les premiers algorithmes de classification par mots-clés et par graphe de communication ont identifié les 200 personnes les plus impliquées parmi les 20 000 boîtes email analysées.

#### 3.4.2.2 La règle de l'email : ce qui est envoyé ne disparaît jamais

★ Attention

**Le principe de la persistance des communications électroniques :** un email envoyé existe en copies multiples, dans la boîte d'envoi de l'expéditeur, la boîte de réception du destinataire, les sauvegardes automatiques des serveurs, les journaux des serveurs relais, les archives légales si elles existent. La suppression d'une copie n'élimine pas les autres.
En contexte judiciaire : la réquisition aux fournisseurs de services (art. 57 Loi 2010/012 [34] au Cameroun ; Convention de Budapest [9] art. 17 et 18 pour la coopération internationale) est le mécanisme légal pour accéder aux copies conservées par les opérateurs.

### 3.4.3 Leçon transférable

★ À retenir

**Enron. Ce que vous emportez :**

- La collecte préservante des emails exige d'extraire les **métadonnées complètes** (en-têtes SMTP, horodatages de réception, Message-ID), pas seulement le corps du message.
- La déduplication basée sur le hachage est la méthode de référence pour traiter de grands volumes sans altérer les preuves.
- En droit camerounais : la réquisition judiciaire aux opérateurs pour obtenir les communications conservées est l'article 57 de la **Loi 2010/012**. Elle doit être formulée avec précision (période, type de données, critères d'identification).

## 3.5 Opération ONAMBELE (Cameroun)

### 3.5.1 Contexte

**Scénario Opérationnel · Opération ONAMBELE. Fraude MoMo**

**Situation initiale :** Mme ABENA Céline, infirmière à Yaoundé, perd 850 000 FCFA en trois virements MTN MoMo (mars 2026) après avoir reçu des SMS lui annonçant qu'elle a gagné une promotion MTN fictive. Les fonds sont transférés vers le numéro de ZANGA Michel, 28 ans, qui a « prêté » son compte à un individu connu sous le nom de « KOFFI » en échange de 5 000 FCFA. KOFFI est identifié comme KOUAME Narcisse, basé à Abidjan (Côte d'Ivoire).

### 3.5.2 Artefacts décisifs et anatomie technique

L'affaire mobilise quatre artefacts complémentaires :

**Artefact · Historique de transactions MoMo**

**Source :** réquisition judiciaire à MTN (**Loi 2010/012**, art. 57).
**Information probante :** horodatages précis des trois virements, numéro destinataire (ZANGA), et la cascade de transferts immédiats vers trois autres numéros puis vers un retrait en espèces.
**Valeur forensique :** la cascade (*layering*) est un schéma classique de blanchiment ; elle prouve que le numéro de ZANGA n'était pas une destination finale mais un relais dans un réseau organisé.

**Artefact · Métadonnées du check-in Facebook de KOFFI**

**Source :** OSINT sur le profil Facebook de KOFFI.
**Information probante :** un check-in dans un restaurant de Yaoundé daté du 25 février 2026, deux semaines avant la fraude. Le profil indiquait être à Abidjan, mais ce check-in contredit cette déclaration et place KOFFI au Cameroun au moment des faits.
**Valeur forensique :** les check-ins Facebook contiennent les coordonnées GPS inscrites dans les métadonnées du post. En l'occurrence : latitude 3.86°N, longitude 11.52°E, centre de Yaoundé.

### 3.5.3 Erreurs à éviter

**★ Attention**

**Erreur n°1. Arrêter à ZANGA :** ZANGA est une « mule », un intermédiaire recruté pour ouvrir un compte et le prêter. L'arrêter seul ne démantèle pas le réseau. L'investigateur doit remonter la chaîne : ZANGA → KOFFI → le vrai organisateur.
**Erreur n°2. Négliger le téléphone allumé :** le téléphone Samsung de ZANGA était allumé lors de l'arrestation. Un OPJ non formé pourrait le brancher sur un

chargeur sans activer le mode avion. En quelques secondes, un message de « remote wipe » pourrait effacer les contacts de KOFFI sur WhatsApp. Procédure correcte : mode avion immédiat, puis ADB.

**Erreur n°3. Omettre la coopération internationale :** KOUAME Narcisse est en Côte d'Ivoire. Sans demande de coopération (Convention de Budapest art. 29 ; accord bilatéral Cameroun-CEDEAO), il ne peut pas être arrêté. La demande doit partir dès l'identification, pas attendre la fin de l'investigation nationale.

**$\Gamma_{CRO}$ Analyse CRO · Confidentialité · Fiabilité · Opposabilité**

**Analyse CRO. Opération ONAMBELE**

$\mathcal{C}$ : le contenu des messages WhatsApp entre ZANGA et KOFFI est une preuve cruciale, mais son accès exige le déblocage du téléphone (code PIN que ZANGA refuse de communiquer). Tenter un brute-force sans mandat risque de violer $\mathcal{C}$ et compromettre $\mathcal{O}$.

$\mathcal{R}$ : les données MoMo (réquisition MTN) sont des preuves fiables car issues directement des bases de l'opérateur, avec horodatages serveur.

$\mathcal{O}$ : l'ensemble du dossier (réquisition MTN + OSINT Facebook + ADB après consentement ou mandat) est admissible si la procédure est respectée.

$\mathcal{C}$: $\sim$ à gérer $\mathcal{R}$: $\uparrow$ $\mathcal{O}$: $\uparrow$ sous conditions

## 3.6 Opération TANGUE (Cameroun)

### 3.6.1 Contexte

**Scénario Opérationnel · Opération TANGUE. Forensique de disque**

BELLO Armand, comptable chez SONATRAV (entreprise de travaux publics), est suspecté d'avoir détourné 25 millions FCFA via de faux bons de commande créés dans le système comptable informatisé. Son ordinateur portable Windows est saisi. Une image forensique E01 est créée avec FTK Imager. Huit artefacts sont cachés dans l'image : l'investigateur doit les trouver tous avec Autopsy.

### 3.6.2 Les huit artefacts et leur localisation

| Artefact | Description | Localisation Autopsy |
|---|---|---|
| A1. Email virement | Email Outlook : ordre de virement avec faux IBAN fournisseur | `Results → E-Mail Messages → rechercher 'virement'` |
| A2. Screenshot banque | Capture portail bancaire UBA après virement | `File Views → Images → filtrer par date` |
| A3. GPS dans photo | Photo prise à Yaoundé (pas à Douala comme déclaré) – coordonnées GPS dans EXIF | `Results → EXIF Metadata → colonnes Latitude/Longitude` |
| A4. Document supprimé | `faux_bon_de_commande.do` marqué supprimé | `File Views → Deleted Files` |
| A5. Tableau détournements | Excel avec suivi des détournements : montants, dates, bénéficiaires | `File Views → Recent Documents` |
| A6. Historique Chrome | Visite portail bancaire le jour du virement à 14h32 | `Results → Web History → filtrer par date` |
| A7. Prefetch keyfinder | `PASSWORDRECOVERY.EXE` – outil d'extraction de mots de passe | `C:\Windows\Prefetch\` |
| A8. Clé USB non déclarée | Kingston 16 Go, branchée le jour du virement à 14h40 | `Results → USB Device Attached` |

*Tableau 3.1. Les huit artefacts de l'Opération TANGUE et leur localisation dans Autopsy*

### 3.6.3 Leçon transférable

L'affaire TANGUE illustre la **convergence probatoire** : aucun des huit artefacts n'est suffisant seul, mais leur combinaison est accablante. L'email prouve l'intention ; le screenshot prouve l'action ; le GPS invalide l'alibi ; le document supprimé prouve la préméditation ; le Prefetch du keyfinder prouve la préparation technique ; la clé USB prouve l'exfiltration.

$\Gamma_{CRO}$ **Analyse CRO · Confidentialité · Fiabilité · Opposabilité**

**Analyse CRO. Opération TANGUE**

L'artefact A5 (tableau de suivi des détournements) pose une question CRO intéressante : un fichier *auto-incriminant* a une valeur probatoire réelle ($\mathcal{R}$ haute : l'auteur lui-même documente ses actes) mais doit être corroboré ($\mathcal{O}$ conditionnelle : sans corroboration, un juge prudent le considèrera comme insuffisant seul).

La corrélation A5 + A1 + A6 (même journée, même heure, même montant) constitue la triade probatoire qui rend le dossier incontestable.

$\mathcal{C}$: $\sim$ $\mathcal{R}$: $\uparrow\uparrow$ $\mathcal{O}$: $\uparrow$ par convergence

## 3.7 Opération MVOM (Cameroun)

### 3.7.1 Contexte

**Scénario Opérationnel · Opération MVOM. Ransomware sur PME**

TRANSBOIS SA, PME forestière de Yaoundé (45 employés, 2 milliards FCFA de CA), subit une attaque ransomware LockBit. 85% des fichiers sont chiffrés (extension `.lockbitcm`). La rançon demandée est de 5 bitcoins (~400 000 USD). L'entrée initiale : une connexion RDP depuis une IP roumaine, utilisant le compte administrateur dont le mot de passe était `Transbois2023`. 2,3 Go de données ont été exfiltrées *avant* le chiffrement.

### 3.7.2 Anatomie technique : reconstruction sur la Kill Chain

La Kill Chain de Lockheed Martin en sept phases est l'outil de référence pour reconstituer une attaque :

| Phase | Nom | Preuve dans l'affaire MVOM |
|---|---|---|
| Phase 1 | Reconnaissance | Non documentée ; probable scan RDP depuis l'IP roumaine |
| Phase 2 | Armement | Préparation du ransomware LockBit ; hors périmètre camerounais |
| Phase 3 | Livraison | Connexion RDP avec `admin_tb` / `Transbois2023` |
| Phase 4 | Exploitation | Accès administrateur obtenu (12/03 02h14) |
| Phase 5 | Installation | Dépôt de `enc_all.ps1` dans `%TEMP%` ; processus `svchost.exe` suspect |
| Phase 6 | C&C | Requête DNS vers `lockbit-pay-cm.onion` ; connexion vers port 4444 |
| Phase 7 | Actions | Exfiltration 2,3 Go (11/03) puis chiffrement (13/03) |

*Tableau 3.2. Reconstruction MVOM sur la Kill Chain (d'après l'analyse Wireshark + Volatility)*

### 3.7.3 L'analyse Volatility : preuve de l'installation

```
# Lister les processus -- identifier le svchost.exe suspect
python3 vol.py -f transbois.mem windows.pslist
# Résultat : PID 4892 svchost.exe -- parent : cmd.exe (PID 4891)
# ANORMAL : svchost.exe ne devrait pas avoir cmd.exe comme parent

# Analyser les connexions réseau du processus suspect
python3 vol.py -f transbois.mem windows.netscan | grep 4892
# Résultat : connexion ESTABLISHED vers 185.220.XX.XX:4444
```

```
9
10 # Lister les fichiers ouverts par le processus
11 python3 vol.py -f transbois.mem windows.filescan | grep enc_all
12 # Résultat : \Device\HarddiskVolume3\Users\admin\AppData\Local\Temp\
       enc_all.ps1
```

Listing 3.2: Volatility 3. analyse mémoire RAM TRANSBOIS

### 3.7.4 Leçon transférable : la double victime

**★ Attention**

**TRANSBOIS est simultanément victime et contrevenante.** Le fait d'être victime d'une attaque ransomware n'exonère pas TRANSBOIS de ses obligations légales : absence de politique de mots de passe robuste (art. 27 **Loi 2024/017** [36]), non-notification de violation de données à l'ANPDP (art. 22 **Loi 2024/017**), absence de registre de traitement (art. 29 **Loi 2024/017**).

**Principe :** un responsable de traitement qui facilite, même involontairement, une attaque contre les données de ses clients engage sa responsabilité administrative et potentiellement pénale. Les deux procédures (victimisation + manquements) sont indépendantes et doivent être traitées séparément.

## 3.8 Opération WOURI (Cameroun)

### 3.8.1 Contexte

**Scénario Opérationnel · Opération WOURI. Réseau BEC transfrontalier**

Un réseau de quatre individus opérant depuis trois pays (Cameroun, Nigeria, Émirats arabes unis) défraude des entreprises camerounaises via des attaques **BEC** (*Business Email Compromise*) : usurpation du domaine d'un fournisseur pour intercepter des virements. Deux victimes : SOTRADI SA (47M FCFA) et AGROBOIS Cameroun (32M FCFA). Rôles : ATANGANA (organisateur, Cameroun), OKAFOR (technicien, Nigeria), HASSAN (blanchisseur, EAU), NGUEMO (complice-mule, Cameroun).

### 3.8.2 Cartographie du réseau criminel

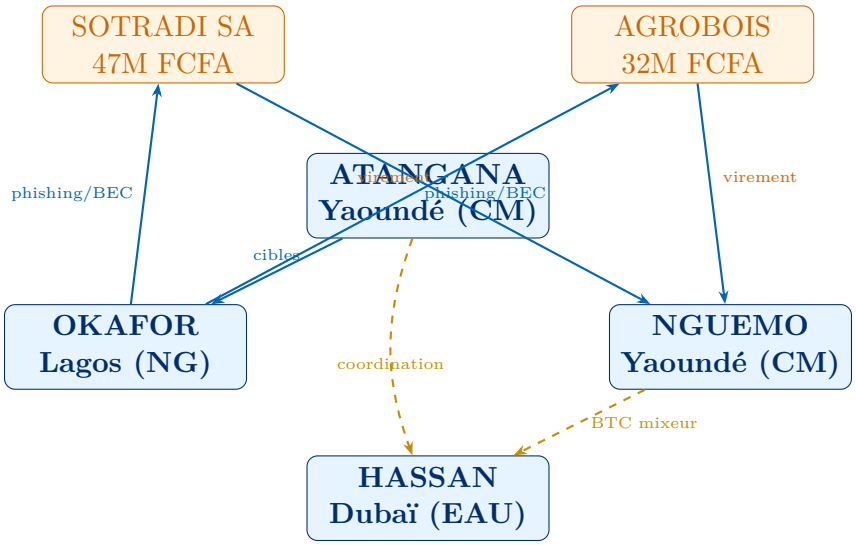



Figure 3.1: Réseau criminel Opération WOURI. flux d'information et financiers

### 3.8.3 L'OSINT comme technique forensique à part entière

L'identification d'OKAFOR (basé à Lagos, jamais entré au Cameroun) repose exclusivement sur l'**OSINT** (*Open Source Intelligence*) :

1. **LinkedIn :** profil de « cybersecurity consultant », 3 anciens emplois vérifiables, email professionnel récupérable.
2. **GitHub :** un script de phishing publié avec des commentaires en anglais et en pidgin nigérian, signé du même pseudo.
3. **Sherlock :** l'outil de recherche de pseudo (`sherlock duke_cyber_ng`) identifie 12 plateformes supplémentaires.
4. **Corrélation blockchain :** les adresses Bitcoin transmises par ATANGANA sont reliées à des adresses connues du groupe SilverTerrier sur Blockchair.

**Application OPJ/Expert Judiciaire**

**Procédure WOURI. Actions coopération internationale**

L'affaire implique trois pays ; la coopération doit être lancée en parallèle dès l'identification des suspects étrangers :

1. **OKAFOR (Nigeria) :** transmission d'une Notice Bleue INTERPOL via le BCN Cameroun ; demande d'entraide judiciaire (ENTR) via l'ANIF si des flux financiers sont identifiés au Nigeria.
2. **HASSAN (Émirats arabes unis) :** demande de conservation urgente à Binance via le portail LEA (*Law Enforcement Agency*) ; demande d'identification du titulaire du compte Bitcoin. Les EAU ont signé la Convention de Budapest

en 2021 : la procédure s'applique.

3. **OKAFOR – arrestation :** une Notice Rouge INTERPOL est nécessaire pour permettre une arrestation provisoire au Nigeria. Elle requiert un mandat d'arrêt camerounais préalable.

$\Gamma_{CRO}$ **Analyse CRO · Confidentialité · Fiabilité · Opposabilité**

**Analyse CRO. Opération WOURI**

$\mathcal{C}$ : les communications WhatsApp d'ATANGANA (trouvées sur son téléphone déverrouillé) sont une preuve directe mais contiennent aussi des communications sans rapport avec l'affaire (famille, travail). Le principe de proportionnalité impose de ne produire en justice que les communications pertinentes.

$\mathcal{R}$ : les données blockchain (Blockchair) sont publiques et reproductibles ; leur fiabilité est très haute. Les données Binance (portail LEA) sont fiables mais leur chaîne d'obtention doit être documentée pour $\mathcal{O}$.

$\mathcal{O}$ : le principal risque d'irrecevabilité est la coopération internationale : si les données obtenues du Nigeria ou des EAU ne respectent pas les procédures MLAT (Mutual Legal Assistance Treaty), un tribunal camerounais peut refuser de les utiliser.

$\mathcal{C}$: $\downarrow$ gérer proportionnalité $\mathcal{R}$: $\uparrow$ $\mathcal{O}$: $\sim$ dépend de la coopération

## 3.9 Tableau de Synthèse : les Leçons Permanentes

Sept affaires, sept leçons, toutes applicables demain matin sur le terrain :

| Affaire | Innovation forensique | Leçon permanente |
|---|---|---|
| BTK / Rader | Métadonnées comme preuve décisive | Extraire systématiquement les métadonnées ; une couche invisible peut identifier un suspect |
| Stuxnet | Cyberforensique industrielle | La sophistication est un marqueur d'attribution ; les ICS/SCADA sont une frontière émergente |
| WannaCry | Kill switch et kill chain | L'attribution est probabiliste ; la synchronisation des horloges est critique |
| Enron | E-discovery à grande échelle | La réquisition aux opérateurs est le levier légal du volume ; la déduplication par hachage est la méthode |
| ONAMBELE | Forensique Mobile Money + OSINT | Remonter la chaîne complète ; traiter le téléphone allumé selon le protocole avant tout |
| TANGUE | Convergence probatoire par artefacts multiples | Aucun artefact seul ne suffit ; la convergence de huit preuves est accablante |
| MVOM | Kill chain + Volatility + Loi 2024 | La victime peut être aussi contrevenante ; les deux procédures sont indépendantes |
| WOURI | BEC + OSINT + coopération multilatérale | Lancer la coopération internationale dès l'identification ; les plateformes LEA sont des outils légaux directement accessibles |

*Tableau 3.3. Synthèse des leçons permanentes*

❍

★ À retenir

**Ce qu'il faut retenir de ce chapitre :**

- Chaque grande affaire a produit une **innovation forensique** qui est aujourd'hui une technique standard : les métadonnées (BTK), le sandboxing comportemental (Stuxnet), l'analyse kill chain (WannaCry, MVOM), la réquisition numérique (Enron, ONAMBELE).
- L'**artefact décisif**. la seule preuve qui a fait basculer le dossier, est rarement la plus spectaculaire. C'est souvent une métadonnée oubliée, un horodatage incohérent, ou un processus système anormal.
- Les **erreurs récurrentes**. brancher le téléphone sans mode avion, arrêter le

maillon faible sans remonter la chaîne, négliger la coopération internationale, sont évitables. Elles se préviennent par le protocole, pas par le talent.

- Les **cas camerounais** (ONAMBELE, TANGUE, MVOM, WOURI) illustrent que les schémas mondiaux (fraude MoMo, ransomware BEC, réseaux transfrontaliers) opèrent au Cameroun avec les mêmes mécanismes et la même sophistication qu'ailleurs.
- Le Trilemme CRO se manifeste différemment dans chaque affaire : Stuxnet sacrifie $\mathcal{O}$ au profit de $\mathcal{C}$ et $\mathcal{R}$ ; TANGUE maximise $\mathcal{R}$ et $\mathcal{O}$ ; WOURI dépend de la coopération internationale pour atteindre $\mathcal{O}$.

### ✍ Exercice 3.1. Identification de l'artefact décisif ★☆☆

Pour chacune des situations suivantes, identifiez l'artefact décisif probable et la méthode qui permettrait de l'extraire :

(a) Un suspect nie avoir participé à une réunion en ligne, mais vous disposez de son ordinateur Windows.

(b) Une entreprise prétend que ses données n'ont pas été exfiltrées avant le chiffrement par un ransomware. Vous disposez d'une capture réseau Wireshark de 48 heures.

(c) Une escroquerie sentimentale via Facebook : le suspect prétend être à Paris, mais la victime affirme avoir été contactée depuis le Cameroun. Vous disposez du profil Facebook du suspect.

### ✍ Exercice 3.2. Reconstitution d'attaque ★★☆

**Scénario MVOM simplifié :** vous recevez les données suivantes concernant une PME camerounaise attaquée :

- Log pare-feu : connexion RDP entrante depuis `91.192.X.X` le 03/04/2026 à 23h47, durée 3h12.
- Processus Volatility : `powershell.exe` (PID 7231), parent : `cmd.exe` (PID 7228), connexion vers `91.192.X.X:443` pendant 2h45.
- Log pare-feu : transfert sortant de 4,7 Go vers `185.220.Y.Y` le 04/04/2026 entre 01h15 et 02h58.
- Autopsy : 87% des fichiers `.xlsx` et `.docx` portent l'extension `.locked2026`.

(a) Placez chaque élément sur la Kill Chain (7 phases).
(b) Quel est le vecteur d'entrée probable ? Quelle preuve l'établit ?
(c) Quand a eu lieu l'exfiltration : avant ou après le chiffrement ? Quelle implication

pour les victimes (données personnelles exfiltrées) ?
(d) Quels articles de la **Loi 2010/012** et de la **Loi 2024/017** qualifier pour les auteurs ? Pour la PME elle-même ?

**✍ Exercice 3.3. Analyse CRO d'une décision investigative ★★★**

Dans l'Opération WOURI, l'OPJ en charge décide d'extraire l'intégralité du téléphone d'ATANGANA via ADB (après que celui-ci a fourni son code PIN) pour analyser toutes ses communications des 12 derniers mois.

(a) Évaluez cette décision selon le Trilemme CRO : quelles dimensions sont renforcées ou fragilisées ?

(b) La décision est-elle proportionnelle ? Argumentez en référence au cadre légal camerounais et au type d'infraction.

(c) Proposez une alternative moins intrusive qui préserverait mieux $\mathcal{C}$ tout en maintenant une $\mathcal{O}$ satisfaisante.

(d) Comment documentez-vous dans votre rapport le choix effectué et sa justification, pour qu'un juge puisse l'évaluer ?

**● Note**

**Transition.** Les Chapitres 4 et 5 complètent la Partie I en formalisant les **fondements théoriques** mobilisés dans ces affaires (Shannon [37], Dolev-Yao [10], théorie de la complexité) et en dressant l'**état de l'art** 2025 (IA forensique, deepfakes, conteneurs). La Partie II construit ensuite le **processus investigatif universel** qui structure la mise en œuvre de toutes ces leçons dans une investigation réelle.

# 4

# FONDEMENTS THÉORIQUES

« La théorie sans la pratique est vaine ; la pratique sans la théorie est aveugle. L'investigation numérique exige les deux. »

Adaptation d'Emmanuel Kant, *Critique de la raison pure*

**Niveau :** *Fondamental* • Mathématiques de niveau licence (probabilités, algèbre de base, notions de complexité). Les résultats sont commentés pour être accessibles sans démonstration exhaustive.

**✦ Objectifs du chapitre**

- ➢ Maîtriser le **principe de Locard numérique** [25] et sa taxonomie des traces : primaires, secondaires, tertiaires, résiduelles.
- ➢ Appliquer les trois outils de la théorie de l'information : entropie, distance de Hamming, distance de Levenshtein.
- ➢ Modéliser un réseau criminel avec la théorie des graphes (centralité de degré, d'intermédiarité, PageRank, graphes temporels).
- ➢ Comprendre le modèle Dolev-Yao et en déduire les menaces sur la preuve numérique.
- ➢ Situer les modèles de processus (DFRWS, Casey, NIST, ISO 27037 [18]) dans leur cohérence et leurs différences.
- ➢ Articuler fondements théoriques et Trilemme CRO.

## 4.1 Le Principe de Locard Numérique

### 4.1.1 Origine et transposition au numérique

Édmond Locard (1877–1966), directeur du premier laboratoire de police scientifique au monde (Lyon, 1910), a formulé le principe fondateur de la criminalistique : *« Tout contact laisse une trace. »* Sa transposition au monde numérique est non triviale mais inévitable.

**Définition**

**Principe de Locard numérique**. Tout processus informatique laisse des traces dans son environnement d'exécution. Ces traces sont automatiques, involontaires, et persistent au sein des systèmes de fichiers, des journaux, de la mémoire et du réseau, indépendamment de la volonté de l'acteur qui a engendré le processus.

La différence cruciale avec le monde physique est que le numérique laisse des traces **à plusieurs niveaux simultanément** : un simple clic sur un lien Web génère des entrées dans l'historique du navigateur, une requête DNS dans les journaux réseau, une connexion TCP dans les logs du routeur, un artefact de cache dans le répertoire temporaire, et potentiellement un enregistrement dans les bases de données du serveur distant.

### 4.1.2 Taxonomie des traces numériques

| Catégorie | Définition | Exemples concrets |
|---|---|---|
| **Traces primaires** | Générées directement par l'action incriminée | Fichier créé, email envoyé, transaction MoMo exécutée, connexion RDP |
| **Traces secondaires** | Générées par l'environnement en réponse à l'action | Logs système, historique navigateur, registre Windows, Prefetch, métadonnées EXIF |
| **Traces tertiaires** | Générées par les outils de sécurité | Alertes IDS/SIEM, logs pare-feu, journaux VPN, audit Active Directory |
| **Traces résiduelles** | Persistant après tentative d'effacement | Fichiers dans l'espace non alloué, entrées MFT orphelines, *slack space*, `$LogFile` NTFS |

*Tableau 4.1. Taxonomie des traces numériques selon le principe de Locard*

### 4.1.3 Locard dans les affaires étudiées

Le principe de Locard explique a posteriori pourquoi chaque grande affaire a pu être résolue :

- **BTK/Rader** : les métadonnées Office sont des *traces secondaires*, générées automatiquement par Word, indépendamment de toute intention de Rader.
- **MVOM** : la connexion RDP est une *trace primaire* dans les logs pare-feu ; le processus `svchost.exe` malveillant en RAM est une *trace secondaire* de son installation.
- **WOURI** : les transactions Bitcoin sont des *traces primaires* permanentes et immuables, Locard dans sa forme absolue.

**L'anti-forensique comme tentative de violation de Locard**

Les techniques d'**anti-forensique** (suppression de fichiers, nettoyage des logs, chiffrement) ne violent pas Locard : elles tentent de le contourner. Mais l'effacement lui-même laisse des traces : les outils utilisés apparaissent dans le Prefetch Windows ; les entrées MFT supprimées persistent dans l'espace non alloué ; l'horodatage de la suppression est enregistré dans `$LogFile`. La trace de la suppression est une trace secondaire au sens de Locard.

## 4.2 Théorie de l'Information : l'Arsenal de Shannon

### 4.2.1 L'entropie comme détecteur d'anomalie

La théorie de Shannon [37] fournit trois outils directement opérationnels. L'entropie $H(X)$ a été introduite au Chapitre 1. Rappelons son calcul sur un fichier binaire : on estime la distribution des 256 valeurs d'octet possibles :

$$H_{\text{fichier}} = -\sum_{b=0}^{255} \frac{n_b}{N} \log_2\left(\frac{n_b}{N}\right) \tag{4.1}$$

où $n_b$ est le nombre d'occurrences de l'octet de valeur $b$ et $N$ le nombre total d'octets analysés.

```python
import math, collections

def entropie(chemin, echantillon=65536):
    with open(chemin, 'rb') as f:
        d = f.read(echantillon)
    n = len(d)
    cpt = collections.Counter(d)
    h = -sum((c/n)*math.log2(c/n) for c in cpt.values())
    return h

# Interprétation
h = entropie('suspect.bin')
if   h > 7.5: print('CHIFFRE ou COMPRESSE -- investigation approfondie')
elif h > 6.0: print('Binaire compile -- normal pour un executable')
elif h > 3.5: print('Texte ou donnees structurees -- normal')
else        : print('Tres repetitif -- fichier sparse ou quasi vide')
```

Listing 4.1: Calcul de l'entropie d'un fichier, script Python forensique

### 4.2.2 La distance de Hamming : identifier les variantes de malware

La **distance de Hamming** mesure le nombre de positions où deux chaînes binaires de même longueur diffèrent :

$$d_H(x, y) = \sum_{i=1}^{n} \mathbf{1}[x_i \neq y_i] \tag{4.2}$$

En pratique, les **fuzzy hashes** (ssdeep, TLSH) calculent des distances approximatives sur des fichiers de taille variable : une distance normalisée $d_H(x, y)/n < 0.15$ entre deux binaires indique une probable appartenance à la même famille de malware.

```
# Calculer le fuzzy hash d'un fichier
ssdeep -b malware_suspect.exe

# Comparer avec une référence (score 0-100, 100 = identiques)
ssdeep -m malware_reference.exe malware_suspect.exe
# Sortie : matches malware_reference.exe (88)
# Score 88 : variante très probable de la même famille

# Comparaison sur un répertoire entier
ssdeep -r -m malware_reference.exe /dossier/suspects/
```

Listing 4.2: Fuzzy hashing avec ssdeep

### 4.2.3 La distance de Levenshtein : typosquatting et comparaison de textes

La **distance de Levenshtein** mesure le nombre minimum d'insertions, suppressions et substitutions pour transformer une chaîne en une autre :

$$d_L(s, t) = \min_{\text{séq. d'opérations}} |\text{opérations}(s \to t)| \tag{4.3}$$

Applications forensiques directes :

- **Typosquatting** (WOURI) : le domaine frauduleux `medequip-portugal.com` a une distance de Levenshtein très faible par rapport au domaine légitime `medequip.pt` ; l'outil *dnstwist* automatise cette détection.
- **Variantes de scripts** : deux scripts avec $d_L$ faible ont probablement le même auteur.
- **Pseudonymes** : deux noms très proches dans des bases de données différentes peuvent désigner la même personne.

```
# Génère toutes les variantes du domaine et vérifie celles enregistr
    ées
dnstwist --registered medequip.pt

# Sortie typique :
# Original*       medequip.pt            185.xx.xx.xx
# Hyphenation     medequip-pt.com        91.xxx.xx.xx   <- SUSPECT
# Transposition   meidquip.pt            [NON ENREGISTRE]
```

Listing 4.3: Détection de typosquatting avec dnstwist

## 4.3 Théorie des Graphes en Investigation Numérique

### 4.3.1 Formalisation des réseaux criminels

Un réseau criminel ou de communication est modélisé par un **graphe orienté pondéré** :

$$G = (V, E, w), \quad E \subseteq V \times V, \quad w : E \to \mathbb{R}^+ \tag{4.4}$$

où $V$ est l'ensemble des entités (personnes, machines, comptes, adresses IP), $E$ l'ensemble des relations (communications, transferts, accès) et $w(u, v)$ le poids de la relation (montant transféré, fréquence d'accès).

### 4.3.2 Métriques de centralité : identifier les acteurs clés

#### *4.3.2.1 Centralité de degré*

$$C_D(v) = \frac{\deg(v)}{|V| - 1} \tag{4.5}$$

Un nœud à forte centralité de degré est un **hub de communication**. Dans WOURI, ATANGANA avait la centralité de degré la plus élevée.

#### *4.3.2.2 Centralité d'intermédiarité (betweenness centrality)*

$$C_B(v) = \sum_{s \neq v \neq t} \frac{\sigma(s, t \mid v)}{\sigma(s, t)} \tag{4.6}$$

où $\sigma(s, t)$ est le nombre de chemins les plus courts entre $s$ et $t$, et $\sigma(s, t \mid v)$ ceux qui passent par $v$. Un acteur à forte centralité d'intermédiarité est un **pont critique** : le neutraliser fragmente le réseau. Dans WOURI, NGUEMO était le pont entre la collecte des fonds (Cameroun) et le blanchiment (EAU).

#### *4.3.2.3 PageRank forensique*

$$\mathrm{PR}(v) = \frac{1 - d}{|V|} + d \sum_{u \in \mathcal{N}^-(v)} \frac{\mathrm{PR}(u)}{\deg^+(u)}, \quad d \approx 0.85 \tag{4.7}$$

En investigation d'emails, PageRank identifie les personnes les plus influentes dans un réseau de communication : celles dont les messages sont fréquemment répondus ou transférés (comme dans l'affaire Enron).

### 4.3.3 Graphes temporels : la chronologie comme dimension analytique

Un **graphe temporel** $G = (V, E, T)$ ajoute une dimension temporelle aux arêtes :

$$E \subseteq V \times V \times T \tag{4.8}$$

En forensique réseau, chaque connexion est un triplet $(\text{source}, \text{destination}, t)$. L'analyse du graphe temporel permet de **reconstituer un chemin d'attaque** : deux événements $e_1$ et $e_2$ sont causalement liés si $t(e_2) - t(e_1)$ est faible et si les entités impliquées se recoupent.

```python
import networkx as nx

G = nx.DiGraph()
# Arêtes : (source, destination, poids)
edges = [
    ('ATANGANA', 'OKAFOR',  {'w': 1, 'd': '2026-01'}),
    ('OKAFOR',   'SOTRADI', {'w': 47, 'd': '2026-01-15'}),
    ('SOTRADI',  'NGUEMO',  {'w': 47, 'd': '2026-01-15'}),
    ('NGUEMO',   'HASSAN',  {'w': 45, 'd': '2026-01-15'}),
]
G.add_edges_from([(u,v,d) for u,v,d in edges])

# Centralité d'intermédiarité
btw = nx.betweenness_centrality(G)
# -> NGUEMO et OKAFOR ont les valeurs les plus élevées

# PageRank (acteur le plus 'central' dans le flux)
pr = nx.pagerank(G, weight='w')
```

Listing 4.4: Analyse de graphe criminel avec NetworkX

## 4.4 Le Modèle Dolev-Yao : l'Adversaire Formel

### 4.4.1 Définition

Le **modèle Dolev-Yao** [10] est le cadre formel standard pour raisonner sur la sécurité d'un protocole cryptographique face à un adversaire actif :

**Définition**

**Adversaire Dolev-Yao**. Un adversaire $\mathcal{A}$ qui :

1. peut **intercepter** tout message transitant sur le réseau ;
2. peut **modifier, rejouer, supprimer ou réordonner** tout message ;
3. peut **injecter** des messages en se faisant passer pour n'importe quelle entité ;
4. **ne peut pas** casser les primitives cryptographiques correctement utilisées (déchiffrer sans clé, forger une signature).

### 4.4.2 Implications forensiques

**Implication 1 :** toute preuve transmise sur un réseau non sécurisé est potentiellement compromise. La chaîne de custody numérique doit inclure la sécurisation des canaux de transmission (chiffrement + signature).

**Implication 2 :** la non-répudiation est un problème difficile. Comment prouver qu'un message a bien été envoyé par Alice et non par $\mathcal{A}$ se faisant passer pour elle ? La réponse est la signature numérique asymétrique : seul le détenteur de la clé privée d'Alice peut produire sa signature. C'est le fondement mathématique du protocole ZK-NR [28] formalisé dans la Partie VI du cours SEC4052.

### 4.4.3 Du modèle Dolev-Yao au Trilemme CRO

Dolev-Yao modélise ce que l'adversaire peut faire techniquement. Le Trilemme CRO généralise en ajoutant la dimension légale :

$$\underbrace{\mathcal{C}}_{\text{protéger contre } \mathcal{A}} + \underbrace{\mathcal{R}}_{\text{résister à } \mathcal{A}} + \underbrace{\mathcal{O}}_{\text{prouver face au juge}} \leq 1 + \epsilon \tag{4.9}$$

La relation (4.9) formalise l'impossibilité : maximiser la protection contre $\mathcal{A}$ ($\mathcal{C}$ et $\mathcal{R}$ élevés) rend la preuve difficile à vérifier par des tiers ($\mathcal{O}$ contraint). Les protocoles ZK résolvent partiellement cette tension.

## 4.5 Complexité Computationnelle et Sécurité Forensique

### 4.5.1 Problèmes difficiles et sécurité cryptographique

Toute la cryptographie moderne repose sur des problèmes **calculatoirement difficiles**. La notation $\mathcal{O}$-grand formalise la complexité :

$$f(n) = \mathcal{O}(g(n)) \iff \exists\, c > 0,\ n_0 \geq 0 \ \text{ tels que } \ \forall n \geq n_0,\ f(n) \leq c\, g(n) \tag{4.10}$$

Les deux problèmes difficiles fondamentaux :

1. **Factorisation d'entiers** : étant donné $N = p \cdot q$, retrouver $p$ et $q$. Complexité classique : $\mathcal{O}(e^{n^{1/3}})$. Fondement de RSA.
2. **Logarithme discret** : étant donné $g^x \bmod p$, retrouver $x$. Fondement de Diffie-Hellman et des courbes elliptiques.

### 4.5.2 La menace quantique : algorithme de Shor

L'algorithme de **Shor** (1994) résout ces deux problèmes en temps polynomial sur un ordinateur quantique :

$$T_{\text{Shor}}(n) = \mathcal{O}(n^3) \quad \text{vs} \quad T_{\text{classique}}(n) = \mathcal{O}(e^{n^{1/3}}) \tag{4.11}$$

L'implication pour la forensique est directe : les preuves collectées en 2026 et chiffrées avec RSA ou ECDSA seront potentiellement déchiffrables dans 10 à 15 ans. C'est la stratégie **Harvest Now, Decrypt Later** : un adversaire étatique collecte aujourd'hui des données chiffrées pour les déchiffrer demain.

★ Attention

**Migration post-quantique, obligation éthique pour les données longue durée.**
Le NIST a publié en 2024 trois standards post-quantiques : CRYSTALS-Kyber (FIPS 203, encapsulation de clés), CRYSTALS-Dilithium (FIPS 204) et SPHINCS+

(FIPS 205) pour les signatures ; FALCON est encore en cours de normalisation (UE SEC4052, chapitre 26). Pour les investigations impliquant des données à longue durée de vie (terrorisme, protection de témoins, secrets industriels), le passage à ces algorithmes est une obligation éthique.

### 4.5.3 Fonctions à sens unique et hachage forensique

Le hachage cryptographique repose sur une **fonction à sens unique** :

$$h : \{0,1\}^* \to \{0,1\}^n \tag{4.12}$$

facile à calculer ($\mathcal{O}(|m|)$), impossible à inverser sans clé. Trois propriétés de sécurité :

1. **Résistance à la préimage** : étant donné $y$, infaisable de trouver $x$ tel que $h(x) = y$.
2. **Résistance à la seconde préimage** : étant donné $x$, infaisable de trouver $x' \neq x$ tel que $h(x') = h(x)$.
3. **Résistance aux collisions** : infaisable de trouver $(x, x')$ tels que $h(x) = h(x')$.

Ces propriétés fondent le **principe de preuve d'intégrité** : si le hash de l'image forensique correspond au hash du disque original, aucune modification n'a eu lieu. L'investigateur ne *déclare* pas l'intégrité ; le hash la *prouve* mathématiquement.

## 4.6 Modèles de Processus Forensique

### 4.6.1 Panorama et positionnement

| Modèle | Origine | Contribution | Niveau |
|---|---|---|---|
| DFRWS 2001 | Recherche | Premier modèle systématique : 6 phases séquentielles | Conceptuel |
| Casey 2004 | Académique | Modèle intégré : 5 phases, contexte judiciaire fort | Académique |
| [NIST SP 800-86] | Gouvernemer | Intégration IR + forensique ; distinction Exam./Analysis | Opérationnel |
| [ISO/IEC 27037] | Normalisatio | Standard international : rôles DEFR et DES définis | Normatif |

*Tableau 4.2. Panorama des modèles de processus*

### 4.6.2 Le modèle DFRWS (2001)

Le **DFRWS** [31] a publié le premier modèle formel de processus en six phases :

1. **Identification**: reconnaître l'incident et définir son périmètre.
2. **Préservation**: isoler et protéger les preuves.
3. **Collection**: acquérir selon des méthodes documentées.

4. **Examination**: extraire les informations des preuves collectées.
5. **Analysis**: corréler pour reconstituer les événements.
6. **Presentation**: communiquer de façon défendable.

La limite du DFRWS est son caractère **linéaire** : un investigateur alterne en réalité entre Collection et Examination au fil des découvertes.

### 4.6.3 La distinction Examination / Analysis (NIST SP 800-86)

La contribution centrale de [NIST SP 800-86] [29] est la distinction :

- ➢ **Examination** : appliquer des méthodes systématiques pour identifier et extraire. L'examinateur documente ce qu'il *trouve*, pas ce que cela *signifie*.
- ➢ **Analysis** : interpréter les données extraites, tester des hypothèses, corréler les sources. L'analyste tire des conclusions.

Cette distinction est fondamentale : un avocat peut attaquer une interprétation ; il ne peut pas attaquer un hash qui correspond.

### 4.6.4 ISO/IEC 27037 : standard international et rôles

[ISO/IEC 27037:2012] définit deux rôles distincts :

- ➢ **DEFR** (*Digital Evidence First Responder*). premier intervenant sur la scène ; responsable de la préservation initiale. Son erreur est irréparable.
- ➢ **DES** (*Digital Evidence Specialist*). analyste en laboratoire ; responsable de l'examination et de l'analysis.

**⚖ Jurisprudence & Droit applicable**

**Compatibilité ISO/IEC 27037 et droit camerounais :**
La **Loi 2010/012** [34], articles 52–59, impose : présence des parties, copie réalisée en leur présence, documentation. Ces exigences sont *substantiellement alignées* sur ISO/IEC 27037. Un investigateur respectant le standard international respecte de facto les articles 52–59.

## 4.7 Théorie de la Preuve Numérique

### 4.7.1 Conditions formelles d'admissibilité

La validité d'une preuve numérique $P$ peut être formalisée :

$$\text{Admissible}(P) \iff \underbrace{\text{Légale}(P)}_{\text{obtention licite}} \wedge \underbrace{\text{Intègre}(P)}_{\text{hash vérifié}} \wedge \underbrace{\text{Authentique}(P)}_{\text{custody continue}} \wedge \underbrace{\text{Pertinente}(P)}_{\text{lien avec les faits}} \tag{4.13}$$

La conjonction ($\wedge$) est stricte : l'absence d'une seule condition invalide la preuve entière.

### 4.7.2 La distinction constatation / interprétation

| Constatation (factuelle) | Interprétation (analytique) |
|---|---|
| « Le fichier `faux_bon.docx` a été créé le 03/02/2026 à 14h22. » | « BELLO a créé ce fichier pour préparer un détournement. » |
| « `svchost.exe` (PID 4892) a `cmd.exe` comme parent. » | « Ce processus est anormal et indique une compromission. » |
| « Le hash MD5 de l'image correspond au hash de l'original. » | « L'image est fidèle au disque et n'a pas été altérée. » |
| « L'adresse IP source est 185.220.XX.XX. » | « L'attaque provenait de Roumanie. » |

*Tableau 4.3. Distinction constatation/interprétation : exemples tirés des affaires TANGUE et MVOM*

### 4.7.3 La méthode des hypothèses concurrentes (ACH)

Un investigateur rigoureux ne cherche pas à *confirmer* sa thèse : il cherche à la *falsifier*. Pour chaque conclusion :

$$H_0 \text{ (hypothèse principale)} \quad \text{vs} \quad H_1, H_2, \ldots, H_k \text{ (hypothèses concurrentes)} \tag{4.14}$$

Exemple dans MVOM : $H_0$ = « Attaque par le groupe LockBit via RDP ».. Hypothèse $H_1$ : « La connexion RDP était légitime (télétravail autorisé) et le ransomware a été introduit par un autre vecteur ». L'investigateur doit **explicitement réfuter** $H_1$, en vérifiant la liste des accès RDP autorisés, les contrats, les bulletins de salaire, avant de conclure à $H_0$.

**La méthode ACH (*Analysis of Competing Hypotheses*)**

Développée par Heuer pour la CIA [14], la méthode ACH formalise cette approche : pour chaque hypothèse, construire une matrice hypothèses/preuves et calculer un score de cohérence. Une hypothèse qui explique toutes les preuves et ne peut être réfutée par aucune est la conclusion la plus solide. Ce principe est au cœur du Processus Investigatif Universel du Chapitre 6.

## 4.8 Synthèse : Fondements Théoriques et Trilemme CRO

| Fondement | Dim. CRO principale | Contribution |
|---|---|---|
| Locard numérique | $\mathcal{R}$ | Garantit l'existence de traces ; justifie l'exhaustivité de la collecte |
| Entropie de Shannon | $\mathcal{R}$ | Détecte les anomalies ; identifie chiffrement et stéganographie |
| Distance Hamming/-Levenshtein | $\mathcal{R}$ | Mesure la similarité ; identifie variants et falsifications |
| Théorie des graphes | $\mathcal{O}$ | Visualise les relations ; cartographie le réseau criminel |
| Modèle Dolev-Yao | $\mathcal{C}$ | Modélise la menace adversariale ; justifie le chiffrement des preuves |
| Complexité / hash | $\mathcal{R} + \mathcal{O}$ | Fonde mathématiquement l'intégrité et l'authenticité |
| Théorie de la preuve | $\mathcal{O}$ | Formalise l'admissibilité et la séparation constat/interprétation |

*Tableau 4.4. Fondements et dimensions CRO*

**$\Gamma_{CRO}$ Analyse CRO · Confidentialité · Fiabilité · Opposabilité**

**La tension fondamentale :** maximiser $\mathcal{O}$ (transparence, vérifiabilité) s'oppose à maximiser $\mathcal{C}$ (opacité, chiffrement). La résolution partielle est apportée par les preuves à divulgation nulle : *je prouve que je sais* sans révéler *ce que je sais*. Ce pont entre $\mathcal{C}$ et $\mathcal{O}$ est le sujet de la Partie VI du cours SEC4052.

**★ À retenir**

**Ce qu'il faut retenir de ce chapitre :**

- **Locard numérique** : quatre niveaux de traces (primaires, secondaires, tertiaires, résiduelles). L'anti-forensique laisse elle-même des traces secondaires.
- **Théorie de l'information** : entropie ($H > 7.5$ : chiffré), fuzzy hashes (ssdeep) pour les variantes de malware, dnstwist pour le typosquatting.
- **Graphes** : $G = (V, E, w)$ modélise les réseaux criminels ; la centralité d'intermédiarité identifie les ponts critiques ; les graphes temporels reconstituent les chemins d'attaque.
- **Dolev-Yao** : adversaire omniscient sur le réseau, impuissant contre la crypto-

graphie correcte. Justifie le chiffrement des preuves et la signature numérique.

- **Complexité** : l'algorithme de Shor réduit RSA/ECDSA à $\mathcal{O}(n^3)$ ; migration vers CRYSTALS-Dilithium/FALCON obligatoire pour les données longue durée.
- **Modèles de processus** : DFRWS (6 phases), NIST SP 800-86 (Exam./Analysis), ISO 27037 (DEFR/DES). La distinction constatation/interprétation est la règle d'or du rapport.
- **Admissibilité formelle** : $\text{Admissible}(P) \iff \text{Légale} \wedge \text{Intègre} \wedge \text{Authentique} \wedge \text{Pertinente}$ ; la conjonction est stricte.

### ✍ Exercice 4.1. Entropie et interprétation ★☆☆

Trois fichiers extraits d'une image forensique :

(a) `rapport_finance.docx` : entropie calculée = 4.7 bits/octet.

(b) `backup_2026.zip` : entropie calculée = 7.9 bits/octet.

(c) `systeme.dll` : entropie calculée = 6.8 bits/octet.

Pour chaque fichier : interprétez l'entropie, indiquez si une investigation approfondie est justifiée, et précisez ce que vous chercheriez.

### ✍ Exercice 4.2. Graphe WOURI ★★☆

À partir des éléments de l'Opération WOURI (quatre suspects, deux victimes, flux de 47M et 32M FCFA), construisez le graphe $G = (V, E, w)$ :

(a) Définissez précisément $V$, $E$ et $w$.

(b) Calculez la centralité de degré de chaque suspect.

(c) Identifiez le suspect à la plus forte centralité d'intermédiarité et justifiez pourquoi sa neutralisation fragmente le réseau.

(d) Proposez quelle preuve supplémentaire permettrait d'ajouter une arête directe entre ATANGANA et HASSAN dans le graphe.

### ✍ Exercice 4.3. Admissibilité et ACH ★★★

Dans l'affaire MVOM, l'investigateur a écrit dans son rapport :

*« Le processus* `svchost.exe` *(PID 4892) était clairement malveillant et a servi à l'installation du ransomware LockBit par les attaquants russes. »*

(a) Identifiez au moins quatre problèmes dans cette phrase (distinctions constatation/interprétation, degré de certitude, attribution).

(b) Réécrivez-la en séparant strictement les constatations vérifiables des interprétations, avec un niveau de confiance explicite.

(c) Formulez la méthode ACH : définissez $H_0$ et deux hypothèses concurrentes ; proposez quelle preuve discriminerait entre $H_0$ et $H_1$.

**Note**

**Transition.** Le Chapitre 5 dresse l'état de l'art de la discipline en 2025 : IA forensique, deepfake detection, forensique de conteneurs, roadmap des certifications. Il complète la Partie I avant le plongeon opérationnel de la Partie II, qui construit le Processus Investigatif Universel sur les fondements posés ici.

5

# ÉTAT DE L'ART ET DÉFIS CONTEMPORAINS

« La science progresse en faisant danser les faits aux rythmes de nouvelles théories. »

Marcel Proust

**Niveau :** *Fondamental* • Ce chapitre est le dernier de la Partie I. Il mobilise les concepts des chapitres précédents pour cartographier l'état de la discipline en 2025–2026 et projeter son évolution à l'horizon 2030.

**✦ Objectifs du chapitre**

- ➢ Situer les cinq frontières actives de l'investigation numérique en 2025–2026 et comprendre les défis spécifiques de chacune.
- ➢ Analyser la valeur et les limites de l'IA forensique : LLM pour triage, machine learning pour classification de malware, deepfake detection.
- ➢ Comprendre les défis forensiques propres au cloud, à l'IoT et au mobile dans le contexte africain et camerounais.
- ➢ Maîtriser les fondamentaux de l'OSINT légal pour les OPJ : outils, cadre juridique, limites.
- ➢ Utiliser le framework DICES pour positionner les pratiques camerounaises par rapport aux standards mondiaux.
- ➢ Construire une roadmap de développement professionnel réaliste sur 36 mois dans le contexte camerounais.

## Bilan d'une Discipline en Accélération

La Partie I de ce cours a posé les fondements : philosophie, histoire, affaires fondatrices, théories mathématiques. Ce dernier chapitre de la Partie I change de registre : il décrit ce qui se passe *maintenant*, les défis que la discipline affronte *aujourd'hui*, et les compétences que vous devrez avoir construites *dans cinq ans*.

L'investigation numérique de 2025 n'est plus celle de 2015. Cinq ruptures simultanées la reconfigurent en profondeur :

1. L'**IA** entre dans la chaîne d'analyse, comme outil d'accélération du triage et comme vecteur d'attaque sophistiqué.
2. Les **deepfakes** brouillent la frontière entre le vrai et le fabriqué, forçant la discipline à développer une sous-spécialité d'authentification des médias.
3. Le **cloud et l'IoT** pulvérisent la notion de scène de crime localisée : les preuves sont partout, souvent éphémères, toujours multi-juridictionnelles.
4. L'**OSINT** s'est professionnalisé au point d'être une compétence à part entière, avec ses outils, son droit et son éthique propres.
5. La **cryptographie post-quantique** est en cours de déploiement : l'investigateur de demain doit comprendre ce que cela change pour la chaîne de preuves.

## 5.1 IA Forensique : Puissance et Limites

### 5.1.1 L'IA comme accélérateur de triage

Le triage forensique, identifier en quelques minutes les artefacts pertinents parmi des milliers, est la tâche où l'IA apporte le gain le plus immédiat. Les **LLM** (*Large Language Models*) peuvent :

- ➢ **Résumer et catégoriser** des volumes d'emails, de journaux ou de logs qui dépassent la capacité d'analyse humaine en temps raisonnable.
- ➢ **Identifier des anomalies linguistiques** dans des communications, syntaxe inhabituelle, traduction automatique, incohérences de registre.
- ➢ **Générer des hypothèses** à partir d'un corpus de preuves hétérogènes : un LLM peut proposer des connections entre artefacts que l'analyste humain n'aurait pas immédiatement vus.

### 5.1.2 Classification automatique de malware

Les approches de machine learning pour la classification de malware reposent sur trois familles de caractéristiques :

| Approche | Caractéristiques | Forces / Limites |
|---|---|---|
| Statique | Chaînes, imports, sections PE, entropie | Rapide, pas d'exécution ; contourné par l'obfuscation |
| Dynamique | Appels système, trafic réseau, comportement | Robuste à l'obfuscation ; lent, risque d'environnement sandbox |
| Hybride | Combinaison statique + dynamique | Meilleure précision ; coûteux en calcul |

*Tableau 5.1. Approches ML pour la classification de malware*

### 5.1.3 Les limites de l'IA forensique, la crise d'opposabilité

L'IA forensique pose une question CRO fondamentale : si une conclusion repose sur un modèle opaque, comment la défendre devant un tribunal ?

**$\Gamma_{CRO}$ Analyse CRO · Confidentialité · Fiabilité · Opposabilité**

**Analyse CRO. IA forensique**
$\mathcal{R}$ (Fiabilité) : les modèles de ML bien entraînés atteignent des précisions de 95–99% sur des jeux de données équilibrés.
$\mathcal{O}$ (Opposabilité) : **c'est la crise.** Un avocat de la défense peut demander l'explication complète du modèle. Si la réponse est "le réseau de neurones a attribué une probabilité de 0.97" sans explication compréhensible, le juge peut refuser la conclusion. L'arrêt *Loomis v. Wisconsin* (2016) aux États-Unis illustre ce risque pour les algorithmes de prédiction en justice.
$\mathcal{C}$ (Confidentialité) : les modèles entraînés sur des données réelles (cas judiciaires précédents) peuvent mémoriser des informations sur des affaires passées et les révéler via des attaques par inversion.
$\mathcal{C}$: ↓ risque de fuite $\mathcal{R}$: ↑ précision technique $\mathcal{O}$: ↓ crise d'explicabilité
**Règle pratique :** utiliser l'IA pour le *triage* (hypothèses, orientation), jamais comme *preuve primaire*. L'analyste humain confirme et documente chaque conclusion de l'IA.

**★ Attention**

**Règle d'or : l'IA oriente, l'humain constate.**
En contexte judiciaire camerounais, aucun texte n'autorise encore une preuve basée uniquement sur un algorithme opaque. L'investigateur doit systématiquement : (1) documenter l'outil utilisé (nom, version, paramètres), (2) vérifier manuellement les conclusions de l'IA sur un échantillon, (3) présenter la conclusion IA comme *indication* corroborée par une analyse humaine, jamais comme preuve autonome.

## 5.2 Deepfake Detection : Authentifier les Médias Numériques

### 5.2.1 Le défi de l'authenticité des médias

Les **deepfakes** (vidéos, images, audios générés ou manipulés par IA) constituent l'une des menaces forensiques les plus graves de la décennie. Trois catégories :

- **Face swap** : substitution du visage d'une personne par celui d'une autre dans une vidéo existante.
- **Voice cloning** : reproduction convaincante de la voix d'une personne à partir d'un échantillon de quelques secondes.

➢ **Document forgery** : génération de documents officiels (relevés bancaires, identités, contrats) cohérents avec les templates réels.

### 5.2.2 Méthodes de détection

Quatre approches complémentaires :

1. **Analyse de cohérence physique** : les deepfakes génèrent souvent des incohérences dans les reflets des yeux, le mouvement des oreilles, la synchronisation labiale.
2. **Analyse spectrale** : les artefacts de compression GAN (*Generative Adversarial Network*) laissent des signatures dans le domaine fréquentiel (FFT) détectables même après recompression.
3. **Métadonnées et provenance** : la **C2PA** (*Coalition for Content Provenance and Authenticity*) développe un standard de signature cryptographique à la capture : chaque photo prise par un appareil certifié porte une signature vérifiable.
4. **Analyse comportementale** : les modèles de langage génèrent des textes avec des patterns statistiques spécifiques détectables par des outils comme GPTZero ou Binoculars.

**Artefact · Vérification d'authenticité d'image – commandes pratiques**

**Étape 1. Extraction des métadonnées EXIF et C2PA :**

```
# ExifTool -- extraction complete
exiftool -a -u -g1 image_suspecte.jpg
# Chercher : Make, Model, GPS, CreateDate, Software
# ALERTE : 'Software: GIMP' sur une photo prétendument originale
# ALERTE : absence de champ GPS sur une photo censée être localisée

# Analyse des erreurs de niveau JPEG (ELA -- Error Level Analysis)
# Disponible via fotoforensics.com ou imagemagick
convert image.jpg -auto-level ela_result.jpg
# Les zones retouchées apparaissent avec un niveau d'erreur différent
```

**Étape 2. Analyse spectrale (FFT) :**

```
python3 -c \"
import cv2, numpy as np, matplotlib.pyplot as plt
img = cv2.imread('suspect.jpg', 0)
f = np.fft.fft2(img)
fshift = np.fft.fftshift(f)
magnitude = 20*np.log(np.abs(fshift)+1)
plt.imshow(magnitude, cmap='gray')
plt.savefig('spectrum.png')
```

```
\"
# Un spectre en croix ou en échiquier indique une génération GAN
```

**Jurisprudence & Droit applicable**

**Statut juridique des deepfakes au Cameroun :**
La **Loi 2010/012** [34], art. 72 (fraude informatique) et art. 71 (modification de données) couvrent la création de documents falsifiés, y compris les deepfakes à des fins frauduleuses. La **Loi 2024/017** [36], art. 59 (utilisation frauduleuse des données personnelles) s'applique lorsque le deepfake utilise le visage ou la voix d'une personne sans son consentement.

## 5.3 Forensique Cloud, IoT et Mobile : la Scène de Crime Distribuée

### 5.3.1 Les trois défis structurels du cloud forensique

La forensique cloud n'est pas une extension de la forensique système : c'est une discipline qui doit être repensée. Trois défis fondamentaux :

1. **Multitenancy** : les données d'un client sont physiquement colocalisées avec celles d'autres clients sur les mêmes serveurs. L'investigateur ne peut pas simplement "saisir le serveur".
2. **Éphéméralité** : les instances cloud (containers, fonctions serverless) durent quelques secondes à quelques minutes. Les logs sont supprimés selon des politiques de rotation que l'investigateur ne contrôle pas.
3. **Multi-juridiction** : un service hébergé chez AWS peut avoir ses données réparties entre des datacenters en Irlande, aux États-Unis et à Singapour. Quelle loi s'applique ? Le *CLOUD Act* [8] américain (2018) donne aux autorités US accès aux données hébergées par des entreprises américaines *n'importe où dans le monde* ; cela entre en conflit avec la souveraineté de nombreux États.

**Outils · Forensique cloud, commandes de collecte AWS/Azure**

**AWS CloudTrail. journaux d'audit :**

```
# Lister les événements récents CloudTrail (30 derniers jours)
aws cloudtrail lookup-events \\
    --lookup-attributes AttributeKey=EventName,AttributeValue=
   DeleteBucket \\
    --max-results 50

# Exporter les logs d'un bucket S3 spécifique vers l'
   investigation
aws s3 cp s3://bucket-suspect/logs/ ./evidence/logs/ --recursive
```

```
# Calculer les hash immédiatement après téléchargement
sha256sum ./evidence/logs/*
```

**Azure Activity Log :**

```
# Lister les activités suspectes sur un abonnement Azure
az monitor activity-log list \\
    --start-time 2026-03-01 \\
    --end-time 2026-03-15 \\
    --query '[?level==`Critical`]' \\
    --output table
```

### 5.3.2 IoT forensique : l'explosion des surfaces de collecte

Selon Cisco, plus de 29 milliards d'appareils IoT seront connectés en 2030. Chacun est potentiellement une scène de crime : routeur compromis, caméra IP, montre connectée, véhicule, thermostat intelligent. Les défis :

- **Hétérogénéité** : chaque fabricant utilise un système d'exploitation propriétaire. Les outils forensiques génériques (Autopsy, FTK) ne fonctionnent pas sur un firmware TP-Link.
- **Volatilité extrême** : beaucoup d'appareils IoT ne conservent leurs logs qu'en RAM ou dans un buffer circulaire de quelques heures.
- **Extraction physique** : certains appareils exigent une extraction via UART, JTAG ou chip-off, des techniques matérielles qui nécessitent un équipement spécialisé.

**Scénario Opérationnel · Caméra IP dans une affaire d'homicide, Yaoundé, fictif**

Une caméra de vidéosurveillance IP a enregistré l'entrée d'un suspect dans un immeuble le soir d'un homicide. L'immeuble utilise un système Hikvision. La caméra est connectée à un NVR (enregistreur réseau).

**Procédure forensique :**

1. Identifier le modèle du NVR et son interface d'administration.
2. Extraire les séquences vidéo via l'interface web ou via l'outil dédié (IVMS-4200 pour Hikvision).
3. Calculer le hash de chaque fichier vidéo extrait.
4. Documenter les paramètres de la caméra (heure système, synchronisation NTP ; un décalage horaire fausse tout témoignage basé sur la vidéo).

**Attention CRO :** $\mathcal{C}$: $\sim$ $\mathcal{R}$: $\uparrow$ si hash documenté $\mathcal{O}$: $\sim$ dépend horloge Le décalage horaire est le piège le plus fréquent des vidéos de surveillance : sans synchronisation NTP documentée, l'heure affichée peut être fausse de plusieurs heures.

### 5.3.3 Mobile forensique : spécificités africaines

En Afrique subsaharienne, le mobile est le premier vecteur de services numériques (banque, communication, commerce). La forensique mobile y est donc disproportionnellement centrale. Quatre niveaux d'acquisition selon [NIST SP 800-101r1] [30] :

| Niveau | Technique | Données accessibles |
|---|---|---|
| Niveau 1 | Extraction manuelle | Photos, contacts, SMS visibles à l'écran |
| Niveau 2 | Extraction logique (ADB) | Fichiers accessibles du système de fichiers, bases SQLite applications |
| Niveau 3 | Extraction physique | Image complète de la mémoire flash ; données supprimées récupérables |
| Niveau 4 | Chip-off / JTAG | Extraction directe de la puce mémoire ; dernier recours |

*Tableau 5.2. Niveaux d'acquisition mobile (NIST SP 800-101r1)*

## 5.4 OSINT : Renseignement en Source Ouverte

### 5.4.1 Définition, périmètre et cadre légal camerounais

L'**OSINT** (*Open Source Intelligence*) désigne la collecte et l'analyse d'informations issues de sources légalement accessibles au public : sites web, réseaux sociaux, bases WHOIS, registres officiels, archives, publications scientifiques.

**⚖ Jurisprudence & Droit applicable**

**Cadre légal OSINT au Cameroun :**

- Art. 41 **Loi 2010/012** : droit au respect de la vie privée. L'OSINT ne couvre que les informations *volontairement* rendues publiques par leur sujet.
- Art. 9 **Loi 2024/017** : la collecte systématique (fichage) et le croisement avec des données non publiques peuvent entrer en conflit avec le principe de finalité déterminée.
- **Règle pratique :** documenter dans chaque rapport OSINT la source exacte et la date de consultation. Une capture d'écran horodatée est indispensable, un lien public aujourd'hui peut être privé à l'audience.
- **Infiltration en ligne :** se faire passer pour quelqu'un d'autre en ligne pour obtenir des informations constitue une provocation ou surveillance couverte ; elle requiert une autorisation judiciaire et sort du cadre OSINT.

### 5.4.2 Le cycle OSINT pour les OPJ

Le cycle OSINT structuré en cinq étapes :

1. **Planification** : définir la cible et les questions clés. Qu'est-ce que j'ignore et que je dois trouver ?
2. **Collecte** : identifier et exploiter les sources pertinentes (réseaux sociaux, WHOIS, enregistrements publics).
3. **Traitement** : organiser, filtrer, supprimer les doublons.
4. **Analyse** : recouper, vérifier, tirer des conclusions.
5. **Diffusion** : produire un rapport utilisable par le magistrat instructeur.

### 5.4.3 Boîte à outils OSINT pour les OPJ camerounais

| Outil | Usage principal | Application forensique |
|---|---|---|
| Sherlock | Recherche de pseudo | Identifier tous les comptes d'une personne à partir d'un username (cas WOURI : `duke_cyber_ng`) |
| WHOIS / dig | Infrastructure | Propriétaire d'un domaine ; serveurs DNS ; enregistrement d'un domaine de phishing |
| crt.sh | Certificats SSL | Trouver tous les sous-domaines d'un domaine ; identifier des sites de phishing (ex : `*.uba-cameroun.com`) |
| dnstwist | Typosquatting | Générer et vérifier les variantes d'un domaine légitime |
| Shodan | Appareils exposés | Identifier des caméras, serveurs, IoT vulnérables associés à une cible |
| ExifTool | Métadonnées | GPS dans les photos, auteur, appareil ; localiser un suspect via ses publications Instagram |
| Blockchair | Blockchain | Tracer les transactions Bitcoin ; identifier les adresses de mixeurs (cas WOURI) |
| Maltego | Graphe de relations | Cartographier visuellement les connexions entre entités (personnes, domaines, IPs) |

*Tableau 5.3. Boîte à outils OSINT pour les OPJ*

```
# 1. Recherche de pseudo identifié (@koffi_biz_225)
sherlock koffi_biz_225
# -> identifie comptes Telegram, Instagram, Twitter/X

# 2. Reverse image search via exiftool si photo disponible
```

```
exiftool photo_profil.jpg | grep -i 'GPS\|Make\|Date'

# 3. Infrastructure : domaine utilisé pour le phishing
whois medequip-portugal.com
dig medequip-portugal.com ANY
crt.sh : medequip-portugal.com  # via navigateur

# 4. Adresses Bitcoin du réseau
# -> Blockchair.com : entrer l'adresse, visualiser le graphe de transactions
# -> Identifier les exchanges (Binance, Kraken) : portail LEA disponible

# 5. Maltego : cartographier les connexions
# Entités : KOUAME, @koffi_biz_225, +225 07XXXXXX,
#           medequip-portugal.com, 3 adresses BTC
```

Listing 5.1: Workflow OSINT complet, cible fictive KOUAME Narcisse

## 5.5 Benchmarking Mondial : le Framework DICES

### 5.5.1 Le framework DICES

Le framework **DICES** (**D**octrine, **I**nfrastructure, **C**apacités, **E**cosystème, **S**tratégie) permet de comparer les pratiques forensiques de différentes juridictions sur cinq axes [31] :

- **D**octrine : philosophie et approche conceptuelle (empirisme pragmatique ou rigueur formelle ?)
- **I**nfrastructure : moyens techniques et organisationnels (laboratoires, équipements, plateformes cloud)
- **C**apacités : compétences humaines et processus (formations, certifications, procédures standardisées)
- **E**cosystème : environnement juridique et institutionnel (lois, tribunaux, organismes de régulation)
- **S**tratégie : vision prospective et adaptation (investissements R&D, coopération internationale)

### 5.5.2 Positionnement comparatif

| Axe DICES | USA/FBI | Europe | Afrique du Sud | Nigeria | Cameroun |
|---|---|---|---|---|---|
| Doctrine | Empirisme | Droit civil | Mixte | Common law | Droit civil fr. |
| Infrastructure | ●●●●● | ●●●● | ●●● | ●● | ●● |
| Capacités | ●●●●● | ●●●● | ●●● | ●● | ●● |
| Ecosystème | CFAA + FRE | RGPD [38] + Budapest | RICA | Budapest | Loi 2010 |
| Stratégie | IA + quantique | ENISA + C2PA | SAPS-DCI | EFCC | ANTIC |

*Tableau 5.4. Comparaison DICES : ● = niveau de maturité*

### 5.5.3 Atouts et lacunes du Cameroun : une lecture honnête

**Atouts réels :**

- Un cadre législatif complet et récent : **Loi 2010/012** et **Loi 2024/017** couvrent les infractions numériques et la protection des données.
- L'ANTIC, institution fonctionnelle et présente dans les enquêtes.
- Une communauté technique en formation rapide (ENSP, Universités, entreprises privées).
- Une expérience terrain sur les fraudes MoMo : le Cameroun forme ses propres enquêteurs sur des cas réels, pas des simulations.

**Lacunes à combler :**

- Absence de laboratoire forensique accrédité au niveau national.
- Faible infrastructure de partage de renseignements cyber (*threat intelligence*) entre les institutions.
- Jurisprudence numérique naissante : peu de décisions de justice commentées et publiées sur la preuve numérique.
- Ressources d'investigation en langue française et en contexte africain : c'est précisément le vide que ce cours est conçu pour combler.

## 5.6 Roadmap de Développement Professionnel

### 5.6.1 Les certifications de référence mondiales

| Certification | Niveau | Spécialité | Coût estimé |
|---|---|---|---|
| GIAC GCFE | Intermédiaire | Forensique Windows | 7 000 USD |
| GIAC GCFA | Avancé | Incident Response | 7 000 USD |
| GIAC GREM | Expert | Malware RE | 7 000 USD |
| EnCE | Intermédiaire | EnCase (outil) | 3 000 USD |
| OSCP | Avancé | Pentest | 1 500 USD |
| CompTIA CySA+ | Intermédiaire | Analyse cyber | 400 USD |
| Cellebrite CCPA | Intermédiaire | Mobile forensique | Variable |

*Tableau 5.5. Certifications forensiques de référence (coûts indicatifs relevés sur les sites des organismes certificateurs ; à vérifier avant toute inscription)*

### 5.6.2 Roadmap réaliste sur 36 mois en contexte camerounais

| Phase | Durée | Objectifs et activités |
|---|---|---|
| Phase 1. Socle | Mois 1–6 | Maîtrise de Kali Linux, Autopsy, FTK Imager, Volatility 3. Réalisation de 20 scénarios de laboratoire (images forensiques fournies). Lecture de ce cours. Obtention CompTIA CySA+ si financement disponible. |
| Phase 2. Spécialisation | Mois 7–18 | Choisir une spécialité : (a) forensique judiciaire (droit + procédure), (b) réponse aux incidents (cloud + SIEM), (c) forensique mobile (Android/iOS). Participation aux CTF forensiques (CyberDefenders, BlueTeamLabs). Contribution à 3 investigations réelles (stage ou DGSN). |
| Phase 3. Excellence | Mois 19–36 | Préparation GIAC GCFE ou GCFA. Rédaction d'un article technique sur un cas camerounais. Contribution à l'élaboration de procédures standardisées pour l'ANTIC ou la DGSN. |

*Tableau 5.6. Roadmap 36 mois en contexte camerounais*

**Application OPJ/Expert Judiciaire**

**Ressources gratuites accessibles depuis le Cameroun :**

- **CyberDefenders.org** : laboratoires forensiques avec images disque, captures réseau, fichiers mémoire. Niveaux Débutant à Expert. Gratuit.

- **BlueTeamLabsOnline.com** : scénarios de réponse aux incidents. Gratuit pour les niveaux de base.
- **HackTheBox / DFIR Track** : challenge forensique mensuel.
- **SANS Cyber Aces** : cours de fondamentaux gratuit.
- **GitHub/volatility3** : documentation officielle avec exemples d'analyse mémoire.
- **Journal of Digital Forensics, Security and Law** : accès ouvert ; articles académiques en forensique.

## 5.7 Synthèse : la Carte de la Discipline en 2025–2026

Ce chapitre clôt la Partie I. La figure ci-dessous synthétise la carte de la discipline telle qu'elle se présente en 2025–2026 :

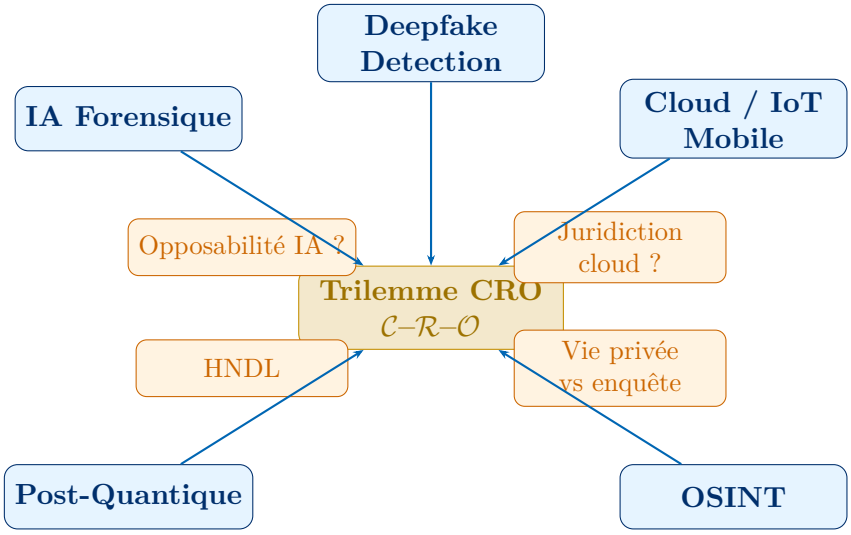



Figure 5.1: Carte de la forensique numérique en 2025–2026 : cinq frontières actives toutes soumises aux tensions du Trilemme CRO

★ À retenir

**Ce qu'il faut retenir de ce chapitre :**

- **IA forensique :** puissant pour le triage, problématique pour l'opposabilité. L'IA oriente ; l'humain constate et signe. Documenter outil, version, paramètres, échantillon de vérification.
- **Deepfakes :** détection par analyse de cohérence physique, analyse spectrale (FFT), métadonnées et standard C2PA. La **Loi 2010/012** art. 72 et la **Loi 2024/017** art. 59 couvrent les deepfakes frauduleux.

- **Cloud forensique :** trois défis : multitenancy, éphéméralité, multi-juridiction. La réquisition aux opérateurs cloud passe par des portails LEA dédiés (AWS, Azure, Google, Binance).
- **Mobile Afrique :** quatre niveaux d'acquisition NIST. En Afrique subsaharienne, la forensique mobile est prioritaire : Mobile Money, WhatsApp, SIM swapping sont les vecteurs dominants.
- **OSINT :** cycle en 5 étapes, 8 outils de référence. La capture d'écran horodatée est obligatoire. L'infiltration en ligne sort du cadre OSINT et exige une autorisation judiciaire.
- **DICES :** le Cameroun a un cadre législatif solide (**Loi 2010/012** + **Loi 2024/017**) mais manque de laboratoire accrédité et de jurisprudence publiée.
- **Roadmap 36 mois :** Socle (Kali/Autopsy/Volatility) → Spécialisation (judiciaire / IR / mobile) → Excellence (GCFE/GCFA + contribution institutionnelle).

### ✍ Exercice 5.1. Évaluation d'un outil IA ★☆☆

Un analyste utilise un outil commercial d'IA pour classifier automatiquement 500 emails dans une affaire de fraude. L'outil indique que 47 emails sont "fortement suspects" avec une probabilité de 0.93.

(a) Quelles informations l'analyste doit-il obtenir sur l'outil avant de l'utiliser dans un rapport judiciaire ?

(b) Comment valide-t-il les conclusions de l'IA sur un échantillon ?

(c) Comment formule-t-il la conclusion dans son rapport pour qu'elle soit défendable devant un tribunal camerounais ?

(d) Formulez l'analyse CRO de cette décision d'utiliser l'IA.

### ✍ Exercice 5.2. Workflow OSINT ★★☆

Dans une affaire de cyberharcèlement, la victime vous fournit :

- Un numéro de téléphone camerounais : `+237 6XX XXX XXX`
- Un pseudo Instagram : `@shadow_cam237`
- Une photo de profil téléchargée depuis Instagram
- Un email reçu depuis : `noreply@camphone-support.cm`

(a) Construisez un workflow OSINT complet : pour chaque élément, quel outil

utilisez-vous et quelle information cherchez-vous ?

(b) Identifier les limites légales de votre collecte : à quel moment devez-vous une réquisition judiciaire pour continuer ?

(c) Comment documentez-vous vos sources pour la recevabilité ?

### ✍ Exercice 5.3. Analyse DICES du Cameroun ★★★

En vous appuyant sur le framework DICES et sur les informations du chapitre :

(a) Pour chaque axe DICES, identifiez une force et une faiblesse spécifique au contexte camerounais en 2026.

(b) Proposez une action concrète et réalisable à court terme ($\leq 2$ ans) pour chacune des deux lacunes les plus critiques.

(c) Dans la roadmap 36 mois, quel axe DICES est le plus influencé par votre choix de spécialisation ? Justifiez.

### ● Note

**Transition vers la Partie II.** La Partie I vous a donné la philosophie (Ch. 1), l'histoire (Ch. 2), les affaires de référence (Ch. 3), les fondements mathématiques (Ch. 4) et l'état de l'art (ce chapitre). Ces cinq chapitres constituent le *pourquoi* de la discipline. La **Partie II** (Chapitres 6–9) en construit le *comment* : le Processus Investigatif Universel, les méthodologies et standards, la chaîne de custody et les outils d'acquisition ; tout ce qu'il vous faut pour conduire votre première investigation de A à Z.

# partie II

# Processus et Méthodologies d'Investigation


© MaletYon

# 6

# PROCESSUS INVESTIGATIF UNIVERSEL

> « La qualité d'une investigation se mesure moins à la rapidité avec laquelle on parvient à des conclusions qu'à la robustesse avec laquelle ces conclusions résistent à la contestation contradictoire. »
>
> Principe fondamental du PIU

**Niveau :** *Fondamental à Intermédiaire* • Lecture de la Partie I recommandée. Ce chapitre constitue le cœur méthodologique de ce cours ; toutes les parties suivantes s'y réfèrent.

**✦ Objectifs du chapitre**

- ➢ Comprendre l'architecture modulaire du **Processus Investigatif Universel** (PIU) : 5 phases, 17 étapes, 3 Quality Gates.
- ➢ Maîtriser la **matrice de criticité** pour calibrer le niveau de rigueur adapté à chaque investigation.
- ➢ Appliquer chaque étape selon trois niveaux de profondeur (minimal, standard, avancé) selon les contraintes du contexte.
- ➢ Conduire une investigation complète dans trois contextes distincts : particulier, entreprise et judiciaire.
- ➢ Comprendre le rôle des Quality Gates comme mécanismes de contrôle qualité obligatoires.
- ➢ Relier chaque phase du PIU aux dimensions du Trilemme CRO.

## 6.1 Introduction et Architecture Générale

### 6.1.1 Objectifs et principes fondateurs

L'investigation, qu'elle soit menée dans un cadre personnel, professionnel ou judiciaire, nécessite une méthodologie rigoureuse garantissant à la fois l'intégrité probatoire et la défendabilité des conclusions. Ce chapitre présente un **Processus Investigatif Universel** (PIU), conçu pour s'adapter à tout contexte investigatif par le biais d'une architecture modulaire et scalable.

Le PIU vise quatre objectifs fondamentaux :

1. **Établissement factuel objectif** : documenter les faits de manière reproductible et vérifiable ;
2. **Intégrité probatoire** : garantir que les éléments collectés conservent leur valeur probante ;
3. **Traçabilité complète** : permettre l'audit de chaque étape du processus investigatif ;
4. **Défendabilité** : produire des conclusions résistant à la contestation contradictoire.

### 6.1.2 Principe d'adaptabilité : trois contextes

Le PIU emploie une terminologie neutre permettant son application dans trois contextes principaux :

- ➢ **Contexte particulier** : investigation menée par un individu pour ses intérêts propres ;
- ➢ **Contexte organisationnel** : investigation interne à une entreprise ou institution ;
- ➢ **Contexte judiciaire** : expertise mandatée par une autorité juridictionnelle.

Chaque étape comporte trois niveaux de profondeur (minimal, standard, avancé) s'ajustant selon la criticité du cas, conformément à la matrice de criticité du Tableau 6.1.3.

### 6.1.3 Matrice de criticité

| Critère | Minimal | Standard | Avancé |
|---|---|---|---|
| Enjeu financier | $< 10$k | 10–100k | $> 100$k |
| Risque pénal | Nul | Contraventionnel | Correctionnel/Criminel |
| Complexité technique | Faible | Moyenne | Haute |
| Nombre parties prenantes | $< 5$ | 5–20 | $> 20$ |
| Durée estimée | $< 1$ semaine | 1 sem. – 3 mois | $> 3$ mois |

*Tableau 6.1.3. Matrice de criticité et niveau de rigueur requis*

### 6.1.4 Architecture globale : 5 phases, 17 étapes, 3 Quality Gates

Le PIU s'articule en cinq phases séquentielles comportant 17 étapes opérationnelles et trois points de contrôle qualité (**Quality Gates**).

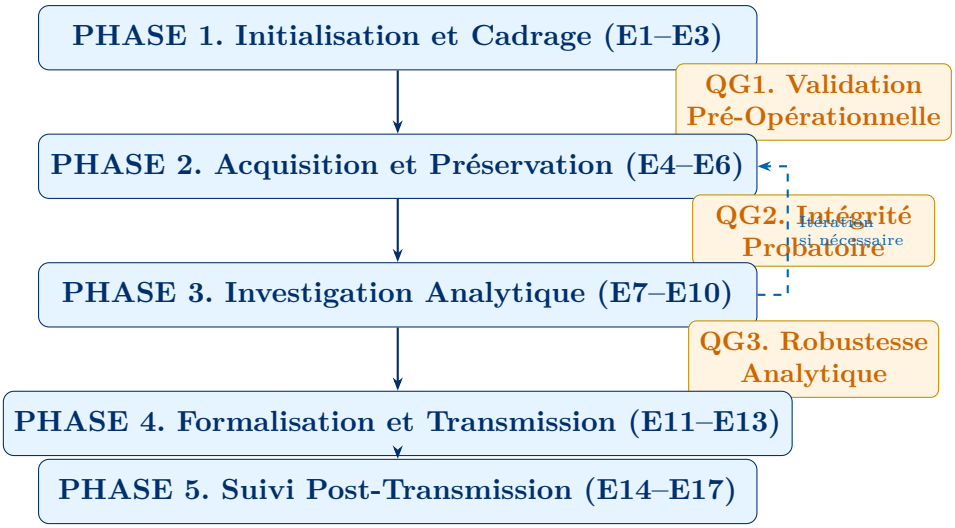



Figure 6.1: Architecture globale du Processus Investigatif Universel (PIU)

### 6.1.5 Principe des Quality Gates

Les **Quality Gates** (QG) constituent des points de contrôle obligatoires validant la conformité avant progression vers la phase suivante. Leur structure s'articule autour de critères graduels :

- **Critères obligatoires** : applicables à tous les contextes ;
- **Critères standard** : pour cas moyennement complexes ;
- **Critères avancés** : pour investigations à haute criticité.

Un échec à un Quality Gate impose soit une remédiation immédiate, soit un retour aux étapes antérieures concernées. Trois décisions possibles :

**VERT** Tous critères obligatoires validés : progression vers la phase suivante.

**ORANGE** Critère non bloquant manquant : progression conditionnelle avec plan de régularisation.

**ROUGE** Critère bloquant non validé : suspension jusqu'à mise en conformité complète.

## 6.2 Phase 1 : Initialisation et Cadrage

La phase d'initialisation détermine la recevabilité de la demande investigative et établit les conditions opérationnelles de sa conduite.

### 6.2.1 Étape E1. Réception et Évaluation Préliminaire

**Objectif :** Comprendre la nature de la demande et évaluer sa recevabilité avant tout engagement de ressources.

*Actions par niveau*

**Niveau minimal :**

- Réception de la demande d'investigation (formelle ou informelle) ;
- Identification du commanditaire et vérification de sa légitimité ;
- Compréhension sommaire des faits allégués ;
- Évaluation première de la faisabilité technique et juridique.

**Niveau standard :** En complément du niveau minimal :

- Demande de précisions écrites formelles au commanditaire ;
- Vérification des autorisations légales préalables nécessaires ;
- Estimation préliminaire des ressources humaines, techniques et temporelles requises ;
- Identification des contraintes réglementaires applicables (Loi 2024/017 [36], Convention de Budapest [9] selon contexte).

**Niveau avancé :** En complément des niveaux précédents :

- Analyse de risque multi-dimensionnelle (légal, réputationnel, technique, financier) ;
- Consultation de spécialistes pour évaluation de faisabilité ;
- Étude de précédents similaires (jurisprudence, cas antérieurs) ;
- Rédaction d'une note d'opportunité structurée.

**Livrable :** *Fiche d'Évaluation Initiale* comprenant : description factuelle de la demande ; enjeux identifiés (financiers, juridiques, humains, réputationnels) ; obstacles prévisibles et risques ; recommandation préliminaire motivée (accepter / refuser / clarifier).

### 6.2.2 Étape E2. Décision d'Engagement

**Objectif :** Valider formellement le lancement de l'investigation selon les critères de gouvernance appropriés au contexte.

*Actions par niveau*

**Niveau minimal :**

- Décision personnelle d'engagement documentée ;
- Vérification d'absence de conflit d'intérêt personnel ;
- Validation de la disponibilité temporelle et des ressources.

**Niveau standard :**

- Validation hiérarchique ou contractuelle formalisée ;
- Signature d'un mandat d'investigation ou lettre de mission ;
- Définition précise du périmètre d'investigation et des limitations ;
- Établissement d'un budget prévisionnel et allocation de ressources ;
- Détermination des délais et jalons intermédiaires.

**Niveau avancé :**

- Validation collégiale impliquant expertises multiples (technique, juridique, éthique) ;
- Obtention des autorisations formelles requises (mandat judiciaire, réquisition ; art. 52 **Loi 2010/012** [34] en contexte camerounais) ;
- Définition du niveau de classification sécuritaire ;
- Constitution d'un comité de pilotage si investigation complexe.

**Livrable :** *Mandat d'Investigation* comprenant : périmètre précis et exclusions explicites ; délais avec jalons intermédiaires ; budget et ressources allouées ; niveau d'autorité conféré ; obligations de confidentialité ; conditions de transmission finale.

### 6.2.3 Étape E3. Planification Opérationnelle

**Objectif :** Structurer l'investigation en mobilisant les ressources adéquates et en anticipant les difficultés opérationnelles.

*Actions par niveau*

**Niveau minimal :**

- Auto-évaluation des compétences requises versus disponibles ;
- Listage des outils et équipements nécessaires ;
- Création d'un calendrier sommaire avec échéances principales.

**Niveau standard :**

- Constitution d'une équipe avec attribution claire des rôles ;
- Rédaction d'un plan d'investigation structuré (axes, méthodologies, jalons, hypothèses préliminaires) ;
- Configuration et test des outils techniques ;
- Mise en place d'un système de documentation et traçabilité.

**Niveau avancé :**

- Planification détaillée type gestion de projet (WBS, Gantt) ;

- Analyse de risque opérationnelle exhaustive avec plan de contingence ;
- Test et calibration des outils critiques ;
- Création d'un environnement de travail sécurisé ;
- Établissement de protocoles d'escalade pour situations critiques.

**Livrable :** *Plan d'Investigation v1.0* comprenant : objectifs et critères de succès mesurables ; méthodologie générale ; ressources mobilisées ; échéancier prévisionnel ; procédures de gestion des imprévus.

### 6.2.4 Quality Gate 1. Validation Pré-Opérationnelle

**Objectif :** Garantir que l'ensemble des conditions préalables au démarrage effectif sont satisfaites.

**Critères obligatoires (tous contextes) :**

- Mandat d'investigation formalisé et validé par l'autorité compétente ;
- Périmètre clairement défini, compris et accepté par toutes parties ;
- Ressources minimales identifiées et effectivement disponibles ;
- Plan d'investigation v1.0 rédigé et approuvé ;
- Outils nécessaires opérationnels ou accessibles dans les délais.

**Critères standard :**

- Validation légale et/ou déontologique obtenue auprès des instances ;
- Protocoles de documentation établis et compris de tous ;
- Système de traçabilité configuré et testé.

**Critères avancés :**

- Plan de contingence documenté couvrant les risques identifiés ;
- Tests opérationnels des outils techniques réalisés ;
- Assurances et couvertures légales vérifiées si applicable.

**Application OPJ/Expert Judiciaire**

**Application OPJ. Contexte camerounais, QG1 :**
En contexte judiciaire camerounais, le passage au VERT du QG1 exige :

1. Réquisition judiciaire ou mandat du procureur (art. 52 **Loi 2010/012**) ;
2. Disponibilité d'un kit forensique de base (write blocker, FTK Imager, clé USB bootable) ;
3. Information du suspect de ses droits (art. 5 CPP Cameroun) si l'investigation

implique une perquisition.

## 6.3 Phase 2 : Acquisition et Préservation

La phase d'acquisition vise à constituer la base probatoire de l'investigation en garantissant l'intégrité et la recevabilité juridique des éléments collectés.

### 6.3.1 Étape E4. Collecte Systématique des Éléments Probatoires

**Objectif :** Rassembler exhaustivement les éléments factuels pertinents en préservant leur intégrité et leur valeur probatoire.

*Actions par niveau*

**Niveau minimal :**

- Identification systématique des sources d'information disponibles ;
- Collecte documentaire (contrats, correspondances, factures, notes) ;
- Réalisation de photographies ou copies des éléments physiques ;
- Rédaction de notes de constatation horodatées.

**Niveau standard :**

- Application d'un protocole de collecte standardisé et documenté ;
- Documentation de chaque action : date/heure, méthode, outils, identité du collecteur, état initial, localisation ;
- Attribution d'une numérotation séquentielle unique à chaque élément ;
- Photographie de contexte (scène, emplacement) avant prélèvement.

**Niveau avancé :**

- Application stricte des protocoles **[ISO 27037]** [18] et principes ACPO [3] ;
- Création d'images forensiques bit-à-bit avec write blocker ;
- Calcul d'empreintes cryptographiques (SHA-256 et SHA-512) pour tous éléments numériques ;
- Réalisation de prélèvements en présence de témoins assermentés si contexte judiciaire.

**Livrable :** *Inventaire des Éléments Probatoires* comprenant : liste numérotée ; description non ambiguë ; provenance et circonstances ; état initial ; empreintes cryptographiques ; chaîne de traçabilité initiale.

### 6.3.2 Étape E5. Sécurisation et Préservation

**Objectif :** Garantir l'intégrité durable des éléments collectés et prévenir toute altération, perte ou accès non autorisé.

*Actions par niveau*

**Niveau minimal :**

- Création immédiate de copies de sauvegarde sur support physique distinct ;
- Stockage sécurisé dans lieu physique protégé ;
- Règle stricte : interdiction de travailler directement sur originaux ;
- Journal des accès (qui, quand, pourquoi).

**Niveau standard :** Principe de sauvegarde 3-2-1 :

- 3 copies de chaque élément ;
- 2 types de supports différents (disque dur, cloud, support optique) ;
- 1 copie en localisation géographique distincte ;
- Chiffrement systématique des données sensibles (AES-256) ;
- Vérification régulière (hebdomadaire) de l'intégrité par hash.

**Niveau avancé :**

- Utilisation de blockchain privée ou horodatage qualifié ;
- Stockage en coffre-fort numérique certifié ;
- Tests d'intégrité automatisés quotidiens ;
- Plan de continuité opérationnelle documenté.

**Livrable :** *Registre de Préservation* comprenant : certificats d'intégrité (hash avec algorithme) ; schéma de localisation des copies ; journal d'accès horodaté ; résultats des tests d'intégrité.

### 6.3.3 Étape E6. Identification et Cartographie des Parties Prenantes

**Objectif :** Recenser exhaustivement toutes les personnes et entités ayant un lien direct ou indirect avec les faits investigués.

*Actions par niveau*

**Niveau minimal :**

- Listage des parties directement mentionnées ;
- Distinction sommaire entre acteurs principaux et secondaires ;
- Recueil des coordonnées disponibles ;
- Notation des relations apparentes entre parties.

**Niveau standard :**

- Cartographie relationnelle détaillée (hiérarchiques, contractuels, familiaux) ;
- Classification par catégories : parties directes ; témoins directs ; témoins indirects ; experts techniques ; autorités de tutelle ;
- Priorisation raisonnée pour la conduite des entretiens ;
- OSINT systématique dans limites légales (cf. Chapitre 5).

**Niveau avancé :**

- Analyse de réseau social formelle (SNA) avec logiciels dédiés ;
- Profilage préliminaire adapté au contexte ;
- Évaluation du risque de collusion ou de coordination entre parties.

**Livrable :** *Matrice des Parties Prenantes* avec pour chaque personne/entité : identité et coordonnées ; rôle et catégorie ; niveau d'implication estimé (1–5) ; crédibilité préliminaire ; priorité d'entretien ; schéma relationnel visuel.

### 6.3.4 Quality Gate 2. Intégrité Probatoire

**Objectif :** Vérifier que la base probatoire constituée est complète, intègre, traçable et juridiquement exploitable.

**Critères obligatoires :**

- Inventaire probatoire exhaustif, numéroté de manière unique ;
- Chaîne de traçabilité documentée sans interruption pour chaque élément ;
- Sauvegardes multiples vérifiées et opérationnelles ;
- Impossibilité technique de modification non tracée ;
- Journal d'accès à jour, sans anomalie détectée.

**Critères standard :**

- Hash cryptographiques calculés et archivés dans localisation distincte ;
- Tests d'intégrité périodiques réalisés (100% des hash correspondants) ;
- Conformité légale de toutes les méthodes de collecte validée.

**Rationale critique :** Un élément probatoire non conforme à QG2 risque l'irrecevabilité juridique (vice de procédure), la contestabilité (doute sur authenticité) ou l'inexploitabilité (altération). La détection précoce évite l'invalidation tardive de l'ensemble du travail investigatif.

**$\Gamma_{CRO}$ Analyse CRO · Confidentialité · Fiabilité · Opposabilité**

**Analyse CRO. Phase 2 : Acquisition et Préservation**
$\mathcal{C}$ : La collecte exhaustive (E4 niveau avancé) peut inclure des données sans rapport avec l'affaire. La proportionnalité doit guider le périmètre de collecte.
$\mathcal{R}$ : Le principe 3-2-1 (E5) et le hachage SHA-256+SHA-512 maximisent la fiabilité. L'impossibilité technique de modification non tracée est le critère QG2 le plus important.
$\mathcal{O}$ : La chaîne de traçabilité continue et les hash documentés sont les preuves d'intégrité opposables en justice.
$\mathcal{C}$: ↓ proportionnalité $\mathcal{R}$: ↑↑ maximisée $\mathcal{O}$: ↑ par la custody

## 6.4 Phase 3 : Investigation Analytique

La phase d'investigation constitue le cœur du processus, durant laquelle hypothèses explicatives sont générées, testées et confrontées aux éléments probatoires. Cette phase comporte une boucle itérative formalisée.

### 6.4.1 Étape E7. Interrogatoires et Collecte Testimoniale

**Objectif :** Recueillir les témoignages, déclarations et expertises orales nécessaires à la compréhension approfondie des faits.

*Actions par niveau*

**Niveau minimal :**

- Conduite d'entretiens informels non structurés ;
- Prise de notes manuscrites contemporaines ;
- Recueil des déclarations spontanées ;
- Conservation soigneuse des témoignages écrits volontairement fournis.

**Niveau standard :**

- Préparation de questionnaires structurés adaptés à chaque catégorie ;
- Conduite d'entretiens semi-directifs (narration libre puis précisions) ;
- Enregistrement audio avec consentement formel écrit ;
- Rédaction de comptes rendus fidèles soumis à validation ;
- Analyse de cohérence interne (chronologie, contradictions) ;
- Documentation des refus de répondre.

**Niveau avancé :**

- Application de protocoles scientifiques : méthode PEACE (*Preparation, Engage, Account, Closure, Evaluation*) ; entretien cognitif pour témoins de bonne foi ;

- Enregistrement multi-modal (audio et vidéo) si approprié ;
- Analyse linguistique approfondie des déclarations ;
- Procédures d'audition formelles respectant strictement les droits processuels (contexte judiciaire).

**Livrable :** *Corpus Testimonial* comprenant : enregistrements archivés ; transcriptions intégrales horodatées ; comptes rendus synthétiques ; matrice d'évaluation de cohérence et crédibilité ; points de convergence et divergences ; éléments corroborant ou réfutant les hypothèses.

### 6.4.2 Étape E8. Génération d'Hypothèses Multiples

**Objectif :** Construire de manière systématique plusieurs scénarios explicatifs distincts des faits, sans présupposé hiérarchique initial, afin d'éviter le biais de confirmation.

*Actions par niveau*

**Niveau minimal :**

- Formulation de 2 à 3 hypothèses principales spontanées ;
- Description narrative sommaire de chaque scénario ;
- Identification intuitive de l'hypothèse la plus probable.

**Niveau standard :**

- Génération systématique d'au moins 5 hypothèses distinctes incluant : hypothèse principale, alternatives crédibles, hypothèse nulle (absence de fait délictuel), hypothèses improbables ;
- Documentation du raisonnement sous-jacent à chaque hypothèse ;
- Construction d'arbres de décision ou diagrammes causaux ;
- Formulation de prédictions testables dérivées (*si H vraie, alors on devrait observer...*).

**Niveau avancé :**

- Application formalisée de la méthode ACH (*Analysis of Competing Hypotheses*) [14] ;
- Modélisation bayésienne des probabilités a priori ;
- Exercice de *red teaming* : simulation d'acteur adversaire ;
- Analyse de précédents historiques similaires (benchmark).

**Livrable :** *Arbre d'Hypothèses v1.0* comprenant pour chaque hypothèse : identifiant unique et intitulé non ambigu ; description narrative ; raisonnement explicite ; prédictions testables ; preuves pro/contra ; conditions de réfutation ; probabilité subjective initiale.

### 6.4.3 Étape E9. Confrontation Hypothèses/Preuves

**Objectif :** Évaluer systématiquement la compatibilité de chaque hypothèse avec l'ensemble des éléments probatoires et témoignages collectés.

*Actions par niveau*

**Niveau standard :**

- Construction d'une matrice de compatibilité hypothèses × preuves ;
- Pour chaque intersection, évaluation qualitative : + Cohérente ; **-** Incohérente ; **o** Neutre ;
- Calcul de scores de cohérence par hypothèse ;
- Identification des preuves discriminantes ;
- Test empirique des prédictions dérivées (E8) ;
- Hiérarchisation des hypothèses par score de cohérence.

**Niveau avancé :**

- Analyse bayésienne formelle ;
- Simulation Monte-Carlo pour quantification des incertitudes ;
- Organisation de sessions de *peer review* ;
- Processus de *red team* cherchant activement à réfuter.

La figure suivante illustre un exemple de matrice de compatibilité :

| | | | | |
|---|---|---|---|---|
| | | | | |
| | − | + | + | o |
| | o | + | − | + |
| | + | o | + | o |
| | − | − | o | + |
| | 1/4 | 2/4 | 2/4 | 3/4 |

Figure 6.2: Exemple de matrice de compatibilité hypothèses/preuves : + Cohérent ; − Incohérent ; **o** Neutre

**Livrable :** *Matrice d'Analyse Hypothèses/Preuves* comprenant : tableau croisé ; scores de cohérence ; liste des hypothèses réfutées ; classement hiérarchique ; lacunes probatoires ; recommandations de collecte.

### 6.4.4 Étape E9bis. Falsification Active

**Objectif :** Appliquer le principe épistémologique de Popper : tenter activement de réfuter chaque hypothèse plutôt que de chercher uniquement des confirmations.

**Justification méthodologique :** Le biais de confirmation constitue l'un des obstacles majeurs à l'objectivité investigative. La falsification active, inspirée de la philosophie des sciences de Karl Popper [33], impose la recherche délibérée d'observations qui, si découvertes, invalideraient l'hypothèse testée. Une hypothèse ayant résisté à de multiples tentatives sérieuses de falsification acquiert une robustesse épistémologique supérieure.

*Actions par niveau*

**Niveau minimal :**

- Pour chaque hypothèse post-E9 : formulation de la question : « Quelle observation prouverait de manière irréfutable que cette hypothèse est fausse ? » ;
- Vérification rapide dans le corpus probatoire ;
- Documentation sommaire.

**Niveau standard :**

- Pour chaque hypothèse viable, processus structuré en 4 étapes : (1) identification des observations critiques ; (2) recherche active dans les preuves existantes ; (3) planification de collecte additionnelle si non trouvées ; (4) documentation des tentatives (succès ou échec) ;
- Calcul d'un indice de robustesse : nombre de tentatives résistées.

**Niveau avancé :**

- Constitution d'une équipe *Red Team* dédiée à la réfutation ;
- Analyse contrefactuelle : « Si l'hypothèse était fausse, qu'observerait-on de différent ? » ;
- Formalisation logique des tests de falsification.

**Livrable :** *Rapport de Falsification* comprenant pour chaque hypothèse testée : conditions de falsification ; résultats ; score de robustesse ; liste des hypothèses définitivement éliminées.

### 6.4.5 Étape E10. Validation et Vérification

**Objectif :** Soumettre les conclusions préliminaires émergentes à un processus rigoureux de validation multi-méthodes avant formalisation définitive.

*Actions par niveau*

**Niveau minimal :**

- Relecture personnelle critique du raisonnement ;
- Vérification arithmétique des analyses quantitatives ;
- Auto-évaluation des biais cognitifs potentiels.

**Niveau standard :**

- Validation par pairs : présentation structurée à collègues ;
- Test de cohérence globale : narration complète et chronologique ;
- Identification et documentation des limitations méthodologiques ;
- Évaluation du niveau de certitude pour chaque conclusion.

**Niveau avancé :**

- Processus *Red Team / Blue Team* formalisé ;
- Réexécution à l'aveugle par expert tiers ;
- Calcul d'intervalles de confiance statistiques ;
- Simulation d'argumentation adverse.

**Livrable :** *Rapport de Validation* comprenant : méthodes de validation employées ; objections identifiées et réponses ; limitations reconnues ; niveau de consensus ; certification de validation (signatures).

### 6.4.6 Quality Gate 3. Robustesse Analytique

**Objectif :** S'assurer que les conclusions sont suffisamment robustes, documentées et défendables pour justifier leur formalisation.

**Critères obligatoires :**

- Génération documentée d'au moins 5 hypothèses distinctes (E8) ;
- Matrice de compatibilité hypothèses/preuves complétée (E9) ;
- Tentatives de falsification documentées pour hypothèses principales ;
- Application d'au moins une méthode de validation formelle (E10) ;
- Limitations de l'investigation clairement identifiées ;
- Traçabilité complète du raisonnement.

**Décision et gestion de l'itération :**

**VERT** Progression vers Phase 4.

**ORANGE** Expertise complémentaire ou re-analyse ciblée (5–10 jours).

**ROUGE** Retour selon nature : lacunes testimoniales → E7 ; incohérences analytiques → E8–E9 ; preuves matérielles manquantes → E4–E6.

**Point critique sur l'itération**

Le retour en Phase 2 ou la réitération de la Phase 3 n'est pas un échec méthodologique mais une **caractéristique normale** du processus investigatif. Les investigations de qualité nécessitent fréquemment 2 à 3 passages dans la boucle analytique. Un taux de passage direct au QG3 de 60–70% est satisfaisant (versus 85–90% pour QG1 et QG2).

## 6.5 Phase 4 : Formalisation et Transmission

La phase de formalisation transforme le travail investigatif en livrables structurés, adaptés au destinataire et juridiquement recevables.

### 6.5.1 Étape E11. Documentation Exhaustive et Consolidation

**Objectif :** Rassembler, structurer et archiver l'intégralité des éléments du dossier dans un format pérenne et auditable.

**Structure documentaire recommandée**. le dossier consolidé s'organise en cinq volumes :

**Volume 1. Synthèse** Sommaire exécutif, chronologie factuelle, conclusions principales (10–20 pages).

**Volume 2. Analyses** Méthodologie détaillée, hypothèses étudiées, raisonnement analytique (50–200 pages).

**Volume 3. Preuves** Éléments probatoires numérotés avec certificats d'intégrité et chaînes de traçabilité.

**Volume 4. Témoignages** Comptes rendus d'entretiens, déclarations écrites, expertises externes.

**Volume 5. Annexes** Journal de bord, références, documents de travail.

**Livrable :** *Dossier d'Investigation Complet* structuré, numéroté, indexé et archivé de manière pérenne.

### 6.5.2 Étape E12. Rédaction du Livrable Final

**Objectif :** Produire un document de synthèse adapté au destinataire, présentant de manière claire, rigoureuse et défendable les conclusions.

*Structure recommandée du rapport*

**Niveau 1. Synthèse Exécutive (2–4 pages) :**

1. Contexte et objet de la mission ;
2. Question(s) posée(s) ;
3. Conclusions principales numérotées ;
4. Niveau de confiance par conclusion (qualitatif ou quantitatif) ;
5. Recommandations actionables immédiates ;
6. Limitations assumées.

**Niveau 2. Rapport Technique (20–100 pages) :**

1. Introduction et contexte approfondi ;
2. Méthodologie (référencement normes/standards) ;
3. Faits matériellement établis (chronologie détaillée) ;
4. Hypothèses étudiées avec arbre décisionnel ;
5. Analyse détaillée des preuves et témoignages ;
6. Raisonnement étape par étape ;
7. Incertitudes et limitations ;
8. Recommandations détaillées ;
9. Bibliographie.

**Niveau 3. Dossier Probatoire (annexes) :** Ensemble des pièces justificatives référencées dans le rapport technique.

*Principes rédactionnels fondamentaux*

**Clarté** Phrases courtes (15–20 mots maximum) ; vocabulaire précis ; structure logique avec transitions explicites.

**Objectivité** Ton neutre (éviter « je pense », « il est évident ») ; différenciation rigoureuse entre faits établis, interprétations et opinions ; limitations assumées.

**Défendabilité** Chaque affirmation appuyée par référence probatoire ; raisonnement sans sauts inférentiels ; traçabilité complète du raisonnement.

**Adaptabilité** Niveau de technicité ajusté selon destinataire ; synthèse exécutive pour décideurs non techniques.

### 6.5.3 Étape E13. Transmission Sécurisée du Livrable

**Objectif :** Remettre le livrable de manière sécurisée, traçable, conforme aux exigences de confidentialité.

*Actions par niveau*

**Niveau minimal :**

- Remise en main propre contre signature ou email sécurisé chiffré ;
- Obtention d'un accusé de réception daté ;
- Conservation de la preuve de transmission.

**Niveau standard :**

- Transmission sécurisée : chiffrement bout-en-bout (GPG, S/MIME) ;
- Bordereau de transmission détaillé et signé ;
- Liste exhaustive des documents transmis.

**Niveau avancé :**

- Remise en présence de témoins (huissier si contexte critique) ;
- Signature électronique qualifiée ;
- Horodatage blockchain pour preuve d'antériorité immuable ;
- Watermarking individualisé par destinataire.

**Livrable :** *Preuve de Transmission* comprenant bordereau signé, liste exhaustive des documents, modalités de transmission, accusé contresigné.

## 6.6 Phase 5 : Suivi Post-Transmission

Cette phase, optionnelle pour investigations simples sans contentieux, devient essentielle dans les contextes judiciaires ou lorsque des contestations sont anticipées.

### 6.6.1 Étape E14. Préparation à la Défense Contradictoire

**Objectif :** Anticiper les contestations possibles et préparer une défense rigoureuse et documentée des conclusions.

**Actions :** Constitution d'un dossier de défense comprenant : analyse des vulnérabilités du rapport ; arguments adverses anticipés avec contre-arguments ; synthèses aide-mémoire par thème ; simulations d'interrogatoires contradictoires ; références scientifiques ou jurisprudentielles de soutien.

### 6.6.2 Étape E15. Maintenance Probatoire Continue

**Objectif :** Préserver intégrité et accessibilité du dossier durant toute la procédure contentieuse ou administrative.

**Actions :** Surveillance active (tests d'intégrité mensuels) ; gestion rigoureuse des accès avec journal exhaustif ; mise à jour de la chaîne de traçabilité ; réponse aux demandes de clarification ; correction d'erreurs matérielles avec versioning strict.

### 6.6.3 Étape E16. Analyse des Contre-Expertises

**Objectif :** Évaluer les rapports contradictoires produits par la partie adverse et préparer une réfutation méthodique.

**Actions :** Analyse méthodologique critique ; identification des erreurs factuelles ; discussion des divergences interprétatives légitimes ; rédaction d'un mémoire en réponse structuré ; proposition d'expertises complémentaires si nécessaire.

### 6.6.4 Étape E17. Clôture et Retour d'Expérience

**Objectif :** Archiver définitivement le dossier, capitaliser les apprentissages et améliorer les processus futurs.

**Actions :** Débriefing structuré d'équipe ; rédaction d'un rapport de retour d'expérience (REX) ; archivage définitif conforme aux durées légales ; destruction sécurisée des données temporaires ; intégration des enseignements dans la base de connaissances ; mise à jour des procédures standard.

**E17 n'est pas optionnelle**

L'étape E17 (*Retour d'Expérience*) n'est pas optionnelle : elle constitue le mécanisme d'amélioration continue permettant l'évolution et l'adaptation du processus aux nouveaux défis investigatifs. Une organisation qui ne fait pas de REX après chaque investigation majeure est condamnée à répéter les mêmes erreurs.

## 6.7 Cas Pratique : L'Affaire de la Facture Suspecte

### 6.7.1 Contexte général

Le 15 mars 2025, Madame Claire ROUSSEAU, dirigeante de la société INNOV-TECH SARL (PME de 25 salariés), constate un débit de 47 850 € sur son relevé bancaire au profit de la société CONSULTING-PRO, dont elle n'a aucune connaissance. En vérifiant ses archives comptables, elle découvre une facture n° CP-2025-089 datée du 28 février 2025, pour des « prestations de conseil stratégique » : prestations qu'elle affirme n'avoir jamais commandées.

Cette investigation illustre comment le PIU s'applique différemment selon trois contextes :

1. **Contexte particulier** : Madame ROUSSEAU mène elle-même l'investigation ;
2. **Contexte entreprise** : INNOV-TECH mandate un audit interne ;
3. **Contexte judiciaire** : un expert est désigné par le tribunal.

### 6.7.2 Application : Contexte particulier (niveau minimal/standard)

**Phase 1 : Initialisation**

**E1 – Réception et Évaluation :** Enjeu financier : 47 850 (significatif) ; complexité : moyenne ; faisabilité : 10h/semaine disponibles ; risque : fraude interne ou externe. Décision : investigation personnelle préliminaire avant éventuel dépôt de plainte.

**E2 – Décision d'Engagement :** Niveau minimal : décision seule. Périmètre : identifier l'origine de la facture et le responsable du paiement. Délai : 3 semaines. Budget : temps personnel + consultation avocat (2h). Pas de mandat formel, mais décision documentée dans un email à elle-même (traçabilité).

**E3 – Planification :**

1. Rassembler tous documents (facture, relevés, contrats, correspondances) ;
2. Interroger ses employés (comptable, assistante administrative) ;
3. Rechercher informations sur CONSULTING-PRO (KBIS, site web) ;
4. Consulter avocat pour aspects juridiques.

**QG1 :** Auto-évaluation VERT. Progression Phase 2.

**Phase 2 : Acquisition**

**E4 – Collecte :** Niveau standard : facture CP-2025-089 (scan haute résolution, horodaté) ; relevé bancaire ; extrait KBIS de CONSULTING-PRO ; tous emails mentionnant « CONSULTING-PRO » ; registre courrier (pas de mention) ; contrats 2024–2025 (aucun avec CONSULTING-PRO). Numérotation : EP001 à EP008.

**E5 – Sécurisation :** 3 copies : disque dur externe chiffré (BitLocker), cloud personnel sécurisé (ProtonDrive), copie papier en coffre. Hash SHA-256 calculé et conservé séparément pour chaque fichier numérique. Règle : jamais travailler sur originaux papier.

**E6 – Parties Prenantes :** Sophie LEMOINE (comptable, a enregistré la facture) ; Julie MARTIN (assistante administrative) ; Marc DUBOIS (gérant CONSULTING-PRO selon KBIS) ; Me Paul BERNARD (avocat conseil).

**QG2 :** 8 éléments numérotés ; 3 copies ; hash calculés ; journal d'accès manuscrit. VERT. Progression Phase 3.

**Phase 3 : Investigation**

**E7 – Interrogatoires :** Sophie LEMOINE (12 mars, 14h) : déclare avoir reçu la facture par email le 1er mars ; semblait régulière, tamponnée « bon à payer » ; ne connaît pas CONSULTING-PRO ; fournit l'email de réception (`contact@consulting-pro.fr`). Julie MARTIN (13 mars) : aucune trace. Comptes rendus signés.

**E8 – Hypothèses :**

- **H1** : Erreur administrative, facture légitime oubliée ;
- **H2** : Fraude externe, CONSULTING-PRO frauduleuse ;
- **H3** : Complicité interne, Sophie complice ;
- **H4** : Usurpation d'identité entreprise ;
- **H5** : Erreur de destinataire (facture destinée à homonyme).

**E9 – Confrontation :** H1 réfutée (gestion rigoureuse, aucun contrat) ; H2 cohérente (KBIS : création 15 janvier 2025, très récent, suspect) ; H3 peu cohérente (Sophie sincère,

5 ans ancienneté, pas d'indice financier) ; H4 possible mais sans preuve ; H5 réfutée (facture mentionne INNOV-TECH avec SIRET correct). Score : H2 dominant.

**E9bis – Falsification :** Pour H2 : si prestation réellement effectuée, il devrait exister : contrat signé, correspondances préalables, livrables. Recherche approfondie : rien trouvé. H2 renforcée.

**E10 – Validation :** Consultation de Me BERNARD (avocat) : confirme indices sérieux de fraude ; recommande dépôt de plainte.

**QG3 :** 5 hypothèses générées ; matrice complétée ; falsification effectuée ; validation externe (avocat). VERT.

**Phase 4 : Formalisation**

**E11–E12 – Rapport :** Dossier simple (15 pages) : synthèse (facture suspecte, aucune prestation commandée, indices de fraude externe) ; chronologie ; copies EP001–EP008 ; comptes rendus d'entretiens ; conclusion : fraude externe présumée (H2). Transmission : avocat (chiffré) + commissariat (copie papier).

**Phase 5 :** Maintien du dossier pour enquête policière éventuelle. Documentation de toutes les suites.

### 6.7.3 Application : Contexte entreprise (niveau avancé)

Le 16 mars, Madame ROUSSEAU alerte son conseil d'administration. Décision collégiale : audit interne approfondi. Mandat formel signé par le Président du CA. Équipe : Jean DUPUIS (Dir. Financier, lead) + Marie LECLERC (DRH) + Me Sophie MOREAU (Avocate). Budget : 15 000. Délai : 6 semaines.

**Phase 2 – Niveau avancé :** Image forensique du serveur de messagerie (période janvier–mars 2025) ; extraction logs accès ERP comptable ; OSINT sur CONSULTING-PRO (révèle antécédents judiciaires de Marc DUBOIS : escroquerie 2019) ; présence huissier pour constat de l'email suspect ; hash SHA-512 sur toutes images forensiques ; blockchain privée pour horodatage immuable.

**Phase 3 – Niveau avancé :** Expertise IT sur l'email révèle : spoofing (falsification de l'adresse expéditeur) ; headers techniques montrent origine depuis serveur russe ; PDF de la facture créé avec logiciel de retouche. Processus ACH formalisé : 7 hypothèses, matrice quantitative bayésienne, tests de falsification systématiques. Conclusion : H2 confirmée avec probabilité $> 95\%$. Red Team interne : consensus 100%.

**Phase 4 :** Rapport 85 pages en 3 volumes ; présentation orale au CA ; archivage légal 10 ans.

### 6.7.4 Application : Contexte judiciaire (niveau avancé systématique)

Le 1er avril 2025, le juge d'instruction désigne Madame Isabelle FONTAINE, expert judiciaire, pour répondre à deux questions : (1) la facture correspond-elle à une prestation réelle ? (2) quelle est son origine ?

**Phase 1 :** Vérification d'absence de conflit d'intérêt ; serment prêté. Mandat conforme : ordonnance ; méthodologie : **[ISO 27037]** pour forensique, principes CNCEJ pour

expertise judiciaire ; délai : 4 mois.

**Phase 2 :** Collecte contradictoire en présence des parties, avec greffier. Saisie contradictoire du serveur messagerie INNOV-TECH (15 avril) ; convocation de Marc DUBOIS (22 avril) : refuse de produire tout document ; scellés judiciaires ; hash SHA-512 certifié par l'expert.

**Phase 3 :** ACH formalisée avec documentation exhaustive ; conclusion : H2 (fraude externe par phishing/spoofing) probabilité $> 98\%$ ; peer review par confrère expert.

**Phase 4 :** Rapport d'expertise judiciaire (65 pages, normes CNCEJ) : réponses aux questions du juge :

- *Q1 – La facture correspond-elle à une prestation réelle ?* **R : Non. Aucun élément probatoire ne démontre qu'une prestation ait été effectuée.**
- *Q2 – Origine de la facture ?* **R : Émission frauduleuse par CONSULTING-PRO via techniques de phishing/spoofing.**

Dépôt au greffe le 25 juillet ; archivage 30 ans.

**Phase 5 :** Contre-expertise privée de CONSULTING-PRO (prétend prestation orale) : réfutée par l'expert (une prestation de 47k ne peut être exclusivement orale). Condamnation pénale de Marc DUBOIS (escroquerie).

### 6.7.5 Synthèse comparative des trois contextes

| Dimension | Particulier | Entreprise | Judiciaire |
|---|---|---|---|
| Niveau rigueur | Minimal/Standard | Standard/Avancé | Avancé systématique |
| Durée | 3 semaines | 6 semaines | 4 mois |
| Ressources | 1 personne + avocat (2h) | Équipe 3 + outils forensiques | Expert + consultant IT |
| Coût estimé | 500 (avocat) | 15 000 | 8 000 (honoraires) |
| Validation | Avocat | Red Team interne | Peer review + juge |
| Livrable | Dossier 15p + plainte | Rapport 85p (3 vol.) | Rapport expertise 65p (CNCEJ) |
| Force probante | Moyenne | Élevée (interne) | Maximale (judiciaire) |

*Tableau 6.1. Comparaison des trois applications contextuelles du PIU*

## 6.8 Recommandations d'Usage et Domaines d'Application

### 6.8.1 Principe fondamental

La qualité d'une investigation se mesure moins à la rapidité avec laquelle on parvient à des conclusions qu'à la robustesse avec laquelle ces conclusions résistent à la contestation contradictoire. Le PIU, par sa structure formelle intégrant falsification active, validation multi-méthodes et Quality Gates, vise cet objectif de défendabilité maximale.

### 6.8.2 Sélection du niveau de rigueur

Le praticien doit calibrer le niveau de rigueur selon la matrice de criticité (Tableau 6.1.3). Une investigation à enjeu limité ne justifie pas systématiquement un niveau avancé (coût/bénéfice) ; une investigation à enjeu critique (pénal, financier majeur) ne peut se satisfaire d'un niveau minimal sans risquer l'invalidation ultérieure.

### 6.8.3 Domaines d'application

Bien que ce cours illustre le PIU dans un contexte de forensique numérique, la méthodologie s'applique à tout domaine investigatif :

- Investigations RH (harcèlement, discrimination) ;
- Forensique numérique (cybercriminalité, fuites de données) ;
- Investigations techniques (accidents, défaillances) ;
- Investigations scientifiques (fraude académique) ;
- Investigations journalistiques ;
- Audits de conformité réglementaire.

### 6.8.4 Documentation comme investissement

L'effort documentaire demandé à chaque étape (inventaires, matrices, journaux) peut sembler lourd mais constitue un **investissement essentiel**. En cas de contestation (Phase 5), la qualité de la documentation initiale détermine directement la capacité à défendre les conclusions, parfois plusieurs années après les faits.

**$\Gamma_{CRO}$ Analyse CRO · Confidentialité · Fiabilité · Opposabilité**

**Analyse CRO. Le PIU dans son ensemble**
Le PIU est conçu pour maximiser $\mathcal{O}$ (opposabilité) tout en maintenant $\mathcal{R}$ (fiabilité) et en gérant $\mathcal{C}$ (confidentialité).
Les Quality Gates sont les mécanismes d'assurance qualité qui garantissent que $\mathcal{R}$ et $\mathcal{O}$ ne sont pas compromises par la pression temporelle ou le biais de confirmation.
La falsification active (E9bis) est le dispositif épistémologique qui protège $\mathcal{R}$ contre les biais.
La confidentialité ($\mathcal{C}$) est gérée par les niveaux de rigueur : le niveau avancé (contexte judiciaire) exige une protection maximale des données sensibles ; le niveau minimal (contexte particulier) accepte davantage de compromis proportionnels à l'enjeu.
$\mathcal{C}$: $\sim$ gérée par niveau $\mathcal{R}$: $\uparrow\uparrow$ maximisée $\mathcal{O}$: $\uparrow\uparrow$ objectif principal

**★ À retenir**

**Ce qu'il faut retenir de ce chapitre :**

- Le **PIU** est un processus modulaire en **5 phases, 17 étapes et 3 Quality Gates** : Initialisation (E1–E3) → Acquisition (E4–E6) → Investigation (E7–E10) → Formalisation (E11–E13) → Suivi (E14–E17).
- La **matrice de criticité** calibre le niveau de rigueur (minimal / standard / avancé) selon l'enjeu financier, pénal, technique, le nombre de parties et la durée.
- Les **Quality Gates** (QG1 : pré-opérationnel ; QG2 : intégrité probatoire ; QG3 : robustesse analytique) sont des points de contrôle obligatoires à trois niveaux : VERT (progression) / ORANGE (conditionnel) / ROUGE (suspension).
- La **boucle itérative** entre Phase 2 et Phase 3 est normale : 2 à 3 passages est satisfaisant ; un passage direct suggère un manque d'approfondissement.
- La **falsification active** (E9bis) – principe poppérien – est la protection contre le biais de confirmation. Chercher à réfuter ses hypothèses, pas à les confirmer.
- L'**affaire ROUSSEAU** illustre que le *même* fait (fraude externe H2 à 47 850) est atteint par trois niveaux de rigueur, mais avec une force probante radicalement différente : suffisante pour une plainte, élevée pour une décision interne, maximale pour une condamnation pénale.

**✍ Exercice 6.1. Matrice de criticité ★☆☆**

Pour chacune des investigations suivantes, déterminez le niveau de rigueur approprié (minimal / standard / avancé) en justifiant votre réponse par la matrice de criticité :

(a) Soupçon de fraude interne de 450 000 FCFA dans une administration publique camerounaise ; suspect unique ; durée estimée : 2 mois.

(b) Recherche de documents compromettants sur le PC d'un employé licencié pour harcèlement moral ; aucune plainte déposée ; enjeu : décision de licenciement interne.

(c) Investigation mandatée par le procureur sur une attaque ransomware ayant paralysé un hôpital pendant 72h ; données patients exposées ; plusieurs suspects identifiés dans 3 pays.

**✍ Exercice 6.2. Application du PIU ★★☆**

Vous êtes mandaté par la direction de TRANSBOIS SA (affaire MVOM, Chapitre 3) pour conduire l'investigation interne sur l'attaque ransomware. Appliquez les étapes E1 à E6 :

(a) Rédigez la *Fiche d'Évaluation Initiale* (E1) : enjeux, risques, faisabilité.

(b) Définissez le périmètre d'investigation (E2) et justifiez le niveau de rigueur choisi.

(c) Listez les 8 premières sources à collecter (E4) en les classant par ordre de volatilité ; précisez la méthode de collecte pour chacune.

(d) Quels critères QG2 risquent d'être difficiles à satisfaire dans ce contexte ? Proposez comment les atteindre.

### ✍ Exercice 6.3. Falsification active ★★★

Dans l'investigation ROUSSEAU (contexte entreprise), l'hypothèse H2 (fraude externe par phishing/spoofing) a été retenue avec une probabilité $> 95\%$.

(a) Identifiez 4 observations critiques qui, si trouvées, auraient définitivement réfuté H2 (conditions de falsification).

(b) Comment calculer l'indice de robustesse de H2 ? Quel score attribuez-vous à cette hypothèse ?

(c) Formulez l'analyse CRO de la décision d'inclure dans le rapport l'analyse forensique des en-têtes email (révèle l'origine depuis un serveur russe, potentiellement sensible géopolitiquement).

(d) Dans quel cas aurait-il fallu activer le niveau ROUGE au QG3 ? Quelles étapes de retour auraient été nécessaires ?

### ● Note

**Bibliographie recommandée pour ce chapitre :**

- **[ISO/IEC 27037:2012]** : Guidelines for identification, collection, acquisition and preservation of digital evidence.
- **[NIST SP 800-86]** [29] : Guide to Integrating Forensic Techniques into Incident Response, 2006.
- Heuer, R. J., *Psychology of Intelligence Analysis*, CIA, 1999 (méthode ACH). [14]
- Popper, K., *La logique de la découverte scientifique*, Payot, 1973. [33]
- ACPO, *Good Practice Guide for Digital Evidence*, 2012.

**Transition.** Le Chapitre 7 compare le PIU aux standards internationaux (SANS FOR508, NIST, DFRWS [31], ACPO) pour en montrer la cohérence et les spécificités. Les Chapitres 8 et 9 approfondissent respectivement la chaîne de custody et les outils d'acquisition, deux dimensions essentielles de la Phase 2.

7

# MÉTHODOLOGIES ET STANDARDS INTERNATIONAUX

« Digital forensics is not just about recovering data, it's about understanding the context in which the data existed. »

Joshua I. James

**Niveau :** *Fondamental* • Lecture du Chapitre 6 (PIU) recommandée : ce chapitre positionne les standards internationaux par rapport au PIU et démontre leur cohérence.

**✦ Objectifs du chapitre**

- ➢ Maîtriser les cinq standards forensiques mondiaux de référence : DFRWS [31], ISO/IEC 27037 [18]/41/42/43, NIST SP 800-86 [29], RFC 3227 [5], ACPO [3].
- ➢ Comprendre la logique des standards : pourquoi ils existent, ce qu'ils imposent, et ce qu'ils laissent libre.
- ➢ Mettre en correspondance chaque standard avec les phases du PIU pour montrer leur cohérence structurelle.
- ➢ Appliquer le framework d'analyse **DICES** pour comparer les méthodologies mondiales.
- ➢ Identifier les équivalences entre standards internationaux et droit camerounais (**Loi 2010/012** [34], **Loi 2024/017** [36]).
- ➢ Choisir le standard adapté à une investigation selon son contexte.

## Standards et PIU : une relation de complémentarité

Le Processus Investigatif Universel (PIU) présenté au Chapitre 6 est un cadre général adaptatif. Les standards internationaux qui font l'objet de ce chapitre sont ses fondements normatifs : ils précisent *comment* chaque phase doit être conduite pour être reconnue par les juridictions et institutions du monde entier. La relation n'est pas de concurrence mais de complémentarité : le PIU structure, les standards légitiment.

## 7.1 Architecture des Standards Forensiques : vue d'ensemble

### 7.1.1 Pourquoi des standards ?

Sans standards communs, deux investigateurs de deux pays différents peuvent analyser la même preuve avec des méthodes incompatibles et produire des conclusions qui se contredisent sans qu'aucune expertise externe ne puisse trancher. Les standards résolvent trois problèmes fondamentaux :

1. **Interopérabilité** : les preuves collectées selon ISO 27037 au Cameroun sont recevables dans un tribunal belge ou canadien ;
2. **Opposabilité** : un expert qui documente sa conformité à NIST SP 800-86 peut répondre à n'importe quelle attaque méthodologique ;
3. **Formation** : les standards constituent une base d'apprentissage commune pour les investigateurs du monde entier.

### 7.1.2 Cartographie des standards

| Standard | Organisme | Domaine | Contribution principale |
|---|---|---|---|
| DFRWS 2001 | DFRWS | Processus global | Premier modèle formel : 6 phases |
| **[ISO/IEC 27037]** | ISO/IEC | Collecte | Rôles DEFR/DES, identification et acquisition |
| **[ISO/IEC 27041]** [19] | ISO/IEC | Méthodes | Validation des méthodes d'investigation |
| **[ISO/IEC 27042]** [20] | ISO/IEC | Analyse | Analyse et interprétation des preuves |
| **[ISO/IEC 27043]** [21] | ISO/IEC | Processus complet | Principes et processus intégrés |
| **[NIST SP 800-86]** | NIST (USA) | IR + Forensique | Intégration réponse aux incidents |
| **[RFC 3227]** | IETF | Volatilité | Ordre de collecte, bonnes pratiques |
| ACPO Guide | ACPO (UK) | Déontologie | 4 principes, responsabilité légale |
| SANS FOR508 | SANS Institute | IR avancée | Forensique entreprise, threat hunting |

*Tableau 7.1. Cartographie des standards forensiques*

### 7.1.3 Correspondance standards / phases PIU

| Standard | Ph.1 | | | |
|---|---|---|---|---|
| Init. | | | | |
| Acquis. | | | | |
| Analyt. | | | | |
| Form. | | | | |
| [ISO/IEC 27037] | • | ••• | | |
| [ISO/IEC 27041] | | • | •• | |
| [ISO/IEC 27042] | | | ••• | |
| [ISO/IEC 27043] | • | • | • | • |
| [NIST SP 800-86] | • | •• | •• | • |
| [RFC 3227] | | ••• | | |
| ACPO Guide | • | •• | • | • |
| SANS FOR508 | •• | • | •• | • |

*Tableau 7.2. Correspondance standards / phases PIU : • pertinent ; •• central ; ••• définitoire*

## 7.2 DFRWS : la Fondation Conceptuelle (2001)

Le **Digital Forensics Research Workshop** publie en 2001 le premier cadre formel de forensique numérique. Son importance est fondatrice : il établit un vocabulaire commun et une séquence logique que tous les standards suivants reprendront et affineront.

### 7.2.1 Les six phases DFRWS

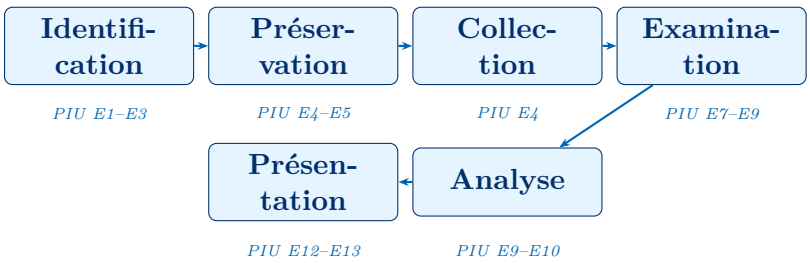



Figure 7.1: Les 6 phases DFRWS et leurs correspondances avec le PIU

**Définition**

**Identification** : reconnaître l'existence d'un incident numérique et en définir le périmètre. **Préservation** : protéger les preuves de toute altération, phase la plus critique, car une erreur ici est irréparable. **Collection** : acquérir les preuves selon des méthodes documentées. **Examination** : extraire les informations pertinentes. **Analyse** : corréler et reconstruire les événements. **Presentation** : communiquer les conclusions de façon défendable.

### 7.2.2 Limite historique du DFRWS et apport du PIU

Le modèle DFRWS est **linéaire**. En pratique, la Phase 3 (*Collection*) et la Phase 4 (*Examination*) s'entrelacent : chaque artefact découvert lors de l'examen peut déclencher une nouvelle collecte. Le PIU formalise cette réalité avec la boucle itérative E4–E6 ↔ E7–E10. Le DFRWS reste la référence conceptuelle ; le PIU est l'implémentation opérationnelle.

## 7.3 La Suite ISO/IEC 2703x : le Standard International de Référence

### 7.3.1 Architecture de la famille

La famille ISO/IEC 2703x constitue l'architecture normative la plus complète et la plus internationalement reconnue pour la forensique numérique. Ses quatre normes couvrent l'intégralité du cycle de vie des preuves numériques.

### 7.3.2 ISO/IEC 27037:2012. Identification, Collecte et Préservation

[ISO/IEC 27037:2012]. *Guidelines for identification, collection, acquisition and preservation of digital evidence*, est **le standard le plus important pour le travail de terrain**. Son apport central est la définition de deux rôles distincts et de quatre principes fondamentaux.

*Les deux rôles*

- **DEFR** (*Digital Evidence First Responder*) : le premier intervenant sur la scène. Son rôle est la préservation initiale. Son erreur est irréparable. C'est l'OPJ qui arrive le premier dans l'affaire MBONGO.
- **DES** (*Digital Evidence Specialist*) : l'analyste en laboratoire. Il reçoit les preuves préservées par le DEFR et conduit l'examination et l'analysis.

*Les quatre principes ISO 27037*

1. **Pertinence** : la collecte doit être ciblée et justifiée. Ne collecter que ce qui est pertinent pour l'investigation.
2. **Fiabilité** : les méthodes utilisées doivent être reproductibles et vérifiables.
3. **Suffisance** : la collecte doit être exhaustive dans le périmètre défini. Pas de lacunes qui permettraient de contester la représentativité de la base probatoire.
4. **Documentation** : traçabilité complète de chaque action.

*Procédure de saisie selon ISO 27037*

```
# Étape 1 : Identification préliminaire
# Type de dispositif, état (allumé/éteint), connexions actives
# -> Appliquer l'ordre de volatilité RFC 3227 (cf. section suivante)

# Étape 2 : Documentation photographique
# Photos du contexte avant toute manipulation
```

```
# Horodatage visible (montre + journal de bord)

# Étape 3 : Isolation du dispositif
# Mobile : mode avion ou sac de Faraday
# PC allumé : capturer RAM avant isolation réseau

# Étape 4 : Acquisition (write-blocker obligatoire)
# FTK Imager : File -> Create Disk Image -> Format E01
# Vérifier que le write-blocker est actif avant montage

# Étape 5 : Vérification d'intégrité (hash SHA-256 minimum)
sha256sum /dev/sdb > hash_source.txt   # Linux
certutil -hashfile image.E01 SHA256    # Windows
# Conserver les deux hash dans le formulaire custody

# Étape 6 : Scellement et transport
# Sachet inviolable, étiquette, formulaire custody signé
```

Listing 7.1: Checklist de saisie ISO 27037, séquence minimale

**⚖ Jurisprudence & Droit applicable**

**Compatibilité ISO/IEC 27037 et droit camerounais :**
Les articles 52–59 de la **Loi 2010/012** imposent : présence des parties, copie réalisée en leur présence, documentation. Ces exigences sont **substantiellement alignées** sur ISO/IEC 27037. Un investigateur respectant le standard international respecte de facto le droit camerounais. Inversement, une investigation conforme aux articles 52–59 satisfait aux critères DEFR d'ISO/IEC 27037.

### 7.3.3 ISO/IEC 27041:2015. Validation des Méthodes

[ISO/IEC 27041:2015]. *Guidance on assuring suitability and adequacy of incident investigative method*, répond à la question : *comment s'assurer qu'une méthode d'investigation est scientifiquement valide ?* Ce standard est particulièrement important pour l'opposabilité : il fournit le cadre pour justifier le choix d'un outil ou d'une technique devant un tribunal.

Quatre domaines de méthodes validées :

- **Live Forensics** : investigation sur système en cours d'exécution ; méthode conforme à RFC 3227.
- **Dead Forensics** : investigation sur système éteint ; méthode conforme à NIST SP 800-86.
- **Network Forensics** : capture et analyse de trafic ; standards IETF (RFC 3227).
- **Mobile Forensics** : quatre niveaux d'acquisition ; NIST SP 800-101 [30]r1.

### 7.3.4 ISO/IEC 27042:2015. Analyse et Interprétation

[ISO/IEC 27042:2015]. *Guidelines for the analysis and interpretation of digital evidence*, est le standard de la Phase 3 du PIU. Son apport clé est la formalisation de la séquence d'analyse :

1. **Préparation** : environnement d'analyse isolé, outils validés et versionnés.
2. **Extraction** : récupération des données depuis les images forensiques.
3. **Analyse** : application des techniques appropriées.
4. **Interprétation** : contextualisation ; c'est ici que la distinction constatation/interprétation s'applique.
5. **Rapport** : documentation rigoureuse des découvertes, des méthodes utilisées et des limitations.

ISO 27042 renforce ce que le PIU appelle E9bis (falsification active) : le standard impose de **tester les conclusions alternatives avant de les rejeter**, pas simplement de choisir l'explication la plus probable.

### 7.3.5 ISO/IEC 27043:2015. Principes et Processus Intégrés

[ISO/IEC 27043:2015] est le standard de niveau le plus élevé : il intègre les trois précédents dans un processus complet incluant la **readiness** (préparation pré-incident) et la gestion post-investigation. Sa représentation canonique :

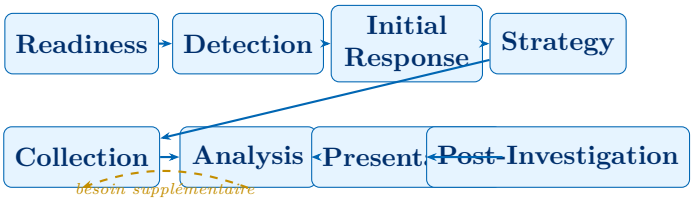



Figure 7.2: Processus ISO/IEC 27043 : 8 phases avec boucle retour

## 7.4 NIST SP 800-86 : Forensique et Réponse aux Incidents

[NIST SP 800-86]. *Guide to Integrating Forensic Techniques into Incident Response*, est la référence américaine. Sa contribution distinctive par rapport aux normes ISO est l'**intégration de la forensique dans la réponse aux incidents** : le NIST ne traite pas la forensique comme une activité autonome mais comme une composante de la gestion des incidents de sécurité.

### 7.4.1 Les quatre phases NIST

| Phase NIST | Activités | Correspondance PIU |
|---|---|---|
| Collection | Priorisation des données ; préservation ; chaîne de custody | E4–E5 (Acquisition) |
| Examination | Extraction des données ; revue manuelle ; analyse automatisée | E7–E8 (Investigation) |
| Analysis | Reconstruction de la chronologie ; corrélation ; attribution | E9–E10 (Investigation analytique) |
| Reporting | Synthèse exécutive ; détails techniques ; recommandations | E11–E12 (Formalisation) |

*Tableau 7.3. Phases NIST SP 800-86 et correspondances PIU*

### 7.4.2 Distinction Examination / Analysis : règle d'or du rapport

La contribution épistémologique la plus importante du NIST SP 800-86 est la séparation stricte entre :

- **Examination** : documenter ce qu'on *trouve*. Résultats factuels, vérifiables, non ambigus. *Exemple :* « Le fichier `enc_all.ps1` est présent dans `%TEMP%` avec un horodatage de création le 12/03/2026 à 02h17. »
- **Analysis** : interpréter ce que cela *signifie*. Conclusions raisonnées, avec niveau de certitude explicite. *Exemple :* « La présence de ce script à cet horodatage, corrélée avec la connexion RDP de 02h14, indique *avec une haute confiance* que le script a été déposé par l'attaquant lors de sa connexion. »

**★ Attention**

**Un avocat peut attaquer une interprétation ; il ne peut pas attaquer un hash qui correspond.** Séparer strictement les deux types d'énoncés dans le rapport est la protection la plus efficace contre les attaques méthodologiques en contre-interrogatoire.

## 7.5 RFC 3227 : l'Ordre de Volatilité

La RFC 3227 (*Guidelines for Evidence Collection and Archiving*, Brezinski & Killalea, 2002) est la référence technique pour l'ordre de collecte sur les systèmes en cours d'exécution. Elle complète ISO 27037 en précisant la **priorité de collecte selon la volatilité des données**.

### 7.5.1 L'ordre de volatilité canonique

| Rang | Type de données | Durée de vie et outil |
|---|---|---|
| 1 | Registres CPU, cache | Nanosecondes ; non capturable en pratique |
| 2 | Mémoire système (RAM) | Jusqu'à extinction ; FTK Imager Portable (`Capture Memory`) |
| 3 | État réseau (tables de routage, ARP, connexions) | Secondes à minutes ; `netstat -ano`, `arp -a` |
| 4 | Processus en cours d'exécution | Minutes ; `tasklist` (Windows) ou `ps aux` (Linux) |
| 5 | Fichiers temporaires, logs actifs | Heures ; `dir /T` ou `ls -lt /tmp` |
| 6 | Disque dur (système de fichiers) | Mois à années ; FTK Imager (image E01 avec hash) |
| 7 | Logs système distants | Jours à semaines selon rotation ; réquisition opérateur |
| 8 | Configuration physique, topologie réseau | Stables ; documentés en dernier |

*Tableau 7.4. Ordre de volatilité RFC 3227* avec outils de collecte

**Application OPJ/Expert Judiciaire**

**Application OPJ : règle mnémotechnique RFC 3227**
**Sur un système allumé : RAM avant disque, réseau avant fichiers.**
Arrivée sur la scène : (1) capturer la mémoire RAM en premier (2 *RAM*) ; (2) documenter les connexions réseau (3 *Réseau*) ; (3) lister les processus actifs (4 *Processus*) ; (4) éteindre proprement ; (5) acquérir le disque avec write blocker (6 *Disque*).
Sur un système éteint : passer directement à l'étape (5). Ne jamais allumer un système éteint sans write blocker actif.

## 7.6 Les Quatre Principes ACPO : Responsabilité et Déontologie

Le guide ACPO (*Association of Chief Police Officers*, Royaume-Uni, 2012) est la référence déontologique mondiale pour les forces de l'ordre. Son importance tient à sa simplicité : quatre principes mémorables qui encadrent toute l'activité forensique policière.

| Principe | Formulation et implications |
|---|---|
| **Principe 1** | **Aucune action ne doit modifier les données.** Toute opération de collecte doit laisser les données originales intactes. Fondement du write blocker, du calcul de hash et du travail sur copies. |
| **Principe 2** | **Si une modification est nécessaire, elle requiert la compétence technique et doit être documentée.** Un OPJ non formé ne doit pas procéder à l'acquisition : il appellera un spécialiste. Toute modification est explicitement justifiée. |
| **Principe 3** | **Un audit trail complet doit être maintenu.** Chaque action, chaque accès, chaque transfert est documenté. C'est la traduction procédurale de la chaîne de custody. |
| **Principe 4** | **Le responsable de l'investigation est responsable de la conformité.** L'investigateur en chef endosse personnellement la responsabilité du respect de ces principes pour l'ensemble de l'équipe. |

*Tableau 7.5. Les quatre principes ACPO*

$\Gamma_{CRO}$ **Analyse CRO · Confidentialité · Fiabilité · Opposabilité**

**Analyse CRO. Principes ACPO**

Les principes ACPO maximisent $\mathcal{R}$ et $\mathcal{O}$ au détriment partiel de la flexibilité opérationnelle : ils imposent une rigueur absolue même dans les situations d'urgence. Cette tension est délibérée : dans le contexte policier, la $\mathcal{O}$ doit primer pour que les preuves collectées mènent à des condamnations incontestables.

Le Principe 4 (responsabilité personnelle) est la réponse institutionnelle au problème d'attribution : quand la chaîne est violée, il doit être possible d'identifier précisément qui est responsable.

$\mathcal{C}$: $\sim$ $\mathcal{R}$: $\uparrow\uparrow$ $\mathcal{O}$: $\uparrow\uparrow$

## 7.7 SANS FOR508 : Forensique d'Entreprise et Threat Hunting

Le cours [SANS FOR508] (*Advanced Incident Response, Threat Hunting, and Digital Forensics*) représente l'état de l'art de la forensique d'entreprise. Contrairement aux normes ISO qui s'appliquent à tous les contextes, FOR508 cible spécifiquement les investigations à grande échelle sur des réseaux d'entreprise compromis.

### 7.7.1 La méthodologie en six phases

1. **Preparation** : plan de réponse aux incidents, validation des outils, formation de l'équipe ;
2. **Identification** : développement des IoC (*Indicators of Compromise*), intégration de la Threat Intelligence, détection d'anomalies ;

3. **Containment** : isolation à court terme, planification de l'éradication, préservation des preuves ;
4. **Eradication** : suppression du malware, correction des vulnérabilités, durcissement des systèmes ;
5. **Recovery** : restauration des systèmes, surveillance renforcée, tests de validation ;
6. **Lessons Learned** : revue post-incident, amélioration des processus, mise à jour de la documentation.

### 7.7.2 Apports distinctifs de FOR508 en 2025

➢ **Forensique mémoire avec Volatility 3** : syntaxe mise à jour (`python3 vol.py -f mem.dmp windows.pslist`), nouveaux plugins pour artefacts modernes.

➢ **EDR Forensics** : exploitation des journaux produits par les outils de détection/-réponse sur les endpoints (CrowdStrike, SentinelOne) ; souvent plus complets que les logs Windows natifs.

➢ **Enterprise-scale IR** : investigation simultanée sur des centaines de machines avec des outils comme Velociraptor ou KAPE.

➢ **Threat Hunting** : recherche proactive de compromissions latentes *avant* qu'une alerte soit déclenchée.

**SANS FOR508 vs ISO 27037 : quelle différence ?**

ISO 27037 est un standard *normatif* : il définit ce que vous devez faire. SANS FOR508 est un cours *opérationnel* : il vous apprend à le faire. FOR508 va beaucoup plus loin dans les techniques spécifiques ; ISO 27037 a une portée légale internationale. En pratique, un bon investigateur maîtrise les deux : la légitimité normative (ISO) et les techniques avancées (SANS).

## 7.8 Analyse Comparative : le Framework DICES Appliqué

### 7.8.1 Grille comparative DICES des standards

Chaque standard peut être analysé selon les cinq axes DICES (**D**octrine, **I**nfrastructure, **C**apacités, **E**cosystème, **S**tratégie) :

| Standard | Doctrine | Public cible | Portée légale | Spécialité forensique |
|---|---|---|---|---|
| [ISO/IEC 27037] | Collecte terrain | DEFR / DES | Internationale | Acquisition et préservation |
| [ISO/IEC 27042] | Analyse | DES | Internationale | Analyse et interprétation |
| [ISO/IEC 27043] | Processus global | Toute équipe | Internationale | Cycle de vie complet |
| [NIST SP 800-86] | IR intégrée | CISO, équipe SOC | USA + adopté monde | IR + forensique |
| [RFC 3227] | Volatilité | Tout OPJ | Universelle | Ordre de collecte |
| ACPO Guide | Déontologie | Forces de l'ordre | Nationale + influence | Principes éthiques |
| SANS FOR508 | Technique avancée | Senior analyste | Formation privée | Forensique entreprise |

*Tableau 7.6. Analyse DICES comparative des standards*

### 7.8.2 Quel standard pour quelle situation ?

| Situation | Standard(s) prioritaire(s) |
|---|---|
| OPJ arrive sur une scène, matériel allumé | RFC 3227 (ordre de collecte) + ISO 27037 (procédure) |
| Analyse d'une image forensique en laboratoire | ISO 27041 (méthode) + ISO 27042 (analyse) |
| Investigation d'un incident ransomware en entreprise | NIST SP 800-86 + SANS FOR508 |
| Expert judiciaire devant un tribunal | ISO 27037 + ACPO Principe 3 + NIST SP 800-86 (rapport) |
| Investigation impliquant un État partenaire Budapest | ISO 27043 + Convention Budapest art. 29 (conservation) |
| Formation d'un OPJ camerounais niveau débutant | ACPO 4 principes + RFC 3227 (ordre volatilité) |

*Tableau 7.7. Sélection du standard selon la situation*

## 7.9 Standards Émergents : Cloud, IoT et Post-Quantique

### 7.9.1 Forensique cloud

- [ISO/IEC 27050] [23] : *Electronic Discovery* ; collecte de données électroniques pour procédures légales, incluant les environnements cloud.
- [NIST SP 800-210] [15] : Cloud forensics challenges ; gestion des défis multitenancy, éphéméralité et multi-juridiction.

➢ **CSA Guidelines** : Cloud Security Alliance, bonnes pratiques d'investigation dans les environnements cloud.

### 7.9.2 Forensique IoT

➢ **[IEEE P2933]** : Trusted IoT Data ; authenticité et intégrité des données produites par des objets connectés.

➢ **[ETSI TR 103 939]** : IoT testing methodology.

➢ **[ISO/IEC 30141]** [22] : IoT reference architecture ; utile pour comprendre où trouver les données forensiques.

### 7.9.3 Post-quantique et authenticité des preuves

Le NIST a publié en 2024 les premiers standards post-quantiques de signature : **[CRYSTALS-Dilithium]** (FIPS 204) et **[SPHINCS+]** (FIPS 205) ; **[FALCON]** est encore en cours de normalisation. Ces algorithmes remplaceront à terme ECDSA et RSA pour la signature cryptographique des preuves numériques. L'enjeu forensique : les preuves signées aujourd'hui avec ECDSA seront potentiellement cassables dans 10–15 ans. Pour les affaires à longue durée (*e.g.* terrorisme), la migration vers les algorithmes post-quantiques est déjà une obligation éthique.

**$\Gamma_{CRO}$ Analyse CRO · Confidentialité · Fiabilité · Opposabilité**

**Analyse CRO. Standards et choix méthodologique**
Le choix d'un standard n'est pas neutre vis-à-vis du Trilemme CRO :
$\mathcal{R}$ (Fiabilité) est maximisée par les standards techniques : RFC 3227 (ordre de collecte), ISO 27037 (hash), ISO 27042 (méthodes validées).
$\mathcal{O}$ (Opposabilité) est maximisée par les standards à portée légale : ISO 27037 et ACPO sont reconnus par les tribunaux du monde entier ; NIST SP 800-86 est reconnu aux USA et dans de nombreux pays.
$\mathcal{C}$ (Confidentialité) est gérée par les standards procéduraux : ACPO Principe 1 (ne pas modifier) protège les données des parties ; ISO 27041 (proportionnalité de la collecte) évite la sur-collecte.
$\mathcal{C}$: ↑ ACPO Pr.1 $\mathcal{R}$: ↑↑ ISO 27037/42 $\mathcal{O}$: ↑↑ ISO 27037/ACPO

❍

**★ À retenir**

**Ce qu'il faut retenir de ce chapitre :**

➢ Les standards forensiques résolvent trois problèmes : **interopérabilité** (preuves recevables partout), **opposabilité** (méthode défendable) et **formation** (base commune).

- **Pour le terrain :** RFC 3227 (ordre de volatilité : RAM → réseau → processus → disque) et ISO 27037 (procédure de saisie, rôles DEFR/DES, hash SHA-256 minimum).
- **Pour l'analyse :** ISO 27042 impose la séquence Préparation → Extraction → Analyse → Interprétation → Rapport ; la distinction Examination/Analysis (NIST SP 800-86) est la règle d'or du rapport forensique.
- **Pour la déontologie :** ACPO 4 principes – (1) ne pas modifier ; (2) compétence si modification ; (3) audit trail ; (4) responsabilité personnelle.
- **En droit camerounais :** ISO 27037 est **substantiellement aligné** sur les articles 52–59 de la **Loi 2010/012**. La conformité à l'un implique la conformité à l'autre.
- **Choix situationnel :** terrain → RFC 3227 + ISO 27037 ; laboratoire → ISO 27041 + ISO 27042 ; entreprise → NIST + SANS ; tribunal → ISO 27037 + ACPO ; transfrontalier → Budapest art. 29.

### ✍ Exercice 7.1. Sélection de standard ★☆☆

Pour chacune des situations suivantes, identifiez le(s) standard(s) à appliquer en priorité et justifiez votre choix :

(a) Un OPJ camerounais arrive chez un suspect ; l'ordinateur est allumé, et un téléphone Android est posé sur le bureau en mode déverrouillé.

(b) Un analyste forensique doit déterminer si les 15 000 emails collectés dans une affaire de fraude ont été altérés depuis leur collecte.

(c) Une PME camerounaise victime d'un ransomware demande une investigation complète pour identifier l'attaquant et produire un rapport pour son assurance.

(d) Un expert judiciaire doit produire un rapport opposable dans une affaire impliquant des preuves stockées sur des serveurs Google (États-Unis).

### ✍ Exercice 7.2. Application ACPO + RFC 3227 ★★☆

Vous intervenez dans l'affaire MVOM (Opération MVOM, Chapitre 3) : serveur Windows compromis par ransomware, allumé, connecté au réseau.

(a) Appliquez l'ordre de volatilité RFC 3227 à cette scène spécifique : listez les 6 premières actions dans l'ordre exact, en précisant l'outil et la commande correspondante.

(b) Pour chaque action, identifiez le principe ACPO auquel elle répond.

(c) L'analyste doit capturer la mémoire RAM (16 Go) sur un serveur en production.

Le Principe 1 ACPO dit “ne pas modifier les données” ; or la capture RAM modifie légèrement la RAM. Comment résoudre cette tension ? Quelle documentation apporter ?

(d) Rédigez l’entrée correspondante dans le formulaire de chaîne de custody (une ligne par action).

### ✍ Exercice 7.3. Analyse comparative DICES ★★★

Un responsable forensique au sein de l’ANTIC doit rédiger une *note de politique forensique* recommandant les standards à adopter officiellement au Cameroun.

(a) Sur la base de l’analyse DICES, quel standard recommandez-vous comme fondement légal principal ? Justifiez en articulant portée légale, compatibilité avec la Loi 2010/012 et facilité de formation pour les OPJ.

(b) Identifiez deux tensions CRO que la mise en œuvre de ce standard créerait dans le contexte camerounais ; proposez une résolution pour chacune.

(c) La Convention de Budapest [9] (art. 29) est complémentaire à ces standards : expliquez en quoi, et dans quel cas un OPJ camerounais l’activerait en *plus* d’ISO 27037.

### ● Note

**Transition.** Le Chapitre 8 approfondit la **chaîne de custody** : le mécanisme procédural qui traduit concrètement ISO 27037 et les principes ACPO en documents et formulaires opposables. C’est le chapitre le plus important pour l’admissibilité des preuves devant les tribunaux camerounais.

8

# CHAÎNE DE CUSTODY ET ADMISSIBILITÉ

« La chaîne de custody ne commence pas quand vous ouvrez Autopsy. Elle commence quand vous posez les yeux sur la scène de crime. »

Principe opérationnel de la forensique judiciaire

**Niveau :** *Fondamental* • Aucun prérequis technique. Ce chapitre est essentiellement procédural et juridique. Il est le plus important pour l'admissibilité des preuves devant les tribunaux camerounais.

**✦ Objectifs du chapitre**

- Définir la **chaîne de custody** et comprendre pourquoi elle est la condition fondamentale de l'admissibilité d'une preuve.
- Maîtriser le cadre légal camerounais : articles 52–59 de la **Loi 2010/012** [34] et leurs implications procédurales concrètes.
- Remplir correctement le **formulaire de chaîne de custody** pour chaque type d'evidence (PC, mobile, serveur, cloud).
- Identifier et éviter les cinq erreurs de custody les plus fréquentes qui provoquent le rejet des preuves à l'audience.
- Appliquer le protocole de custody à chaque étape : collecte, transport, stockage, transfert, analyse, présentation.
- Analyser chaque décision de custody à travers le Trilemme CRO.

## Le cas qui revient au début

Le Prologue de ce cours s'est ouvert sur l'affaire MBONGO : un dossier judiciaire complet (emails, captures d'écran, historique de navigation) anéanti en dix minutes d'audience parce que l'OPJ avait allumé le PC du suspect avant de l'acquérir. Tout le travail technique était irréprochable. La chaîne de custody était brisée.

Ce chapitre est la réponse directe à cette affaire. Il ne s'agit pas de théorie : chaque procédure décrite ici correspond à une erreur réelle qui a fait rejeter une preuve numé-

rique devant un tribunal. Lire ce chapitre, c'est apprendre à ne pas répéter ces erreurs.

❍

## 8.1 Définition et Fondements de la Chaîne de Custody

### 8.1.1 Définition formelle

**Définition**

**Chaîne de custody** (*Chain of custody, chain of evidence*). Document chronologique enregistrant chaque personne ayant eu accès à une preuve, chaque action effectuée sur cette preuve, et chaque transfert de cette preuve entre deux personnes, depuis le moment de sa collecte jusqu'à sa présentation devant la juridiction compétente. La chaîne de custody est la condition nécessaire de l'**authenticité** d'une preuve : elle permet de prouver que l'objet présenté à l'audience est bien celui qui a été saisi sur la scène de crime, sans modification.

### 8.1.2 Pourquoi la chaîne de custody prime sur l'analyse technique

Un rapport d'analyse de 100 pages, produit par les meilleurs outils du monde, avec des conclusions irréfutables sur le plan technique, perd toute valeur probatoire si on ne peut pas prouver que l'evidence analysée est bien celle saisie sur la scène de crime. Voici pourquoi :

1. **Le tribunal ne voit pas la scène de crime** : il ne peut évaluer les preuves que sur la base des documents qui lui sont soumis. Si ces documents ne prouvent pas l'intégrité de la preuve, la preuve n'existe pas juridiquement.
2. **La défense cherche la rupture** : un avocat compétent examinera systématiquement la chaîne de custody pour trouver une période non documentée, un transfert non signé, un hash non calculé. Une seule lacune peut suffire.
3. **La contamination peut être involontaire** : dans l'affaire MBONGO, l'OPJ n'avait pas l'intention de contaminer les preuves ; il ne savait simplement pas que d'allumer le PC entraînerait des modifications automatiques. L'ignorance ne protège pas.

$\Gamma_{CRO}$ **Analyse CRO · Confidentialité · Fiabilité · Opposabilité**

**Analyse CRO. La chaîne de custody**
La chaîne de custody est le mécanisme qui maximise $\mathcal{O}$ (opposabilité) en construisant une preuve que l'evidence n'a pas été altérée. Elle a un coût : $\mathcal{R}$ peut être légèrement réduite (certaines preuves volatiles se perdent pendant le temps de documentation) et $\mathcal{C}$ est engagée (la documentation révèle qui a eu accès).
Ce coût est non seulement acceptable, il est *constitutif* : une preuve dont la custody

n'est pas documentée est une preuve qui n'existe pas juridiquement, quelle que soit sa valeur technique.
$\mathcal{C}$: ↓ assumé $\mathcal{R}$: ∼ légère contrainte $\mathcal{O}$: ↑↑ maximisé

## 8.2 Cadre Légal Camerounais de la Custody

### 8.2.1 Articles 52–59 de la Loi 2010/012 : les perquisitions numériques

La **Loi 2010/012** consacre ses articles 52–59 aux perquisitions et saisies en matière de cybersécurité. Ces articles définissent le cadre légal de la collecte de preuves numériques au Cameroun. Leur maîtrise est obligatoire pour tout OPJ intervenant sur une scène numérique.

**Jurisprudence & Droit applicable**

**Article 52. Autorisation de perquisition :**

> Les officiers de police judiciaire peuvent, dans le cadre de la recherche des infractions *[...]* procéder à la perquisition des systèmes informatiques et des réseaux de communications électroniques, ainsi qu'à la saisie des données informatiques qui s'y trouvent, sur autorisation du procureur de la République ou du juge d'instruction.

**Implication opérationnelle :** toute perquisition numérique exige une autorisation préalable du procureur ou du juge. Une investigation menée sans cette autorisation produit des preuves irrecevables, quelles que soient leur qualité technique et leur pertinence.

**Jurisprudence & Droit applicable**

**Article 53, alinéa 1. Copies en présence des parties :**

> Les perquisitions *[...]* peuvent porter sur des copies réalisées en présence des personnes qui assistent à la perquisition.

**Implication opérationnelle :** l'acquisition forensique (création de l'image E01) doit être réalisée en présence du détenteur ou de son représentant. C'est la traduction légale du rôle DEFR d'ISO 27037 [18] : l'acquisition est un acte public, transparent, documenté. L'absence des parties pendant l'acquisition peut suffire à faire contester l'authenticité.

**Jurisprudence & Droit applicable**

**Article 55. Saisie des données :**

> Les données informatiques saisies sont immédiatement copiées et une

> copie est remise contre décharge au détenteur. Le support original est restitué après réalisation de la copie, sauf décision contraire du juge compétent.

**Implication opérationnelle :** en règle générale, l'OPJ acquiert une copie forensique (image E01) et restitue l'original. Il ne *saisit* l'original que sur décision judiciaire. Cela signifie que le hash de l'original doit être calculé *avant* sa restitution et conservé comme référence d'intégrité.

**⚖ Jurisprudence & Droit applicable**

**Article 57. Réquisitions aux opérateurs :**

> Les officiers de police judiciaire peuvent requérir tout opérateur de communications électroniques, tout fournisseur de services de communication au public en ligne *[...]* de lui communiquer les données techniques relatives à l'identification des numéros d'abonnement ou de connexion, les données relatives au trafic *[...]*.

**Implication opérationnelle :** les logs d'opérateur (MTN, Orange, Camtel) et les données des plateformes (Meta, Google, WhatsApp) peuvent être obtenus par réquisition judiciaire. La réponse de l'opérateur constitue une preuve numérique soumise aux mêmes règles de custody que toute autre evidence.

### 8.2.2 Tableau de correspondance : Loi 2010/012 et ISO 27037

| Article Loi 2010 | Exigence légale | Correspondance ISO 27037 |
|---|---|---|
| Art. 52 | Autorisation judiciaire préalable | QG1 du PIU (mandat validé) |
| Art. 53 al. 1 | Copie réalisée en présence des parties | DEFR : acquisition transparente et documentée |
| Art. 55 | Copie immédiate, original restitué | Hash avant restitution ; principe 3-2-1 (E5 PIU) |
| Art. 57 | Réquisitions aux opérateurs | Collection phase NIST SP 800-86 [29] |

*Tableau 8.1. Correspondance Loi 2010/012 et standards forensiques internationaux*

## 8.3 Le Formulaire de Chaîne de Custody : Anatomie et Utilisation

### 8.3.1 Principe général : le formulaire commence au premier contact

Le formulaire de custody ne se remplit pas après l'acquisition. Il commence au moment où l'OPJ ou l'investigateur numérique pose les yeux sur l'evidence, avant même de la toucher. La première entrée est la **description visuelle initiale**, réalisée sans manipulation. Toutes les entrées suivantes doivent être horodatées et signées à mesure qu'elles se produisent, pas reconstituées a posteriori.

### 8.3.2 Formulaire type. version académique complète

**Chaîne de Custody**

**FORMULAIRE DE CHAÎNE DE CUSTODY**

République du Cameroun – Unité de Police Judiciaire Fictive – Direction des Investigations

**N° de dossier :** _____ **N° d'evidence :** _____

**Affaire :** _____

**Date de collecte :** _____ **Heure :** _____

**Description physique de l'evidence :**

Marque : _____ Modèle : _____ N° de série : _____

Couleur : _____ État : _____

**Lieu de collecte :** _____

**Collecté par :** Nom : _____ Grade/matricule : _____

**Hash MD5 de l'original :**

_____

**Hash SHA-256 de l'original :**

_____

**Hash MD5 de l'image forensique :**

_____

**Hash SHA-256 de l'image forensique :**

_____

**Intégrité vérifiée :** ☐ OUI: les hash correspondent ☐ NON: acquisition à reprendre

**Outil d'acquisition :** Nom : _____ Version : _____ OS hôte : _____

**TRANSFERTS DE CUSTODY :**

| De | À | Date/Heure | Raison |
|---|---|---|---|
| | | | |
| | | | |
| | | | |

**Signature du collecteur :** _____ Date : _____

### 8.3.3 Champ par champ : comment remplir correctement

| Champ | Comment le remplir, erreurs fréquentes |
|---|---|
| N° de dossier | Numéro du parquet ou de l'unité ; cohérent avec tous les documents du dossier. Ne jamais laisser vide. |
| N° d'evidence | Numérotation séquentielle dans le dossier (EV-001, EV-002 ...). Ne jamais renuméroter un bien déjà enregistré. |
| Description physique | Suffisamment précise pour qu'un tiers puisse identifier l'objet sans l'avoir vu : marque, modèle, numéro de série, couleur, rayures visibles, caches manquants. |
| Hash MD5 + SHA-256 | Calculer les DEUX sur l'original AVANT acquisition ; puis les DEUX sur l'image APRÈS acquisition. Les conserver séparément de l'image (sur papier et en fichier texte chiffré). |
| Intégrité vérifiée | Cocher OUI uniquement si hash source = hash image. Si NON : stopper, identifier la cause, recommencer l'acquisition. |
| Outil d'acquisition | Nom *exact* + version *exacte*. "FTK Imager" n'est pas suffisant. "FTK Imager 4.7.3.81 sur Windows 11 Pro 22H2" est correct. |
| Transferts | Chaque transfert, même temporaire, doit être documenté : remise au laboratoire, transport au greffe, consultation par un avocat, retour pour analyse complémentaire. |

*Tableau 8.2. Guide de remplissage champ par champ*

## 8.4 Protocole de Custody par Type d'Evidence

### 8.4.1 PC allumé : préserver avant de saisir

**Application OPJ/Expert Judiciaire**

**Protocole. PC allumé (ordre impératif)**

1. **Photographier l'écran** dans son état actuel avant tout geste. Horodatage visible (barre des tâches + montre de l'OPJ ou l'investigateur numérique en main).

2. **Capturer la RAM** : FTK Imager → `File` → `Capture Memory`. Support de destination : clé USB distincte, *jamais le disque interne*.
3. **Documenter les connexions réseau** : `netstat -ano` (CMD) ou `Get-NetTCPConnection` (PowerShell). Photographier.
4. **Éteindre proprement** via le menu Windows. *Exception* : si destruction de données en cours (chiffrement actif, suppression rapide), débrancher immédiatement et documenter le motif.
5. **Activer le write blocker** logiciel :

```
reg add HKLM\SYSTEM\CurrentControlSet\Control\
   StorageDevicePolicies
    /v WriteProtect /t REG_DWORD /d 1 /f

```

6. **Acquérir avec FTK Imager** : format E01, métadonnées complètes (N° dossier, N° evidence, examinateur).
7. **Calculer et documenter les hash** MD5 et SHA-256. Remplir le formulaire. Sceller l'original.

### 8.4.2 PC éteint : ne pas allumer

**Application OPJ/Expert Judiciaire**

**Protocole. PC éteint**

1. **Ne pas allumer.** Appuyer sur le bouton Power contamine la scène avant même que l'OS soit chargé (BIOS, UEFI, Windows Write Cache : tous modifient des données).
2. Photographier le matériel sous tous les angles, câbles en place.
3. Activer le write blocker et retirer physiquement le disque dur (ou SSD) pour connexion sur le poste d'acquisition.
4. Acquérir, hasher, documenter. Sceller l'original.
5. Si le BIOS requiert un démarrage pour identifier le modèle : démarrer sur un Live CD forensique (SIFT, Kali) qui ne monte pas les partitions Windows automatiquement.

### 8.4.3 Téléphone mobile : mode avion avant tout

**Application OPJ/Expert Judiciaire**

**Protocole. Téléphone mobile**

**RÈGLE 1 : MODE AVION EN PREMIER**

1. **Téléphone allumé** : mode avion immédiat (coupe les signaux sans effacer les données). Si écran inaccessible : sac de Faraday ou enveloppe d'aluminium ménager hermétique.
2. **Ne pas brancher sur un chargeur** avant isolation : le branchement active la synchronisation (certains appareils déclenchent une sauvegarde automatique qui modifie des données).
3. **Documenter** : N° IMEI (`*#06#` ou sous la batterie), opérateur, état de l'écran, niveau de batterie estimé.
4. **Acquisition ADB (Android, code connu)** :

```
# Vérifier connexion et droits
adb devices
# Extraction du système de fichiers (niveau logique)
adb pull /sdcard/ ./extraction/sdcard/
# Liste des applications installées
adb shell pm list packages -f > apps_list.txt
# Sauvegarde complète (si autorisée)
adb backup -all -apk -shared -f backup_mbongo.ab

```

5. **Téléphone chiffré, code inconnu** : conserver éteint, transmettre à un laboratoire spécialisé. Ne pas tenter de bruteforce sans autorisation judiciaire (art. 52 **Loi 2010/012**).

### 8.4.4 Données cloud et réponses opérateurs

Les preuves obtenues par réquisition (art. 57 **Loi 2010/012**) (logs d'opérateur MTN, réponses Meta/Google, journaux CloudTrail) sont des preuves numériques soumises aux mêmes exigences de custody :

1. **Documenter la réquisition** : numéro, date, autorité émettrice, périmètre demandé.
2. **Documenter la réception** : date de réception de la réponse, nom du fichier, format.
3. **Calculer immédiatement le hash** du fichier reçu.
4. **Conserver la chaîne documentaire complète** : réquisition + accusé de réception + réponse + hash.

5. **Ne pas modifier le fichier reçu** : travailler sur une copie. Le fichier original reste en custody scellée.

## 8.5 Les Cinq Erreurs Fatales de Custody

Ces cinq erreurs sont les plus fréquentes dans les dossiers rejetés par les tribunaux camerounais. Chacune correspond à une règle de custody violée.

### 8.5.1 Erreur 1 : allumer le PC suspect sans acquisition préalable

★ Attention

**L'erreur de l'affaire MBONGO.**
Un OPJ allume l'ordinateur du suspect "pour constater les faits". Windows monte les partitions, crée des fichiers temporaires (`pagefile.sys`, `hiberfil.sys`), met à jour le registre, modifie les horodatages d'accès NTFS. Le hash du disque avant et après allumage diffère. La preuve est contaminée.
**Règle absolue :** sur un PC éteint, ne jamais allumer avant d'avoir activé le write blocker. Sur un PC allumé, capturer la RAM en premier, *puis* éteindre proprement, *puis* acquérir le disque.

### 8.5.2 Erreur 2 : travailler sur l'evidence originale

★ Attention

**Analyser directement sur le disque original ou sur l'image sans write blocker.**
Autopsy modifie-t-il les données en les lisant ? Non, si l'image E01 est montée en lecture seule. Mais si l'OPJ ou l'investigateur numérique ouvre l'image avec Windows Explorer, il crée des fichiers `Thumbs.db` et met à jour les horodatages d'accès.
**Règle :** toute analyse doit être conduite :

1. sur une *copie* de l'image forensique ;
2. montée en *lecture seule* (Autopsy le fait automatiquement) ;
3. l'original physique est scellé et inaccessible sauf sur autorisation.

### 8.5.3 Erreur 3 : le transfert non documenté

★ Attention

**"J'ai confié l'ordinateur à mon collègue pendant 2 heures."**
Ce transfert non documenté crée une période de custody inconnue. L'avocat de la défense peut arguer que l'ordinateur a été manipulé pendant ces deux heures.
**Règle :** tout transfert d'une evidence entre deux personnes, même temporaire, même entre collègues du même service, est documenté : date, heure, raison, signatures des deux parties. Si le transfert a eu lieu sans documentation : documenter le fait du transfert a posteriori en indiquant les circonstances, et re-vérifier l'intégrité par

hachage avant et après.

### 8.5.4 Erreur 4 : oublier les versions d'outils

★ Attention

**"Analysé avec Autopsy" dans le rapport.**
L'avocat demande : quelle version ? Quel système d'exploitation ? Si l'analyste ne le sait pas, l'expert de la partie adverse peut arguer que la version utilisée avait un bug connu qui produisait de faux positifs sur ce type de fichier.
**Règle :** documenter systématiquement dans le formulaire de custody :

- ➢ Nom de l'outil (ex. : FTK Imager)
- ➢ Version exacte (ex. : 4.7.3.81)
- ➢ Système d'exploitation hôte (ex. : Windows 11 Pro 22H2, build 22621)
- ➢ Date d'utilisation

### 8.5.5 Erreur 5 : les hash non calculés ou non conservés séparément

★ Attention

**"Le hash est dans l'image E01."**
Insuffisant. Si l'image E01 est l'objet de la contestation, le hash qui y est intégré n'est pas une preuve indépendante.
**Règle : les hash doivent être conservés séparément de l'image, en au moins deux endroits distincts :**

1. Manuscrit sur le formulaire papier de custody (signé et daté) ;
2. Dans un fichier texte chiffré sur un support distinct ;
3. Optionnel niveau avancé : horodatage blockchain ou tiers de confiance.

La règle : si demain l'image E01 disparaît, les hash doivent subsister ailleurs pour permettre de certifier une copie de sauvegarde.

## 8.6 Custody et Scénario MBONGO : l'Investigation Correcte

Voici la reconstitution complète et correcte de l'affaire MBONGO du Prologue, avec le formulaire de custody rempli correctement.

🔍 Scénario Opérationnel · Affaire MBONGO. Formulaire de custody complet

**Evidence EV-001. PC portable Windows de MBONGO Joseph**

| | | | |
|---|---|---|---|
| **N° dossier :** | DOS-2026-034 | **N° evidence :** | EV-001 |
| **Date collecte :** | 15/03/2026 | **Heure :** | 14h22 |

**Description :** Dell Inspiron 15 3000, S/N GF8T3Y2, noir, rayure 3 cm sur le bord gauche, autocollant “SONATRAV” en bas à gauche.

**Lieu :** Bureau comptabilité, 3e étage, SONATRAV SA, Akwa, Douala.

**Collecté par :** OPJ NKENG Éric, Matricule FICTIF 4471-B, DCPJ Douala.

**État initial :** PC allumé, déverrouillé, fenêtre navigateur Edge ouverte sur portail UBA.

**Actions pré-acquisition :**

1. 14h22. Photographies de l’écran (8 photos, horodatées).
2. 14h24. Capture RAM avec FTK Imager 4.7.3.81 : fichier `MBONGO_RAM_20260315.mem` (16 Go).
3. 14h41. `netstat -ano` documenté (2 connexions ESTABLISHED).
4. 14h43. Arrêt propre Windows.
5. 14h50. Write blocker logiciel activé (registre : WriteProtect=1).

**Acquisition :** FTK Imager 4.7.3.81, Windows 11 Pro 22H2, format E01.
Durée : 47 minutes (15h03–15h50). Support destination : HDD externe 2 To, S/N WD-WXL1A89K3456.

```
[MD5 original] a3f7b29c8e1d4f56a2c8b7e3d9f0a142
[SHA-256 original] 3d9c8f2b7e4a1c6d5f8e2b9a7c4d3f1e6b8a2c5d7f9e1b3a4c6d8f0e2b4a6c81
[MD5 image] a3f7b29c8e1d4f56a2c8b7e3d9f0a142
[SHA-256 image] 3d9c8f2b7e4a1c6d5f8e2b9a7c4d3f1e6b8a2c5d7f9e1b3a4c6d8f0e2b4a6c81
```

**Intégrité :** ✓ OUI: hash identiques. Acquisition valide.

**Scellé :** sachet inviolable n° DL-2026-0347, 15h52, signature OPJ NKENG.

**Transfert :** De NKENG → Dépôt DCPJ Douala. Date : 15/03/2026 17h10. Raison : stockage sécurisé. Signatures : NKENG + Responsable dépôt OPJ BIYA Marie.

**Scénario Opérationnel · Affaire MBONGO – Evidence EV-002 – Téléphone Android**

**Evidence EV-002. Samsung Galaxy A53 de MBONGO Joseph**
**Actions :**

1. 14h23. Mode avion activé (téléphone déverrouillé, écran actif).
2. 14h23. Photographié : IMEI : 357128094771034 visible sur l'écran (`*#06#`).
3. 15h55. Extraction ADB : `adb pull /sdcard/` (`1 447 fichiers extraits`).
4. 16h10. Hash SHA-256 du répertoire d'extraction : calculé.
5. 16h12. Scellé : sachet inviolable n° DL-2026-0348.

L'ensemble de l'extraction est intégré au dossier avec le formulaire de custody EV-002 signé par OPJ NKENG.

## 8.7 Custody et Admissibilité : le Chemin vers le Tribunal

### 8.7.1 Les quatre conditions d'admissibilité revisitées

La formule d'admissibilité posée au Chapitre 4 prend ici son sens concret :

$$\text{Admissible}(P) \iff \underbrace{\text{Légale}(P)}_{\text{art. 52–59}} \wedge \underbrace{\text{Intègre}(P)}_{\text{hash identiques}} \wedge \underbrace{\text{Authentique}(P)}_{\text{custody continue}} \wedge \underbrace{\text{Pertinente}(P)}_{\text{lien avec les faits}} \tag{8.1}$$

| Condition | Ce que le tribunal vérifie | Document qui le prouve |
|---|---|---|
| Légalité | Autorisation judiciaire préalable (art. 52) ; absence d'actes coercitifs illicites | Réquisition ou mandat judiciaire signé |
| Intégrité | Hash source = hash image ; aucune modification après acquisition | Formulaire custody + hash conservés séparément |
| Authenticité | Chaîne de custody continue depuis la scène ; chaque transfert documenté | Formulaire custody complet + signatures |
| Pertinence | Lien démontré entre l'evidence et les faits ; rapport forensique documentant les constatations | Rapport forensique (section Constatations) |

*Tableau 8.3. Conditions d'admissibilité et documents probatoires correspondants*

### 8.7.2 Ce que l'avocat de la défense cherche et comment s'y préparer

Un avocat de la défense compétent examinera systématiquement :

1. **L'autorisation judiciaire** : est-elle antérieure à l'acquisition ? Son périmètre couvre-t-il ce qui a été saisi ?
2. **Les hash** : sont-ils calculés sur l'original avant acquisition ? Sont-ils identiques entre original et image ?
3. **Les périodes non documentées** : y a-t-il un moment où l'evidence n'était pas en custody documentée ? Qui l'avait ? Où ?
4. **Les versions d'outils** : les outils utilisés avaient-ils des bugs connus sur ce type de fichier à cette date ?
5. **La présence des parties** : l'acquisition a-t-elle été réalisée en présence du détenteur (art. 53 al. 1) ?

Pour chacun de ces points, la réponse est dans le formulaire de custody. Un formulaire complet et signé est la meilleure défense contre toutes ces attaques.

❍

★ À retenir

**Ce qu'il faut retenir de ce chapitre :**

- La **chaîne de custody** est la condition de l'**authenticité** : elle prouve que l'evidence présentée au tribunal est bien celle saisie sur la scène, sans modification.
- En droit camerounais : art. 52 (**autorisation judiciaire**), art. 53 al. 1 (**acquisition en présence des parties**), art. 55 (**copie + restitution de l'original**), art. 57 (**réquisition aux opérateurs**).
- Le **formulaire de custody** commence au premier contact, pas après l'acquisition. Champs obligatoires : description physique, hash MD5+SHA-256 (original ET image), outil+version, tous les transferts.
- **Cinq erreurs fatales** : allumer le PC sans write blocker ; travailler sur l'original ; transfert non documenté ; version d'outil non renseignée ; hash non conservés séparément de l'image.
- **Les hash doivent être conservés séparément** : sur le formulaire papier signé ET dans un fichier texte sur support distinct ; jamais seulement dans l'image E01.
- La chaîne de custody maximise $\mathcal{O}$ (opposabilité) au coût d'une légère contrainte sur $\mathcal{C}$ et $\mathcal{R}$ ; ce coût est non seulement acceptable mais constitutif de l'admissi-

bilité.

### ✍ Exercice 8.1. Diagnostic de custody ★☆☆

Pour chacune des situations suivantes, identifiez la violation de custody et son impact sur l'admissibilité :

(a) Un OPJ saisit un téléphone Android, le branche sur son chargeur pendant 20 minutes en attendant les renforts, puis l'emballe.

(b) Le rapport forensique indique : *"Hash SHA-256 : 3d9c8f2b…"*. Pas de hash MD5. Pas de hash de l'original.

(c) L'evidence a été transportée du dépôt au laboratoire par un OPJ ; aucune entrée dans le formulaire pour ce transport.

(d) L'analyste a ouvert l'image E01 avec Windows Explorer pour naviguer rapidement dans les fichiers avant d'ouvrir Autopsy.

### ✍ Exercice 8.2. Remplissage de formulaire ★★☆

L'Opération TANGUE (Chapitre 3) a produit les éléments suivants lors de l'arrestation de BELLO Armand :

- PC portable HP EliteBook 840, S/N CND7382741, allumé, verrouillé par code PIN ;
- Clé USB Kingston 16 Go bleue, S/N non visible sur l'objet, branchée dans le PC ;
- Téléphone Samsung Galaxy S22, allumé, déverrouillé.

Rédigez le formulaire de custody pour l'evidence EV-001 (PC HP) en détaillant : (a) les actions pré-acquisition dans l'ordre correct, (b) les informations à remplir champ par champ, (c) le protocole d'acquisition compte tenu de l'état du PC (allumé, verrouillé).

### ✍ Exercice 8.3. Défense en contre-interrogatoire ★★★

Vous êtes l'expert forensique dans l'affaire MVOM. L'avocat de TRANSBOIS SA (qui cherche à contester votre analyse pour réduire sa responsabilité) vous pose les questions suivantes :

(a) *"Comment pouvez-vous prouver que l'image E01 que vous avez analysée est bien celle du serveur de TRANSBOIS et non une image que vous avez préparée ?"*

(b) *"Le serveur était allumé lors de la saisie. Quelle modification du disque a été causée par les actions que vous avez menées avant d'acquérir l'image ?"*

(c) *"Vous avez utilisé Volatility 3 pour analyser la RAM. Cette version avait-elle des bugs connus en mars 2026 sur les systèmes Windows Server 2022 ?"*

Rédigez vos réponses telles que vous les donneriez à l'audience. Pour chaque réponse, identifiez le document de custody qui vous permet de l'étayer.

**Note**

**Transition.** Le Chapitre 9 approfondit les **outils et techniques d'acquisition** : FTK Imager en détail, formats d'image forensique (E01, DD, AFF), write blockers matériels et logiciels, acquisition de mémoire RAM, et acquisition mobile avancée. C'est la mise en œuvre technique de ce que ce chapitre a établi sur le plan procédural.

# 9

# OUTILS ET TECHNIQUES D'ACQUISITION

> « By approaching each case methodically, you can evaluate the evidence thoroughly and document the chain of evidence. »
>
> Amelia Phillips

**Niveau :** *Intermédiaire* • Notions de systèmes de fichiers et de ligne de commande recommandées. Lecture du Chapitre 8 obligatoire : ce chapitre met en œuvre les procédures de custody.

**✦ Objectifs du chapitre**

- ➢ Maîtriser le **write blocker** matériel et logiciel : principe, activation, vérification.
- ➢ Conduire une acquisition forensique complète avec FTK Imager : formats E01, DD ; disque, RAM et mobile.
- ➢ Comprendre les cinq formats d'image forensique et savoir choisir le format adapté au contexte.
- ➢ Extraire et analyser les données d'un téléphone Android avec ADB.
- ➢ Conduire une analyse mémoire de base avec Volatility 3.
- ➢ Analyser une capture réseau avec Wireshark pour identifier des communications suspectes.
- ➢ Appliquer la grille CRO à chaque décision technique d'acquisition.

## 9.1 Le Write Blocker : Protection Absolue de l'Evidence

### 9.1.1 Principe et nécessité

Le **write blocker** est un dispositif (matériel ou logiciel) qui permet de lire un support numérique en interdisant toute écriture. Sans write blocker, le simple branchement d'un disque sur un PC Windows déclenche une cascade invisible de modifications : création de fichiers temporaires, mise à jour de la base de registre, modification des horodatages d'accès NTFS. En quelques secondes, l'evidence est contaminée.

$$\text{Write blocker} \implies \forall\,\text{opération d'écriture} \rightarrow \texttt{DENIED} \quad \text{pendant toute la durée de l'acquisition} \tag{9.1}$$

### 9.1.2 Write blocker matériel

Le write blocker matériel est un boîtier physique qui s'intercale entre le support à acquérir et le poste d'acquisition. C'est le standard de référence : indépendant du système d'exploitation, il ne peut pas être contourné par un bug logiciel.

| Modèle de référence | Interfaces | Usage |
|---|---|---|
| Tableau Forensics WiebeTech | SATA, IDE, SAS, USB, SD | Standard FBI ; ~ 500 USD |
| ICS Image MASSter Solo | SATA, IDE, USB | Acquisition autonome sans PC |
| Wiebetech Forensic UltraDock | SATA, USB 3.0, NVMe | Portable ; adapté aux SSD modernes |

*Tableau 9.1. Write blockers matériels de référence*

### 9.1.3 Write blocker logiciel

En l'absence de write blocker matériel, situation fréquente dans les unités PNC camerounaises actuelles, le write blocker logiciel est une alternative acceptable si correctement documentée.

**Outils · Write blocker logiciel Windows, activation registre**

```
@ Activation
reg add HKLM\SYSTEM\CurrentControlSet\Control\
    StorageDevicePolicies
     /v WriteProtect /t REG_DWORD /d 1 /f

@ Verification
reg query HKLM\SYSTEM\CurrentControlSet\Control\
    StorageDevicePolicies
@ Attendu : WriteProtect  REG_DWORD  0x1

@ Test validation (doit echouer)
echo test > D:\test_write.txt
@ Attendu : Acces refuse

@ Desactivation apres acquisition
reg add HKLM\SYSTEM\CurrentControlSet\Control\
    StorageDevicePolicies
     /v WriteProtect /t REG_DWORD /d 0 /f
```

**Outils · Write blocker logiciel Linux**

```
# Identifier le disque (ne JAMAIS supposer sdb)
lsblk

# Passer en lecture seule AVANT montage
blockdev --setro /dev/sdb
blockdev --getro /dev/sdb     # Attendu : 1

# Montage en lecture seule (double protection)
mount -o ro,noatime /dev/sdb1 /mnt/evidence

# Test validation (doit echouer)
touch /mnt/evidence/test.txt
# Attendu : Read-only file system
```

**Write blocker logiciel vs matériel**

Le write blocker logiciel est acceptable en investigation préliminaire. En contexte judiciaire (comparution devant le TCS), le write blocker matériel est recommandé pour éviter toute contestation. Documenter obligatoirement : activation + test de vérification (captures d'écran horodatées dans le formulaire de custody).

## 9.2 Formats d'Image Forensique

| Format | Compressio | Métadonnée | Usage recommandé |
|---|---|---|---|
| **E01** | Oui (LZX) | Riches | **Standard de référence.** Autopsy, FTK, EnCase. Préférer pour toute investigation. |
| **Ex01** | Oui | Riches + AES | E01 chiffré ; données sensibles |
| **DD / Raw** | Non | Aucune | Compatible *tous* outils Linux ; précision absolue ; taille = taille disque original |
| **AFF4** | Oui | Très riches + signature | Standard émergent ; signé cryptographiquement |
| **VMDK / VHD** | Variable | Limitées | Machines virtuelles ; Autopsy ouvre directement |

*Tableau 9.2. Formats d'image forensique comparés*

**Définition**

**Format E01** : format d'Exterro (EnCase). Il segmente l'image en fichiers configurables (`.E01`, `.E02` ...) et intègre : hash MD5 et SHA-1 de chaque segment ; métadonnées de l'affaire (N° dossier, examinateur, notes) ; vérification d'intégrité automatique à l'ouverture. C'est le format le plus reconnu devant les tribunaux.

## 9.3 FTK Imager : Acquisition Disque et RAM

### 9.3.1 Procédure d'acquisition disque en 7 étapes

**Outils · FTK Imager, acquisition disque**

**Étape 1 :** Activer le write blocker. Vérifier l'espace disponible sur le support de destination (minimum : 110% de la taille source).
**Étape 2 :** `File` → `Create Disk Image`. Type de source :

- **Physical Drive** : image complète incluant l'espace non alloué ; recommandé en investigation forensique.
- **Logical Drive** : partition uniquement ; plus rapide mais peut manquer des artefacts.

**Étape 3 :** Format E01. Options : segmentation 0 (pas de segmentation) ; compression 5 ; cocher *Verify images after they are created.*
**Étape 4 :** Métadonnées :

```
Case Number     : DOS-2026-034
Evidence Number: EV-001
Unique Description: Dell Inspiron 15 SN-GF8T3Y2 MBONGO
Examiner        : OPJ NKENG Eric - Matricule PNC 4471-B
Notes           : PC allume - RAM capturee prealablement
```

**Étape 5 :** Support de destination *distinct* de la source (jamais le même disque). Nom sans espaces : `MBONGO_EV001_20260315.E01`.
**Étape 6 :** Lancer. FTK Imager affiche la progression, les hash MD5 et SHA-1 en temps réel, et les erreurs de lecture (bad sectors).
**Étape 7 :** Vérifier que hash source = hash image. Reporter dans le formulaire de custody. Sceller l'original.

**★ Attention**

**Erreurs fréquentes :**

- Acquérir sur le même disque : l'acquisition échoue à mi-chemin.
- Oublier les métadonnées : sans Case Number, pas de valeur probatoire.
- Ne pas vérifier les hash : si source ≠ image, recommencer.
- Format DD sur 1 To : 1 To non compressé ; préférer E01 (≈ 50% compression).

### 9.3.2 Acquisition de la mémoire RAM

La mémoire RAM contient ce qui n'existe nulle part ailleurs : processus en cours d'exécution, connexions réseau actives, mots de passe en mémoire, clés de chiffrement actives. Sa capture requiert que le PC soit allumé et constitue la **première action** sur

tout système actif (RFC 3227 [5], rang 2).

**Outils · FTK Imager, capture mémoire RAM**

```
# Interface graphique FTK Imager :
# File --> Capture Memory
# Destination : support externe (jamais disque interne)
# Cocher 'Include pagefile' si disponible
# Cliquer Capture Memory

# Resultat : fichier .mem de la taille de la RAM installee
# 16 Go RAM  --> fichier ~16 Go
# 32 Go RAM  --> fichier ~32 Go

# Hash SHA-256 immediatement apres capture :
certutil -hashfile MBONGO_RAM_20260315.mem SHA256
# Reporter dans le formulaire de custody
```

**La RAM modifie la RAM**

La capture de la mémoire modifie légèrement la mémoire : le processus FTK Imager utilise lui-même de la RAM pendant la capture. C'est inévitable et documenté, un fait, pas une violation de custody. Documenter dans le formulaire : *"Légère modification de la RAM inhérente à l'outil, conformément à ACPO [3] Principe 2. Capture réalisée avant toute autre action."*

### 9.3.3 Acquisition Linux avec dd

Sur Kali Linux ou tout système Linux, l'outil natif `dd` permet une acquisition bit-à-bit sans aucun logiciel supplémentaire :

```
# Identifier le disque (ne jamais supposer sdb)
lsblk -o NAME,SIZE,FSTYPE,MOUNTPOINT

# Hash SHA-256 AVANT acquisition (original)
sha256sum /dev/sdb | tee hash_source_EV001.txt

# Acquisition dd
dd if=/dev/sdb of=/mnt/evidence/EV001.dd
   bs=65536 conv=noerror,sync status=progress
# bs=65536 : blocs 64 Ko (optimal)
# conv=noerror,sync : continue sur erreur, padde zeros

# Alternative dcfldd (hash pendant l'acquisition)
dcfldd if=/dev/sdb of=/mnt/evidence/EV001.dd
   bs=65536 hash=sha256 hashwindow=10M
   hashlog=/mnt/evidence/EV001_hashlog.txt

# Hash SHA-256 APRES (image)
```

```
sha256sum /mnt/evidence/EV001.dd | tee hash_image_EV001.txt

# Comparaison (identiques = integrite OK)
diff hash_source_EV001.txt hash_image_EV001.txt
echo "INTEGRITE: $?"     # 0 = OK
```

Listing 9.1: Acquisition forensique dd + dcfldd

## 9.4 Acquisition Mobile : Android et iOS

### 9.4.1 Les quatre niveaux d'acquisition mobile

| Niveau | Technique | Données accessibles | Conditions |
|---|---|---|---|
| Niveau 1 | Manuelle (écran) | Contacts, SMS, photos visibles | Téléphone déverrouillé ; documentation par photo |
| Niveau 2 | Logique (ADB) | Système de fichiers utilisateur | Android déverrouillé ; Options développeur activées |
| Niveau 3 | Physique | Mémoire flash complète ; données supprimées | Outils spécialisés (Cellebrite, GrayKey) |
| Niveau 4 | Chip-off / JTAG | Extraction directe de la puce | Matériel spécialisé ; risque destruction ; dernier recours |

*Tableau 9.3. Niveaux d'acquisition mobile (NIST SP 800-101 [30]r1)*

### 9.4.2 ADB. Android Debug Bridge

**ADB** (*Android Debug Bridge*) est l'outil officiel Google pour communiquer avec un téléphone Android. En forensique, il constitue le niveau 2 : accès au système de fichiers utilisateur sans modifier les données.

**Prérequis :**

1. Mode avion activé (obligatoire cf. Ch. 8).
2. Options développeur : `Paramètres` → `À propos` → `Numéro de build` → `appuyer 7 fois.`
3. Débogage USB activé : `Options développeur` → `Débogage USB` → `Activé.`
4. Autorisation sur le téléphone lors du premier branchement.

**Outils · ADB. commandes forensiques essentielles**

```
# Verifier la connexion
adb devices
# Attendu : R5CR71XXXX    device

# Identifier l'appareil
adb shell getprop ro.product.model        # Modele
adb shell getprop ro.build.version.release   # Android version
adb shell getprop ro.serialno             # Numero de serie

# Extraction du systeme de fichiers utilisateur
adb pull /sdcard/ ./extraction/sdcard/
# /sdcard : photos, videos, telechargements, backups WhatsApp

# Liste des applications installees
adb shell pm list packages -f > ./extraction/applications.txt

# Extraction SMS (selon version Android)
adb shell content query --uri content://sms/
    > ./extraction/sms.txt

# Contacts
adb shell content query --uri content://contacts/people/
    > ./extraction/contacts.txt

# Journal systeme
adb logcat -d > ./extraction/logcat.txt

# Sauvegarde complete
adb backup -all -apk -shared -f backup_evidence.ab

# Hash SHA-256 de l'extraction
find ./extraction/ -type f -exec sha256sum {} \;
    > hash_extraction.txt
```

**$\Gamma_{CRO}$ Analyse CRO · Confidentialité · Fiabilité · Opposabilité**

**Analyse CRO. Extraction ADB complète vs ciblée**

L'extraction complète (`adb pull /sdcard/`) capture tout : photos personnelles, messages privés, données de santé.

$\mathcal{C}$ : extraction complète = atteinte maximale à la vie privée ; extraction ciblée = atteinte proportionnée.

$\mathcal{R}$ : extraction complète préférable pour ne pas manquer des preuves dans des répertoires inattendus.

$\mathcal{O}$ : le principe de proportionnalité (art. 52 **Loi 2010/012** [34]) exige que la saisie soit limitée au pertinent.

$\mathcal{C}$: ↓ tension à gérer $\mathcal{R}$: ↑ extraction complète $\mathcal{O}$: ∼ justification requise
**Règle pratique :** en contexte judiciaire, documenter pourquoi une extraction complète était nécessaire (impossibilité de cibler ; risque de preuves dans des répertoires inattendus).

### 9.4.3 iOS. contraintes spécifiques

- Chiffrement hardware depuis iOS 8 ; pas d'équivalent ADB ;
- Extraction logique via iTunes/Finder uniquement avec code PIN ;
- Extraction physique : outils commerciaux (Cellebrite UFED, Magnet AXIOM) ;
- Données iCloud : réquisition à Apple (`legalprocess.apple.com`).

En l'absence d'outils spécialisés : conserver éteint ou mode avion, documenter l'IMEI, transmettre à un laboratoire accrédité. **Ne jamais tenter de brute-forcer le code PIN** : après 10 tentatives échouées, iOS efface les données.

## 9.5 Volatility 3 : Analyse de la Mémoire RAM

### 9.5.1 Architecture et principe

**Volatility 3** est le standard mondial d'analyse forensique de la mémoire RAM. Il analyse le fichier `.mem` capturé avec FTK Imager et révèle l'état du système *au moment de la capture* : processus en cours, connexions réseau, mots de passe, clés de chiffrement.

La version 3 (depuis 2021) utilise une syntaxe unifiée sans profil obligatoire : le profil Windows est détecté automatiquement.

**Outils · Volatility 3, commandes essentielles**

```
# -- IDENTIFICATION --
python3 vol.py -f memoire.mem windows.info

# -- PROCESSUS --
# Liste complete (PID, PPID, dates)
python3 vol.py -f memoire.mem windows.pslist

# Arborescence parent-enfant
python3 vol.py -f memoire.mem windows.pstree
# Indicateur suspect : svchost.exe enfant de cmd.exe
# (svchost legitime a toujours services.exe comme parent)

# -- RESEAU --
python3 vol.py -f memoire.mem windows.netscan
# Indicateur suspect : connexion ESTABLISHED vers port 4444

# -- COMMANDES EXECUTEES --
python3 vol.py -f memoire.mem windows.cmdline
```

```
# Indicateur suspect : PowerShell encodedcommand base64

# -- FICHIERS EN MEMOIRE --
python3 vol.py -f memoire.mem windows.filescan

# Extraire un fichier depuis la memoire
python3 vol.py -f memoire.mem windows.dumpfiles
    --virtaddr 0xXXXXXXXX

# -- HASHES MOTS DE PASSE --
python3 vol.py -f memoire.mem windows.hashdump

# -- CAPTURES D'ECRAN --
python3 vol.py -f memoire.mem windows.screenshotss
    -D ./screenshots/
```

### 9.5.2 Détecter un processus malveillant : cas MVOM

```
# Etape 1 : processus
python3 vol.py -f transbois.mem windows.pslist
# Resultat SUSPECT :
# 4892  4891  svchost.exe   2026-03-13 02:17:44
# 4891  4888  cmd.exe       2026-03-13 02:17:42
# ANORMAL : svchost ne doit pas avoir cmd comme parent

# Etape 2 : connexions reseau
python3 vol.py -f transbois.mem windows.netscan | grep 4892
# Resultat :
# ESTABLISHED  10.0.0.15:49212  185.220.XX.XX:4444  4892
# Connexion active vers C2 (port 4444)

# Etape 3 : identifier le fichier malveillant
python3 vol.py -f transbois.mem windows.filescan | grep enc_all
# Resultat :
# \Device\...\AppData\Local\Temp\enc_all.ps1
# Preuve de l'installation au moment de la capture
```

Listing 9.2: Analyse Volatility. Opération MVOM TRANSBOIS SA

## 9.6 Wireshark : Analyse du Trafic Réseau

### 9.6.1 Modes d'utilisation forensique

**Wireshark** s'utilise en deux modes :

1. **Analyse de capture fournie** : ouvrir un fichier `.pcap` / `.pcapng` collecté sur la scène.
2. **Capture live** : capturer en temps réel (nécessite une position dans le réseau : SPAN port, mirror, hub).

### 9.6.2 Filtres de référence

**Outils · Wireshark, filtres forensiques essentiels**

```
# Tout le trafic d'une IP
ip.addr == 185.220.XX.XX

# Communications entre deux hotes
ip.addr == 10.0.0.15 && ip.addr == 185.220.XX.XX

# HTTP (non chiffre)
http

# Soumissions de formulaires (mots de passe)
http.request.method == "POST"

# Requetes DNS (domaines consultes)
dns

# Port suspect (Metasploit, shells inverses)
tcp.port == 4444

# Trafic email non chiffre
smtp || pop3 || imap

# Recherche textuelle dans les trames
frame contains "password"
frame contains "Authorization"

# FONCTIONS UTILES :
# Statistics --> Conversations : toutes les paires IP
# Statistics --> Protocol Hierarchy : volumes par protocole
# File --> Export Objects --> HTTP : extraire fichiers
    telecharges
```

**Scénario Opérationnel · Wireshark, cas WOURI BEC**

La capture réseau SOTRADI.pcap est disponible. L'analyste reconstruit l'attaque :

1. Filtre `smtp` → email entrant depuis `contact@medequip-portugal.com`.
2. Clic droit → *Follow TCP Stream* : les en-têtes SMTP révèlent l'IP source réelle : serveur russe.
3. Filtre `dns` → chercher `medequip-portugal.com` : la résolution confirme l'enregistrement récent (12/01/2026, 3 jours avant le paiement).
4. *Statistics* → *Conversations* : volumes de transfert anormaux vers IPs suspectes.

**Constatation forensique (sans interprétation) :** "Le paquet

# 14 872 (timestamp 2026-01-15 14h28) contient un email SMTP depuis `contact@medequip-portugal.com`, originant depuis l'IP `91.XXX.XX.XX` selon le champ `Received`. Le domaine `medequip-portugal.com` a été enregistré le 12/01/2026 selon les bases WHOIS."

## 9.7 File Carving : Récupérer les Fichiers Supprimés

### 9.7.1 Principe des magic bytes

Le **file carving** récupère des fichiers depuis les données brutes d'un disque en cherchant les **magic bytes** (séquences d'octets caractéristiques de chaque type de fichier) sans se fier à la table de fichiers (qui peut être effacée ou corrompue).

| Type | Magic bytes (hex) | Usage forensique |
|---|---|---|
| JPEG | `FF D8 FF E0` | Photos ; contient souvent les métadonnées GPS |
| PDF | `25 50 44 46` | Documents (factures, contrats, bons de commande) |
| ZIP / Office | `50 4B 03 04` | .docx, .xlsx, .pptx (format ZIP interne) |
| PNG | `89 50 4E 47` | Images ; captures d'écran |
| EXE / DLL | `4D 5A` ("MZ") | Exécutables ; malware supprimé |

*Tableau 9.4. Magic bytes des types courants*

```
# Foremost -- types cibles
foremost -t jpg,pdf,docx,xlsx -i evidence.dd -o /output/carving/

# Resultats
ls /output/carving/
# jpg/  pdf/  docx/  audit.txt

cat /output/carving/audit.txt
# nombre de fichiers, taille totale, positions

# Scalpel -- configuration flexible
scalpel -c /etc/scalpel/scalpel.conf evidence.dd
    -o /output/scalpel/

# Rechercher des strings dans l'espace non alloue
strings -a evidence.dd
    | grep -i "momo\|virement\|password\|iban"
    > strings_suspects.txt
```

Listing 9.3: File carving avec Foremost et Scalpel

## 9.8 Synthèse : Choisir ses Outils selon la Situation

| Situation | Outil | Procédure |
|---|---|---|
| PC allumé. capturer la RAM | FTK Imager | `File` → `Capture Memory` |
| PC éteint. image disque (Windows) | FTK Imager | `File` → `Create Disk Image` → `E01` |
| PC éteint. image disque (Linux) | `dd` / `dcfldd` | `dd if=/dev/sdb of=image.dd bs=65536` |
| Android déverrouillé | ADB | `adb pull /sdcard/` + backup |
| iOS | iTunes | Sauvegarde ; réquisition Apple LEA |
| Analyse RAM | Volatility 3 | `windows.pslist`, `netscan`, `filescan` |
| Analyse capture réseau | Wireshark | Filtres `http`, `smtp`, `tcp.port` |
| Récupérer fichiers supprimés | Foremost / Autopsy | `foremost -t jpg,pdf` ou Deleted Files |

*Tableau 9.5. Sélection des outils par situation*

★ À retenir

**Ce qu'il faut retenir de ce chapitre :**

- **Write blocker** : activer AVANT de brancher l'evidence. Matériel = gold standard ; logiciel acceptable si documenté (activation + test de refus d'écriture).
- **FTK Imager** : 7 étapes (write blocker → type → format E01 → métadonnées → destination distincte → lancer → vérifier hash). RAM : `File` → `Capture Memory` sur support externe.
- **Format E01** : standard ; compression ≈ 50% ; métadonnées embarquées ; vérification automatique. DD : compatible tous outils mais taille source = taille image.
- **ADB** : 4 prérequis (mode avion, options développeur, débogage USB, autorisation). `adb pull /sdcard/` + backup. Limites : WhatsApp chiffré sans root. Gérer la tension $\mathcal{C}$ vs $\mathcal{R}$ (proportionnalité).
- **Volatility 3** : trio de base : `windows.pslist` + `netscan` + `filescan`. Indicateurs suspects : `svchost.exe` enfant de `cmd.exe` ; connexion ESTABLISHED port 4444.

➢ **Wireshark** : quatre filtres clés : `ip.addr` (isoler une IP) ; `smtp` (emails) ; `http.request.method == "POST"` (formulaires) ; `frame contains "password"`.

➢ **File carving** : `foremost -t jpg,pdf` ; magic bytes ; utile quand la table de fichiers est corrompue ou délibérément effacée.

### ✍ Exercice 9.1. Choix d'outil ★☆☆

Pour chacune des situations, indiquez l'outil, la commande exacte et le format de sortie :

(a) PC Windows allumé saisi : capturer la mémoire RAM.

(b) SSD SATA extrait après extinction : image forensique sous Linux.

(c) Samsung Galaxy A32, Android 11, déverrouillé : extraire photos et liste des applications.

(d) Image DD 500 Go : récupérer tous les fichiers PDF supprimés.

### ✍ Exercice 9.2. Analyse Volatility ★★☆

La sortie de `python3 vol.py -f incident.mem windows.pstree` donne (extrait) :

```
PID   PPID  Name                CreateTime
1024  788   services.exe
  1284 1024  svchost.exe        (7 instances normales)
4892  4888  svchost.exe         2026-03-13 02:17:44
  4888 4884  cmd.exe            2026-03-13 02:17:42
    4884 4880  powershell.exe   2026-03-13 02:17:40
      4880 4876  explorer.exe   2026-03-13 02:17:38
```

(a) Identifiez au moins deux anomalies dans cette arborescence.

(b) Formulez une constatation forensique (sans interprétation) pour chaque anomalie.

(c) Quelles commandes Volatility lanceriez-vous ensuite ? Dans quel ordre et pourquoi ?

### ✍ Exercice 9.3. Pipeline complet ★★★

Vous arrivez sur la scène MVOM : serveur Dell PowerEdge R740, Windows Server 2022, allumé, connecté au réseau. Le ransomware était actif il y a 20 minutes.

(a) Rédigez le protocole d'acquisition complet dans l'ordre : chaque action, outil, commande exacte, justification forensique.

(b) Le serveur a 128 Go de RAM. Quel support ? Durée estimée ? Comment documenter la modification inévitable de la RAM ?

(c) Appliquez la grille CRO à la décision d'effectuer une capture Wireshark live de 60 minutes avant d'éteindre le serveur.

(d) Rédigez les deux premières entrées du formulaire de custody.

**Note**

**Transition.** La Partie II est maintenant complète : PIU (Ch. 6), Standards (Ch. 7), Custody (Ch. 8) et ce chapitre constituent le socle opérationnel de tout ce qui suit. La **Partie III** (Chapitres 10–13) approfondit le cadre normatif : normes globales ISO et Budapest, législation mondiale comparative, droit camerounais et africain, déontologie de l'investigateur. Elle n'est pas un doublon : elle donne la *légitimité juridique* qui confère toute leur valeur aux procédures techniques que vous maîtrisez maintenant.

# partie III

# Cadre Normatif, Judiciaire et Déontologique


© MaletYon

10

# CADRE NORMATIF GLOBAL

> « La loi doit fournir un cadre sans entraver l'innovation, protéger sans étouffer, réguler sans paralyser. »
>
> Simone Veil

**Niveau :** *Fondamental* • Aucun prérequis technique. Ce chapitre est essentiellement juridique et procédural. Lecture du Chapitre 7 (Standards) recommandée pour ne pas dupliquer, les deux se complètent.

**✦ Objectifs du chapitre**

- ➢ Situer la Convention de Budapest [9] dans le paysage du droit international du cyber et comprendre sa relation avec la législation camerounaise.
- ➢ Maîtriser les articles fondamentaux de Budapest : art. 2–11 (infractions), art. 16–21 (mesures procédurales), art. 23–35 (coopération).
- ➢ Comparer Budapest et Malabo sur cinq critères : champ d'application, infractions, protection des données, coopération, ratifications.
- ➢ Mobiliser le bon instrument international selon la nature, l'urgence et la géographie d'une demande de coopération.
- ➢ Utiliser les canaux INTERPOL (réseau 24/7) et AFRIPOL pour des demandes de coopération urgentes.
- ➢ Soumettre une demande structurée aux portails LEA des grands fournisseurs (Meta, Google, Microsoft).

## Pourquoi un cadre normatif global ?

Le cybercrime n'a pas de frontières. Un ransomware déployé depuis Saint-Pétersbourg, chiffrant des fichiers à Yaoundé, via un serveur de commande en Roumanie, est une réalité quotidienne. Sans cadre normatif commun entre les États, chaque frontière est un mur : les preuves disparaissent avant que les demandes d'entraide n'arrivent, les suspects se réfugient dans des pays sans traités, les fonds blanchis traversent des juridictions incompatibles.


© MaletYon

Ce chapitre répond à une question pratique : *quand une affaire dépasse les frontières camerounaises, sur quelle base légale demander quoi, à qui, par quel canal, dans quel délai ?*

## 10.1 La Convention de Budapest : Premier Traité International sur la Cybercriminalité

### 10.1.1 Contexte, portée et position du Cameroun

Adoptée par le Conseil de l'Europe le 23 novembre 2001 (STE n° 185), la **Convention de Budapest** est le premier et unique traité international contraignant en matière de cybercriminalité. En 2026, plus de 68 États la ont ratifiée, dont les États-Unis, le Japon, l'Australie, le Canada, et sur le continent africain : le Cap-Vert, le Ghana, le Maroc, la Mauritanie, le Nigeria, le Sénégal et la Tunisie.

★ Attention

**Position du Cameroun vis-à-vis de Budapest :**
Le Cameroun **n'est pas signataire** de la Convention de Budapest (juin 2026). Ce fait ne le place pas hors du droit international du cyber pour autant :

1. La **Loi 2010/012** [34] s'est directement inspirée de Budapest. les deux textes sont largement alignés sur les infractions et les mesures procédurales.
2. Les partenaires africains ayant ratifié Budapest (Ghana, Nigeria, Sénégal) coopèrent avec le Cameroun via leurs propres obligations.
3. Le Cameroun peut rejoindre Budapest à tout moment, la Convention est ouverte à tous les États.

**Posture opérationnelle :** maîtriser Budapest comme si le Cameroun en était partie, parce que les partenaires avec qui les OPJ coopèrent l'appliquent, et parce que la Loi 2010/012 en est directement issue.

### 10.1.2 Architecture de la Convention

| Section | Contenu essentiel |
|---|---|
| Chapitre I. Définitions (art. 1) | Lexique commun : système informatique, données informatiques, fournisseur de services, données de trafic. |
| Chapitre II Sect. 1. Droit pénal (art. 2–13) | Infractions que chaque État doit ériger en droit interne. |
| Chapitre II Sect. 2. Procédure (art. 14–22) | Pouvoirs d'investigation : conservation, production, perquisition, interception. |
| Chapitre III. Coopération (art. 23–35) | Mécanismes d'entraide : extradition, MLAT, réseau 24/7, conservation urgente transfrontalière. **Le cœur opérationnel.** |
| Chapitre IV. Dispositions finales (art. 36–48) | Signatures, ratifications, réserves. |

*Tableau 10.1. Architecture de la Convention de Budapest*

### 10.1.3 Les infractions pénales : articles 2 à 11

Ces articles définissent les infractions que chaque État partie doit ériger en droit interne. Pour un OPJ camerounais, ils fondent les demandes de coopération vers les États partenaires.

⚖ Jurisprudence & Droit applicable

**Article 2. Accès illégal :**

> Chaque Partie adopte les mesures législatives *[...]* pour ériger en infraction pénale *[...]* le fait intentionnel d'accéder sans droit à tout ou partie d'un système informatique.

**Équivalent camerounais :** Loi 2010/012, art. 65 al. 2. Formulations quasi-identiques.
**Usage opérationnel :** art. 2 fonde la demande de coopération quand le serveur piraté ou l'auteur de l'intrusion est situé dans un État partie à Budapest.

⚖ Jurisprudence & Droit applicable

**Article 8. Fraude informatique :**

> *[...]* le fait de causer un préjudice patrimonial à autrui par toute introduction, altération, effacement ou suppression de données informatiques *[...]* dans l'intention frauduleuse ou déloyale d'obtenir sans droit un bénéfice économique.

**Équivalent camerounais :** Loi 2010/012, art. 72. **L'article le plus utilisé en pratique.**

Couvre : BEC, phishing bancaire, fraude Mobile Money, virement frauduleux par manipulation. Art. 8 fonde la demande vers le pays de l'auteur *ET* vers la banque destinataire pour gel des fonds.

| Article | Infraction | Équiv. Loi 2010 | Cas typique Cameroun |
|---|---|---|---|
| Art. 2 | Accès illégal | Art. 65 al. 2 | Intrusion CNPS, système bancaire |
| Art. 3 | Interception illégale | Art. 65 al. 1 | Logiciel espion C2 étranger |
| Art. 4 | Atteinte aux données | Art. 67 | Ransomware hôpital |
| Art. 5 | Atteinte au système | Art. 66 | DDoS infrastructure |
| Art. 6 | Abus de dispositifs | Art. 86 | Kit phishing vendu sur dark web |
| Art. 7 | Falsification | Art. 72 + CP 155 | Documents administratifs falsifiés |
| Art. 8 | Fraude informatique | Art. 72 | BEC, MoMo fraud, phishing |
| Art. 9 | CSAM | Art. 76 | Contenus pédopornographiques |

*Tableau 10.2. Articles Budapest, équivalents camerounais et cas typiques*

### 10.1.4 Les mesures procédurales : articles 16, 17, 18 et 29

Ces articles sont les plus directement utiles à l'enquêteur. Ils définissent les outils d'investigation que chaque État doit mettre à disposition et les mécanismes de coopération procédurale.

**⚖ Jurisprudence & Droit applicable**

**Article 16. Conservation rapide de données stockées :**

> *[...]* ordonner ou d'imposer *[...]* la conservation rapide de données électroniques spécifiées *[...]* notamment lorsqu'il y a des raisons de croire que celles-ci sont particulièrement susceptibles de perte ou de modification. La période de conservation est aussi longue que nécessaire, jusqu'à un maximum de 90 jours.

**L'outil d'urgence n° 1 de l'enquêteur cyber.** Les données numériques disparaissent vite : logs effacés, comptes supprimés, serveurs réinitialisés.

**Conservation ≠ Divulgation :** art. 16 préserve les données (mise sous scellé numérique temporaire). La divulgation nécessite art. 17–18. Ces deux étapes ne

peuvent pas être sautées.

**Jurisprudence & Droit applicable**

**Article 29. Conservation urgente transfrontalière :**

> Une Partie peut demander à une autre Partie d'ordonner ou d'imposer d'une autre façon la conservation rapide de données stockées au moyen d'un système informatique situé sur le territoire de cette autre Partie et pour lesquelles la Partie requérante souhaite présenter une demande d'entraide en vue d'obtenir leur divulgation.

**Réflexe obligatoire :** dès qu'une adresse IP suspecte est identifiée sur un serveur étranger, envoyer *immédiatement* une demande de conservation via le réseau 24/7 INTERPOL. Attendre la voie diplomatique classique = arriver après effacement des données.

**Jurisprudence & Droit applicable**

**Article 35. Réseau 24/7 :** Chaque Partie désigne un point de contact disponible 24h/24, 7j/7, pour assister les autres Parties dans les investigations sur les systèmes informatiques et les données stockées.
Pour le Cameroun : **BCN INTERPOL Yaoundé (DGSN/DCPJ)** est le point de contact pour les demandes entrantes et sortantes via le réseau I-24/7.

$\Gamma_{CRO}$ **Analyse CRO · Confidentialité · Fiabilité · Opposabilité**

**Analyse CRO. Article 29 et conservation urgente**
$\mathcal{R}$ (Fiabilité) : la conservation urgente préserve les données avant qu'elles ne disparaissent, elle maximise la fiabilité future du dossier.
$\mathcal{O}$ (Opposabilité) : art. 29 fonde légalement la demande ; sans cette base, les données obtenues peuvent être contestées comme ayant été recueillies sans fondement.
$\mathcal{C}$ (Confidentialité) : la conservation implique que le fournisseur étranger a connaissance de l'investigation. Dans certains cas, cela peut alerter le suspect (via compromission du fournisseur).
$\mathcal{C}$: $\downarrow$ risque à évaluer $\mathcal{R}$: $\uparrow\uparrow$ conservation = intégrité future $\mathcal{O}$: $\uparrow\uparrow$ base légale solide

## 10.2 La Convention de Malabo : Réponse Africaine

### 10.2.1 Contexte et entrée en vigueur

La **Convention de Malabo** (Convention de l'Union Africaine sur la cybersécurité et la protection des données personnelles) a été adoptée le 27 juin 2014 et est entrée en vigueur le 8 juin 2023, après sa 15$^{e}$ ratification. En 2026, environ 15–16 États africains l'ont ratifiée.

Contrairement à Budapest (purement pénale), Malabo est une convention **trifonctionnelle** : elle couvre simultanément le commerce électronique (Chap. II), la protection des données personnelles (Chap. III) et la cybercriminalité (Chap. V).

### 10.2.2 Infractions spécifiques à Malabo

Par rapport à Budapest, Malabo ajoute trois infractions absentes :

- **Usurpation d'identité (art. V-41)** : ABSENTE de Budapest. Malabo criminalise spécifiquement l'usurpation d'identité en ligne. Directement applicable : SIM swapping, faux profils Facebook, phishing par usurpation de marque.
- **Cyberterrorisme (art. V-42)** : actes terroristes via les TIC ou ciblant des infrastructures critiques. Pertinent pour les menaces Boko Haram utilisant les réseaux sociaux.
- **Cybersquatting (art. V-46)** : enregistrement de noms de domaine imitant des marques ou institutions de mauvaise foi ; faux sites imitant les banques camerounaises, administrations, opérateurs Mobile Money.

### 10.2.3 Tableau comparatif Budapest / Malabo

| Critère | Budapest (2001) | Malabo (2014) |
|---|---|---|
| Origine | Conseil de l'Europe | Union Africaine |
| Portée | Mondiale (ouverte à tous) | Africaine (membres UA) |
| États parties (2026) | ≈ 68 | ≈ 15–16 |
| Entrée en vigueur | 1er juillet 2004 | 8 juin 2023 |
| Infractions spécif. | Art. 2–11 + CSAM + droit d'auteur | Idem + usurpation identité + cyberterrorisme + cybersquatting |
| Protection données | Absente (couverte par Convention 108) | Intégrée (Chap. III complet) |
| Commerce électronique | Absent | Intégré (Chap. II) |
| Coopération | Réseau 24/7 (art. 35), MLAT, art. 29 | AFRIPOL ; moins formalisé |
| Force contraignante | Élevée ; jurisprudence abondante | Plus faible ; texte récent, peu de pratique |
| Position Cameroun | Non signataire, influence via Loi 2010 | Signataire non-ratifiant (juin 2026) |

*Tableau 10.3. Comparaison Budapest / Malabo*

**Règles de choix entre Budapest et Malabo**

1. Utiliser toujours le texte que l'État requis a ratifié.
2. Si l'État requis a ratifié les deux → Budapest en priorité (plus de pratique, mécanismes plus rodés).
3. Si l'État requis a ratifié Malabo mais pas Budapest (ex. : Angola) → Malabo Chap. V.
4. Si l'État requis n'a ratifié ni l'un ni l'autre → accords bilatéraux ou canal INTERPOL/AFRIPOL.
5. Vérification obligatoire avant toute demande : `treaty.un.org` (Budapest) et `au.int` (Malabo).

## 10.3 Les Protocoles Additionnels de Budapest

| Protocole | Objet | Impact opérationnel |
|---|---|---|
| **Protocole I** (STE 189, 2003) | Contenus racistes et xénophobes | 35 États. USA non-signataire. Demandes difficiles vers les USA pour ce type de contenu. |
| **Protocole II** (STE 224, 2022, en vigueur 2024) | Accès élargi aux données stockées dans le cloud | Délai 45–90 jours vs 18 mois pour MLAT classique. Révolutionne la forensique cloud transfrontalière. |

*Tableau 10.4. Protocoles additionnels Budapest*

Le Protocole II est particulièrement important : il crée une procédure accélérée pour accéder aux données cloud détenues par des fournisseurs dans les États parties. Pour la forensique cloud, il représente un changement de paradigme : délais de mois réduits à semaines.

## 10.4 INTERPOL et AFRIPOL : Architecture de la Coopération

### 10.4.1 INTERPOL. réseau mondial

| Composante | Description |
|---|---|
| Structure | 195 pays membres. Siège : Lyon. Bureau régional Afrique centrale : Yaoundé. Direction Cybercriminalité : Singapour (IGCI). |
| Réseau I-24/7 | Réseau mondial sécurisé entre les 195 BCN. Accessible uniquement via le BCN national (DGSN pour le Cameroun). |
| Notices | 7 types : **Rouge** (arrestation), **Bleue** (renseignements), Verte (avertissement), Mauve (modes opératoires), Orange (menaces), Jaune (disparitions), Noire (cadavres). |
| Opérations récentes | HAECHI I–IV (fraudes en ligne Asie) ; FALCON I–II (fraude au courriel d'affaires, Nigeria) ; GOLDFISH ALPHA (malwares routeurs). |

*Tableau 10.5. Architecture INTERPOL cyber*

*Procédure d'activation du réseau 24/7*

| Paramètre | Détail |
|---|---|
| Qui peut activer ? | Tout OPJ, via la chaîne hiérarchique → BCN Cameroun (DGSN/DCPJ) → réseau I-24/7. Impossible de bypasser le BCN. |
| Types de demandes | Conservation urgente (art. 29 Budapest), identification IP, identification abonné, localisation suspect. |
| Délais moyens | Conservation : 24–48h. Identification IP : 48–72h. Identification abonné : 72h–7 jours. |
| Format | Fiche INTERPOL standardisée (disponible au BCN). Minimum : infraction, données à identifier, urgence motivée, coordonnées de contact. |
| Suivi | Toujours noter un numéro de référence interne. Relancer après 48h sans réponse. Urgence vitale : appel téléphonique direct au BCN du pays requis. |

*Tableau 10.6. Procédure réseau 24/7 INTERPOL*

### 10.4.2 AFRIPOL. coopération africaine

**AFRIPOL** est le mécanisme de coopération policière de l'Union Africaine : opérationnel depuis 2014, siège à Alger, unité Cybercriminalité créée en 2017.

➢ **Opérations FALCON (2020) et FALCON II (2021–2022)** : conduites par INTERPOL avec la police nigériane et des partenaires privés contre des réseaux de fraude au courriel d'affaires ; trois puis onze arrestations au Nigeria [16], [17].

➢ **Ce qu'AFRIPOL apporte** : un cadre continental pour prolonger ce type d'opération au-delà d'un seul pays ; sa participation à une opération donnée se vérifie dans les communiqués officiels.

➢ **Avantage comparatif** : meilleure compréhension du contexte africain, moins de barrières culturelles. Utiliser en complément d'INTERPOL, pas à sa place.

## 10.5 Les MLAT et les Portails LEA

### 10.5.1 La règle d'or : conservation avant divulgation

★ Attention

**RÈGLE D'OR. CONSERVATION AVANT TOUT**

1. **Conservation IMMÉDIATE**. réseau 24/7 INTERPOL / portail LEA urgence, délai cible : 24–72h.
2. **Qualification + instrument**. Budapest / Malabo / accord bilatéral applicable.
3. **MLAT formel**. dans les 60 jours, pour obtenir les données avec valeur probatoire opposable en tribunal.

**Erreur fatale :** attendre le MLAT pour demander la conservation. Le MLAT prend 3 semaines à 18 mois. Les données volatiles disparaissent en heures.

### 10.5.2 Les portails LEA des grands fournisseurs

| Fournisseur | Portail | Données disponibles | Délais |
|---|---|---|---|
| **Meta** (FB, IG, WA) | `facebook.com/recor` | Abonné, logs, IP connexion. Contenu messages : MLAT USA. | Standard : 7–21j. Urgence : 24–72h. |
| **Google** (Gmail, YT, Android) | `support.google.com/` | Abonné Gmail, localisation Android (précise). Contenu : MLAT. | Standard : 10–30j. Urgence : 24–48h. |
| **Microsoft** (Outlook, OneDrive) | `microsoft.com/lega` | Abonné, historique connexion. Contenu : MLAT. | Le plus réactif aux demandes étrangères. |
| **TikTok** | `tiktok.com/legal/l` | Abonné, activité. | Standard : 14–30j. |
| **Telegram** | (portail limité) | Répond rarement sans ordonnance. | Privilégier MLAT. |

*Tableau 10.7. Portails LEA des grands fournisseurs*

**Application OPJ/Expert Judiciaire**

**WhatsApp : limite technique irréductible**

Le chiffrement de bout en bout d'WhatsApp signifie que Meta *ne peut pas* fournir le contenu des messages, même avec une ordonnance. Accessible via portail LEA : uniquement les métadonnées (qui a communiqué avec qui, quand, durée). Le contenu des messages nécessite un MLAT USA, et même alors, Meta ne peut fournir que ce qu'elle stocke (métadonnées).

**Alternative pratique :** saisir physiquement le téléphone du suspect et acquérir les messages via ADB (si téléphone déverrouillé), la donnée est sur l'appareil, pas chez Meta.

## 10.6 Tableau de Décision : Quel Canal pour Quelle Demande ?

| Situation | Protocole d'action | Délais et remarques |
|---|---|---|
| Urgence vitale (menace de mort, CSAM actif) | 1. Portail LEA urgent (24–72h). 2. BCN INTERPOL 24/7. 3. Conservation urgente art. 29. | Agir immédiatement. Ne pas attendre l'autorisation judiciaire formelle pour la conservation. |
| Données volatiles (IP suspecte, logs) | 1. *IMMÉDIATEMENT* : conservation BCN INTERPOL. 2. Portail LEA en parallèle. 3. MLAT dans les 60 jours. | Conservation = réflexe n° 1. Tout le reste peut attendre. |
| Identification IP étrangère | 1. WHOIS (pays propriétaire). 2. Si Budapest : réseau 24/7 BCN. 3. Réquisition FAI camerounais si IP de transit. | 48h–7j. FAI européens/américains : conservation 6 mois–1 an. |
| Compte réseau social | 1. Portail LEA fournisseur. 2. Urgence : cocher Emergency. 3. BCN INTERPOL si délai insuffisant. | Abonné : 7–30j. Urgence : 24–72h. Contenu : MLAT (mois). |
| Gel de fonds crypto | 1. Identifier plateforme et pays. 2. GABAC → GIABA. 3. Demande gel via canaux financiers. | Plateformes légales : obligations AML/KYC. Bitcoin : analyse blockchain via Blockchair. |
| État africain signataire Malabo | 1. Vérifier ratification (au.int). 2. Citer Malabo Chap. V. 3. AFRIPOL si nécessaire. | En cas de doute : contacter AFRIPOL directement. |
| État non-signataire Budapest/Malabo | 1. Accords bilatéraux. 2. Canal INTERPOL hors Budapest. 3. Chercher nœuds de la chaîne dans des pays coopérants. | Russie, Chine : coopération limitée. Chercher les nœuds intermédiaires dans des pays plus accessibles. |

*Tableau 10.8. Tableau de décision : canal selon la situation*

## 10.7 Cas Pratique : Opération BAOBAB

**Scénario Opérationnel · Opération BAOBAB. Fraudes MoMo transfrontalières**

**Contexte :** Fraudes MTN MoMo : 47 millions FCFA détournés en 3 mois sur 23 victimes camerounaises. Les fonds ont été transférés vers un compte Binance, convertis en Bitcoin et envoyés vers une adresse dont la dernière connexion provient d'une IP sénégalaise (`41.82.XXX.XXX`, Sonatel).

**Données disponibles :**

1. IP de connexion au compte Binance.
2. Email du compte Binance.
3. Adresse Bitcoin de destination.
4. Dates et montants de toutes les transactions MTN MoMo.

**Trois actions simultanées :**

| Action | Description | Base légale et délai |
|---|---|---|
| **Action 1**. Conservation Binance | Demande de conservation urgente : données d'abonne, logs, transactions. Via portail LEA Binance + BCN INTERPOL. | Art. 16/29 Budapest si État partie ; portail LEA. Cible : 48h. |
| **Action 2**. Identification IP Sénégal | Demande d'entraide urgente vers Sonatel pour identification de l'abonné de l'IP sénégalaise. | Art. 29 Budapest (Sénégal est partie). BCN Sénégal. 7–14 jours. |
| **Action 3**. Analyse blockchain | Tracer l'adresse Bitcoin de destination. Identifier les transferts ultérieurs et les plateformes d'échange. | `Blockchair.com` (gratuit, public). Résultat immédiat. |

*Tableau 10.9. Opération BAOBAB : trois actions simultanées*

★ Attention

**Erreurs les plus fréquentes dans cet exercice :**

1. Envoyer directement une demande de divulgation sans conservation préalable : les données sont effacées avant réponse.
2. Ne pas citer la base légale dans la demande : une demande sans base légale est systématiquement renvoyée.
3. Adresser la demande directement à Sonatel sans canal officiel : une demande directe à un opérateur étranger sans voie officielle a peu de chances d'aboutir rapidement.

★ À retenir

**Ce qu'il faut retenir de ce chapitre :**

➢ Le Cameroun **n'est pas signataire de Budapest** mais la Loi 2010/012 en est

directement issue : les deux textes sont alignés. Maîtriser Budapest comme si le Cameroun en était partie.

- **Articles Budapest à retenir :** art. 2 (accès illégal) ; art. 8 (fraude : le plus utilisé) ; art. 16 (conservation nationale : 90 jours max) ; art. 29 (conservation urgente transfrontalière : réflexe n° 1) ; art. 35 (réseau 24/7).
- **Malabo** ajoute trois infractions absentes de Budapest : usurpation d'identité, cyberterrorisme, cybersquatting. Moins de pratique mais adapté à la réalité africaine.
- **Règle d'or** : Conservation → Qualification → MLAT (dans cet ordre, toujours). Ne jamais attendre le MLAT pour demander la conservation.
- **Portails LEA** : Meta/Google/Microsoft permettent d'obtenir les données d'abonné en 24h–30j. Le contenu des messages nécessite toujours un MLAT.
- **INTERPOL réseau 24/7** : accessible via le BCN Cameroun (DGSN). Délais : 24–48h pour conservation, 48–72h pour identification IP.
- **Le tableau de décision** (Tableau 10.8) est le mémo opérationnel : une ligne par situation, trois colonnes : protocole, canal, délai.

### ✍ Exercice 10.1. Qualification internationale ★☆☆

Pour chacune des situations suivantes, identifiez : (A) l'article Budapest applicable, (B) l'article équivalent de la Loi 2010/012, (C) une divergence éventuelle et ses conséquences pratiques :

(a) Un groupe de hackers depuis le Nigeria a accédé au système de gestion des marchés publics camerounais et modifié des données d'attribution.

(b) Un ressortissant sénégalais a intercepté les communications d'un dirigeant d'entreprise camerounais via un logiciel espion.

(c) Un réseau distribué dans 12 pays envoie 4 millions de faux emails au nom d'UBA Cameroun, récoltant les identifiants bancaires de 3 000 victimes.

(d) Un site web hébergé en Côte d'Ivoire imite fidèlement le portail de Mobile Money de MTN Cameroun pour voler les identifiants.

### ✍ Exercice 10.2. Choix de canal ★★☆

Pour chacun des 6 scénarios suivants, identifiez le canal de coopération à activer en premier, la base légale applicable, et le délai attendu :

(a) Serveur de phishing bancaire hébergé aux Pays-Bas (Budapest).

(b) Compte Facebook d'un harceleur identifié au Sénégal (Budapest + Malabo).

(c) Fonds blanchis sur Orange Money Côte d'Ivoire (Malabo ratifié).

(d) Serveur C2 de logiciel espion situé en Russie (non-Budapest, non-Malabo).

(e) Vidéo terroriste Boko Haram sur YouTube (serveurs USA).

(f) Contenu CSAM sur Telegram.

### ✍ Exercice 10.3. Rédaction de demande de conservation ★★★

Dans l'Opération WOURI (Chapitre 3), vous avez identifié : l'IP `91.XXX.XX.XX` (enregistrée aux Pays-Bas) comme origine de l'email de phishing ; un compte Binance utilisé pour le blanchiment ; une adresse Bitcoin liée à des transactions vers un exchange aux Émirats arabes unis (Budapest-ratifié depuis 2021).

(a) Rédigez la demande de conservation urgente selon art. 29 Budapest pour l'IP néerlandaise : base légale, nature de l'infraction, données demandées, urgence motivée, délai demandé.

(b) Quels sont les trois éléments *sans lesquels* la demande sera systématiquement rejetée ?

(c) Appliquez la grille CRO à la décision d'activer simultanément les trois canaux (Pays-Bas, Binance, EAU) : quels risques pour $\mathcal{C}$ et comment les gérer ?

### ● Note

**Transition.** Le Chapitre 11 approfondit la **législation mondiale comparative** : RGPD [38], CLOUD Act [8], NIS 2 en Europe ; CCPA aux États-Unis ; PIPL en Chine. Ces législations conditionnent directement la coopération internationale : savoir ce que le droit local d'un État partenaire autorise ou interdit est indispensable pour formuler des demandes qui aboutissent.

11

# LÉGISLATION MONDIALE ET RÉGIONALE

« Cybercrime knows no borders, but our laws still do. International cooperation is not just desirable, it's imperative. »

Susan W. Brenner

**Niveau :** *Fondamental* • Lecture des Chapitres 10 (Cadre normatif global) recommandée : ce chapitre examine les droits nationaux que le Chapitre 10 ne couvre pas directement.

**✦ Objectifs du chapitre**

- ➢ Comprendre le droit américain applicable aux investigations impliquant des fournisseurs US : FRE, SCA, CFAA, CLOUD Act [8].
- ➢ Identifier les tensions entre RGPD [38] européen et investigation forensique, et comprendre comment les résoudre en pratique.
- ➢ Maîtriser eIDAS et NIS 2 : leur impact sur la valeur probatoire des preuves numériques et la sécurité des systèmes.
- ➢ Connaître les cadres régionaux africains : CEDEAO, SADC, EAC et leur utilité opérationnelle pour les OPJ camerounais.
- ➢ Appliquer une grille de lecture comparative pour choisir la stratégie juridique optimale dans une affaire transfrontalière.

## Question directrice de ce chapitre

Quand un OPJ camerounais réquisitionne Google pour les emails d'un suspect, c'est le droit américain qui s'applique chez Google, pas le droit camerounais. Quand des preuves proviennent d'un serveur hébergé en Allemagne, c'est le RGPD qui contraint le fournisseur. Quand un partenaire sénégalais coopère sur une affaire transfrontalière, c'est leur propre cadre législatif qui détermine ce qu'ils peuvent partager.

Ce chapitre répond à une question pratique : *quel droit local s'applique chez quel partenaire, et qu'est-ce que cela change concrètement pour mes demandes et mes preuves ?*

## 11.1 Droit Américain : le Cadre des Grands Fournisseurs

Les plus grands fournisseurs de services numériques mondiaux (Google, Meta, Microsoft, Amazon, Apple) sont des entreprises américaines soumises au droit fédéral des États-Unis. Comprendre ce droit n'est pas une option académique : c'est la condition pour formuler des demandes qui aboutissent.

### 11.1.1 Federal Rules of Evidence (FRE) : admissibilité aux États-Unis

Les **Federal Rules of Evidence** (FRE) régissent l'admissibilité des preuves devant les juridictions fédérales américaines. Deux règles sont particulièrement importantes pour la forensique numérique internationale :

**Jurisprudence & Droit applicable**

**FRE Rule 901. Authentication :**

> To satisfy the requirement of authenticating or identifying an item of evidence, the proponent must produce evidence sufficient to support a finding that the item is what the proponent claims it is.

**Application numérique :** les hash SHA-256 sont acceptés comme preuve d'authenticité ; la chaîne de custody doit être documentée ; le témoignage d'un expert est souvent requis pour expliquer les méthodes forensiques. MD5 est considéré *deprecated* pour les nouveaux dossiers.

**Jurisprudence & Droit applicable**

**FRE Rule 803(6). Business Records Exception :** Les enregistrements de routine d'une entreprise (logs système, emails conservés, transactions financières) sont admissibles même sans témoignage direct si : (1) ils ont été créés dans le cours normal des affaires ; (2) ils ont été conservés selon les procédures habituelles de l'entreprise ; (3) un représentant qualifié en atteste.

**Impact forensique :** les réponses aux réquisitions LEA de Meta ou Google constituent des "business records", elles sont directement admissibles selon cette règle devant les tribunaux américains, et leur valeur probatoire est reconnue dans la plupart des juridictions francophones par réciprocité.

### 11.1.2 Stored Communications Act (SCA) : protection et accès

Le **Stored Communications Act** (SCA, 18 U.S.C. §§ 2701–2712) protège les communications électroniques stockées par des tiers. Il régit ce que les fournisseurs américains *peuvent* et *doivent* communiquer aux forces de l'ordre.

| Type de données | Instrument requis | Impact pour les OPJ camerounais |
|---|---|---|
| Données d'abonné de base (nom, adresse, facturation) | Administrative subpoena | Accessibles via portail LEA sur simple réquisition ; délai : 7–21 jours |
| Adresses IP de connexion, logs de session | Court order (18 U.S.C. § 2703(d)) | Portail LEA ; urgence : 24–72h ; standard : 7–30j |
| Contenu des communications (emails, messages) | Search warrant (mandat de perquisition) | **MLAT USA obligatoire** ; délai : 6–18 mois ; Protocole II Budapest peut réduire ce délai (si ratifié) |

*Tableau 11.1. SCA : instruments selon le type de données*

**Pourquoi les portails LEA ne donnent pas le contenu des emails**

Le SCA interdit aux fournisseurs américains de communiquer le contenu des communications sans warrant (mandat de perquisition), même à des autorités étrangères. Ce n'est pas un refus de coopérer, c'est une obligation légale. La seule voie légale pour obtenir le contenu est le MLAT ou le Protocole II Budapest (si l'État requis l'a ratifié). Reformuler la demande en ciblant les métadonnées (admissibles sans warrant) est souvent la stratégie plus rapide et suffisante.

### 11.1.3 Computer Fraud and Abuse Act (CFAA) : base des poursuites US

Le **CFAA** (18 U.S.C. § 1030) définit les infractions informatiques fédérales américaines. Bien que principalement applicable aux faits commis sur le sol américain, il importe à deux titres :

1. **Base de coopération** : quand l'OPJ camerounais demande une entraide aux États-Unis, la demande doit démontrer que les faits constituent une infraction dans les deux pays (*double incrimination*). Montrer que les faits tombent sous le CFAA *et* sous la Loi 2010/012 [34] renforce la demande.
2. **Compétence extraterritoriale** : le CFAA s'applique quand une infrastructure américaine est visée ou utilisée, même si l'auteur et la victime sont à l'étranger. Un attaquant nigérian ciblant une banque camerounaise via des serveurs Amazon peut être poursuivi aux États-Unis.

| Infraction CFAA | Peine max. | Équivalent Loi 2010/012 |
|---|---|---|
| Accès non autorisé à un ordinateur protégé | 1–10 ans | Art. 65 al. 2 (accès illicite) |
| Accès avec obtention d'information | 1–10 ans | Art. 65 al. 2–3 + Art. 72 si préjudice |
| Dommages intentionnels (ransomware) | 10 ans (1re offense) | Art. 66–67 (atteinte au système et aux données) |
| Fraude informatique | 5–20 ans | Art. 72 (fraude informatique) |

*Tableau 11.2. CFAA et équivalents Loi 2010/012*

### 11.1.4 CLOUD Act : accès transfrontalier aux données

Le **CLOUD Act** (*Clarifying Lawful Overseas Use of Data Act*, 2018) est la loi la plus controversée dans le domaine de la coopération numérique internationale. Elle détermine les obligations des entreprises américaines vis-à-vis des demandes étrangères.

**$\Gamma_{CRO}$ Analyse CRO · Confidentialité · Fiabilité · Opposabilité**

**Analyse CRO. CLOUD Act**

$\mathcal{R}$ (Fiabilité) : le CLOUD Act permet aux autorités américaines d'accéder aux données stockées par des entreprises US *n'importe où dans le monde*, indépendamment du pays de stockage. Pour la forensique : les preuves obtenues via CLOUD Act ont une valeur probatoire élevée car elles sont certifiées par l'entreprise américaine.

$\mathcal{O}$ (Opposabilité) : les données obtenues via CLOUD Act sont admissibles devant les tribunaux américains selon FRE 803(6), et généralement reconnues par réciprocité dans les pays partenaires.

$\mathcal{C}$ (Confidentialité) : **tension majeure.** Le CLOUD Act signifie que les données d'un ressortissant camerounais hébergées chez Google aux États-Unis peuvent être accessibles aux autorités américaines sans que le Cameroun en soit informé. La souveraineté numérique camerounaise est directement engagée.

$\mathcal{C}$: $\downarrow\downarrow$ tension souveraineté $\mathcal{R}$: $\uparrow$ pour preuves obtenues $\mathcal{O}$: $\uparrow\uparrow$ recov. us-based

**Implication pratique :** pour les OPJ camerounais le CLOUD Act joue en leur faveur : les partenaires américains peuvent obtenir des données chez des fournisseurs US plus facilement qu'un MLAT classique, et les partager via accords bilatéraux.

## 11.2 Droit Européen : RGPD, eIDAS, NIS 2 et e-Evidence

L'Union Européenne a construit le cadre normatif numérique le plus dense au monde. Pour un OPJ camerounais coopérant avec des partenaires européens ou réquisitionnant des fournisseurs basés en Europe, quatre textes sont directement pertinents.

### 11.2.1 RGPD : tensions avec l'investigation forensique

Le **RGPD** (Règlement (UE) 2016/679) est le texte de référence mondial sur la protection des données personnelles. Il crée des tensions structurelles avec la forensique numérique :

| Droit RGPD | Tension forensique | Résolution |
|---|---|---|
| Droit à l'effacement (art. 17) | Un suspect peut demander la suppression de ses données chez un fournisseur européen, y compris des preuves potentielles | Art. 17(3)(e) : exception pour *constatation, exercice ou défense de droits en justice* ; conservation possible sur injonction |
| Minimisation des données (art. 5) | La collecte exhaustive de toutes les données d'un suspect viole le principe de minimisation | L'investigation judiciaire constitue une base légale distincte (art. 6(1)(e) : mission d'intérêt public) |
| Notification de violation (art. 33) | Un fournisseur victime d'une fuite doit notifier sous 72h. ce qui peut alerter le suspect visé | Les autorités judiciaires peuvent demander le report de la notification (art. 23) si cela entrave l'enquête |

*Tableau 11.3. Tensions RGPD / investigation forensique*

**Jurisprudence & Droit applicable**

**RGPD Article 23. Limitations :**

> Le droit de l'Union ou le droit d'un État membre *[. . . ]* peut limiter la portée des obligations *[. . . ]* lorsqu'une telle limitation respecte l'essence des libertés et droits fondamentaux et qu'elle constitue une mesure nécessaire et proportionnée dans une société démocratique pour garantir : *(d) la prévention et la détection d'infractions pénales, ainsi que les enquêtes et les poursuites en la matière ou l'exécution de sanctions pénales.*

**Implication opérationnelle :** l'article 23 est la base légale qui permet aux partenaires européens de transmettre des données au Cameroun malgré le RGPD, dans le cadre d'une coopération judiciaire. Citer explicitement cet article dans toute demande d'entraide adressée à un État européen.

### 11.2.2 eIDAS : valeur probatoire des signatures et horodatages électroniques

Le règlement **eIDAS** (Règlement (UE) 910/2014, révisé 2024) établit un cadre pour la confiance numérique en Europe. Son impact forensique porte sur la valeur probatoire des documents électroniques provenant d'Europe.

| Niveau | Description | Valeur probatoire |
|---|---|---|
| **Signature simple** | Toute donnée électronique liée à un signataire | Faible ; contestable |
| **Signature avancée** | Identifie le signataire de manière unique ; liée aux données de façon détectable en cas de modification | Moyenne ; présomption simple d'authenticité |
| **Signature qualifiée** | Certificat qualifié + dispositif sécurisé certifié QSCD ; équivalent légal d'une signature manuscrite | **Maximale** ; présomption irréfragable en droit européen |
| **Horodatage qualifié** | Preuve d'existence d'un document à un instant précis ; délivré par une autorité de confiance certifiée | **Force probante maximale** pour la date d'existence |

*Tableau 11.4. Niveaux de signature et valeur probatoire (eIDAS)*

**eIDAS et forensique camerounaise**

Quand un partenaire européen transmet des preuves numériques signées avec une signature qualifiée eIDAS, ces preuves ont une valeur probatoire maximale en droit européen. Dans un tribunal camerounais, la **Loi 2024/017** [36] (art. 6 : principe d'intégrité) et les principes généraux du droit de la preuve permettent de faire reconnaître cette valeur si l'expert forensique explique le système de certification. Documenter systématiquement le niveau eIDAS des documents reçus dans le rapport d'analyse.

### 11.2.3 NIS 2 : implications pour la forensique d'incident

La Directive **NIS 2** (Directive (UE) 2022/2555) impose des obligations de cybersécurité aux opérateurs de secteurs essentiels dans l'UE. Son impact sur la forensique :

- **Obligation de notification d'incident** : les entités essentielles doivent notifier l'incident dans les 24h à l'autorité nationale compétente, et dans les 72h un rapport initial complet. Ces rapports d'incident constituent des preuves documentaires exploitables en forensique.
- **Logs conservés** : NIS 2 impose la conservation de logs de sécurité pendant une durée suffisante pour permettre les investigations post-incident. Pour l'OPJ coopérant avec un partenaire UE : ces logs existent, ils sont conservés, ils peuvent être requis.
- **Incident Response Plans** : les entités NIS 2 sont tenues de maintenir des procédures de réponse aux incidents documentées. La conformité NIS 2 d'un partenaire est une garantie de qualité probatoire de ses données.

### 11.2.4 Règlement e-Evidence : la révolution en cours

Le Règlement (UE) 2023/1543 (**e-Evidence**), applicable depuis 2026, crée un mécanisme direct pour l'obtention de preuves électroniques entre les États membres de l'UE :

- **European Production Order** : les autorités judiciaires d'un État membre peuvent directement requérir un fournisseur établi dans un autre État membre ; délai cible : 10 jours (6h en urgence).
- **Impact pour le Cameroun** : les délais de coopération intra-UE se raccourcissent drastiquement ; les partenaires européens du Cameroun peuvent obtenir des données pan-européennes bien plus vite, et les partager ensuite dans le cadre d'un MLAT.

## 11.3 Droit Africain Régional : CEDEAO, SADC et EAC

### 11.3.1 CEDEAO : le cadre d'Afrique de l'Ouest

La **CEDEAO** (*Communauté Économique des États de l'Afrique de l'Ouest*) a adopté deux textes harmonisant le droit numérique de ses 15 membres :

| Texte | Contenu et pertinence forensique |
|---|---|
| **Directive C/DIR/1/08/11** sur la cybercriminalité | Harmonise les infractions cyberpénales : accès illicite, interception, atteinte à l'intégrité. Infractions similaires à Budapest. **Pertinence :** base pour demandes de coopération vers les membres CEDEAO (Sénégal, Ghana, Nigeria : membres). |
| **Acte additionnel A/SA.2/01/10** sur les données personnelles | Définit les principes de protection des données pour les États membres. Influence les réponses aux réquisitions de données de citoyens des États membres. |

*Tableau 11.5. Textes CEDEAO pertinents pour la forensique*

**CEDEAO et coopération avec le Nigeria et le Sénégal**

Le Nigeria et le Sénégal (deux États membres CEDEAO ayant également ratifié Budapest) constituent les partenaires les plus sollicités par les OPJ camerounais dans les affaires transfrontalières. La CEDEAO ajoute une couche de coopération régionale : des demandes peuvent être acheminées via le mécanisme CEDEAO *en plus* du canal INTERPOL, augmentant les chances d'obtenir une réponse rapide.

### 11.3.2 SADC : le modèle d'Afrique Australe

La **SADC** (*Southern African Development Community*) a développé une *Model Law on Computer Crime and Cybercrime* servant de référence pour l'harmonisation législative de ses 16 membres (Zimbabwe, Zambie, Mozambique, Afrique du Sud . . . ).

Points clés de la *Model Law* :

- Criminalisation cohérente avec Budapest des accès illicites, interceptions, atteintes à l'intégrité.
- Dispositions spécifiques sur la cyberfraude et les atteintes aux données financières : pertinent pour les fraudes bancaires transfrontalières Cameroun-Afrique du Sud.
- L'Afrique du Sud (*Cybercrimes Act* 2020) est le système le plus abouti de la région : laboratoire forensique national, unité cybercrime SAPS, coopération INTERPOL établie.

### 11.3.3 EAC : le cadre d'Afrique de l'Est

La **EAC** (*East African Community*) a développé un *Framework for Cyberlaws* couvrant les membres : Kenya, Tanzanie, Ouganda, Rwanda, Burundi, Sud-Soudan.

Pour les OPJ camerounais, les deux points de contact pertinents sont :

- **Rwanda** : l'un des cadres les plus avancés d'Afrique sub-saharienne ; *Computer Crime Law* 2020, Autorité nationale de cybersécurité (NCSA) opérationnelle.
- **Kenya** : *Computer Misuse and Cybercrimes Act* 2018 ; coopération INTERPOL active ; hub financier (M-Pesa) : réquisitions sur les fraudes mobile money régionales aboutissent bien.

## 11.4 Grille de Lecture Comparative : Choisir sa Stratégie Juridique

### 11.4.1 Tableau synthétique : droit local et implications opérationnelles

| Juridiction | Texte-clé | Spécificité forensique | Canal recommandé |
|---|---|---|---|
| **USA** | SCA + CLOUD Act | Contenu emails : mandat obligatoire. Métadonnées : portail LEA. | Portail LEA (métadonnées) ; MLAT USA (contenu) ; Protocole II Budapest si disponible |
| **UE** | RGPD + e-Evidence | Art. 23 RGPD : exception judiciaire. e-Evidence : 10 jours. | MLAT bilatéral ; e-Evidence (intra-UE) ; citer art. 23 RGPD explicitement |
| **Afrique West** | CEDEAO Directive | Harmonisation avec Budapest. Sénégal/Ghana/Nigeria : Budapest. | INTERPOL réseau 24/7 ; canal CEDEAO en complément |
| **Afrique Sud** | Malabo ; SADC Model Law | Rwanda/Kenya : lois modernes. Af-Sud : coopération établie. | INTERPOL ; AFRIPOL ; accords bilatéraux |
| **Russie / Chine** | (pas Budapest, pas Malabo) | Coopération très limitée. Chercher les nœuds intermédiaires. | Identifier les segments du chemin dans des États coopérants ; OSINT sur les nœuds accessibles |

*Tableau 11.6. Grille comparative : droit local et stratégie*

### 11.4.2 Processus de qualification d'une affaire transfrontalière

Face à une affaire impliquant un élément étranger, la démarche en cinq étapes :

1. **Identifier les éléments étrangers** : où est le serveur ? Où est le suspect ? Où est hébergé le fournisseur ? Où ont transité les fonds ?
2. **Cartographier les droits locaux applicables** : pour chaque État impliqué, quel texte encadre la coopération ? Budapest, Malabo, CEDEAO, accord bilatéral, ou rien ?
3. **Qualifier l'infraction en double incrimination** : montrer que les faits constituent une infraction dans les deux pays. Sans double incrimination, la coopération peut être refusée.
4. **Prioriser : données volatiles d'abord** : activer immédiatement la conservation (art. 29 Budapest, portail LEA). Le droit local du partenaire ne change rien à cette priorité.

5. **Choisir le canal adapté** : MLAT formel si contenu requis ; portail LEA si métadonnées suffisent ; INTERPOL 24/7 si urgence.

**Scénario Opérationnel · Affaire BEC Cameroun-UE-USA, stratégie juridique**

**Faits :** SONATRAV SA, Douala, perd 85 millions FCFA dans une attaque BEC. L'email frauduleux a été envoyé depuis une adresse Gmail (`@gmail.com`), via un VPN hébergé en Allemagne. Les fonds ont transité vers un compte Revolut (UE) puis vers Binance (Caïmans).

**Cartographie juridique :**

- Gmail → **Google USA** : SCA ; métadonnées via portail LEA ; contenu MLAT USA ; base : CFAA § 1030 (fraude via ordinateur protégé) + Loi 2010/012 art. 72.
- VPN Allemagne → **droit allemand + RGPD** : MLAT franco-camerounais indirect (via UE) ; citer art. 23 RGPD ; e-Evidence § si partenaire UE impliqué.
- Revolut (Lituanie/UE) → **RGPD + e-Evidence** : European Production Order ; délai 10 jours.
- Binance → identifier la juridiction réelle ; analyse blockchain Blockchair ; portail LEA Binance si disponible.

**Séquence d'actions :**

1. Conservation urgente simultanée : portail LEA Google (urgence) + BCN INTERPOL pour VPN Allemagne (art. 29 Budapest).
2. Analyse blockchain Binance : tracer les fonds (OSINT légal).
3. MLAT USA pour contenu Gmail dans les 60 jours.
4. Demande e-Evidence à Revolut Lituanie.

**★ À retenir**

**Ce qu'il faut retenir de ce chapitre :**

- **Droit USA** : SCA impose un *mandat* pour le contenu des communications ; les métadonnées s'obtiennent via portail LEA. CLOUD Act : les entreprises US peuvent livrer des données stockées n'importe où. CFAA : base pour la double incrimination.
- **RGPD européen** : tension structurelle avec la forensique, résolue par l'art. 23 (exception judiciaire) et l'art. 6(1)(e) (mission d'intérêt public). Citer explicite-

ment ces articles dans toute demande à un partenaire européen.

- **eIDAS** : trois niveaux de signature ; la signature qualifiée a valeur légale maximale ; l'horodatage qualifié prouve l'existence à un instant ; documenter le niveau eIDAS des preuves reçues d'Europe.
- **NIS 2** : impose la conservation de logs et la notification d'incidents ; les entités conformes constituent des sources de preuves documentaires de qualité.
- **Afrique régionale** : CEDEAO renforce les demandes vers Sénégal/Ghana/Nigeria ; SADC couvre l'Afrique australe (Afrique du Sud : meilleur partenaire forensique) ; EAC couvre Rwanda/Kenya (lois modernes, coopération active).
- **Double incrimination** : condition nécessaire dans la plupart des coopérations ; montrer que les faits constituent une infraction chez les deux partenaires. Loi 2010/012 + CFAA/RGPD-infraction/Budapest = base solide.
- **Grille de décision en 5 étapes** : identifier les éléments étrangers → cartographier les droits → double incrimination → conservation d'abord → canal adapté.

### ✍ Exercice 11.1. Identification du cadre légal ★☆☆

Pour chacune des situations suivantes, identifiez : (A) le ou les textes légaux applicables chez le partenaire étranger, (B) l'instrument requis pour obtenir les données demandées, (C) le délai réaliste :

(a) Vous souhaitez obtenir les données d'abonné d'un compte Gmail suspect (`@gmail.com`) utilisé dans une fraude MoMo.

(b) Vous devez obtenir le contenu des emails Outlook d'un suspect hébergés par Microsoft USA dans le cadre d'une escroquerie.

(c) Un serveur Apache hébergé en France a servi à déposer un malware. Vous demandez les logs d'accès au fournisseur d'hébergement.

(d) Un compte Facebook utilisé pour harcèlement identifie son propriétaire au Sénégal. Vous demandez les données d'abonné.

### ✍ Exercice 11.2. Tensions RGPD ★★☆

Un fournisseur d'hébergement allemand vous informe qu'il ne peut pas répondre à votre réquisition en raison du RGPD et du principe de minimisation des données :

(a) Quel article du RGPD invoqueriez-vous pour contester ce refus ? Rédigez le paragraphe de réponse à inclure dans votre demande.

(b) Quelle condition doit être remplie pour que l'exception judiciaire de l'art. 23

RGPD soit valablement invoquée ?

(c) Si le fournisseur maintient son refus, par quel canal alternatif pouvez-vous obtenir les données ?

(d) Appliquez la grille CRO à la décision d'invoquer l'art. 23 ou de passer directement au MLAT.

**✍ Exercice 11.3. Stratégie juridique complète ★★★**

Dans l'Opération WOURI (Chapitre 3), l'analyse révèle que l'attaque BEC implique :

- Email phishing envoyé depuis un compte Outlook (`@hotmail.fr`) hébergé en Irlande (centre de données Microsoft Europe) ;
- VPN utilisé : NordVPN (siège social : Panama, serveurs aux Pays-Bas) ;
- Compte bancaire destinataire : HSBC Hong Kong ;
- Fonds convertis en BTC et envoyés vers une adresse dont la dernière transaction pointe vers un exchange turc (Paribu).

(a) Pour chaque élément, identifiez le cadre légal applicable et l'instrument de coopération optimal.

(b) La double incrimination est-elle satisfaite dans chaque cas ? Justifiez en citant les textes de loi des deux pays.

(c) Rédigez le plan d'action chronologique complet : dans quel ordre agir, par quel canal, dans quel délai, et quel résultat attendre à chaque étape.

(d) Quel élément de cette chaîne est le plus vulnérable à un refus de coopération ? Proposez une stratégie de contournement.

**● Note**

**Transition.** Le Chapitre 12 approfondit le **droit camerounais du numérique** : architecture complète de la **Loi 2010/012** et de la **Loi 2024/017**, jurisprudence naissante, rôle de l'ANTIC, articulation avec le Code pénal et le Code de procédure pénale. Ce chapitre sera le plus important pour la rédaction des procès-verbaux et la qualification des infractions devant les tribunaux camerounais.

12

# DROIT CAMEROUNAIS ET AFRICAIN

« Africa must develop its own digital legal framework that respects both international standards and local cultural realities. »

Nnenna Ifeanyi-Ajufo

**Niveau :** *Fondamental* • Notions de droit général recommandées mais non indispensables : ce chapitre part de zéro sur le droit camerounais du numérique.

**✦ Objectifs du chapitre**

- ➢ Identifier les trois textes du cadre normatif national et leur articulation : **Loi 2010/012** [34], **Loi 2024/017** [36], Code pénal.
- ➢ Qualifier les infractions numériques les plus fréquentes au Cameroun (fraude, accès illicite, ransomware, CSAM) selon l'article de loi exact.
- ➢ Appliquer la **Loi 2024/017** aux violations de données personnelles et identifier les sanctions applicables.
- ➢ Maîtriser les règles d'articulation des trois textes : quand cumuler, quand choisir.
- ➢ Identifier les six erreurs de qualification les plus fréquentes et leurs conséquences sur la validité du dossier judiciaire.
- ➢ Rédiger un rapport de qualification d'infraction numérique transmissible au parquet.

## Ce chapitre dans la pratique quotidienne

Un OPJ qui ne maîtrise pas les qualifications nationales sera incapable de rédiger un procès-verbal valable, de choisir le bon article d'inculpation et de préparer un dossier transmissible au parquet. Les droits internationaux des chapitres précédents sont inutilisables sans cette fondation nationale.

**Méthode de ce chapitre :** partir systématiquement de cas concrets camerounais (fraudes MoMo, escroqueries Facebook, SIM swapping, ransomware) et remonter vers la qualification légale. Jamais l'inverse.

## 12.1 Architecture du Cadre Normatif National : Trois Textes

### 12.1.1 Vue d'ensemble

Trois textes constituent le droit camerounais du numérique :

| Texte | Objet | Rôle pour l'enquêteur |
|---|---|---|
| **Loi 2010/012** du 21 déc. 2010 | Cybersécurité et cybercriminalité | **Texte principal de qualification pénale.** 97 articles, 5 titres, 73 définitions. |
| **Loi 2024/017** du 23 déc. 2024 | Protection des données à caractère personnel | Complète la Loi 2010 pour les violations de données. Sanctions administratives ET pénales. |
| **Code pénal camerounais** | Droit pénal général | S'applique en cumul pour l'escroquerie, le faux, la diffamation, les menaces. |

*Tableau 12.1. Les trois textes du cadre national*

★ Attention

**Quatre points clés avant de qualifier :**

1. L'article 4 de la Loi 2010/012 définit **73 termes**. Ces définitions ont valeur juridique contraignante. Une qualification fondée sur une définition incorrecte fragilise le dossier.
2. La Loi 2010 n'abroge pas le Code pénal. **Les deux se cumulent.** Un même fait peut être à la fois escroquerie (CP) et fraude informatique (art. 72 Loi 2010).
3. **Art. 89 Loi 2010 : le sursis est impossible.** Tout condamné sous la Loi 2010 purge sa peine. Mentionner ce point dans chaque rapport transmis au parquet.
4. Le champ d'application est large : réseaux + systèmes d'information + équipements terminaux. **Un téléphone mobile est un équipement terminal. Un groupe WhatsApp est un réseau de communications électroniques.**

### 12.1.2 Architecture de la Loi 2010/012

| Titre | Contenu et articles clés |
|---|---|
| **Titre I**. Dispositions générales | Définitions (art. 4. 73 termes). Champ d'application. Exclusion défense/sécurité nationale (art. 2). |
| **Titre II**. Cybersécurité | Politique de sécurité (art. 6). Régulation ANTIC (art. 7–9). Certification et signature électronique (art. 10–23). Protection des réseaux et vie privée (art. 24–51). |
| **Titre III**. Cybercriminalité | **Dispositions processuelles (art. 52–59) : perquisitions, saisies, réquisitions. Infractions et sanctions (art. 60–89) : toutes les qualifications pénales.** |
| **Titre IV**. Coopération judiciaire | Entraide judiciaire internationale (art. 91–94). |
| **Titre V**. Dispositions finales | Textes d'application (art. 95–97). |

*Tableau 12.2. Architecture de la Loi 2010/012*

## 12.2 Les Infractions de la Loi 2010/012 : Titre III

### 12.2.1 Articles 65 à 69 : accès, interception, atteinte à l'intégrité

⚖ Jurisprudence & Droit applicable

**Article 65. Accès illicite et interception illégale :**

(1) Est puni d'un emprisonnement de cinq (05) à dix (10) ans et d'une amende de 5 000 000 à 10 000 000 F CFA *[...]* celui qui effectue, sans droit ni autorisation, l'interception par des moyens techniques, de données lors des transmissions *[...]* à destination, en provenance ou à l'intérieur ou non d'un réseau de communications électroniques.

(2) Est puni des mêmes peines tout accès non autorisé à l'ensemble ou à une partie d'un réseau de communications électroniques ou d'un système d'information ou d'un équipement terminal.

(3) Les peines prévues à l'alinéa 1 ci-dessus sont doublées, en cas d'accès illicite portant atteinte à l'intégrité, la confidentialité, la disponibilité du réseau ou du système d'information.

(4) Est puni des mêmes peines celui qui, sans droit, permet l'accès dans un réseau ou dans un système d'information par défi intellectuel.

**L'article fondamental.** Toute intrusion informatique non autorisée tombe sous cet article, qu'elle ait causé un dommage ou non. L'argument de la "simple curiosité" ne constitue pas une défense : l'al. 4 le criminalise explicitement.

**Circonstance aggravante (al. 3) :** peines doublées si l'accès porte atteinte à l'intégrité, la confidentialité ou la disponibilité. En pratique : toute intrusion qui modifie, copie ou rend inaccessibles des données tombe dans l'aggravation.

**Cas type PNC :** accès au compte bancaire en ligne d'un tiers en utilisant ses identifiants volés → art. 65 al. 2 + art. 65 al. 3 (données copiées).

**Jurisprudence & Droit applicable**

**Articles 66–67. Atteinte à l'intégrité des réseaux et systèmes :** Art. 66 al. 1 : puni de 2 à 5 ans + 1 000 000 à 2 000 000 F CFA, celui qui entraîne la perturbation ou l'interruption du fonctionnement d'un réseau en introduisant, transmettant, endommageant, effaçant, détériorant, modifiant, supprimant ou rendant inaccessibles les données.

**Distinction art. 66 vs art. 67 :** art. 66 = perturbation d'un réseau ou équipement terminal ; art. 67 = atteinte à l'intégrité d'un système d'information. Les deux peuvent être cumulés.

**Couverture pratique :** attaques DDoS (saturation = perturbation) ; ransomware (chiffrement = rendre inaccessibles) ; defacement de site web (modification = art. 67) ; sabotage de base de données.

**Jurisprudence & Droit applicable**

**Articles 68–69. Accès aggravé et espionnage informatique :** Art. 68 : puni de 5 à 10 ans + 10 M à 50 M F CFA celui qui accède ou se maintient frauduleusement dans un système en causant une perturbation. **Peines doublées si suppression ou modification de données (art. 68 al. 2).**

Art. 69 : accès en violation des mesures de sécurité pour obtenir des données d'un système interconnecté. Amende plafond : **100 millions FCFA.**

**Cas type art. 69 :** intrusion dans le système de paie d'une administration camerounaise depuis Internet pour extraire des données salariales.

### 12.2.2 Articles 70 à 72 et 86 : fraude, manipulation, abus de dispositifs

**Jurisprudence & Droit applicable**

**Article 72. Fraude informatique :** Est puni des peines de l'art. 66 celui qui, de quelque manière que ce soit, sans droit, introduit, altère, efface ou supprime, **afin d'obtenir un bénéfice économique**, les données électroniques, de manière à causer un préjudice patrimonial à autrui.

**Trois éléments constitutifs :** (1) acte sur des données (introduction, altération, effacement, suppression), (2) sans droit, (3) pour obtenir un bénéfice économique causant un préjudice patrimonial.

**L'article le plus utilisé pour les escroqueries en ligne.** BEC, phishing bancaire, fraude MoMo, modification de relevés bancaires tous tombent sous art. 72.

**Cumul recommandé :** art. 72 Loi 2010 + art. 318 Code pénal (escroquerie) quand la victime a été manipulée ET que des données ont été altérées.

**Jurisprudence & Droit applicable**

**Article 86. Abus de dispositifs informatiques :** Est puni d'un emprisonnement de 2 à 5 ans *[...]* celui qui importe, détient, offre, cède, vend ou met à disposition un programme informatique, un mot de passe, un code d'accès ou toutes données informatiques similaires conçus et/ou spécialement adaptés pour permettre d'accéder à un système d'information.

**Criminalise la préparation :** vendre un kit de phishing, partager des identifiants volés, mettre à disposition un logiciel d'intrusion même sans attaque effective.

**Peines accessoires (art. 87) :** confiscation des outils ; interdiction d'exercer une activité professionnelle (5 ans) ; fermeture d'établissement ; exclusion des marchés publics.

### 12.2.3 Article 88 : refus de remettre la clé de déchiffrement

**Jurisprudence & Droit applicable**

**Article 88. Refus de déchiffrement :** (1) Est puni d'un emprisonnement de **un (01) à cinq (05) ans** et d'une amende de **100 000 à 1 000 000 F CFA** celui qui refuse de remettre aux autorités judiciaires compétentes la convention secrète de déchiffrement d'un moyen cryptologique susceptible d'avoir été utilisé pour préparer ou commettre une infraction.
(2) Les peines prévues à l'alinéa 1 sont portées de 3 à 5 ans et de 1 000 000 à 5 000 000 F CFA lorsque la remise de ladite convention aurait permis d'éviter un crime ou délit ou d'en limiter les effets.

**Application OPJ/Expert Judiciaire**

**L'article 88 : réflexe obligatoire face à un téléphone chiffré**
Un suspect refuse de déverrouiller son téléphone. L'OPJ ne doit pas bloquer :

1. Obtenir une réquisition formelle du procureur ou du juge d'instruction (la réquisition est la condition préalable).
2. Si le suspect refuse après réquisition : art. 88 al. 1 constitue une infraction autonome *indépendante* de l'infraction principale.
3. Si des éléments montrent que le déchiffrement aurait permis d'éviter un crime en cours : art. 88 al. 2 (aggravé : 3–5 ans).
4. Documenter précisément : date et heure de la réquisition, formulation exacte

de la demande, refus exprimé clairement.

**Erreur fréquente :** beaucoup d'enquêteurs ignorent l'existence de cet article. Un dossier CSAM ou ransomware peut être débloqué par la seule citation de l'art. 88.

### 12.2.4 Article 76 : CSAM et contenus sexuels impliquant des mineurs

**Jurisprudence & Droit applicable**

**Article 76. Pornographie enfantine :** Est puni d'un emprisonnement de **cinq (05) à dix (10) ans** et d'une amende de **5 000 000 à 10 000 000 F CFA** celui qui fixe, enregistre, transmet ou diffuse, via un système d'information ou un réseau de communications électroniques, des images pornographiques impliquant des mineurs.

**Ressource opérationnelle clé :** NCMEC CyberTipline (`cybertipline.org`). Les fournisseurs américains ont l'obligation légale de signaler tout CSAM détecté ; les signalements sont transmis via INTERPOL.

**Cumul obligatoire :** art. 76 Loi 2010 + art. 295 Code pénal (attentat à la pudeur aggravé) + art. 80–81 Loi 2010 si proposition sexuelle en ligne à un mineur.

## 12.3 La Loi 2024/017 : Protection des Données Personnelles

### 12.3.1 Architecture et innovations par rapport à la Loi 2010

La **Loi 2024/017** du 23 décembre 2024 comble un vide : la Loi 2010 réprimait les violations de données, mais ne fixait pas les obligations préventives (consentement, sécurité obligatoire, registre de traitement, notification de violation). La Loi 2024 établit un système complet analogue au RGPD [38] européen.

| Titre / Chapitre | Objet | Articles clés |
|---|---|---|
| Titre I. Général | Champ d'application, définitions fondamentales | Art. 1–5 |
| Titre II. Principes | Légitimité, consentement, finalité, minimisation, sécurité | Art. 6–36 |
| Titre III. Droits | Accès, rectification, effacement, portabilité, opposition | Art. 37–47 |
| Titre IV. Interdictions | Données sensibles, profilage, traitements illicites | Art. 48–52 |
| Titre V. Autorité | Création et pouvoirs de l'Autorité de protection | Art. 53 |
| Titre VI. Sanctions | Administratives + pénales | Art. 54–71 |

*Tableau 12.3. Architecture de la Loi 2024/017*

### 12.3.2 Définitions fondamentales : art. 5

- **Donnée personnelle :** toute information permettant d'identifier directement ou indirectement une personne physique. **L'adresse IP est une donnée personnelle.** Une intrusion qui consigne les adresses IP des victimes active la Loi 2024.
- **Donnée sensible :** origine tribale ou raciale, opinions politiques, convictions religieuses, appartenance syndicale, données de santé, vie sexuelle, données génétiques, biométriques. **Protection renforcée : peines doublées (art. 74 al. 5 Loi 2010, art. 66 Loi 2024).**
- **Responsable du traitement :** toute personne physique ou morale qui détermine les finalités et les moyens du traitement.
- **Profilage :** traitement automatisé visant à évaluer des aspects personnels relatifs à une personne (santé, préférences, localisation, situation économique).

### 12.3.3 Obligations clés du responsable du traitement

**Jurisprudence & Droit applicable**

**Article 22. Notification de violation de données ("breach")**
Le responsable du traitement notifie **sans délai** à l'Autorité de protection toute violation de données à caractère personnel susceptible d'engendrer un risque pour les droits et libertés des personnes concernées.
**Sanction du défaut de notification :** art. 56 : amende administrative de 1 à 10 millions FCFA.
**Pour l'enquêteur :** quand une entreprise victime d'un ransomware ou d'une fuite de données n'a pas notifié l'Autorité noter ce manquement dans le rapport d'enquête. C'est une infraction administrative indépendante, sanctionnable en plus des infractions commises par l'attaquant.

**Jurisprudence & Droit applicable**

**Article 27. Sécurité obligatoire des données**
Le responsable du traitement met en œuvre *[. . . ]* les mesures techniques et organisationnelles appropriées : **traçabilité des accès** (journaux de connexion, logs d'audit) ; **contrôle d'accès** (principe du moindre privilège) ; chiffrement des données sensibles ; sauvegardes régulières et plans de continuité.
**Points utiles pour l'enquête :** (1) le responsable a l'obligation de constituer et conserver des logs d'audit ils existent, ils peuvent être requis ; (2) un employé qui accède à des données hors de son périmètre commet une infraction ET son employeur est en faute s'il n'avait pas mis en place les contrôles.

**Jurisprudence & Droit applicable**

**Article 32. Transfert international de données :** Le transfert de données à caractère personnel vers un État étranger est subordonné à une **autorisation préalable** de l'Autorité de protection, qui doit s'assurer : que le pays de destination offre un niveau de protection suffisant ; de l'entrée en vigueur d'un instrument juridique avec ce pays ; de la souscription de clauses contractuelles types.

**Sanction : art. 69 : 3 à 10 ans + 2 à 20 millions FCFA.** L'une des infractions les plus graves de la Loi 2024.

### 12.3.4 Les sanctions pénales de la Loi 2024/017

**Jurisprudence & Droit applicable**

**Article 63. Collecte frauduleuse de données personnelles :** (1) Puni de **2 à 5 ans + 200 000 à 5 000 000 F CFA** celui qui collecte des données à caractère personnel ou y accède par un moyen frauduleux, déloyal ou illicite.

(2) **Peines doublées** lorsque la collecte frauduleuse s'accompagne d'un verrouillage, d'un cryptage ou de toute autre technique portant atteinte à la disponibilité et à l'intégrité des données.

**Al. 2 couvre directement les ransomwares :** l'attaque ransomware = collecte frauduleuse + chiffrement = peines doublées.

**Cumul possible avec art. 65 Loi 2010** quand la collecte frauduleuse implique une intrusion dans un système d'information.

## 12.4 Tableau Comparatif des Sanctions : les Trois Textes

| Infraction | Loi 2010/012 | Loi 2024/017 | Code pénal (cumul) |
|---|---|---|---|
| Accès illicite | Art. 65 : 5–10 ans + 5–10M | Art. 63 si données perso. | Tentative possible (art. 97) |
| Interception illégale | Art. 65 al. 1 : 5–10 ans | Art. 63 si données perso. | Art. 305 si contenu utilisé |
| Atteinte intégrité syst. | Art. 66–67 : 2–5 ans + 1–2M | Art. 63 al. 2 si chiffrement | Art. 318 si préjudice |
| Fraude informatique | Art. 72 : 2–5 ans + 1–2M | Art. 63 si données perso. | Art. 318 escroquerie |
| Collecte frauduleuse | Art. 74 al. 4 : 6 mois–2 ans + 1–5M | Art. 63 : 2–5 ans (plus lourd) | Art. 318 si revente |
| Données sensibles | Art. 74 al. 5 : peines × 2 | Art. 66 : 6 mois–2 ans + 500K–5M | Art. 305 |
| Transfert illégal étranger | Art. 74 al. 7 : 6 mois–2 ans + 5–50M | Art. 69 : **3–10 ans + 2–20M** | Art. 99 si données étatiques |
| Profilage sans consentement | Non prévu expressément | Art. 65 : 3–10 ans + 1–20M | Non prévu |
| CSAM | Art. 76/80 : 5–10 ans + 5–10M | Art. 52 atteinte à la dignité | Art. 295 aggravé |
| Refus déchiffrement | Art. 88 : **1–5 ans + 100K–1M** | Non prévu | Non prévu |
| Personnes morales | Art. 64 : 5–50M + peine access. | Art. 71 : **50M à 1 milliard** | Dissolution possible |

*Tableau 12.4. Comparatif des sanctions : valeurs en millions FCFA sauf mention*

**Trois chiffres à mémoriser**

- **100 millions FCFA** (Loi 2010 : espionnage, art. 69) . l'amende la plus lourde de la Loi 2010.
- **1 milliard FCFA** (Loi 2024, art. 71 : personnes morales) . l'amende la plus lourde du dispositif national.
- **Sursis impossible** sous Loi 2010 (art. 89). unique dans le droit camerounais.

## 12.5 Règles d'Articulation des Trois Textes

| Règle | Contenu et exemples |
|---|---|
| **Règle 1. Spécialité** | La Loi 2010 est la *lex specialis* du droit pénal cyber. Elle prime sur le Code pénal pour les infractions qu'elle définit expressément. Mais le Code pénal s'applique en complément pour les éléments non couverts ou les qualifications aggravées. |
| **Règle 2. Cumul** | Un même fait peut être qualifié sous plusieurs textes si les éléments constitutifs sont indépendants. Loi 2010 + Code pénal : toujours possible. Loi 2010 + Loi 2024 : possible si la violation porte à la fois sur l'intégrité du système ET sur les données personnelles. |
| **Règle 3. Plus solide** | Quand deux qualifications sont possibles, choisir celle dont les éléments constitutifs sont les plus faciles à prouver, pas nécessairement la peine la plus élevée. |
| **Règle 4. Données perso.** | Tout fait impliquant des données à caractère personnel (y compris l'adresse IP : art. 5 Loi 2024) active potentiellement la Loi 2024 EN PLUS des autres textes. |
| **Règle 5. Personnes morales** | La Loi 2024 prévoit des amendes pour personnes morales bien supérieures à la Loi 2010 (jusqu'à 1 milliard FCFA vs 50 millions). Pour les infractions d'entreprises : toujours vérifier si la Loi 2024 est applicable. |
| **Règle 6. Sursis** | Art. 89 Loi 2010 : sursis impossible. Loi 2024 : pas de disposition similaire, le sursis est en principe possible (Code pénal). Cette différence peut orienter la stratégie du parquet. |

*Tableau 12.5. Règles d'articulation des trois textes*

### 12.5.1 Grille de qualification par type d'infraction courant

| Infraction type | Articles à citer (toujours au moins deux textes) |
|---|---|
| Fraude MoMo / BEC | Art. 72 Loi 2010 + Art. 318 CP (escroquerie) ; si données perso. : + Art. 63 Loi 2024 |
| Intrusion système | Art. 65 al. 2 Loi 2010 ; aggravé : art. 65 al. 3 si dommage ; + Art. 65 Loi 2024 si données perso. |
| Ransomware | Art. 66–67 Loi 2010 + Art. 63 al. 2 Loi 2024 (peines doublées) + Art. 22 Loi 2024 si pas de notification |
| Vol de base de données | Art. 63 Loi 2024 + Art. 74 Loi 2010 + Art. 318 CP (revente) |
| CSAM | Art. 76 + Art. 80–81 Loi 2010. Signaler NCMEC CyberTipline. + Art. 295 CP aggravé |
| Phishing / site frauduleux | Art. 72 + Art. 86 Loi 2010 + Art. 318 CP + Art. 155 CP (faux) |
| Téléphone chiffré, refus | Art. 88 Loi 2010. Réquisition judiciaire obligatoire préalablement. |
| Transfert données étranger | Art. 69 Loi 2024 (3–10 ans) : la sanction la plus lourde du dispositif. |

*Tableau 12.6. Grille de qualification par infraction type*

## 12.6 Six Erreurs de Qualification et Comment les Éviter

| Erreur | Description | Correction |
|---|---|---|
| **1. Tout qualifier sous art. 74 Loi 2010** | Art. 74 couvre la vie privée. Beaucoup d'enquêteurs l'utilisent pour toutes les infractions sur les données : renvoi de dossier. | Pour les violations de données personnelles post-23 déc. 2024 : utiliser les articles pertinents Loi 2024. Art. 74 reste applicable pour les faits antérieurs. |
| **2. Oublier art. 88** | Suspect refuse de déverrouiller son téléphone. Blocage total. L'enquêteur ignore qu'il existe une infraction autonome. | Réquisition du juge → refus = art. 88. Infraction indépendante de l'infraction principale. |
| **3. Ne pas citer le Code pénal** | PV ne cite que Loi 2010. Le magistrat rejette la qualification pour un vice de forme. Pas de filet de sécurité. | Systématiquement citer en alternative : art. 318 CP (escroquerie), art. 155–162 (faux), art. 305–308 (diffamation). |
| **4. Confondre art. 66 et art. 72** | Art. 66 = perturbation sans bénéfice économique. Art. 72 = manipulation avec préjudice patrimonial. Qualifier une fraude sous art. 66 est faux. | Élément clé : y a-t-il un bénéfice économique et un préjudice patrimonial ? Oui → art. 72. Non (sabotage pur) → art. 66. |
| **5. Ignorer que l'IP est une donnée perso.** | OPJ note une IP sans penser à qualifier sous Loi 2024 la collecte de ces IP par un acteur non autorisé. | Art. 5 Loi 2024 : l'adresse IP est explicitement une donnée personnelle. Toute collecte sans base légale active la Loi 2024. |
| **6. Ne pas noter le défaut de notification** | Entreprise victime d'un ransomware n'a pas notifié l'Autorité. L'OPJ ne le signale pas dans son rapport. | Art. 22 Loi 2024 = obligation de notifier "sans délai". Défaut = infraction administrative indépendante (art. 56 : amende 1–10M). |

*Tableau 12.7. Six erreurs de qualification et corrections*

## 12.7 Le Cadre Procédural : De la Plainte au Jugement

### 12.7.1 Autorités compétentes

- **ANTIC** (Agence Nationale des TIC) : autorité de régulation technique ; point focal de la coopération internationale cyber ; compétences d'enquête administrative.
- **DGSN/DPJ** : Direction de la Police Judiciaire ; BCN INTERPOL Cameroun ; unité de cybercriminalité.
- **Parquet spécialisé** : Tribunal de Grande Instance de Yaoundé et Douala disposent de magistrats affectés aux affaires cyber.
- **Autorité de protection des données (Loi 2024, art. 53)** : organisme public indépendant ; délivre les autorisations ; dispose d'un arsenal de sanctions administratives. **Statut (juin 2026) :** à créer par décret présidentiel ; surveiller le Journal Officiel.
- **Experts agréés** : Décret N° 69/DF/544 ; BAC+5 informatique minimum ; 5 ans d'expérience ; agrément du Ministère de la Justice.

### 12.7.2 Procédure type d'investigation numérique

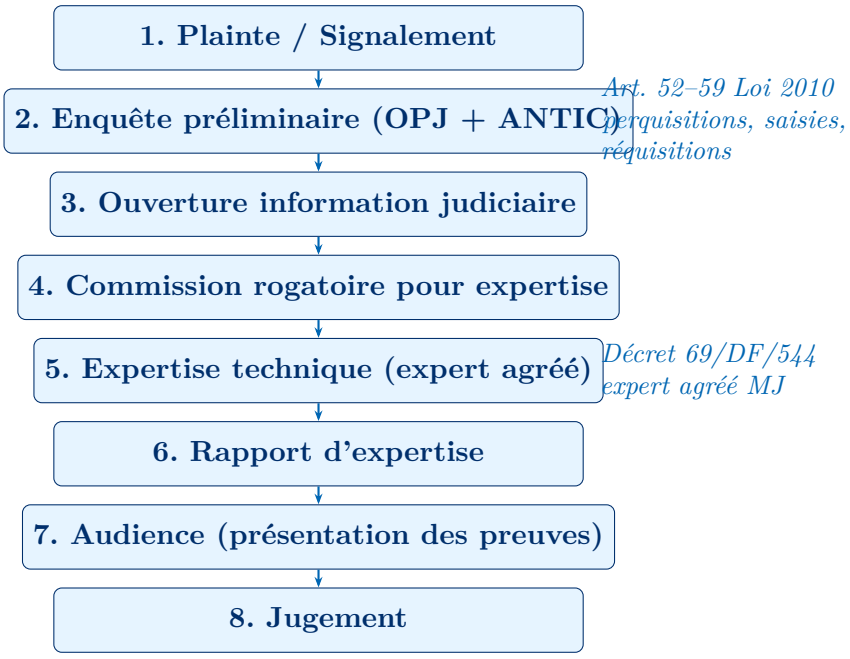



Figure 12.1: Procédure type d'investigation numérique au Cameroun

## 12.8 Jurisprudence Camerounaise : Premières Décisions de Référence

La jurisprudence numérique camerounaise est naissante : peu de décisions publiées à ce jour. Trois affaires de référence :

**Scénario Opérationnel · Affaire CAMTEL c. X (2018), première condamnation pour intrusion**

**Faits :** intrusion non autorisée dans les systèmes de CAMTEL ; modification de données de facturation au profit du prévenu.
**Qualification retenue :** art. 65 al. 2 + art. 65 al. 3 Loi 2010/012 (accès illicite + aggravation pour modification de données).
**Preuves admises :** logs système ; IP tracking ; analyse forensique d'un expert agréé.
**Décision :** 2 ans d'emprisonnement ferme (sursis refusé, art. 89) ; 5 millions FCFA d'amende ; dommages-intérêts à CAMTEL.
**Enseignement :** première validation judiciaire des logs système comme preuves numériques suffisantes. La chaîne de custody de l'expert agréé était irréprochable.

**Scénario Opérationnel · Affaire Ministère public c. Y (2020), fraude Mobile Money**

**Faits :** escroquerie via Mobile Money ; le prévenu interceptait des codes OTP par SIM swapping ; 47 victimes ; préjudice total : 23 millions FCFA.
**Qualification retenue :** art. 72 Loi 2010 (fraude informatique) + art. 318 Code pénal (escroquerie).
**Innovation :** première utilisation des données USSD d'Orange Cameroun comme preuve admissible.
**Enseignement :** les données opérateurs (MTN MoMo, Orange Money) constituent des preuves admissibles. Le cumul art. 72 Loi 2010 + art. 318 CP est validé par la jurisprudence.

### 12.8.1 Défis de la jurisprudence camerounaise

1. **Formation des magistrats :** insuffisante en technique ; le projet de formation continue des magistrats sur le droit du numérique est en cours au Ministère de la Justice.
2. **Délais d'expertise :** 1 à 3 mois en moyenne ; absence de laboratoire forensique national accrédité.
3. **Jurisprudence non publiée :** peu de décisions commentées et diffusées ; lacune que ce cours contribue à combler.
4. **Absence de normes nationales d'accréditation :** l'agrément des experts (Décret 69/DF/544) ne fixe pas de standard technique précis.

**★ À retenir**

**Ce qu'il faut retenir de ce chapitre :**

- **Trois textes, toujours cités en cumul : Loi 2010/012** (lex specialis cyber) + Code pénal (escroquerie, faux, diffamation) + **Loi 2024/017** (données personnelles).
- **Art. 89 Loi 2010 : sursis impossible.** Mentionner dans chaque rapport transmis au parquet.
- **L'adresse IP est une donnée personnelle** (art. 5 Loi 2024). Toute intrusion consignant des IP active la Loi 2024 en plus de la Loi 2010.
- **Art. 88 pour les téléphones chiffrés :** refus de déverrouiller après réquisition judiciaire = infraction autonome (1–5 ans). Ne jamais bloquer sur ce point.
- **Ransomware :** art. 66–67 Loi 2010 + art. 63 al. 2 Loi 2024 (peines doublées : chiffrement = atteinte à la disponibilité). + art. 22 Loi 2024 si la victime n'a pas notifié l'Autorité.
- **Personnes morales :** Loi 2024 prévoit jusqu'à 1 milliard FCFA (art. 71). Pour les infractions d'entreprises, toujours rechercher si la Loi 2024 est applicable l'effet dissuasif est sans commune mesure avec la Loi 2010.
- **Transfert illégal de données à l'étranger :** art. 69 Loi 2024 : 3–10 ans. La sanction la plus lourde du dispositif national. L'autorisation préalable de l'Autorité de protection est obligatoire pour tout transfert.

**✍ Exercice 12.1. Qualification nationale ★☆☆**

Pour chacun des 5 cas suivants, identifiez : (A) l'article Loi 2010/012 applicable, (B) l'article Loi 2024/017 si pertinent, (C) l'article Code pénal en cumul :

(a) Un individu accède au compte Facebook d'une étudiante en utilisant son mot de passe dérobé par phishing et publie des photos intimes.

(b) Un employé copie la base de données clients de son employeur (50 000 entrées avec téléphone et email) et la vend à un concurrent.

(c) Un ransomware paralyse le système de facturation d'une clinique privée de Douala pendant 5 jours ; toutes les données patients sont chiffrées.

(d) Le directeur informatique d'une banque refuse de remettre la clé de déchiffrement du serveur de sauvegarde après réquisition formelle du juge d'instruction.

(e) Une startup camerounaise envoie sans autorisation les données personnelles de 200 000 utilisateurs vers ses serveurs AWS en Irlande.

### ✍ Exercice 12.2. Tableau de sanctions ★★☆

En utilisant le Tableau 12.4 :

(a) Quelle est la qualification qui expose l'auteur aux peines les plus sévères dans chaque cas : le dirigeant d'une PME qui a vendu des données clients à l'étranger sans autorisation (1 000 personnes concernées) ?

(b) Pour une entreprise qui a subi une fuite de données massive et n'a pas notifié l'Autorité de protection : quelles infractions peut-on retenir contre l'entreprise elle-même (personne morale) ? Quelle est la sanction maximale potentielle ?

(c) Le sursis peut-il être accordé pour un condamné pour fraude informatique (art. 72 Loi 2010) ayant subtilisé 3 millions FCFA via Mobile Money ? Justifiez.

### ✍ Exercice 12.3. Simulation MOABI ★★★

La Brigade de lutte contre la cybercriminalité de Yaoundé reçoit une plainte. L'entreprise MOABI SA (200 employés) signale :

1. Son site e-commerce a été piraté : 45 000 numéros de cartes bancaires clients dérobés.
2. Son serveur de paie a été chiffré par un ransomware (données RH inaccessibles depuis 4 jours).
3. Elle n'a pas encore notifié ses clients ni l'Autorité de protection des données.
4. Le suspect identifié a supprimé son téléphone principal mais possède un second téléphone chiffré qu'il refuse de déverrouiller.

(a) Listez toutes les infractions constituées avec les articles précis (distinguez : infractions du suspect vs infractions de MOABI SA).

(b) Identifiez les responsabilités de MOABI SA en tant que personne morale : quels articles de la Loi 2024 s'appliquent ?

(c) Rédigez un rapport de qualification transmissible au parquet (une page maximum) : structure : faits / qualifications / articles / sanctions encourues / mention art. 89.

(d) Quel est l'enjeu de l'art. 88 dans ce dossier ? Quelle démarche l'OPJ doit-il engager ?

**● Note**

**Transition.** Le Chapitre 13 (Déontologie de l'investigateur) clôt la Partie III. Il aborde les obligations éthiques, les conflits d'intérêt, les responsabilités personnelles et la conduite de l'investigateur en situation difficile la dimension humaine du métier

que les textes de loi ne couvrent pas.

13

# DÉONTOLOGIE DE L'INVESTIGATEUR NUMÉRIQUE

« L'excellence investigative n'est pas seulement maîtrise de techniques, mais développement d'un caractère vertueux : intègre, courageux, prudent, juste. »

*Compétences Non Techniques de l'Investigateur Numérique*

**Niveau :** *Fondamental* • Aucun prérequis technique. Ce chapitre est philosophique, éthique et pratique. Il complète les chapitres juridiques en abordant ce que les textes de loi ne couvrent pas : les choix moraux que l'investigateur doit faire sous pression.

**✦ Objectifs du chapitre**

- ➢ Comprendre pourquoi la déontologie est une condition de l'efficacité investigative, pas seulement une contrainte éthique.
- ➢ Maîtriser les trois cadres éthiques fondamentaux : déontologique (Kant), conséquentialiste (Mill) et des vertus (Aristote).
- ➢ Identifier les cinq tensions déontologiques majeures auxquelles tout investigateur sera confronté ; savoir les résoudre.
- ➢ Reconnaître les biais cognitifs qui compromettent l'objectivité et appliquer des contre-mesures systématiques.
- ➢ Maîtriser les obligations de confidentialité et leurs limites légales en droit camerounais.
- ➢ Conduire un entretien investigatif respectueux des droits fondamentaux et juridiquement recevable.

## Paradoxe de l'investigation numérique

Une investigation numérique n'échoue pas seulement pour des raisons techniques. Elle échoue aussi parce qu'un entretien a été mal conduit, parce qu'un droit n'a pas été respecté, parce qu'un témoignage a été contaminé, ou parce que l'investigateur a cherché à confirmer ce qu'il croyait déjà : les travaux sur les biais cognitifs en sciences forensiques

l'ont documenté [11], et le modèle d'entretien PEACE est né en Angleterre de la volonté de prévenir ces dérives [26].

La déontologie n'est donc pas un supplément d'âme : c'est la condition de la **confiance institutionnelle** sur laquelle repose toute la chaîne judiciaire, et l'un des facteurs les plus prédictifs du succès à long terme d'une carrière d'investigateur.

## 13.1 Fondements Éthiques : Trois Cadres pour Décider

### 13.1.1 Éthique déontologique : Kant et les droits absolus

L'**éthique déontologique** (Kant, *Fondements de la Métaphysique des Mœurs*, 1785) évalue une action selon sa conformité à un devoir ou une règle, indépendamment des conséquences.

**Définition**

**Impératif catégorique de Kant** : « Agis uniquement d'après la maxime qui fait que tu peux vouloir en même temps qu'elle devienne une loi universelle. »
**Droits inaliénables kantiens :** la dignité humaine est non négociable. L'humain est fin en soi, jamais simple moyen. Interdit l'instrumentalisation : manipuler une personne comme un outil viole sa dignité, même si c'est efficace.
**Application investigative :** un suspect a des droits indépendamment de sa culpabilité présumée. L'interrogatoire coercitif qui viole ces droits est éthiquement interdit kantiennement même si les aveux obtenu sont vrais.

### 13.1.2 Éthique conséquentialiste : Mill et le calcul des conséquences

L'**éthique conséquentialiste** (Mill, *L'Utilitarisme*, 1863) évalue la moralité d'une action par ses conséquences : maximiser le bien-être, minimiser la souffrance.

**Tension fondamentale Kant/Mill en investigation**

**Kant :** droits absolus, non négociables (déontologie).
**Mill :** droits relatifs au bien-être global (conséquences).
**Cas concret :** un suspect refuse de déverrouiller son téléphone. Des vies sont peut-être en danger.

- ➢ Kant : le droit à ne pas s'auto-incriminer est absolu. La coercition est interdite.
- ➢ Mill : si les bénéfices (vies sauvées) l'emportent sur les coûts (violation d'un droit) , la coercition pourrait être justifiée.

**Réponse légale camerounaise :** art. 88 Loi 2010/012 [34] tranche la tension : le refus après réquisition judiciaire est une infraction autonome. La loi choisit la voie kantienne la contrainte légale remplace la coercition directe.

### 13.1.3 Éthique des vertus : Aristote et le caractère de l'investigateur

L'**éthique des vertus** (Aristote, *Éthique à Nicomaque*) demande non pas "quelle règle dois-je suivre ?" mais "quel type de personne dois-je être ?"

Les **quatre vertus de l'investigateur** :

1. **Intégrité** : dire la vérité même quand elle contredit ses hypothèses initiales ; documenter les preuves qui réfutent autant que celles qui confirment.
2. **Courage** : signaler une violation de procédure commise par un collègue ; résister aux pressions hiérarchiques pour "conclure vite" ; accepter l'incertitude.
3. **Prudence** (*phronèsis*) : la sagesse pratique qui permet de juger correctement dans les situations singulières. Aucun manuel n'anticipe toutes les situations ; la prudence est ce qui comble le vide.
4. **Justice** : traiter chaque personne équitablement, indépendamment de ses antécédents, de son appartenance sociale ou de la présomption de culpabilité.

La trajectoire de développement déontologique comporte trois stades :

**Stade 1. Conformité externe** Le débutant suit les règles mécaniquement (checklists, protocoles).

**Stade 2. Intériorisation** L'intermédiaire comprend les raisons des règles et les applique avec jugement.

**Stade 3. Vertu intégrée** L'expert a internalisé les vertus ; il agit vertueusement spontanément ("seconde nature").

## 13.2 Les Cinq Tensions Déontologiques Majeures

### 13.2.1 Tension 1 : Efficacité vs Droits fondamentaux

La pression de "résoudre vite" une affaire peut pousser à contourner les procédures. Chaque raccourci procédural :

1. Viole les droits de la personne visée ;
2. Fragilise la valeur probatoire des preuves obtenues ;
3. Expose l'investigateur à des poursuites personnelles.

$\Gamma_{CRO}$ **Analyse CRO · Confidentialité · Fiabilité · Opposabilité**

**Analyse CRO. Tension efficacité vs droits**
$\mathcal{R}$ : les méthodes coercitives produisent des aveux non fiables (taux de faux aveux : 15–25% selon les études). L'efficacité à court terme se paye d'une fiabilité dégradée.
$\mathcal{O}$ : toute preuve obtenue en violation des droits fondamentaux sera contestée et potentiellement exclue. L'opposabilité est maximisée par le respect strict des droits,

pas par leur contournement.
$\mathcal{C}$ : les méthodes coercitives violent la confidentialité des données personnelles du suspect.
$\mathcal{C}$: ↓ coercition viola privauté $\mathcal{R}$: ↓↓ aveux non fiables $\mathcal{O}$: ↓↓ exclusion probable
**Conclusion :** le respect des droits et l'efficacité ne sont pas en tension, ils convergent. Un dossier propre est un dossier solide.

### 13.2.2 Tension 2 : Confidentialité vs Obligation de divulgation

L'investigateur est soumis à deux obligations contradictoires : protéger les informations confidentielles qu'il collecte, ET divulguer ce qui est nécessaire à la justice.

| Situation | Obligation | Base légale |
|---|---|---|
| Données personnelles collectées pendant l'investigation | Confidentialité stricte ; usage limité à la finalité de l'enquête | Art. 74 Loi 2010 ; Art. 9–11 Loi 2024 |
| Preuves pertinentes pour la défense (innocence du suspect) | Obligation de divulgation au parquet ; ne pas dissimuler | CPP camerounais ; ACPO [3] Principe 4 |
| Informations compromettantes sur des collègues | Obligation déontologique de signalement ; résistance à la complaisance corporative | Art. 89 Code pénal (recel) ; éthique professionnelle |
| Données protégées par le secret professionnel | Saisie limitée ; respect du secret médical, de l'avocat | CPP ; art. 5 Loi 2024 (données sensibles) |

*Tableau 13.1. Tensions confidentialité / divulgation*

### 13.2.3 Tension 3 : Objectivité vs Biais de confirmation

Le **biais de confirmation**, la tendance à privilégier les informations qui confirment nos croyances initiales, est l'ennemi structurel de l'objectivité investigative. Sa particularité : il opère de façon *inconsciente*.

**Le biais de confirmation en chiffres**

Une hypothèse préalable (“c’est lui le coupable”) modifie l’interprétation de tout ce qui suit :

- Un interviewé nerveux → s’il est étiqueté “menteur” : confirmation du mensonge. S’il est étiqueté “victime” : compréhension du traumatisme.
- Une incohérence dans le récit → si hypothèse coupable : preuve de mensonge. Si hypothèse innocent : erreur de mémoire.
- Chaque comportement réinterprété à travers le filtre de l’étiquette initiale biais de confirmation en cascade.

**Contre-mesure :** E9bis du PIU (falsification active). Pour chaque hypothèse : chercher activement ce qui la réfuterait, pas ce qui la confirme.

### 13.2.4 Tension 4 : Loyauté institutionnelle vs Intégrité personnelle

Quand un supérieur hiérarchique demande de “conclure vite” ; quand un collègue a contaminé une scène ; quand des preuves pointent vers des personnes influentes :

- **Signalement interne** : documenter précisément les faits ; remonter par la chaîne hiérarchique ; conserver une copie personnelle de toute documentation transmise.
- **Signalement externe** : si le signalement interne échoue ou est bloqué : ANTIC ; parquet ; inspection générale des services.
- **Protection :** un OPJ qui signale de bonne foi une irrégularité bénéficie en principe d’une protection contre les représailles même si la protection légale explicite est encore faible en droit camerounais.

★ **Attention**

**Le courage déontologique : la compétence la moins enseignée**

Il est plus difficile de refuser d’exécuter un ordre illégal d’un supérieur que de résister à un suspect hostile. Les études sur les erreurs judiciaires montrent que la plupart impliquent au moins un acteur qui “savait” mais s’est tu. Le courage déontologique est la vertu qui protège la chaîne judiciaire de la corruption systémique.

### 13.2.5 Tension 5 : Compétence personnelle vs Délégation nécessaire

L’investigateur doit savoir reconnaître les limites de ses propres compétences. Intervenir au-delà de sa formation :

- Contamine les preuves (violation d’ACPO Principe 2) ;
- Engage sa responsabilité personnelle ;
- Fragilise l’ensemble du dossier.

**Règle pratique :** « Si je ne sais pas faire sans risque de modifier les données, je ne fais pas. J'appelle un spécialiste et je documente pourquoi. » Cette auto-évaluation honnête est elle-même une compétence déontologique.

## 13.3 Droits des Personnes Interrogées

### 13.3.1 Cadre légal et principe

Tout entretien investigatif implique des personnes : victimes, témoins, suspects. Chaque catégorie dispose de droits spécifiques qui conditionnent la valeur probatoire des témoignages recueillis.

**⚖ Jurisprudence & Droit applicable**

**Droits fondamentaux en contexte d'entretien investigatif :**

- **Droit à l'information** : toute personne entendue doit être informée de l'objet de l'entretien et de son droit de refuser (sauf obligation légale contraire).
- **Droit à l'assistance** : un suspect en garde à vue a le droit à l'assistance d'un avocat dès le début (CPP camerounais).
- **Droit au silence** : le suspect ne peut être contraint à s'auto-incriminer (principe *nemo tenetur*).
- **Droits des mineurs** : présence obligatoire d'un représentant légal ; protocoles spécifiques ; attention particulière aux processus de mémoire (contamination facile).
- **Droit à l'interprète** : si la personne ne maîtrise pas la langue de l'entretien ; l'interprète doit être assermenté pour les actes judiciaires.

### 13.3.2 La méthode PEACE : entretien éthique et efficace

La méthode **PEACE** (*Preparation, Engage, Account, Closure, Evaluation*), développée par la police britannique en 1992, est la référence mondiale pour les entretiens investigatifs respectueux des droits :

| Phase | Contenu et objectifs |
|---|---|
| **P. Preparation** | Définir l'objectif de l'entretien. Recueillir toutes les informations disponibles. Choisir le lieu et le moment adaptés. Préparer les questions ouvertes. |
| **E. Engage and Explain** | Établir le rapport ; présenter l'objet ; informer des droits ; mettre à l'aise. Un témoin à l'aise révèle davantage. |
| **A. Account** | Recueillir le récit libre sans interruption ; puis poser des questions de clarification. Ne jamais diriger ; ne pas suggérer. |
| **C. Closure** | Résumer ; donner à l'interviewé l'opportunité de corriger, compléter ou ajouter. Informer des suites. |
| **E. Evaluation** | Documenter immédiatement ; évaluer la cohérence ; identifier les lacunes ; planifier les entretiens suivants. |

*Tableau 13.2. Méthode PEACE : entretien éthique et efficace*

**Pourquoi PEACE est plus efficace que l'interrogatoire coercitif**

Les études de psychologie légale montrent que les techniques d'entretien basées sur l'instauration d'une confiance et la narration libre obtiennent *plus* d'informations utiles que les techniques coercitives, tout en produisant *moins* de faux aveux. L'entretien éthique n'est pas un sacrifice d'efficacité c'est une méthode supérieure.

## 13.4 Biais Cognitifs et Contre-Mesures

### 13.4.1 Les six biais les plus dangereux en investigation

| Biais | Manifestation investigative | Contre-mesure |
|---|---|---|
| **Confirmation** | Chercher des preuves qui confirment l'hypothèse initiale ; ignorer les preuves contraires | E9bis PIU : chercher activement ce qui réfuterait l'hypothèse |
| **Ancrage** | Première information reçue oriente toutes les suivantes ; première suspicion difficile à réviser | Générer plusieurs hypothèses (E8 PIU) avant de fixer une conclusion |
| **Étiquetage prématuré** | Qualifier "suspect" ou "menteur" oriente l'interprétation de tous les comportements ultérieurs (Becker, 1963) [4] | Maintenir des catégories ouvertes ; consigner les observations avant les interprétations |
| **Disponibilité** | Surestimer la probabilité d'un scénario parce qu'il est familier ; "ce ressemble à ce que j'ai vu l'an dernier" | Vérifier la ressemblance par les faits, pas par l'intuition ; raisonner sur les statistiques |
| **Surconfiance** | Croire être objectif quand on ne l'est pas ; "je sais quand quelqu'un ment" | Taux de précision humain dans détection du mensonge : 54% à peine mieux que le hasard |
| **Tunnelisation** | Se focaliser sur un seul suspect/scénario ; négliger les alternatives | "Quelle est l'hypothèse que je n'ai pas explorée ?" Rotation de l'hypothèse active tous les 48h |

*Tableau 13.3. Biais cognitifs et contre-mesures*

### 13.4.2 La pratique de l'objectivité : protocoles concrets

1. **Séparer constatations et interprétations :** dans chaque document : une section "Constatations" (faits vérifiables) et une section "Analyse" (interprétations, avec niveau de certitude explicite). Jamais mêlés.
2. **Documenter les preuves contraires :** noter explicitement chaque preuve qui ne s'accorde pas avec l'hypothèse principale. Si le dossier n'en contient aucune, chercher plus.
3. **Rotation des hypothèses :** tous les deux jours, s'obliger à défendre l'hypothèse inverse. Que faudrait-il pour qu'elle soit vraie ?
4. **Revue par les pairs :** présenter les conclusions préliminaires à un collègue avec le mandat explicite de les contester.

5. **Journal de bord éthique :** noter les situations où la pression a été ressentie pour orienter les conclusions ; les moments de doute ; les décisions difficiles. Ce journal constitue une protection en cas de contestation ultérieure.

## 13.5 Responsabilité Personnelle de l'Investigateur

### 13.5.1 Responsabilité pénale personnelle

L'investigateur numérique n'est pas protégé par "j'exécutais un ordre". En droit camerounais :

- **Responsabilité pour violation de procédure :** un OPJ qui conduit une perquisition sans autorisation judiciaire (art. 52 Loi 2010) commet une faute personnelle ; il peut être poursuivi pour violation de domicile, atteinte à la vie privée.
- **Responsabilité pour faux :** un investigateur qui falsifie un rapport d'expertise ou un formulaire de custody commet le crime de faux en écriture (art. 155–162 Code pénal) ; c'est une infraction personnelle, indépendante du résultat de l'affaire.
- **Responsabilité pour complicité :** un investigateur qui couvre la violation procédurale d'un collègue peut être poursuivi pour complicité ou recel (art. 89 Code pénal).

### 13.5.2 ACPO Principe 4 : responsabilité du chef d'investigation

Le Principe 4 du guide ACPO établit que **le responsable de l'investigation est personnellement responsable de la conformité de l'ensemble de l'équipe**. Cette responsabilité :

- S'étend à toutes les actions de chaque membre de l'équipe ;
- Implique une supervision active : pas de délégation aveugle ;
- Exige une documentation systématique des décisions : chaque choix procédural doit pouvoir être justifié.

### 13.5.3 L'obligation d'auto-évaluation continue

Le formulaire d'auto-évaluation de compétences non techniques (grille CNT 1–15) est un outil de développement professionnel : identifier ses lacunes avant qu'elles ne causent une erreur judiciaire. Les cinq questions clés à se poser à la clôture de chaque investigation :

1. Ai-je cherché activement des preuves contraires à mon hypothèse ?
2. Ai-je respecté scrupuleusement les droits de chaque personne rencontrée ?
3. Ai-je documenté tous les transferts d'evidence, même temporaires ?
4. Y a-t-il un moment où j'ai ressenti de la pression pour orienter mes conclusions ? L'ai-je documenté ?
5. Mon rapport est-il défendable mot à mot en contre-interrogatoire ?

## 13.6 Déontologie et Témoignage Expert

L'investigateur peut être amené à témoigner en tant qu'expert devant un tribunal. Cette situation exige une préparation spécifique.

### 13.6.1 Obligations de l'expert judiciaire

- **Impartialité** : l'expert n'est ni l'avocat de l'accusation ni celui de la défense. Il est le serviteur de la vérité même si ses conclusions déplaisent à l'autorité qui l'a mandaté.
- **Compétence déclarée** : l'expert ne doit témoigner que dans le domaine de sa compétence réelle. Affirmer une certitude que la technique ne permet pas est une faute grave.
- **Limites explicites** : déclarer ce que l'analyse *ne peut pas* établir est aussi important que déclarer ce qu'elle établit.
- **Distinction constatation/interprétation** : devant le tribunal : « J'ai constaté X. Une interprétation de X serait Y, mais d'autres explications sont possibles. »

### 13.6.2 Résistance au contre-interrogatoire

**Comment se préparer au contre-interrogatoire**

1. Relire l'intégralité du rapport d'expertise la veille ;
2. Identifier soi-même les trois points les plus attaquables ;
3. Préparer une réponse factuelle et documentée pour chacun ;
4. Pendant l'interrogatoire : répondre aux questions posées, pas aux questions redoutées ; ne pas sur-interpréter ; dire "je ne sais pas" quand c'est vrai.
5. Ne jamais modifier verbalement une conclusion écrite sous la pression d'un avocat compétent : "Mon rapport parle pour lui-même."

## 13.7 Cas Pratique : L'Affaire ONAMBELE. Décisions Déontologiques

**Scénario Opérationnel · Affaire ONAMBELE, trois décisions sous pression**

**Contexte :** L'OPJ NKENG, en charge de l'affaire ONAMBELE (fraude sur les marchés publics, Chapitre 3), est confronté à trois situations de pression déontologique au cours de la même semaine.

**Situation 1. Pression hiérarchique :** Le directeur de la DCPJ convoque l'OPJ NKENG et lui demande de "clore le dossier rapidement" un responsable politique est dans l'entourage du suspect. NKENG doit décider : céder à la pression ou maintenir son investigation.

**Analyse déontologique :**

- Vertu en jeu : **courage** la vertu la moins enseignée mais la plus nécessaire.
- Action correcte : documenter précisément la demande (date, heure, contenu, nom du demandeur) ; poursuivre l'investigation selon les règles ; escalader au parquet si la pression s'intensifie.
- Risque : représailles. Protection : la documentation.

**Situation 2. Preuve contraire à l'hypothèse :** L'analyse forensique révèle que les virements suspects ont été initiés depuis un compte que l'OPJ NKENG avait classé comme "témoin innocent" pas depuis le compte du suspect principal. L'hypothèse principale s'effondre.
**Analyse déontologique :**

- Biais en jeu : **biais de confirmation** résistance à réviser une hypothèse investie de plusieurs semaines de travail.
- Action correcte : consigner immédiatement la découverte dans le journal de bord ; rouvrir le champ des hypothèses (E8–E9 PIU) ; informer le parquet de la révision d'hypothèse.
- Vertu en jeu : **intégrité** dire la vérité même quand elle contrarie son travail antérieur.

**Situation 3. Violation par un collègue :** L'OPJ NKENG découvre que son collègue BITA a interrogé un suspect sans présence d'avocat et sans l'informer de ses droits les déclarations obtenues sont potentiellement irrecevables.
**Analyse déontologique :**

- Tension : loyauté envers un collègue vs intégrité du dossier.
- Action correcte : informer le parquet ; documenter la violation ; proposer de faire réentendre le suspect dans le respect de ses droits.
- Conséquence de l'inaction : si la violation n'est pas signalée et est découverte par la défense à l'audience, c'est l'ensemble du dossier qui est fragilisé et l'OPJ NKENG qui a couvert peut être impliqué.

★ À retenir

**Ce qu'il faut retenir de ce chapitre :**

- La déontologie n'est pas une contrainte c'est une **condition de l'efficacité** : un dossier propre est un dossier solide.

- **Trois cadres éthiques** : Kant (droits absolus) ; Mill (conséquences) ; Aristote (vertus). Les quatre vertus de l'investigateur : intégrité, courage, prudence, justice.
- **Le biais de confirmation est le plus dangereux** : il opère inconsciemment et réinterprète chaque indice pour confirmer l'hypothèse initiale. Contre-mesure : E9bis PIU (falsification active).
- **Méthode PEACE** : Préparation → Engage → Account → Closure → Evaluation. Plus efficace que l'interrogatoire coercitif, et juridiquement recevable.
- **Responsabilité personnelle** : l'investigateur ne peut pas se cacher derrière "j'exécutais un ordre". Violation de procédure = faute personnelle ; faux = crime personnel ; complicité de violation = poursuite personnelle.
- **ACPO Principe 4** : le responsable de l'investigation est personnellement responsable de la conformité de toute son équipe. Pas de délégation aveugle.
- **Journal de bord éthique** : documenter les pressions reçues, les moments de doute, les décisions difficiles. C'est à la fois un outil de développement professionnel et une protection légale.
- **Cinq questions de clôture** : cherché des preuves contraires ? Respecté les droits ? Documenté tous les transferts ? Noté les pressions ? Rapport défendable mot à mot ?

### ✍ Exercice 13.1. Identification éthique ★☆☆

Pour chacune des situations suivantes, identifiez : (A) la tension déontologique en jeu, (B) le cadre éthique applicable (Kant / Mill / Aristote), (C) l'action correcte :

(a) Un investigateur découvre, au cours d'une analyse forensique d'un PC suspect, des photos compromettantes pour un ministre sans lien avec l'affaire en cours. Son supérieur lui demande de "signaler informellement" cette découverte à un tiers.

(b) Un OPJ a passé 3 semaines à construire un dossier contre un suspect ; une nouvelle preuve suggère une autre personne. Un collègue lui dit : "tu as déjà trop de travail dans ce dossier pour recommencer".

(c) L'entreprise victime demande à l'investigateur de ne pas inclure dans son rapport les failles de sécurité internes qui ont facilité l'attaque pour protéger sa réputation.

### ✍ Exercice 13.2. Biais cognitifs ★★☆

Relisez ce fragment de rapport d'investigation :

> *"Lors de l'entretien du 12 mars, BELLO Armand a présenté un comportement nerveux (regards fuyants, mains tremblantes) confirmant sa culpabilité dans le détournement. L'analyse des logs révèle 3 connexions depuis son poste, cohérentes avec notre hypothèse. Le fait que d'autres employés aient eu accès au même système ne constitue pas un obstacle significatif à notre conclusion."*

(a) Identifiez au moins trois biais cognitifs dans ce passage.

(b) Réécrivez ce passage en séparant strictement constatations et interprétations, et en appliquant le principe de falsification.

(c) Quelles questions supplémentaires cet investigateur aurait-il dû se poser avant de rédiger ce passage ?

### ✍ Exercice 13.3. Simulation décision éthique ★★★

Vous êtes l'expert judiciaire désigné dans l'affaire WOURI (Chapitre 3). À l'audience, l'avocat de la défense vous pose les questions suivantes :

(a) *"Votre rapport affirme que l'email provenait d'un serveur russe. Êtes-vous certain à 100% de cette conclusion ?"*

(b) *"Vous avez utilisé Volatility 3 pour analyser la RAM. N'est-il pas vrai que ce logiciel modifie lui-même la RAM pendant la capture ?"*

(c) *"Vous êtes mandaté par le parquet. Vos conclusions ne sont-elles pas par nature orientées contre mon client ?"*

Rédigez vos réponses telles que vous les donneriez à l'audience, en respectant les obligations déontologiques de l'expert judiciaire. Identifiez pour chaque réponse le principe éthique mobilisé.

### ● Note

**Clôture de la Partie III.** Ce chapitre clôt la Partie III (Cadre normatif et déontologie). Les quatre chapitres de cette partie ont construit votre culture juridique : cadre normatif global (Ch. 10), législation mondiale (Ch. 11), droit camerounais (Ch. 12) et déontologie (ce chapitre).

Le cours SEC4052 (Parties IV à VI) aborde les techniques avancées : forensique réseau opérationnelle, anti-forensique et contre-mesures, analyse formelle et cryptanalyse. Ces chapitres mobilisent l'intégralité des fondements posés dans les Parties I

à III techniques, juridiques et déontologiques.

A

# GLOSSAIRE

Ce glossaire reprend, sous une forme abrégée, les notions définies dans les chapitres. Le renvoi indique le chapitre où la notion est présentée et illustrée ; c'est là qu'il faut lire la définition complète.

**Acquisition** Production d'une copie fidèle d'un support ou de données, vérifiable par empreinte (ISO/IEC 27037 ; Ch. 9).

**Acquisition logique, physique** Copie des fichiers visibles par le système, ou copie bit à bit de tout le support, espace non alloué compris (Ch. 9).

**Admissibilité** Qualité d'une preuve numérique qui la rend recevable dans une procédure judiciaire (Prologue ; Ch. 8).

**AFRIPOL** Mécanisme de coopération policière de l'Union africaine (Ch. 10).

**Analyse** Examen des données acquises pour établir des faits, séparé de leur interprétation (Ch. 6).

**Analyse des hypothèses concurrentes (ACH)** Méthode qui confronte chaque élément de preuve à toutes les hypothèses, pour réfuter plutôt que confirmer (Heuer ; Ch. 6).

**Biais de confirmation** Tendance à retenir les éléments qui confirment une hypothèse déjà formée (Ch. 13).

**Bloqueur d'écriture (*write blocker*)** Dispositif matériel ou logiciel qui permet de lire un support en interdisant toute écriture (Ch. 9).

**Carving** Récupération de fichiers à partir de leurs signatures, sans s'appuyer sur le système de fichiers (Ch. 9).

**Chaîne de custody (chaîne de conservation)** Registre chronologique de chaque personne ayant détenu une pièce et de chaque action effectuée, de la collecte à l'audience (Prologue ; Ch. 8).

**CLOUD Act** Loi des États-Unis (2018) qui permet aux autorités américaines d'exiger d'un fournisseur des données qu'il contrôle, où qu'elles soient stockées (Ch. 11).

**Constatation** Fait vérifiable par un autre expert, avec sa source ; distincte de l'analyse (Ch. 6).


© *MaletYon*

**Convention de Budapest** Convention du Conseil de l'Europe sur la cybercriminalité (2001), premier traité international en la matière (Ch. 10).

**Convention de Malabo** Convention de l'Union africaine sur la cybersécurité et la protection des données à caractère personnel (2014) (Ch. 10).

**Copie de travail** Copie de l'image de référence sur laquelle porte l'analyse ; l'original reste scellé (Ch. 8).

**DFRWS** *Digital Forensic Research Workshop* ; son rapport de 2001 propose le premier modèle de processus de la discipline (Ch. 7).

**Données volatiles** Données qui disparaissent à l'extinction de l'appareil : mémoire vive, connexions, processus (Ch. 9).

**Empreinte (*hash*)** Valeur de taille fixe calculée par une fonction de hachage cryptographique ; toute modification des données la change (Ch. 4, 8).

**Entraide judiciaire (MLAT)** Procédure par laquelle un État demande à un autre d'accomplir un acte d'enquête (Ch. 10).

**Format E01** Format d'image forensique qui embarque métadonnées, compression et empreintes (Ch. 9).

**Format brut (*raw*, dd)** Copie bit à bit sans métadonnées (Ch. 9).

**Identification** Première étape : reconnaître l'incident et en définir le périmètre (Ch. 7).

**Image forensique** Copie bit à bit d'un support, avec ses empreintes (Ch. 9).

**Intégrité** Garantie que la preuve n'a pas été modifiée depuis sa collecte (Prologue ; Ch. 8).

**INTERPOL** Organisation internationale de police criminelle ; ses bureaux centraux nationaux relaient les demandes (Ch. 10).

**Investigation numérique** Discipline scientifique appliquée qui identifie, préserve, analyse et présente des preuves numériques de façon recevable (Prologue ; Ch. 1).

**Métadonnées** Données qui décrivent d'autres données : dates, auteur, logiciel, géolocalisation (Ch. 3).

**Méthode PEACE** Méthode d'entretien d'enquête en cinq étapes (préparation, engagement, récit, clôture, évaluation), fondée sur la recherche d'informations plutôt que sur l'aveu (Ch. 13).

**Modèle de Dolev-Yao** Modèle d'adversaire qui contrôle entièrement le réseau sans pouvoir casser les primitives cryptographiques (Ch. 4).

**Normes ISO/IEC 27037, 27041, 27042, 27043** Lignes directrices sur la preuve numérique : collecte et préservation, validation des méthodes, analyse et interprétation, processus d'investigation (Ch. 7).

**Opposabilité** Caractère d'une preuve qui peut être valablement opposée à une partie en justice (Ch. 1).

**Ordre de volatilité** Règle qui impose d'acquérir d'abord les données les plus volatiles (RFC 3227 ; Ch. 9).

**OSINT** Collecte et analyse d'informations issues de sources légalement accessibles au public (Ch. 5).

**Préservation** Protection de la preuve contre toute altération, et traçabilité de chaque accès (Ch. 8).

**Principe de Locard numérique** Tout processus informatique laisse des traces dans son environnement d'exécution (Ch. 4).

**Principes de l'ACPO** Quatre principes britanniques : ne pas modifier les données, compétence de qui y accède, piste d'audit, responsabilité de l'enquêteur (Ch. 7).

**Processus investigatif universel (PIU)** Méthode du cours en phases séparées par des contrôles de qualité (*Quality Gates*) (Ch. 6).

**Régime de vérité numérique** Ensemble historiquement situé des traces tenues pour preuves et des procédures qui les valident (Ch. 2).

**Reproductibilité** Propriété d'une méthode qui, appliquée par un autre investigateur qualifié aux mêmes données, donne le même résultat (Prologue ; Ch. 7).

**RGPD** Règlement (UE) 2016/679 sur la protection des données personnelles (Ch. 11).

**Scellé** Conditionnement qui garantit qu'une pièce n'a pas été ouverte depuis sa fermeture (Ch. 8).

**Scène de crime numérique** Tout environnement numérique susceptible de contenir des traces probantes d'un acte délictueux (Prologue).

**SIM swapping** Fraude qui consiste à faire transférer le numéro d'une victime sur une nouvelle carte SIM (Ch. 5).

**Trace numérique** Marque laissée sans intention par un processus informatique, que l'investigateur interprète (Ch. 1).

**Trilemme CRO** Tension formalisée entre confidentialité, fiabilité et opposabilité d'une preuve (Ch. 1 ; [27]).

**Volatility** Cadriciel d'analyse de la mémoire vive (Ch. 9).

B

# RÉFÉRENTIEL DES OUTILS

Cette annexe rassemble les outils mobilisés dans le cours et dans les labs de NDAP SUKULU. Les noms de logiciels sont des exemples : les versions évoluent, et tout rapport cite l'outil *et sa version*. Un outil se valide avant usage, sur des données de référence (ISO/IEC 27041).

## Préserver et acquérir

| Outil | Usage | Chapitre |
|---|---|---|
| Bloqueur d'écriture matériel | Lire un support sans pouvoir y écrire | Ch. 9 |
| `dc3dd`, `dd`, `ewfacquire` | Image brute ou E01, avec empreintes | Ch. 9 |
| FTK Imager, Guymager | Imagerie avec interface graphique, vérification | Ch. 9 |
| `sha256sum` | Calculer et vérifier une empreinte | Ch. 8 |
| Formulaire de custody | Tracer chaque détention et chaque action | Ch. 8 |

## Mémoire, mobile, réseau

| Outil | Usage | Chapitre |
|---|---|---|
| Volatility 3 | Analyser une capture de la mémoire vive | Ch. 9 |
| ADB, outils d'extraction mobile | Acquisition logique d'un téléphone Android | Ch. 9 |
| Wireshark, `tcpdump` | Capturer et lire le trafic réseau | Ch. 9 |
| Autopsy, The Sleuth Kit | Explorer une image, récupérer des fichiers | Ch. 9 |
| `foremost`, `scalpel` | Carving par signatures | Ch. 9 |

★ Attention

**Rappel.** Aucun outil n'est utilisé sur un système réel sans cadre légal ni autorisation écrite (loi n° 2010/012, art. 65, 69 et 86 ; Annexe D).


© *MaletYon*

C

# MODÈLES OPÉRATIONNELS

Cette annexe rassemble les modèles à reproduire en mission. Chacun renvoie au chapitre où il est expliqué.

## Fiche de chaîne de custody

| Rubrique | Contenu |
|---|---|
| Identification | Numéro de pièce, description, numéro de série, état apparent |
| Saisie | Lieu, date et heure, personne, cadre légal (réquisition, perquisition) |
| Acquisition | Outil et version, format, empreintes SHA-256 de l'original et de l'image |
| Scellé | Numéro, date, signataires |
| Mouvements | Date et heure, remis par, remis à, motif, empreinte vérifiée |
| Restitution ou destruction | Décision, date, signataires |

## Procès-verbal d'acquisition

- Cadre : autorité, réquisition, mission, personnes présentes.
- Support : description, photographies, état allumé ou éteint.
- Ordre de volatilité respecté (RFC 3227) et justification des choix.
- Outils, versions, paramètres ; empreintes calculées et vérifiées.
- Incidents et écarts à la procédure, consignés au moment où ils surviennent.

## Plan du rapport forensique


© MaletYon

| Section | Contenu |
|---|---|
| Synthèse | Deux à quatre pages, sans jargon : questions, réponses, niveau de confiance |
| Mission | Contexte et questions posées, telles quelles |
| Méthode | Normes suivies, outils et versions, ordre des opérations |
| Constatations | Faits numérotés, horodatés, avec leur source et leur annexe |
| Analyse | Chronologie, niveau de confiance, hypothèses alternatives, limites |
| Conclusions | Réponses aux questions ; la qualification juridique relève de l'autorité judiciaire |
| Annexes | Pièces, empreintes, formulaires de custody |

## Les contrôles de qualité du PIU

Chaque phase du processus investigatif universel se ferme sur un contrôle de qualité (*Quality Gate*) : le périmètre est-il écrit ? les empreintes sont-elles vérifiées ? chaque constatation a-t-elle sa source ? Le détail figure au Ch. 6.

D

# TEXTES JURIDIQUES ET NORMATIFS

Cette annexe rassemble les textes cités dans le cours. Seuls les extraits lus dans leur version officielle sont reproduits entre guillemets ; les autres sont résumés, avec leur référence.

## Loi n° 2010/012 relative à la cybersécurité et à la cybercriminalité

**Jurisprudence & Droit applicable**

**Texte officiel** [34]

**Article 4, point 9** : *« Audit de sécurité : examen méthodique des composantes et des acteurs de la sécurité, de la politique, des mesures, des solutions, des procédures et des moyens mis en oeuvre par une organisation, pour sécuriser son environnement, effectuer des contrôles de conformité, des contrôles d'évaluation de l'adéquation des moyens (organisationnels, techniques, humains, financiers) investis au regard des risques encourus, d'optimisation, de rationalité et de performance. »*

**Article 25, alinéas 1 et 2** : *« (1) Les opérateurs de réseaux et les fournisseurs de services de communications électroniques ont l'obligation de conserver les données de connexion et de trafic pendant une période de dix (10) ans. (2) Les opérateurs de réseaux et les fournisseurs de services de communications électroniques installent des mécanismes de surveillance de trafic des données de leurs réseaux. Ces données peuvent être accessibles lors des investigations judiciaires. »*

**Article 52, alinéa 3** : *« Les Officiers de Police Judiciaire et les agents habilités de l'Agence peuvent, lors des investigations, accéder aux moyens de transport, à tout local à usage professionnel, à l'exclusion des domiciles privés, en vue de rechercher, de constater les infractions, de demander la communication de tous les documents professionnels et en prendre copie, recueillir, sur convocation ou sur place, les renseignements et justifications. »*

**Article 53, alinéa 1** : *« Les perquisitions en matière de cybercriminalité sont susceptibles de porter sur des données qui peuvent être des supports physiques ou des copies réalisées en présence des personnes qui assistent à la perquisition. »*

**Article 54** : *« Les perquisitions et les saisies sont effectuées conformément aux dispositions du Code de Procédure Pénale en tenant compte du dépérissement des*


© MaletYon

*preuves. »*

**Article 55** : *« (1) Lorsqu'il apparaît que les données saisies ou obtenues au cours de l'enquête ou de l'instruction ont fait l'objet d'opérations de transformation empêchant d'accéder en clair ou sont de nature à compromettre les informations qu'elles contiennent, le Procureur de la République, le Juge d'Instruction ou la juridiction de jugement peuvent réquisitionner toute personne physique ou morale qualifiée, en vue d'effectuer les opérations techniques permettant d'obtenir la version en clair desdites données. (2) Lorsqu'un moyen de cryptographie a été utilisé, les autorités judiciaires peuvent exiger la convention secrète de déchiffrement du cryptogramme. »*

**Article 65, alinéa 2** : *« Est puni des peines prévues à l'alinéa 1 ci-dessus, tout accès non autorisé, à l'ensemble ou à une partie d'un réseau de communications électroniques ou d'un système d'information ou d'un équipement terminal. »*

**Article 69** : *« Est puni d'un emprisonnement de cinq (05) à dix (10) ans et d'une amende de 10.000.000 (dix millions) à 100.000.000 (cent millions) F CFA ou de l'une de ces deux peines seulement, celui qui accède sans droit, et en violation des mesures de sécurité, à l'ensemble ou à une partie d'un réseau de communications électroniques, d'un système d'information ou d'un équipement terminal, afin d'obtenir des informations ou des données, en relation avec un système d'information connecté à un autre système d'information. »*

## Autres textes

| Texte | Objet | Vérification |
|---|---|---|
| Loi n° 2010/013 [35] | Communications électroniques | Présentée ; articles à vérifier |
| Loi n° 2024/017 [36] | Protection des données personnelles | Présentée ; texte à collationner au Journal officiel |
| Convention de Budapest [9] | Cybercriminalité, entraide, conservation rapide | Texte du Conseil de l'Europe |
| Convention de Malabo [2] | Cybersécurité et données personnelles (UA) | Texte de l'Union africaine |
| RGPD [38] | Données personnelles (UE) | Journal officiel de l'UE |
| CLOUD Act [8] | Accès aux données détenues par des fournisseurs américains | Texte fédéral des États-Unis |

## Normes de la preuve numérique

| Norme | Objet |
|---|---|
| ISO/IEC 27037 [18] | Identification, collecte, acquisition et préservation |
| ISO/IEC 27041 [19] | Assurer l'aptitude des méthodes d'investigation |
| ISO/IEC 27042 [20] | Analyse et interprétation de la preuve numérique |
| ISO/IEC 27043 [21] | Principes et processus d'investigation |
| NIST SP 800-86 [29] | Intégrer la forensique à la réponse aux incidents |
| RFC 3227 [5] | Collecte et archivage des preuves, ordre de volatilité |
| Guide de l'ACPO [3] | Quatre principes de la preuve numérique |

E

# BIBLIOGRAPHIE COMMENTÉE

Pour chaque partie, quelques lectures, avec ce qu'elles apportent. Les références complètes figurent dans la bibliographie du livre. Les textes de l'auteur sont des prépublications déposées sur l'IACR ePrint ; aucun travail non publié n'est cité.

## Pour commencer

- Casey [7] : le manuel de référence sur la preuve numérique et la criminalité informatique.
- Pollitt [32] et Garfinkel [13] : l'histoire de la discipline et ses défis.

## Partie I · Fondements

- Kuhn [24], Popper [33], Foucault [12] : paradigmes, réfutation, régimes de vérité.
- Locard [25] : l'échange de traces, transposé au numérique.
- Shannon [37], Dolev et Yao [10] : l'information et l'adversaire.
- Abbott [1] : la formation d'une profession.
- Le Trilemme CRO [27] : le fil rouge du cours.

## Partie II · Processus et méthodologies

- DFRWS [31] : le premier modèle de processus.
- ISO/IEC 27037, 27041, 27042, 27043 [18]-[21] ; NIST SP 800-86 et 800-101 [29], [30] ; RFC 3227 [5] ; guide de l'ACPO [3].
- Heuer [14] : l'analyse des hypothèses concurrentes.
- Carrier [6] : les systèmes de fichiers, pour comprendre ce que l'on acquiert.

## Partie III · Cadre normatif et déontologie

- Convention de Budapest [9], Convention de Malabo [2], RGPD [38], CLOUD Act [8].
- Lois n° 2010/012, 2010/013 et 2024/017 [34]-[36].
- Dror [11] : les biais cognitifs de l'expert ; Milne et Bull [26] : l'entretien d'enquête ; Becker [4] : l'étiquetage.

## La suite

L'UE SEC4052 prolonge ces lectures vers la forensique opérationnelle et les fondements cryptographiques de la preuve.

F

# CONTACTS ET RESSOURCES

Les adresses ci-dessous sont celles des sites institutionnels à la date de rédaction ; elles sont à vérifier avant usage.

## Institutions

| Institution | Rôle dans le cours | Site |
|---|---|---|
| ANTIC | Sécurité électronique, audits (loi n° 2010/012) | `www.antic.cm` |
| MINPOSTEL | Tutelle des communications électroniques | `www.minpostel.gov.cm` |
| INTERPOL | Coopération policière, notices, opérations | `www.interpol.int` |
| AFRIPOL | Coopération policière de l'Union africaine | `afripol.africa-union.org` |
| Conseil de l'Europe | Convention de Budapest, programme Octopus | `www.coe.int` |
| Union africaine | Convention de Malabo | `au.int` |

## Normes et communauté scientifique

| Organisation | Ressources | Site |
|---|---|---|
| ISO | Normes ISO/IEC 2703x | `www.iso.org` |
| NIST | SP 800-86, 800-101, jeux de données de référence | `www.nist.gov` |
| DFRWS | Conférences et défis de la recherche forensique | `dfrws.org` |
| IACR ePrint | Prépublications de cryptographie | `eprint.iacr.org` |
| FIRST | Équipes de réponse aux incidents | `www.first.org` |

## NDAP SUKULU

Les fiches d'auto-évaluation et les labs du cours sont disponibles sur NDAP SUKULU, sous le code SEC4031. NDAP SUKULU est une propriété de MaletYon, mise à la disposition des étudiants et des praticiens : `maletyon@proton.me`.

# RÉFÉRENCES BIBLIOGRAPHIQUES


[1] A. Abbott, *The System of Professions: An Essay on the Division of Expert Labor*. University of Chicago Press, 1988.

[2] African Union, *African Union Convention on Cyber Security and Personal Data Protection*, Malabo Convention, 2014.

[3] Association of Chief Police Officers, *ACPO Good Practice Guide for Digital Evidence*, 5e éd., 2012.

[4] H. S. Becker, *Outsiders: Studies in the Sociology of Deviance*. Free Press, 1963.

[5] D. Brezinski et T. Killalea, « Guidelines for Evidence Collection and Archiving, » Internet Engineering Task Force, RFC 3227, 2002.

[6] B. Carrier, *File System Forensic Analysis*. Addison-Wesley Professional, 2005.

[7] E. Casey, *Digital Evidence and Computer Crime*. Academic Press, 2004.

[8] Congrès des États-Unis, *Clarifying Lawful Overseas Use of Data Act (CLOUD Act)*, Consolidated Appropriations Act, 2018, Division V, Public Law 115-141, 2018.

[9] Council of Europe, *Convention on Cybercrime*, Budapest Convention, 2001.

[10] D. Dolev et A. C. Yao, « On the Security of Public Key Protocols, » *IEEE Transactions on Information Theory*, t. 29, no 2, p. 198-208, 1983.

[11] I. E. Dror, « Cognitive and Human Factors in Expert Decision Making: Six Fallacies and the Eight Sources of Bias, » *Analytical Chemistry*, t. 92, no 12, p. 7998-8004, 2020.

[12] M. Foucault, *L'archéologie du savoir*. Paris : Gallimard, 1969.

[13] S. L. Garfinkel, « Digital Forensics Research: The Next 10 Years, » *Digital Investigation*, t. 7, S64-S73, 2010.

[14] J. Heuer Richards J., *Psychology of Intelligence Analysis*. Washington, DC : Center for the Study of Intelligence, Central Intelligence Agency, 1999.

[15] V. C. Hu, M. Iorga, W. Bao, A. Li, Q. Li et A. Gouglidis, « General Access Control Guidance for Cloud Systems, » National Institute of Standards et Technology, NIST Special Publication 800-210, 2020.

[16] INTERPOL, *Three arrested as INTERPOL, Group-IB and the Nigeria Police Force disrupt prolific cybercrime group (Operation Falcon)*, Communiqué de presse, https://www.interpol.int/News-and-Events, 2020.

[17] INTERPOL, *Operation Falcon II: eleven suspected members of a business email compromise network arrested in Nigeria*, Communiqué de presse, https://www.interpol.int/News-and-Events, Intitulé exact à vérifier sur le site d'INTERPOL, 2022.

[18] ISO/IEC, *Information technology. Security techniques. Guidelines for identification, collection, acquisition and preservation of digital evidence*, ISO/IEC 27037:2012, 2012.

[19] ISO/IEC, *Information technology. Security techniques. Guidance on assuring suitability and adequacy of incident investigative method*, ISO/IEC 27041:2015, 2015.

[20] ISO/IEC, *Information technology. Security techniques. Guidelines for the analysis and interpretation of digital evidence*, ISO/IEC 27042:2015, 2015.

[21] ISO/IEC, *Information technology. Security techniques. Incident investigation principles and processes*, ISO/IEC 27043:2015, 2015.

[22] ISO/IEC, *Internet of Things (IoT). Reference Architecture*, ISO/IEC 30141:2018, 2018.

[23] ISO/IEC, *Information technology. Electronic discovery. Part 1: Overview and concepts*, ISO/IEC 27050-1:2019, 2019.

[24] T. S. Kuhn, *The Structure of Scientific Revolutions*. Chicago : University of Chicago Press, 1962.

[25] E. Locard, *L'enquête criminelle et les méthodes scientifiques*. Paris : Flammarion, 1920.

[26] R. Milne et R. Bull, *Investigative Interviewing: Psychology and Practice*. Wiley, 1999.

[27] T. E. Minka Mi Nguidjoi, F. S. Mani Onana et T. Djotio Ndié, *The CRO Trilemma: a formal incompatibility between Confidentiality, Reliability and legal Opposability in Post-Quantum proof systems*, Cryptology ePrint Archive, Paper 2025/1348, 2025. adresse : https://eprint.iacr.org/2025/1348.

[28] T. E. Minka Mi Nguidjoi, F. S. Mani Onana et T. Djotio Ndié, *ZK-NR: A Layered Cryptographic Architecture for Explainable Non-Repudiation*, Cryptology ePrint Archive, Paper 2025/1138, 2025. adresse : https://eprint.iacr.org/2025/1138.

[29] National Institute of Standards and Technology, *Guide to Integrating Forensic Techniques into Incident Response*, NIST Special Publication 800-86, 2006.

[30] National Institute of Standards and Technology, *Guidelines on Mobile Device Forensics*, NIST Special Publication 800-101 Rev. 1, 2014.

[31] G. Palmer, « A Road Map for Digital Forensic Research, » Digital Forensic Research Workshop (DFRWS), Utica, NY, rapp. tech. DTR-T001-01, 2001.

[32] M. Pollitt, « A History of Digital Forensics, » in *Advances in Digital Forensics VI*, sér. IFIP Advances in Information and Communication Technology, K.-P. Chow et S. Shenoi, éd., t. 337, Springer, 2010, p. 3-15.

[33] K. R. Popper, *La logique de la découverte scientifique*. Paris : Payot, 1973.

[34] République du Cameroun, *Loi N° 2010/012 du 21 décembre 2010 relative à la cybersécurité et la cybercriminalité*, 2010.

[35] République du Cameroun, *Loi N° 2010/013 du 21 décembre 2010 régissant les communications électroniques au Cameroun*, 2010.

[36] République du Cameroun, *Loi N° 2024/017 du 23 décembre 2024 relative à la protection des données à caractère personnel*, 2024.

[37] C. E. Shannon, « A Mathematical Theory of Communication, » *Bell System Technical Journal*, t. 27, n° 3, p. 379-423, 1948.

[38] Union européenne, *Règlement (UE) 2016/679 du Parlement européen et du Conseil du 27 avril 2016 relatif à la protection des personnes physiques à l'égard du traitement des données à caractère personnel (RGPD)*, Journal officiel de l'Union européenne, L 119, 2016.

# INDEX


414s, 35
419, fraude, 41

419, 41

ADB, 154
admissibilité, 9
AFRIPOL, 172
analyse automatisée, 38
anti-forensique, 67
archiviste du réel, 23
artefact décisif, 47

BEC, 58
biais de confirmation, 212
BTK, 48
Budapest, Convention de, 166

C2PA, 82
CEDEAO, 185
CFAA, 181
charte de l'investigateur, 29
Chaîne de custody, 7
chaîne de custody, 7, 133, 134
CLOUD Act, 182
Convention de Budapest, 166
Convention de Malabo, 169
cyberforensique industrielle, 49

deepfake, 81
deepfakes, 81
DFRWS, 72, 121
DICES, 87, 119
DICES, framework, 87
Digital Forensics Research Workshop, 121
distance de Hamming, 67
distance de Levenshtein, 68
Dolev-Yao, modèle, 70
double hélice, 33

e-Evidence, 185
E01, format, 151
EAC, 186
eIDAS, 183
empreintes cryptographiques, 5
entropie de Shannon, 24
entropie informationnelle, 24

Federal Rules of Evidence, 180
file carving, 159
fonction à sens unique, 72
forensique
    journaux distribués, 52
forensique des journaux distribués, 52
formulaire de chaîne de custody, 133
fuzzy hash, 68
fuzzy hashes, 68

graphe
    orienté pondéré, 69
    temporel, 69
graphe orienté pondéré, 69
graphe temporel, 69

Harvest Now Decrypt Later, 71
Harvest Now, Decrypt Later, 71
hash, 6

intégrité
    preuve numérique, 5
investigation numérique, iii, 20
investigation transnationale, 39

LLM, 80
LLM forensique, 80
Locard, principe numérique, 66

magic bytes, 159
Malabo, Convention de, 169
matrice de criticité, 95

modèle Dolev-Yao, 70
métadonnées, 35
méthode PEACE, 214

NIS 2, 184
NIS 2, 184

OSINT, 59, 85

paradoxe de l'authenticité invisible, 19, 26
PEACE, 214
pratique discursive, 20
praxis de liberté, 19, 29
principe de Locard numérique, 65
Processus Investigatif Universel, 95

Quality Gates, 96, 97

readiness, 124
reproductibilité, 8
RGPD, 182
régime de vérité numérique, 19, 20

SADC, 185
SCA, 180
scène de crime numérique, 4
Shor, 71
Shor, algorithme de, 71
Stored Communications Act, 180
Stuxnet, 49

TAR, 53
Technology-Assisted Review, 53
temporalité numérique, 22
termes clés, vii
théorie des graphes, 25
trace numérique, 21
Trilemme CRO, iii, 3, 9, 14, 27

utilitarisme, 210

Volatility, 156
Volatility 3, 156
volatilité, 4

WannaCry, 51
Wireshark, 157
write blocker, 6, 149

Zero-Knowledge Non-Repudiation, 27

éthique conséquentialiste, 210
éthique des vertus, 211
éthique déontologique, 210

# À propos de ce cours

Ce cours constitue le socle méthodologique et juridique de toute pratique d'investigation numérique. Là où la cybersécurité prévient et détecte l'incident, l'investigation numérique en établit la preuve : elle transforme une trace technique en élément opposable devant une juridiction.

Ce premier volume pose les fondements de l'investigation numérique : fondements philosophiques et historiques, processus investigatif universel et standards internationaux, chaîne de conservation de la preuve, outils d'acquisition, cadre normatif et déontologie. Il prépare l'UE SEC4052, consacrée à la forensique opérationnelle, à l'anti-forensique et à la crypto-forensique.

Ancré dans les standards internationaux (ISO/IEC 27037, NIST SP 800-86, RFC 3227, ACPO) et le cadre juridique camerounais (Loi 2010/012, Loi 2024/017, Convention de Budapest, Convention de Malabo), ce support s'adresse aux étudiants (ingénieurs et master) et aux officiers de police judiciaire spécialisés, appelés à conduire des investigations numériques recevables devant les tribunaux.

**MINKA MI NGUIDJOÏ Thierry Emmanuel**

CISA · CISM · CGEIT · CRISC · CDPSE · ISO 27001 · ISO 22301 · ISO 9001

*Enseignant Chercheur au laboratoire d'Ingénierie Mathématiques et des Systèmes d'Information*

*Chercheur | Cryptologue | Auditeur Senior | Expert Judiciaire | GRC & Sécurité de l'Information*